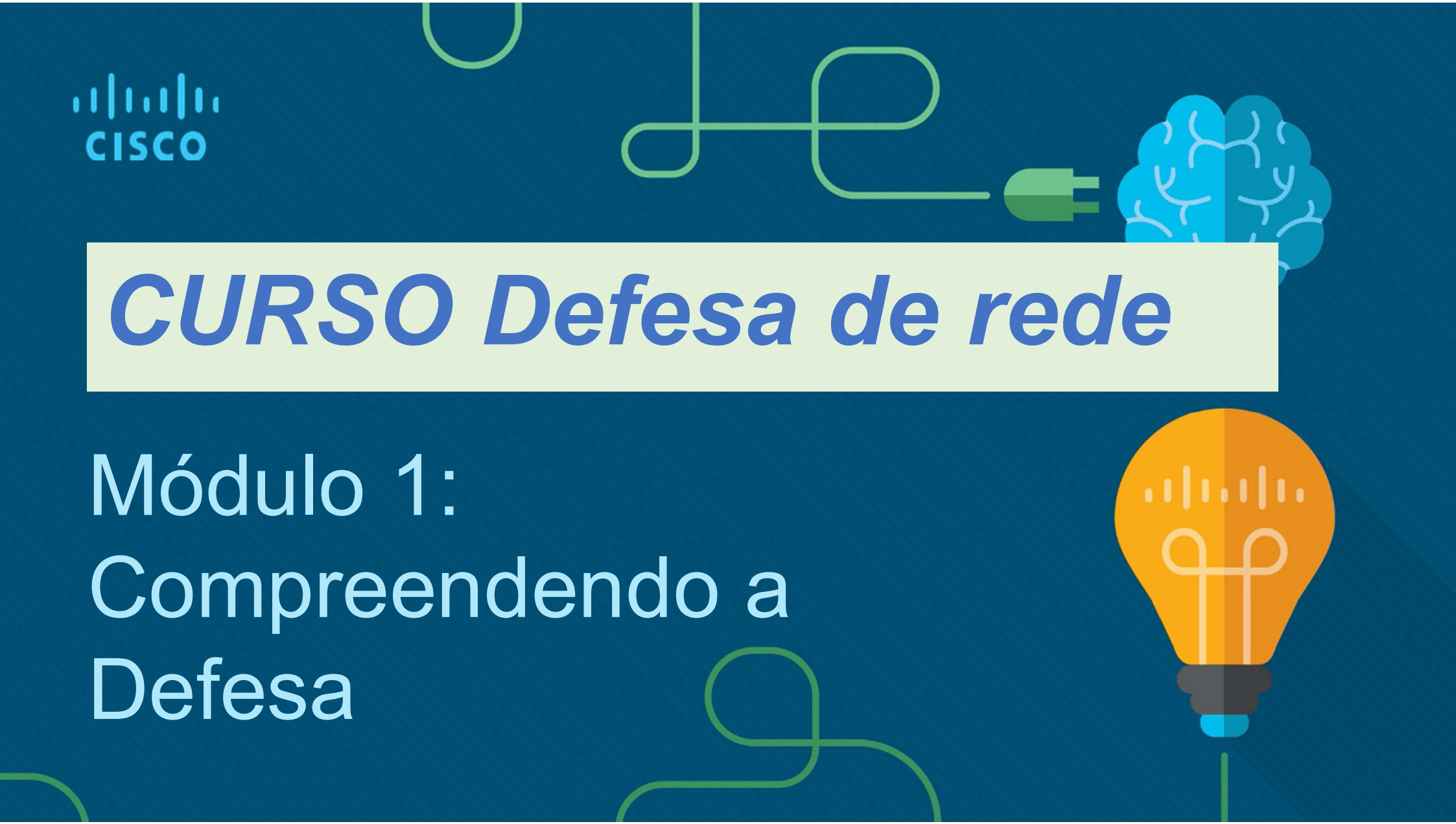

CISCO
CURSO Defesa de rede
Módulo 1:
Compreendendo a
Defesa

Objetivos do Módulo

Título do Módulo: Compreendendo a defesa

Objetivo do módulo: Explicar abordagens para a defesa da segurança da rede.

Título do Tópico	Objetivo do Tópico
Defesa em profundidade	Explicar como a estratégia de Defesa em profundidade é usada para proteger as redes.
Gerenciamento de operações de cibersegurança	Explicar como uma empresa monitora as ameaças de cibersegurança.
Políticas, regulamentos e padrões de segurança	Explicar as políticas, os regulamentos e os padrões de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.1 Defesa em profundidade

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

Ativos, Vulnerabilidades, Ameaças

- Analistas de cibersegurança devem se preparar para qualquer tipo de ataque. É seu trabalho proteger os ativos da rede da organização.

- Para fazer isso, os analistas de cibersegurança devem primeiro identificar:
  - **Ativos** - qualquer coisa de valor para uma organização que deve ser protegida, incluindo servidores, dispositivos de infraestrutura, dispositivos finais e o maior ativo, dados.

  - **Vulnerabilidades** - Uma fraqueza em um sistema ou em seu design que pode ser explorada por um agente de ameaça.

  - **Ameaças** - Qualquer perigo potencial para um ativo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

Identificar Ativos

- A coleta de todos os dispositivos e informações de propriedade ou gerenciadas pela organização são ativos.
- Os ativos constituem a superfície de ataque que os atores da ameaça podem atingir.
- À medida que uma organização cresce, seus ativos também crescem. Considere o número de ativos que uma grande organização teria de proteger.
- O gerenciamento de ativos consiste em inventários de todos os ativos e, em seguida, desenvolver e implementar políticas e procedimentos para protegê-los.
- Organizações precisam identificar onde os ativos de informações essenciais estão armazenados e como o acesso é obtido a essas informações.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em profundidade

Classificação de ativos

- A classificação de ativos atribui todos os recursos de uma empresa a um grupo, com base em características comuns.

- As informações mais importantes precisam receber o nível mais alto de proteção e ainda podem exigir um tratamento especial.

- Uma empresa pode adotar um sistema de rotulagem, de acordo com o valor, a confidencialidade e a importância das informações.

- As etapas para identificar e classificar ativos são:
  Etapa 1: Determinar a categoria adequada de identificação de ativos:
  - Ativos de informações
  - Ativos de software
  - Ativos físicos
  - Serviços

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

Classificação de ativos (Cont.)

Etapa 2: Estabeleça a responsabilização, identificando o proprietário de todos os ativos de informações e de cada et software:

- Identificar o proprietário de todos os ativos de informações
- Identificar o proprietário de todo o software de aplicação

Etapa 3: Determine os critérios de classificação**.**

- Confidencialidade
- Valor
- Tempo
- Direitos de acesso
- Destruição

Etapa 4: Implemente um esquema de classificação**.**

- Adotar uma maneira uniforme de identificação de informações para assegurar a proteção uniforme

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

Padronização de Ativos

- Os padrões de ativos identificam produtos de hardware e software específicos usados e suportados pela empresa.

- Quando há uma falha, a ação imediata ajuda a manter o acesso e a segurança.
  - Se uma empresa não padronizar sua seleção de hardware, provavelmente será difícil o pessoal encontrar um componente de reposição.

  - Além de exigirem mais conhecimento para serem gerenciados, ambientes não padronizados aumentam o custo com contratos de manutenção e inventário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estágios do Ciclo de Vida dos Ativos

- Parte do trabalho dos especialistas em cibersegurança é gerenciar ativos de informação e sistemas relacionados durante todo o ciclo de vida do ativo. As fases do ciclo de vida do ativo são:

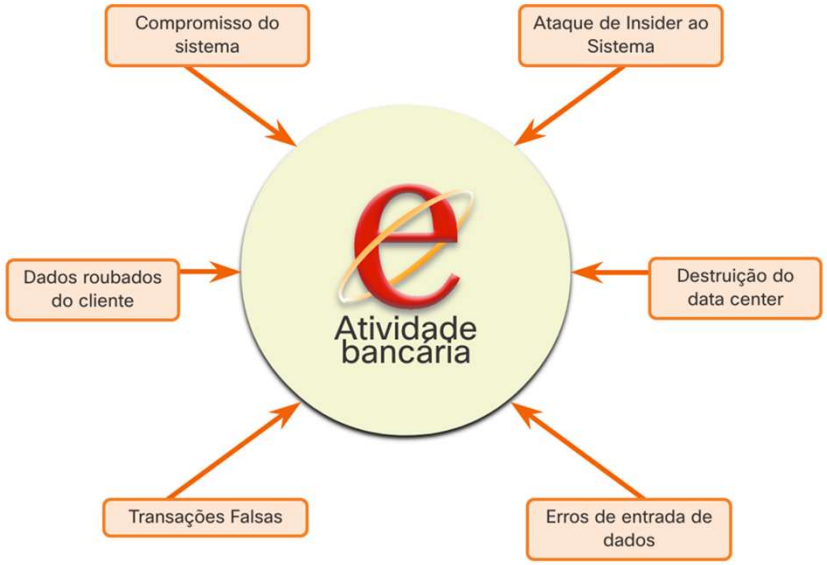
Aquisição	A empresa compra os ativos de acordo com as necessidades identificadas nos dados coletados para justificar a compra. O ativo é adicionado ao inventário da empresa.
Implantação	O ativo é montado e inspecionado para verificar se há falhas ou outros problemas. A equipe realiza testes e instala tags ou códigos de barras para fins de rastreamento. O ativo passa do inventário para o em uso.
Utilização	Essa é a fase mais longa do ciclo. O desempenho do ativo é verificado continuamente. Atualizações, correções de patches, compras de novas licenças e auditorias de conformidade fazem parte do estágio de utilização.
Manutenção	Ela ajuda a prolongar a vida produtiva de um ativo. Os funcionários podem modificar ou atualizar o ativo.
Eliminação	Ao fim da vida produtiva do ativo, ele deve ser descartado. Todos os dados devem ser apagados do ativo. O descarte pode incluir a desmontagem de um ativo em peças. Quaisquer peças que possam causar riscos ambientais devem ser descartadas de acordo com as diretrizes locais.

Defesa em profundidade

Identificar Vulnerabilidades

- A identificação de ameaças fornece a uma organização uma lista de prováveis ameaças para um ambiente específico.

- Ao identificar ameaças, é importante fazer várias perguntas:
  - Quais são as possíveis vulnerabilidades de um sistema?
  - Quem pode querer explorar essas vulnerabilidades para acessar ativos de informações específicos?
  - Quais são as consequências se as vulnerabilidades do sistema forem exploradas e os ativos forem perdidos?



ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Identificar Vulnerabilidades (Cont.)

- A identificação da ameaça para um sistema de e-banking incluiria:
  - **Comprometimento do sistema interno** - O atacante usa os servidores de e-banking expostos para invadir um sistema bancário interno.
  - **Dados roubados do cliente** - Um atacante rouba os dados pessoais e financeiros dos clientes bancários do banco de dados do cliente.
  - **Transações falsas de um servidor externo** - Um invasor altera o código do aplicativo de e-banking e faz transações personificando um usuário legítimo.
  - **Transações falsas usando um PIN de cliente roubado ou cartão inteligente** - Um invasor rouba a identidade de um cliente e conclui transações mal-intencionadas da conta comprometida.
  - **Ataque interno no sistema** - Um funcionário do banco encontra uma falha no sistema a partir do qual monta um ataque.
  - **Erros de entrada de dados** - Um usuário insere dados incorretos ou faz solicitações de transação incorretas.
  - **Destruição do data center** - Um evento cataclísmico danifica gravemente ou destrói o data center.

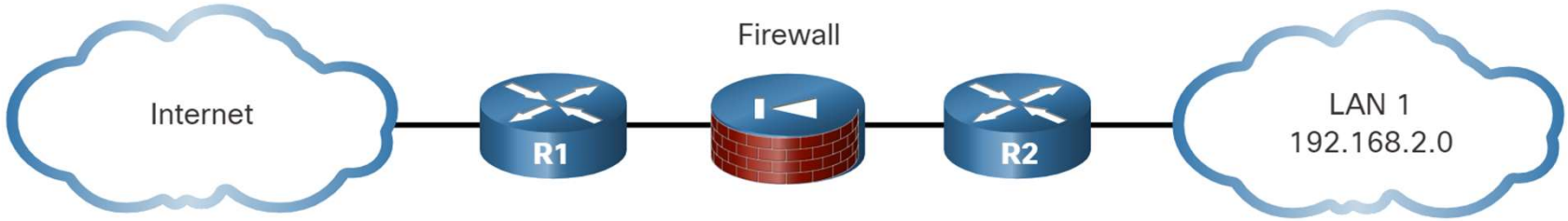
- Identificar vulnerabilidades em uma rede requer uma compreensão dos aplicativos importantes que são usados, bem como das diferentes vulnerabilidades desse aplicativo e hardware.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

Identificar Ameaças

- As organizações devem usar uma abordagem de defesa profunda para identificar ameaças e proteger ativos vulneráveis. Essa abordagem usa várias camadas de segurança na borda da rede, na rede e nos pontos de extremidade da rede.



- Roteador de borda (R1) - A primeira linha de defesa é o roteador de borda, que possui um conjunto de regras especificando qual tráfego ele permite ou nega. Ele passa todas as conexões que se destinam à LAN interna para o firewall.

- Firewall - A segunda linha de defesa é o firewall. Ele é um dispositivo de ponto de verificação que executa filtragem adicional e rastreia o estado das conexões.

- Roteador interno (R2) - Outra linha de defesa é o roteador interno. Ele pode aplicar regras de filtragem finais no tráfego antes de ser encaminhado para seu destino.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

Identificar Ameaças (Cont.)

- Os roteadores e firewalls não são os únicos dispositivos que são usados em uma abordagem de defesa profunda.

- Outros dispositivos de segurança incluem IPS (Intrusion Prevention Systems), Proteção Avançada contra Malware (AMP), sistemas de segurança de conteúdo da Web e de e-mail, serviços de identidade, controles de acesso à rede e muito mais.

- Na abordagem de segurança em camadas de defesa profunda, as diferentes camadas trabalham juntas para criar uma arquitetura de segurança na qual a falha de uma salvaguarda não afeta a eficácia das outras salvaguardas.

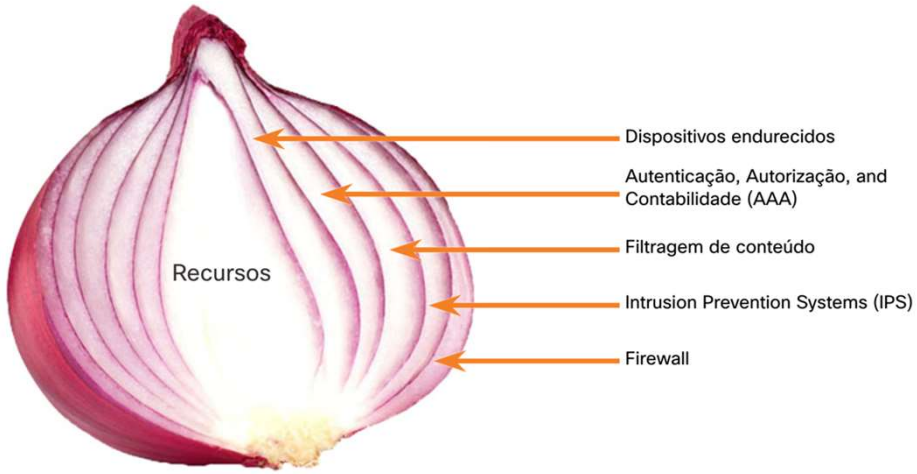
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

The Security Onion e The Security Artichoke

- **Security Onion**
  - Uma analogia comum usada para descrever uma abordagem de defesa em profundidade.
  - Um ator de ameaça teria que descascar as defesas de uma rede, camada por camada, como se estivesse descascando uma cebola.
  - Somente depois de penetrar cada camada, o ator de ameaça alcançaria os dados ou o sistema de destino.

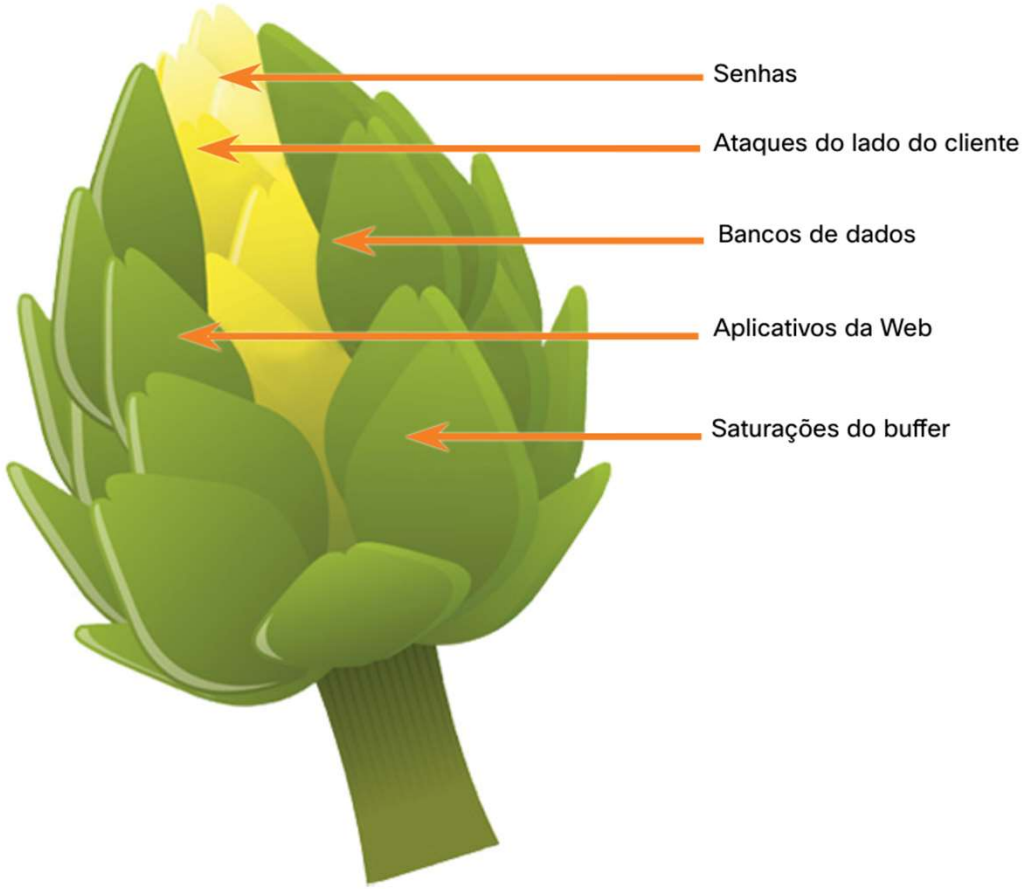
Observação: A Security Onion descrita nesta página é uma forma de visualizar a defesa em profundidade. Isso não deve ser confundido com o conjunto Security Onion de ferramentas de segurança de rede.



:co e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Profundidade

The Security Onion and The Security Artichoke(Cont.)



- O cenário em mudança da rede, como a evolução das redes sem fronteiras, mudou essa analogia para a “alcachofra de segurança”, que beneficia o ator de ameaça.
- Os atores de ameaças não precisam mais remover cada camada.
- Eles só precisam remover certas “artichoke leaves”.
- O bônus é que cada “folha” da rede pode revelar dados confidenciais que não estão bem protegidos.
- O hacker arranca a armadura de segurança ao longo do perímetro para chegar ao “coração” da empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.1.11 Estratégias de Defesa em Produndidade

- Para garantir que as informações e os dados permaneçam disponíveis, uma empresa precisa criar diferentes camadas de proteção.
  - **Camadas:** Para garantir que as informações e os dados permaneçam disponíveis, uma empresa precisa criar diferentes camadas de proteção.
  - **Limitação:** Limitar o acesso aos dados e às informações reduz a possibilidade de uma ameaça. Uma empresa deve restringir o acesso para que os usuários tenham apenas o nível de acesso necessário para fazer o seu trabalho.
  - **Diversidade:** Se todas as camadas protegidas fossem as mesmas, não seria muito difícil, para os criminosos virtuais , realizar um ataque bem-sucedido. As camadas devem ser diferentes para que, se uma camada for penetrada, a mesma técnica não funcionará em todas as outras, o que comprometeria todo o sistema.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estratégias de Defesa em Produndidade (Cont.)

- **Ofuscação:** A ofuscação de informações também pode proteger dados e informações. Uma empresa não deve revelar informações que os criminosos virtuais podem usar para descobrir a versão do sistema operacional em execução em um servidor ou o tipo de equipamento que ele usa.

- **Simplicidade:** A complexidade não garante, necessariamente, a segurança. Se os funcionários não entenderem como configurar uma solução complexa corretamente, pode ser tão fácil quando em uma solução mais simples para os criminosos virtuais comprometerem esses sistemas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.2 Gerenciamento de operações de Cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de Configurações

- O gerenciamento de configuração refere-se à identificação, controle e auditoria da implementação e de quaisquer alterações feitas à linha de base estabelecida de um sistema.

- A configuração da linha de base inclui todas as definições definidas para um sistema que fornecem a base para todos os sistemas semelhantes, como um tipo de modelo.

- Os recursos de configuração documentados podem incluir:
  - Mapas de rede, diagramas de cabeamento e rede, especificações de configuração da aplicação
  - Convenções de nomenclatura padrão usadas para computadores
  - Esquema IP para rastrear endereços IP

- O reforço do sistema operacional é uma parte importante para garantir que os sistemas tenham configurações seguras.

- A configuração de arquivos de log junto com a auditoria, a alteração de nomes de conta e senhas e a implementação de políticas de conta e controle de acesso no nível de arquivo são usados para criar um sistema operacional seguro.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Arquivos de Log

- Um log registra todos os eventos que ocorrem.
- Entradas de log compõem um arquivo de log e uma entrada de log contém todas as informações relacionadas a um evento específico.
- Com o aumento do número de arquivos de log gerados para fins de segurança do computador, a empresa deve considerar um processo de gerenciamento de logs.
- O gerenciamento de dados do log de segurança do computador deve determinar os procedimentos para :
  - Geração dos arquivos de log
  - Transmissão de arquivos de log
  - Armazenamento de arquivos de log
  - Análise de dados
  - Descarte dos dados de log



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs do sistema operacional e Logs de segurança do aplicativo

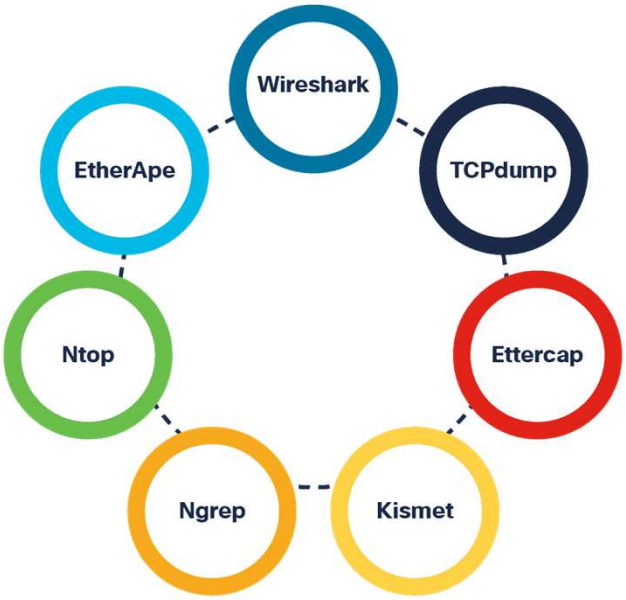
- **Logs do sistema operacional** registra eventos de registro que estão vinculados a ações relacionadas ao sistema operacional. Os eventos do sistema incluem:
  - Solicitações do cliente e respostas do servidor, como autenticações de usuário bem-sucedidas
  - Informações de uso que contêm o número e o tamanho das transações em cada período.

- **Logs de Segurança de Aplicativos:** As empresas usam software de segurança pela rede ou pelo sistema para detectar atividade mal-intencionada.
  - Esse software gera um log de segurança para fornecer dados de segurança do computador.
  - Os logs são úteis para a realização de análise de auditoria e para a identificação de tendências e de problemas no longo prazo.
  - Os logs também permitem que uma empresa forneça documentação que mostre que está em conformidade com as leis e os requisitos regulatórios.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Analisadores de Protocolos

- Os packet analyzers (ou analisadores de pacotes) interceptam e registram o tráfego de rede.
- O packet analyzer captura cada pacote, mostra os valores de vários campos no pacote e analisa o conteúdo.
- Um sniffer pode capturar o tráfego em redes com e sem fio.
- Packet analyzers executam as seguintes funções:
  - Log de tráfego
  - Análise de problemas de rede
  - Detecção de uso indevido da rede
  - Detecção de tentativas de invasão da rede
  - Isolamento do sistema explorado



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.3 Políticas, Regulamentos e Padrões de Segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Políticas, Regulamentos e Padrões de Segurança

Políticas de Negócios

- São as diretrizes que são desenvolvidas por uma organização para governar suas ações.
- As políticas definem padrões de comportamento correto para a empresa e seus funcionários.
- Se um comportamento que viola a política de negócios(linha de base) for detectado na rede, é possível que tenha ocorrido uma violação de segurança.

Uma organização pode ter diversas políticas orientadoras:

Política	Descrição
Políticas da empresa	Elas estabelecem as regras de conduta e as responsabilidades dos trabalhadores e dos empregadores. Elas protegem os direitos dos trabalhadores, bem como os interesses comerciais dos empregadores.
Políticas de Colaboradores	Essas políticas são criadas e mantidas pela equipe de recursos humanos para identificar o salário dos funcionários, o cronograma de pagamento, os benefícios dos funcionários, o horário de trabalho, as férias e muito mais.Elas são fornecidos a novos colaboradores para revisar e assinar.
Políticas de Segurança	Essas políticas identificam um conjunto de objetivos de segurança para uma empresa, definem as regras de comportamento para usuários e administradores e especificam os requisitos do sistema.Esses objetivos, regras e requisitos garantem coletivamente a segurança de uma rede e dos sistemas de computador em uma organização.

Política de Segurança

- Uma política de segurança abrangente tem vários benefícios:
  - Demonstra o compromisso de uma organização com a segurança
  - Define as regras para o comportamento esperado
  - Garante a consistência nas operações do sistema, aquisição e uso de software e hardware e manutenção
  - Define as consequências legais das violações
  - Dá ao pessoal de segurança o apoio da gestão

- As políticas de segurança são usadas para informar os usuários, funcionários e gerentes sobre os requisitos de uma organização para proteger os ativos de tecnologia e informação.

- Uma política de segurança também especifica os mecanismos necessários para atender aos requisitos de segurança e fornece uma linha de base a partir da qual adquirir, configurar e auditar sistemas e redes de computadores para conformidade.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Política de Segurança (Cont.)

Políticas que podem ser incluídas em uma política de segurança são:

Política	Descrição
Política de identificação e autenticação	Especifica pessoas autorizadas que podem ter acesso a recursos de rede e procedimentos de verificação de identidade.
Políticas de senha	Garante que as senhas atendam aos requisitos mínimos e sejam alteradas regularmente.
Acceptable Use Policy (AUP)	Identifica os aplicativos e usos de rede que são aceitáveis para a organização.
Política de acesso remoto	Identifica como os usuários remotos podem acessar uma rede e o que é acessível por meio de conectividade remota.
Políticas de Manutenção de Rede	Especifica procedimentos de atualização de sistemas operacionais dos dispositivos de rede e de aplicativos de usuário final.
Procedimentos de tratamento de incidentes	Descreve como os incidentes de segurança são tratados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Políticas BYOD

- Muitas organizações agora também devem suportar Traga seu próprio dispositivo (BYOD), permitindo que os funcionários usem seus próprios dispositivos móveis para acessar sistemas, software, redes ou informações da empresa.

- Ele fornece vários benefícios importantes para as empresas, incluindo aumento da produtividade, redução dos custos operacionais e de TI, melhor mobilidade para os funcionários e maior atração quando se trata de contratar e reter funcionários.

Uma política de segurança BYOD deve ser desenvolvida para realizar o seguinte:

- Especifique os objetivos do programa BYOD.
- Identifique quais funcionários podem trazer seus próprios dispositivos.
- Identifique quais dispositivos serão suportados.
- Identificar o nível de acesso que os funcionários são concedidos ao usar dispositivos pessoais.
- Descrever os direitos de acesso e as atividades permitidas ao pessoal de segurança no dispositivo.
- Identifique quais regulamentos devem ser cumpridos ao usar dispositivos de funcionários.
- Identifique as salvaguardas a serem implementadas se um dispositivo for comprometido.

Políticas de BYOD (Cont.)

A tabela a seguir lista as melhores práticas de segurança BYOD para ajudar a mitigar vulnerabilidades BYOD:

Melhores Práticas	Descrição
Acesso protegido por senha	Use senhas exclusivas para cada dispositivo e conta.
Controle manualmente a conectividade sem fio	Desative a conectividade Wi-Fi e Bluetooth quando não estiver em uso. Conecte-se apenas a redes confiáveis.
Mantenha-se atualizado	Mantenha sempre o sistema operacional do dispositivo e outros softwares atualizados. O software atualizado geralmente contém patches de segurança para mitigar contra as ameaças ou explorações mais recentes.
Dados de backup	Ative o backup do dispositivo caso ele seja perdido ou roubado.
Ative "Encontrar meu Dispositivo"	Assine um serviço de localizador de dispositivos com o recurso de apagamento remoto.
Fornece software antivírus	Fornecer software antivírus para dispositivos BYOD aprovados.
Use um software gerenciamento de dispositivos móveis (MDM)	Ele permite que as equipes de TI implementem configurações de segurança e configurações de software em todos os dispositivos que se conectam às redes da empresa.

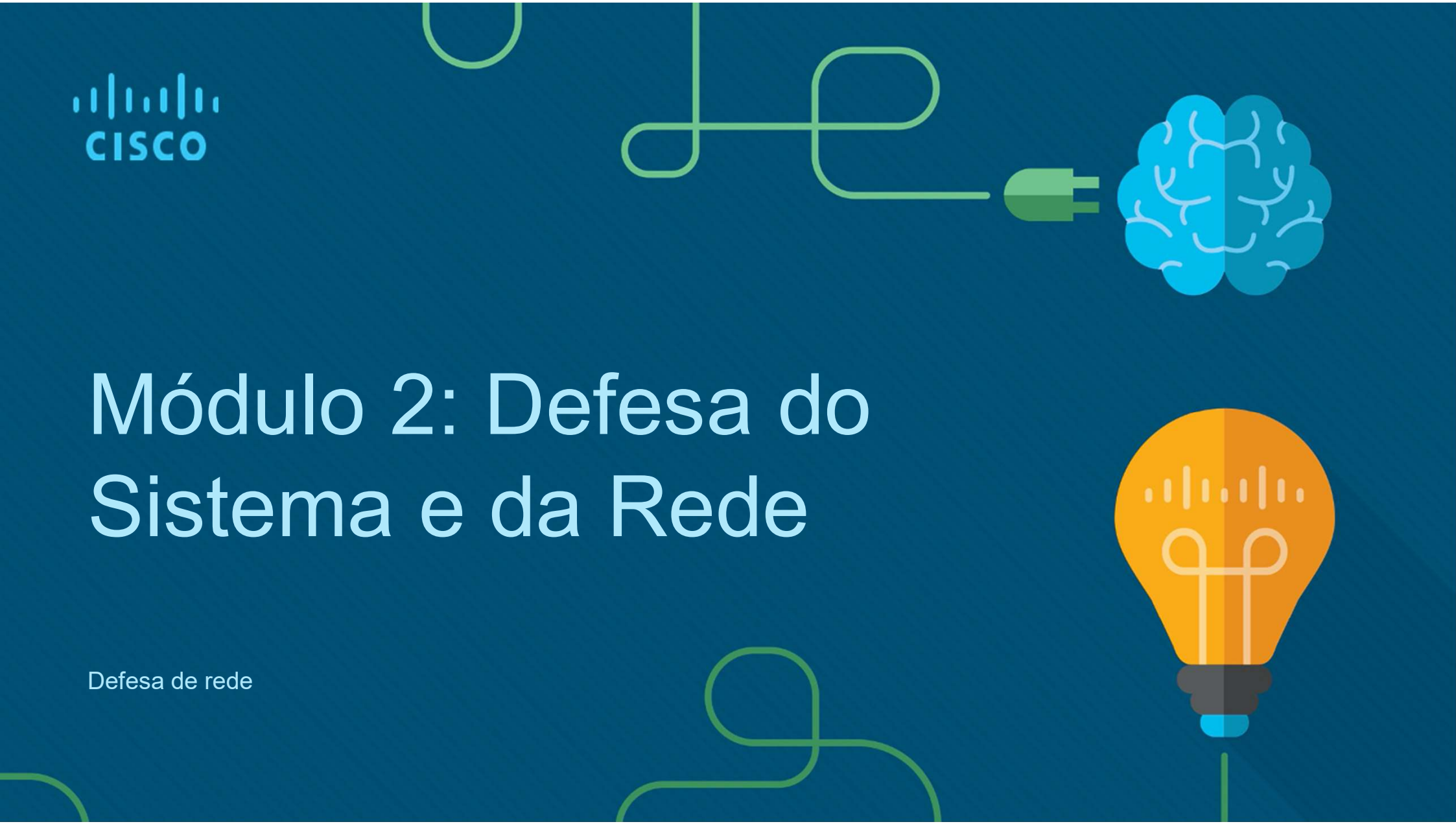
Conformidade Regulatória e de Padrões

- Há também regulamentos externos em relação à segurança da rede.
- Os profissionais de segurança de rede devem estar familiarizados com as leis e códigos de ética que são vinculativos para os profissionais de Segurança de Sistemas de Informação (INFOSEC).
- Muitas organizações são obrigadas a desenvolver e implementar políticas de segurança.
- Os regulamentos de conformidade definem o que as organizações são responsáveis pelo fornecimento e a responsabilidade caso não cumpram.
- Os regulamentos de conformidade que uma organização é obrigada a seguir dependem do tipo de organização e dos dados que a organização manipula.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

1.4 Resumo de Entendendo a Defesa

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 2: Defesa do Sistema e da Rede

Defesa de rede

Objetivos do módulo

Título do módulo: Defesa de Rede eSistema

Objetivo do Módulo: Implementar alguns dos vários aspectos de defesa do sistema e da rede.

Título do Tópico	Objetivo do Tópico
Segurança Física	Explica como as medidas de segurança física são implementadas para proteger o equipamento da rede.
Segurança de aplicações	Explicar como aplicar as medidas de segurança de aplicações.
Blindagem de Serviços e Protocolos	Explicar como blindar os serviços e protocolos de rede.
Blindagem de rede: segmentação	Explicar como a segmentação de rede pode ajudar a fortalecer a rede.
Blindagem (codificação) de dispositivos sem fio e móveis	Configurar a blindagem e a segurança dos roteadores sem fio.
Resiliencia de Cybersegurança	Explique a segurança física com dispositivos de IoT.
Sistemas Embarcados e Especiais	Implemente segurança física com dispositivos de IoT.

2.1 Segurança Física

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Física

2.1.2 Cercas e Barreiras Físicas

- Barreiras físicas são a primeira coisa que vem à mente quando se pensa em segurança física.

- Em muitas situações, elas são a camada mais externa da defesa e as mais visíveis. Todas as barreiras devem atender a requisitos específicos do projeto e a especificações da fábrica.

As barreiras físicas podem ter os seguintes componentes:

- Sistema de cerca de perímetro
- Sistema de portão de segurança
- Cabeços de amarração (postes curtos usados para impedir invasões em veículos)
- Barreiras de entrada de veículo
- Abrigos de proteção
- Cercamento

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Cercas e Barreiras Físicas

Uma **cerca** é uma barreira que protege áreas seguras e designa os limites da propriedade.

Ao projetar um sistema de cerca de perímetro, aplicam-se as seguintes diretrizes de altura:

- Um metro (3 a 4 pés) só irá deter invasores casuais
- Dois metros (6 a 7 pés) é muito alto para invasores casuais subirem
- Dois metros e meio (8 pés) oferecerá atraso limitado para um invasor determinado

- Áreas de alta segurança geralmente requerem uma “proteção superior”, como arame farpado ou fio de arame farpado.

- As regulamentações locais podem restringir o tipo de sistema de cerca que uma empresa pode usar e é importante lembrar que as cercas exigem manutenção regular.

- Além disso, os veículos nunca devem ser estacionados perto de uma cerca de segurança, pois isso pode ajudar o invasor a escalar ou causar danos à cerca.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Física

Biometria

- Biometria são as características fisiológicas ou comportamentais de um indivíduo, e há práticas de segurança baseadas na identificação e concessão de acesso usando a biometria.

- Sistemas de autenticação de biometria incluem medições da face, impressão digital, geometria da mão, íris, retina, assinatura e voz.

- Tecnologias de biometria podem ser a base da identificação altamente segura e de soluções de verificação pessoal.

- A biometria pode garantir transações financeiras confidenciais e privacidade de dados pessoais - um exemplo bem conhecido são os smartphones que usam leitores de impressão digital para desbloquear o dispositivo e acessar aplicativos, incluindo sistemas bancários e de pagamentos online.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Física

Biometria (Cont.)

Ao selecionar sistemas biométricos, há vários fatores importantes a serem considerados, incluindo:

- Precisão
- Velocidade ou taxa de transferência
- Aceitação para usuários
- Exclusividade do órgão biométrico e ação
- Resistência à falsificação
- Integridade
- Requisitos de armazenamento de dados
- Tempo de inscrição
- Intrusão na verificação

O mais importante desses fatores é a precisão, que é expressa em tipos de erro e taxas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Física

Biometria (Cont.)

- Em muitas aplicações biométricas, particularmente no varejo ou no setor bancário, as falsas rejeições (erro Tipo I) podem ter um impacto muito negativo nos negócios devido à perda de uma transação ou venda.

- Aceitação falsa é um erro Tipo II. Os erros de tipo II permitem a entrada de pessoas que não deveriam ter acesso, o que significa que um criminoso digital pode obter acesso.
  - Erros de tipo II permitem a entrada de invasores e, portanto, são considerados o erro mais importante em um sistema de controle de acesso de biometria.

- A taxa de aceitação também é um conceito importante aqui. A taxa de aceitação é indicada como uma percentagem e é a taxa na qual um sistema aceita indivíduos que cancelaram a inscrição ou impostores como usuários autênticos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Física

Vigilância

Todos os controles de acesso físicos, incluindo sistemas de impedimento e de detecção dependem, em última análise, de pessoal para intervir e parar o ataque ou a invasão real.

- **A vigilância eletrônica e por vídeo** complementam ou, em alguns casos, substituem, os guardas de segurança.
- A vantagem da vigilância por vídeo e eletrônica é a capacidade de monitorar áreas mesmo que nenhum guarda ou pessoal esteja presente, a capacidade de gravar e registrar vídeos e dados de vigilância por longos períodos e a capacidade de incorporar a detecção e notificação de movimento.
- Em um ambiente altamente seguro, uma empresa deve colocar vigilância eletrônica e por vídeo em todas as entradas, saídas, locais de carregamento, escadas e áreas de coleta de refugo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Física

Vigilância (Cont.)

- **Guardas e Escoltas:** Os guardas de segurança são uma ótima solução para controle de acessos que requerem uma resposta instantânea e adequada.

- As desvantagens incluem custo e incapacidade de monitorar e registrar grandes volumes de tráfego e o risco de erro humano.

- Nas instalações com sistema de informação altamente seguro, guardas controlam o acesso a áreas confidenciais da empresa.

- O benefício do uso de guardas é que eles podem se adaptar mais do que sistemas automatizados. Guardas podem aprender e distinguir muitas condições e situações diferentes e tomar decisões imediatamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Vigilância (Cont.)

- **Vigilância RFID e sem fio:** Gerenciar e localizar importantes ativos do sistema de informações é um desafio fundamental para a maioria das organizações.
  - O crescimento do número de dispositivos móveis e de dispositivos IoT tem tornado esse trabalho ainda mais difícil.
  - O uso de tags do recurso RFID (Radio Frequency Identification, Identificação por radiofrequência) pode ser de grande valor para o pessoal da segurança.
    - Uma organização pode colocar os leitores de RFID nos batentes das portas de áreas seguras para que não fiquem visíveis.
    - O benefício de tags do recurso RFID é que elas podem rastrear qualquer ativo que fisicamente deixa uma área segura.
    - Os novos sistemas de tags do recurso RFID podem ler várias tags ao mesmo tempo.
    - Sistemas RFID não precisam estar na linha de visão para ler as tags.
    - Outra vantagem do RFID é a capacidade de ler as tags que não estão visíveis.
    - Ao contrário de códigos de barras e tags legíveis humanas que devem ser fisicamente localizados e visíveis para ler, etiquetas RFID não precisam estar visíveis para serem lidas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.2 Segurança da Aplicação

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Desenvolvimento de aplicações

Para manter a segurança em todas as etapas de desenvolvimento de aplicativos, um processo robusto precisa ser seguido.

- **Desenvolvimento e** teste: o software é desenvolvido e atualizado em um ambiente de desenvolvimento, onde pode ser desenvolvido, testado e depurado antes de ser implantado.
  - Um ambiente de desenvolvimento é menos restritivo do que o ambiente ativo e tem um nível de segurança mais baixo.
  - O software de controle de versão ajuda a rastrear e gerenciar alterações no código do software.
  - Os desenvolvedores também podem trabalhar em um ambiente de sandbox para que o código não seja substituído à medida que o desenvolve.

- Durante o teste, os desenvolvedores analisam como o código interage com o ambiente normal.
  - A garantia de qualidade (QA) pode encontrar falhas no software.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Desenvolvimento de aplicações (Cont.)

- **Preparação e produção: os** ambientes de preparação devem corresponder de perto ao ambiente de produção da organização
  - Ao testar em um ambiente intermediário, os desenvolvedores podem verificar se o software é executado sob as configurações de segurança necessárias.
  - Depois que o desenvolvedor executa e testa a segurança, o programa pode ser implantado em produção.

- **Provisionamento e desprovisionamento:** Provisionamento é a criação ou atualização de software. O desprovisionamento é sua remoção.
  - Uma empresa pode usar um portal de autoatendimento para automatizar o desprovisionamento e o provisionamento de software.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Técnicas de Codificação de Segurança

Ao codificar aplicações, os desenvolvedores usam várias técnicas para validar se todos os requisitos de segurança foram atendidos.

- **A normalização** é usada para organizar dados em um banco de dados e ajudar a manter a integridade dos dados. A normalização converte uma sequência de entrada em sua forma mais simples conhecida para garantir que todas as sequências tenham representações binárias exclusivas e que qualquer entrada mal-intencionada seja identificada.

- Um **procedimento armazenado**é um grupo de instruções SQL pré-compiladas armazenadas em um banco de dados que executa uma tarefa. Se você usar um procedimento armazenado para aceitar parâmetros de entrada de clientes que usam dados de entrada diferentes, reduzirá o tráfego de rede e obterá resultados mais rápidos.

- **A ofuscação oculta** dados originais com caracteres ou dados aleatórios. **A camuflagem** substitui os dados confidenciais por dados fictícios realistas. Um desenvolvedor pode usar a ofuscação e a camuflagem para impedir que o software seja reprojetado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Técnicas de Codificação de Segurança (Cont.)

- **A reutilização de código significa** usar o software atual para criar um novo software, economizando tempo e custos de desenvolvimento. É preciso ter cuidado, no entanto, para evitar a introdução de vulnerabilidades.

- **SDKs (Software development kits)** e bibliotecas de terceiros fornecem um repositório de código útil para tornar o desenvolvimento de aplicativos mais rápido e barato.
  - A desvantagem é que qualquer vulnerabilidade em SDKs ou bibliotecas de terceiros pode afetar muitos aplicativos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Validação de Entrada

- Controlar o processo de entrada de dados é fundamental para manter a integridade do banco de dados.
  - Muitos ataques são executados em um banco de dados e inserem dados malformados.
  - O ataque pode confundir, falhar ou fazer com que o aplicativo divulgue informações demais para o invasor.

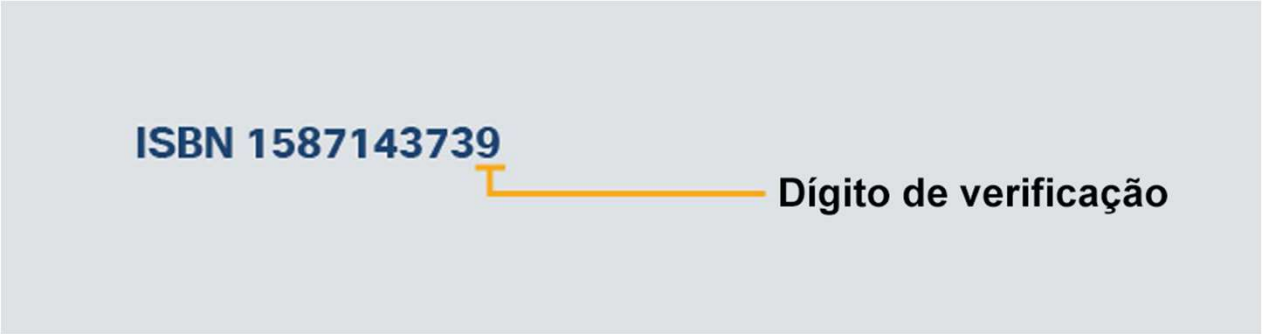
- Por exemplo, os usuários preenchem um formulário usando um aplicativo da Web para assinar uma newsletter.
  - Um aplicativo de banco de dados gera e envia automaticamente confirmações por e-mail para os clientes.
  - Quando os usuários recebem as confirmações de e-mail com um link URL, para confirmar a assinatura, os invasores modificam o link URL.
  - Essas modificações podem alterar o nome de usuário, o endereço de e-mail ou o status da assinatura dos clientes quando eles clicam para confirmar a assinatura.
  - Os hackers podem automatizar o ataque para inundar o aplicativo da Web com milhares de assinantes inválidos no banco de dados da newsletter.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sobre as Regras de Validação

Uma regra de validação verifica se os dados estão nos parâmetros definidos pelo projetista de banco de dados. Uma regra de validação ajuda a garantir a integridade, a precisão e a consistência dos dados. Os critérios usados na regra de validação incluem o seguinte:

- **Tamanho** – verifica o número de caracteres em um item de dados
- **Formato** – verifica se os dados estão de acordo com um formato**especificado**
- **Consistência** – verifica a consistência dos códigos nos itens de dados relacionados
- **Intervalo** – verifica se os dados estão dentro de valores mínimo e máximo
- **Dígito de verificação** – efetua um cálculo extra para gerar um dígito de verificação para detecção de erros

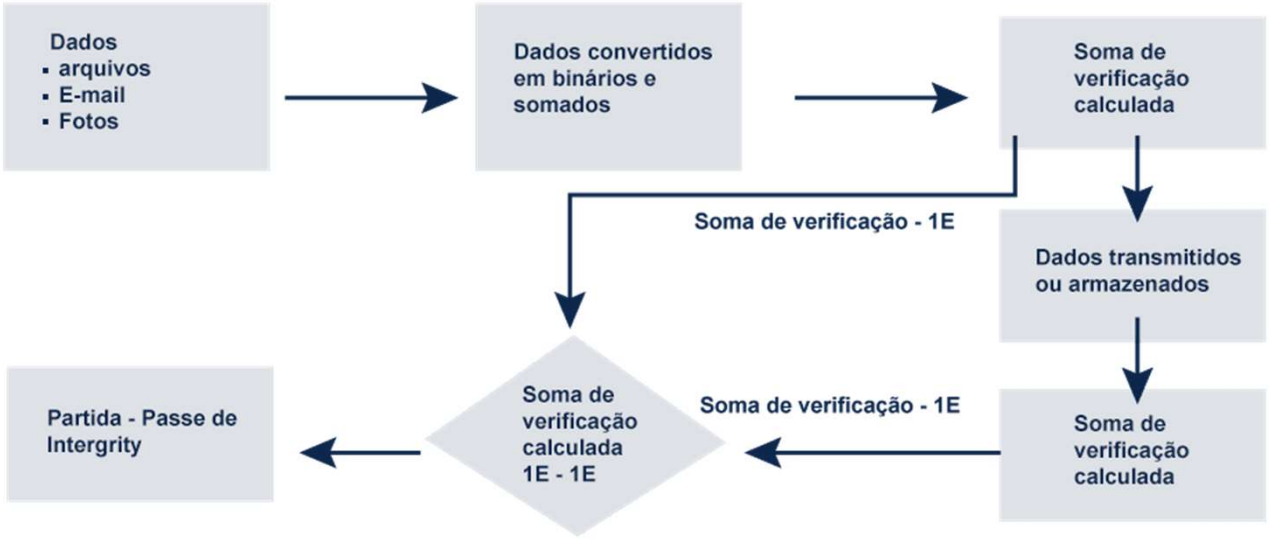


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificações de integridade

Dados comprometidos podem ameaçar a segurança de seus dispositivos e sistemas.

Uma **verificação de integridadepode**medir a consistência dos dados em um arquivo, imagem ou registro para garantir que eles não tenham sido corrompidos. A verificação de integridade executa uma **função hash** para obter um instantâneo de dados e, em seguida, usa esse instantâneo para garantir que os dados permaneçam inalterados. Um **checksum** é um exemplo de uma função hash.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificações de Integridade (Cont.)

Como funciona um checksum

- Uma checksum verifica a integridade de arquivos, ou de strings de caracteres, antes e depois de serem transferidos de um dispositivo para outro por uma rede local ou pela Internet.
  - Checksum converte cada conjunto de informações para um valor e soma o total.
  - Para testar a integridade de dados, um sistema de recebimento apenas repete o processo. Se as duas somas forem iguais, os dados são válidos. Caso contrário, uma alteração ocorreu em algum lugar ao longo do caminho.

Funções hash

- Funções hash comuns incluem MD5, SHA-1, SHA-256 e SHA-512.
  - Eles usam algoritmos matemáticos complexos para comparar dados com um valor de hash.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificações de Integridade (Cont.)

Controle de versão

- As empresas usam controle de versão para evitar alterações acidentais por usuários autorizados.
  - O controle de versão significa que dois usuários não podem atualizar o mesmo objeto, como um arquivo, registro de banco de dados ou transação, ao mesmo tempo.

Backups:

- Backups precisos ajudam a manter a integridade de dados, se os dados forem corrompidos.
- Uma empresa precisa verificar o seu processo para garantir a integridade do backup, antes que ocorra perda de dados.

Autorização:

- A autorização determina quem tem acesso aos recursos da empresa, de acordo com a necessidade de cada um.
  - Por exemplo, controles de acesso de usuário e permissões de arquivo garantem que apenas determinados usuários possam modificar os dados.
  - Um administrador pode definir as permissões de um arquivo como somente leitura.
    - Como resultado, um usuário que acessa esse arquivo não pode fazer nenhuma alteração.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Outras Práticas de Segurança de Aplicações

Como você pode ter certeza de que um software que você está instalando é autêntico ou que as informações são seguras ao navegar na Internet?

A assinatura de código ajuda a provar que um software é autêntico.

- Os executáveis projetados para instalar e executar em um dispositivo são assinados digitalmente para validar a identidade do autor e fornecer garantia de que o código de software não foi alterado desde que foi assinado.

Cookies seguros

- O uso de cookies seguros protege as informações armazenadas em cookies contra hackers.
- Quando seu sistema cliente interage com um servidor, o servidor envia uma resposta HTTP que instrui seu navegador a criar pelo menos um cookie.
    - O cookie armazena dados para solicitações futuras enquanto você estiver navegando no site.

- Os desenvolvedores da Web devem usar cookies com HTTPS para proteger os cookies e impedir que eles sejam transmitidos por HTTP não criptografado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controle de Ameaças a Aplicações

As empresas podem implementar várias medidas para controlar ameaças ao domínio da aplicação:

Acesso não autorizado a data centers, salas de computador e armário de cabos

- Implementar políticas, padrões e procedimentos para os funcionários e para os visitantes, para garantir que as instalações sejam seguras.

Período de inatividade do sistema

- Desenvolver um plano de continuidade de negócios para aplicativos essenciais para manter a disponibilidade das operações.
- Desenvolver um plano de recuperação de desastres para aplicativos e dados essenciais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de Ameaças a Aplicações

Vulnerabilidade de software do sistema operacional de rede

- Desenvolva uma políticapara lidar com atualizações de software de aplicativo e sistema operacional
- Instale correções e atualizações regularmente.

Acesso não autorizado a sistemas:

- Use a autenticação multifator.
- Monitore arquivos de log

Perda de Dados:

- Implemente padrões de classificação de dados.
- Implemente procedimentos de backup.

Vulnerabilidades de desenvolvimento de software:

- Realize testes antes do lançamento do software.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de Aplicações

Laboratório - Investigação do OWASP

Neste laboratório, você completará os seguintes objetivos:

- Parte 1: OWASP Top 10
- Parte 2: Páginas de comunidade do OWASP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.3 Fortalecimento da Rede: Serviços e Protocolos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de rede e de roteamento

- Os criminosos usam serviços de rede vulneráveis para atacar um dispositivo ou usá-lo como parte do ataque.

- Para verificar os serviços de rede não protegidos, verifique se um dispositivo tem portas abertas usando um scanner de porta.

- Um scanner de porta envia uma mensagem para cada porta e espera por uma resposta, indicando como a porta é usada e se está aberta.
  - Os criminosos virtuais também irão usar scanners de porta pelo mesmo motivo.
  - Proteger os serviços de rede garante que somente as portas necessárias estejam expostas e disponíveis.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de Rede e Roteamento (Cont.)

O DHCP (Protocolo de Configuração Dinâmica de Host) usa um servidor para atribuir um endereço IP e outras informações de configuração automaticamente aos dispositivos de rede.

- Na realidade, o dispositivo está obtendo uma permissão do servidor DHCP para usar a rede.
- Os invasores podem direcionar servidores DHCP para negar o acesso a dispositivos na rede, mas medidas de segurança como rastreamento de DHCP impedem que servidores DHCP invasores forneçam endereços IP para clientes ao validar mensagens de fontes que não são confiáveis.

- A Figura 1 fornece uma lista de verificação de segurança para DHCP.
  - Proteja fisicamente o servidor DHCP.
  - Aplique as correções de software.
  - Localize o servidor DHCP atrás de um firewall.
  - Monitore a atividade do DHCP analisando os registros do DHCP.
  - Mantenha uma solução antivírus forte.
  - Desinstale qualquer serviço e aplicação não utilizado.
  - Feche as portas não utilizadas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de Rede e Roteamento (Cont.)

O DNS converte um URL ou endereço de site, como www.cisco.com, em um endereço IP numérico. Quando os usuários digitam um endereço da Web na barra de endereços, o servidor DNS reconhece o endereço IP.

As DNS Security Extensions (DNSSEC) usam assinaturas digitais para fortalecer a autenticação e proteger contra ameaças ao DNS.

- Uma checklist de segurança para DNS:
  - Manter softwares DNS atualizados.
  - Impeça que a string de versão revele informações.
  - Separe os servidores DNS internos e externos.
  - Restrinja as transações permitidas pelo endereço IP do cliente.
  - Use assinaturas de transação para autenticar transações.
  - Desative ou restrinja as transferências de zona e as atualizações dinâmicas o máximo possível.
  - Habilitar o log e analisar logs.
  - Use Domain Name System Security Extensions (DNSSEC).
  - Assine zonas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de Rede e Roteamento (Cont.)

Protocolo de mensagens de controle da Internet (ICMP): os dispositivos de rede usam o ICMP para enviar mensagens de erro informando que um serviço solicitado não está disponível ou que o host não conseguiu acessar o roteador, por exemplo.

- O comando ping é um utilitário de rede que usa o ICMP para testar a acessibilidade de um host em uma rede.
  - O ping envia mensagens ICMP para o host e aguarda uma resposta.
  - Os criminosos digitais podem alterar o uso do ICMP para executar ataques de canal secreto e reconhecimento, negação de serviço (DoS).
  - Muitas redes filtram solicitações de ICMP para evitar esses ataques.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de Rede e Roteamento (Cont.)

O RIP (Routing information protocol): limita o número de saltos permitidos em um caminho em uma rede do dispositivo de origem para o destino.

- O número máximo de saltos permitidos para o RIP é 15.
- O RIP é um protocolo de roteamento usado para trocar informações de roteamento sobre quais redes cada roteador pode acessar e a que distância estão essas redes.

- O RIP calcula a melhor rota com base na contagem de saltos, mas os criminosos digitais também podem direcionar roteadores e o protocolo RIP.
  - Esses ataques a serviços de roteamento podem afetar o desempenho e a disponibilidade; alguns ataques podem até resultar em redirecionamento de tráfego.
  - Use os serviços seguros com autenticação e implemente patches e atualizações de sistema para proteger serviços de roteamento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Serviços de Rede e Roteamento (Cont.)

O NTP (Network Time Protocol) é um protocolo que sincroniza os relógios de sistemas de computadores.

- Ter o tempo correto nas redes é importante.
  - Carimbos de data e hora corretos são necessários para rastrear com precisão os eventos da rede, como as violações de segurança.
  - Além disso, a sincronização do relógio é fundamental para a interpretação correta dos eventos nos arquivos de dados syslog, bem como para os certificados digitais.

- O NTP permite que os dispositivos de rede sincronizem as configurações de hora com um servidor NTP.
  - Os criminosos virtuais atacam servidores de tempo para interromper a comunicação segura que depende de certificados digitais e esconder informações do ataque, como carimbos de data e hora.
  - Use a autenticação NTP para verificar se o servidor é confiável.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Telnet, SSH e SCP

O Secure Shell (SSH) é um protocolo que fornece uma conexão com um dispositivo remoto de natureza segura (criptografada) e baseada em uma linha de comando.

O Telnet é um protocolo mais antigo que usa transmissão de texto não criptografado, não protegido, tanto para autenticação de logon (nome de usuário e senha) quanto para dados transmitidos entre os dispositivos de comunicação.

- O SSH deve ser usado em vez do Telnet para gerenciar conexões, pois ele oferece criptografia forte.
  - O SSH usa a porta TCP 22.
  - Já o Telnet usa a porta 23.

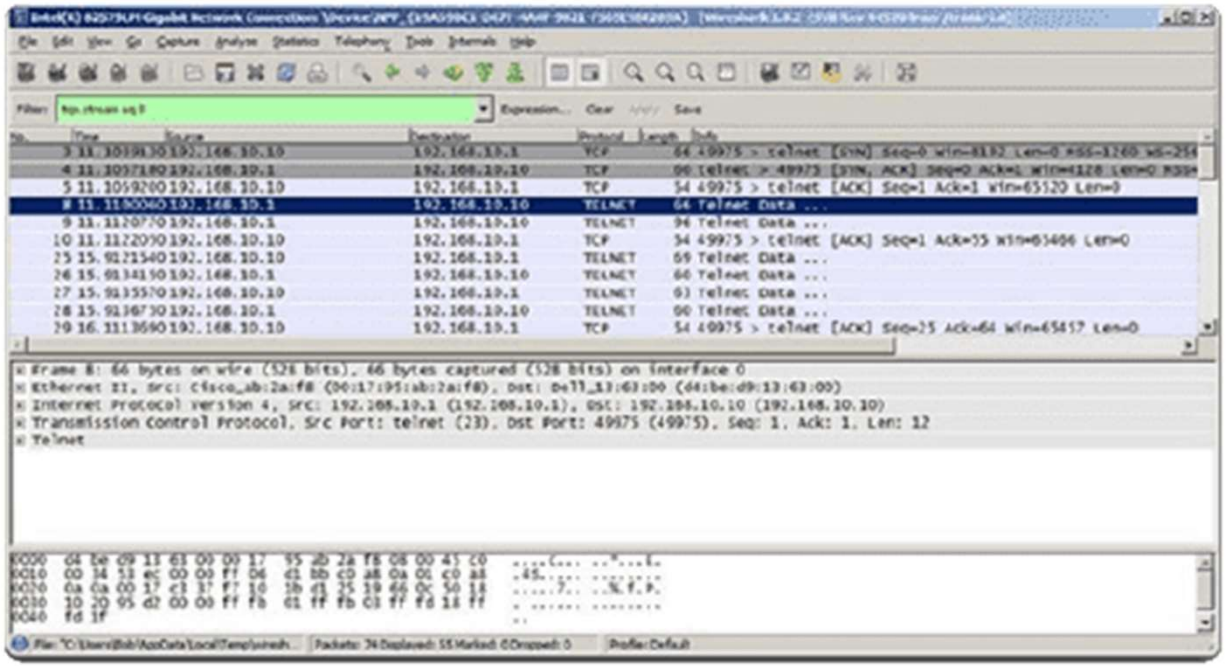
A SCP (Secure Copy, cópia segura) , transfere, com segurança, arquivos de computador entre dois sistemas remotos.

- O SCP usa o SSH para a transferência de dados (incluindo o elemento de autenticação), para que o SCP garanta a autenticidade e a confidencialidade dos dados em trânsito.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

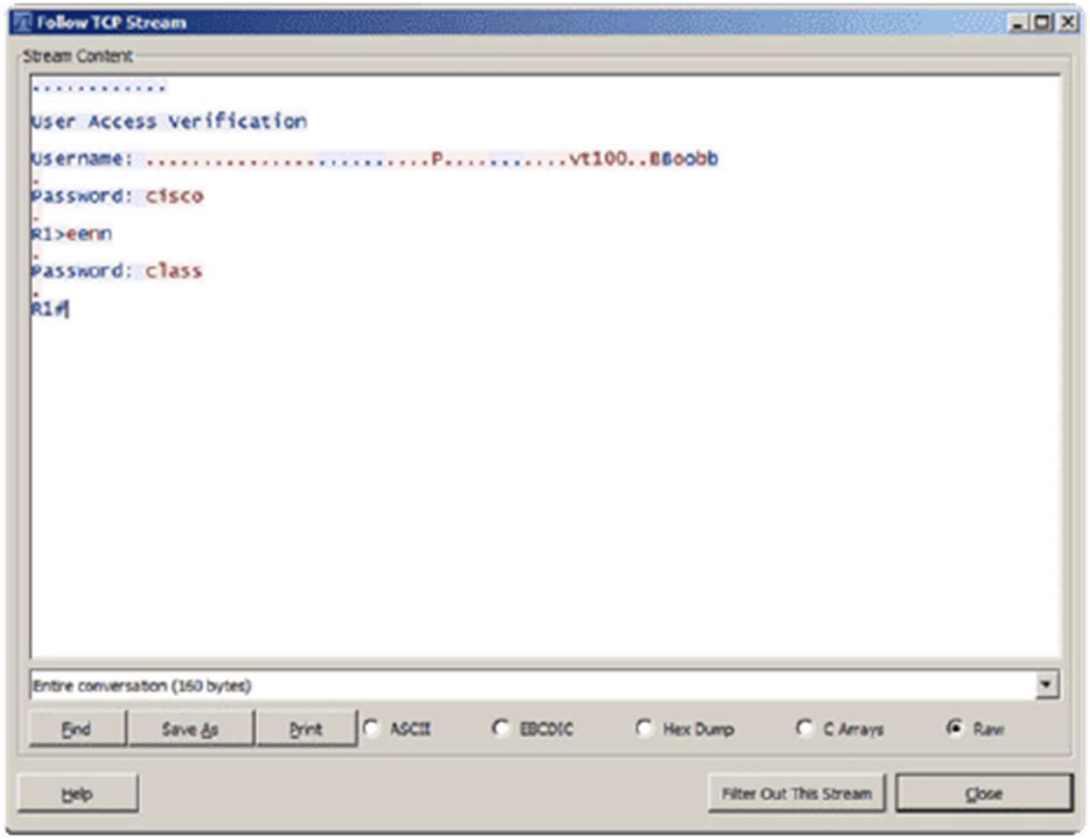
Telnet, SSH e SCP (Cont.)

Captura Wireshark de acessos Telnet: os cibercriminosos monitor am pacotes usando o Wireshark.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Telnet, SSH e SCP (Cont.)

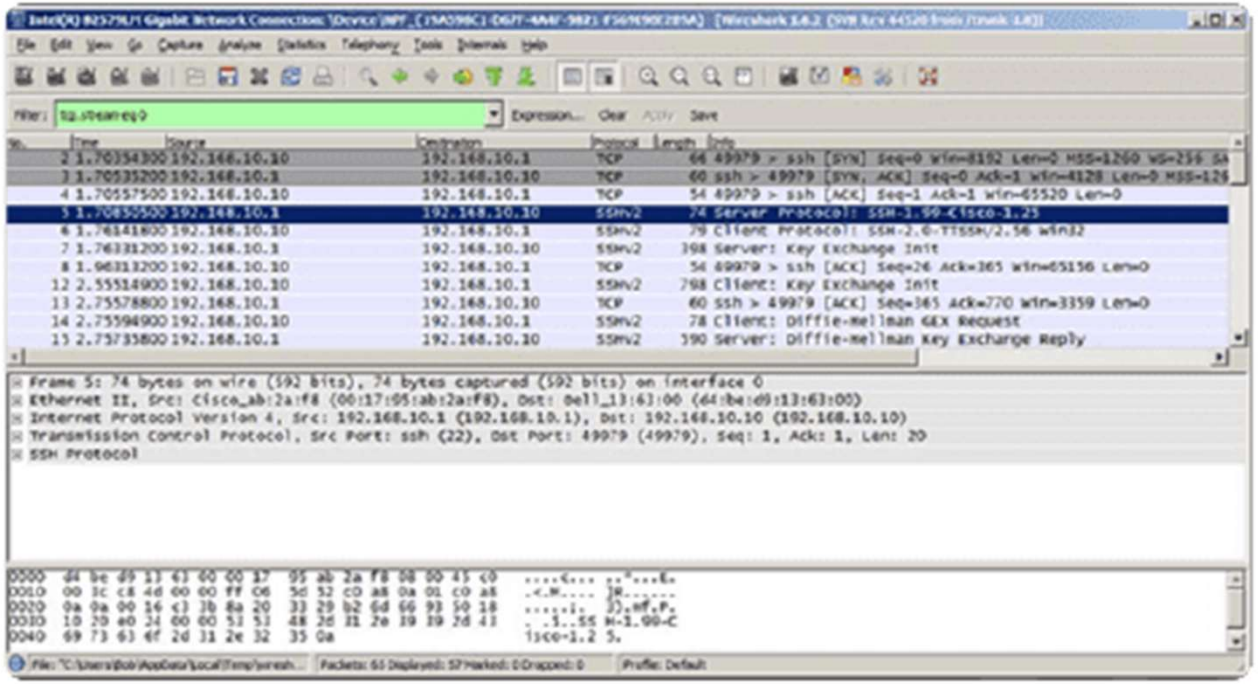


Captura de nome de usuário e senha em texto simples: os cibercriminosos captur am o nome de usuário e a senha do administrador da sessão Telnet em texto simples.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Telnet, SSH e SCP (Cont.)

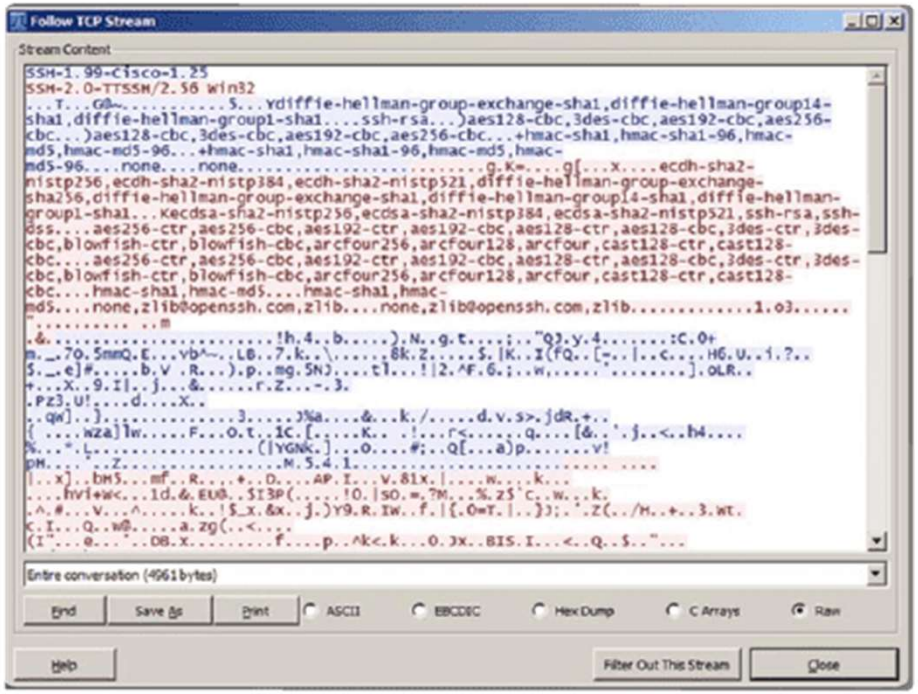
Captura Wireshark SSH: A visualização Wireshark de uma sessão SSH. O ator de ameaça pode rastrear a sessão usando o endereço IP do dispositivo administrador.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Telnet, SSH e SCP (Cont.)

Criptografia de nome de usuário e senha: Asessão criptografa o nome de usuário e a senha.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos Seguros

Os invasores podem penetrar na infraestrutura de uma rede por meio de serviços, protocolos e portas abertas.

O SNMP (Protocolo de Gerenciamento de Rede) coleta estatísticas de dispositivos TCP / IP para monitorar a rede e equipamentos de computador. O SNMPv3 é o padrão atual - ele usa criptografia para evitar a espionagem e garantir que os dados não tenham sido violados durante o trânsito.

O Hypertext Transfer Protocol (HTTP) fornece conectividade básica da Web e usa a porta 80. O HTTP contém segurança interna limitada e é aberto ao monitoramento de tráfego durante a transmissão de conteúdo, deixando o computador do usuário aberto para ataques.

- Protocolos que fornecem uma conexão mais segura:
  - **A Secure Sockets Layer (SSL)** gerencia a criptografia usando um handshake de SSL no início de uma sessão para fornecer confidencialidade e evitar a interceptação e a violação.
  - **O Transport Layer Security (TLS)** é um substituto atualizado e mais seguro para SSL.
  - O SSL / TLS criptografa a comunicação entre o cliente e o servidor. Onde for usado, o usuário verá HTTPS no campo de URL de um navegador em vez de HTTP.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos seguros (Cont.)

O File Transfer Protocol (FTP) oferece a capacidade de transferir arquivos entre um cliente e um servidor. No FTP, o cliente usa um nome de usuário e uma senha de texto sem formatação para se conectar. O File Transfer Protocol Secure (FTPS) é mais seguro - ele adiciona suporte a TLS e SSL para evitar a interceptação, a violação e a falsificação de mensagens trocadas.

O e-mail usa **Post Office Protocol (POP)**, **IMAP (Internet Message Access Protocol)** e **MIME (Multipurpose Internet Mail Extensions)** para anexar dados sem texto, como imagens ou vídeos, a uma mensagem de e-mail.

- Para proteger o POP (porta 110) ou IMAP (porta 143), use SSL / TLS para criptografar e-mails durante a transmissão.
- O protocolo Secure / Multipurpose Internet Mail Extensions (S / MIME) oferece um método seguro de transmissão.
    - Ele envia mensagens digitalmente assinadas e criptografadas que fornecem autenticação, integridade de mensagem e não-repudiação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.4 Fortalecimento da Rede: Segmentação

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento da rede: Segmentação

Virtual Local Area Networks (VLANs)

Uma **rede local virtual (VLAN)**pode ser usada para segmentar a rede e criar uma área segura para os dados confidenciais.

Os dispositivos estão agrupados

- As VLANs fornecem uma forma de agrupar dispositivos em uma LAN e em switches individuais.
- VLANs não são iguais a LANs: LANs virtuais são baseadas em conexões lógicas, enquanto LANs são baseadas em conexões físicas.
- Portas individuais de um switch podem ser atribuídas a uma VLAN específica.
- Outras portas (trunks) podem ser usadas para interconectar fisicamente os switches e permitir o tráfego de várias VLANs entre os switches.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento da rede: Segmentação

Virtual Local Area Networks (VLANs) (Cont.)

A rede é segmentada

- As VLANs permitem que um administrador segmente uma rede com base em fatores como função, projeto, equipe ou aplicativo.
- Os dispositivos em uma VLAN atuam como se estivessem em sua própria rede independente, mesmo que compartilhem uma infraestrutura comum com outras VLANs.
- Uma VLANpode separar grupos que têm dados confidenciais do resto da rede, diminuindo as chances de violações de informações confidenciais.
- Troncos permitem que indivíduos na VLAN do RH estejam conectados fisicamente a vários switches diferentes.

Os dados são protegidos

- As VLANs oferecem uma maneira de limitar o tráfego de transmissão em uma rede comutada.
- Para proteger a VLAN, monitorar seu desempenho, usar configurações avançadas e instalar regularmente patches e atualizações.

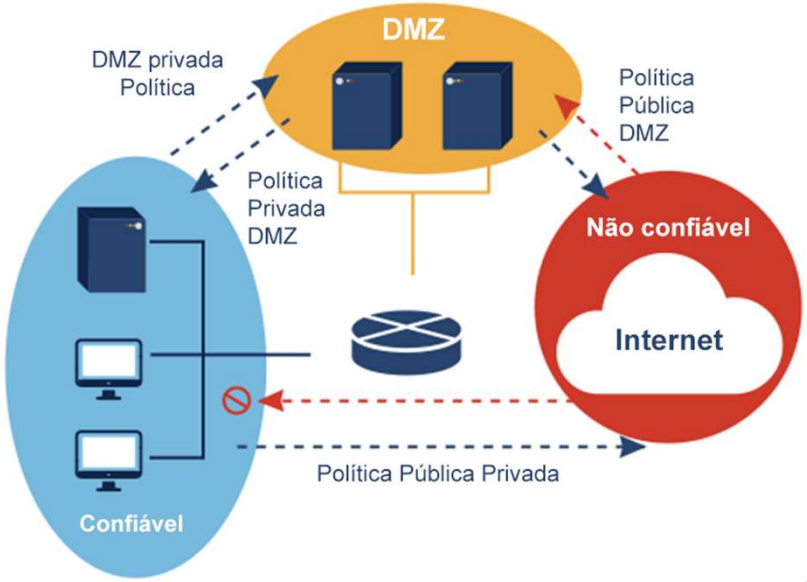
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento da rede: Segmentação

Zona Desmilitarizada (DMZ)

Uma zona desmilitarizada (DMZ) é uma pequena rede entre uma rede privada confiável e a Internet.

Acesso a redes não confiáveis: os servidores da Web e de correio geralmente são colocados na DMZ para permitir que os usuários acessem uma rede não confiável, como a Internet, sem comprometer a rede interna.



suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento da rede: Segmentação

A Zona Desmilitarizada (DMZ)(Cont.)

Zonas de risco: a maioria das redes tem de duas a quatro zonas de risco (a LAN privada confiável, a DMZ, a Internet e uma extranet).

- Na zona de LAN, o nível de risco é baixo e o nível de confiança é alto.
- Na zona da extranet, o nível de risco é médio-baixo e o nível de confiança médio-alto.
- Na DMZ, o nível de risco é médio-alto e o nível de confiança é médio-baixo.
- Na zona da Internet, o nível de risco é alto e o nível de confiança é baixo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento da rede: Segmentação

A Zona Desmilitarizada (DMZ)(Cont.)

Modelo Zero Trust: Os firewalls gerenciam o tráfego de ponta a ponta (tráfego que vai entre os servidores no data center da empresa) e o tráfego de ponta a ponta (dados que entram e saem da rede da empresa).

- Para proteger sua rede, uma empresa pode implementar um modelo de confiança zero.
- Confiar em usuários e endpoints automaticamente na empresa pode colocar qualquer rede em risco, já que usuários confiáveis podem se mover por toda a rede para acessar dados.
- A rede Zero Trust monitora constantemente todos os usuários na rede, independentemente de status ou função.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.5 Fortalecimento de dispositivos sem fio e móveis

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de Dispositivos Sem Fio

A Wired Equivalent Privacy (WEP) foi o primeiro protocolo de segurança usado para redes sem fio. Isso foi substituído pelo Wi-Fi Protected Access (WPA), que melhorou a segurança das conexões sem fio.

- **Configuração WPA:** O Wi-Fi Protected Access (WPA) foi a resposta do setor de computadores para enfraquecer a utilização do padrão WEP. A configuração mais comum de WPA é WPA-PSK (Pre-Shared Key, Chave pré-compartilhada). As chaves usadas pelo WPA são 256 bits, um aumento significativo sobre as chaves de 64 bits e 128 bits usadas no sistema WEP.

- **Recursos WPA:** o WPA fornecia verificações de integridade da mensagem (Message Integrity Checks - MIC) que poderiam detectar se um invasor tinha capturado e alterado os dados transmitidos entre o ponto de acesso sem fio e um cliente sem fio. O padrão TKIP (Temporal Key Integrity Protoco) proporcionou a capacidade de tratar, proteger e alterar melhor as chaves de criptografia. O AES (Advanced Encryption Standard, Padrão de criptografia avançada) substituiu o TKIP por um melhor gerenciamento de chaves e proteção de criptografia..

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento de dispositivos sem fio e móveis

Segurança de Dispositivos Sem Fio (Cont.)

- **O padrão Wi-Fi Protected Access II (WPA2)** foi lançado em 2006. Isso introduziu o uso obrigatório de algoritmos AES e substituiu o TKIP pelo modo de cifra de contador pelo protocolo de código de autenticação de mensagens de cadeia de bloco (CCMP).

- **O Wi-Fi Protected Access III (WPA3)** WPA3 adicionou mais recursos ao WPA2, como manter algoritmos criptográficos fortes e melhorar a troca de chaves.

- **Wi-Fi Protected Setup (WPS)** pode ser usada para configurar uma rede doméstica sem fio segura. Conectar dispositivos de IoT à rede sem fio No entanto, o WPS apresenta uma grande vulnerabilidade de segurança, pois o PIN do usuário pode ser descoberto através de um ataque de força bruta. Por isso, o WPS não deve ser usado e deve ser desativado por completo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

PT Video - Configurar o fortalecimento e a segurança dos roteadores sem fio.

Este vídeo demonstra a configuração da segurança sem fio em um roteador sem fio.

- Parte 1: Configuração das definições básicas em um roteador sem fio
- Parte 2: Configurar a segurança de rede do roteador sem fio
- Parte 3: Configurar a segurança de rede de clientes sem fio
- Parte 4: Verificar as configurações de conectividade e segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento de dispositivos sem fio e móveis

2.5.4 PT Packet Tracer - Configurar o fortalecimento e a segurança do roteador sem fio

Nesta atividade do Packet Tracer, você atingirá os seguintes objetivos:

Parte 1: Configuração das definições básicas em um roteador sem fio
Parte 2: Configurar a segurança de rede do roteador sem fio
Parte 3: Configurar a segurança de rede de clientes sem fio
Parte 4: Verificar as configurações de conectividade e segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação

Dispositivos móveis e sem fio se tornaram o tipo predominante de dispositivos na maioria das redes modernas. Eles oferecem mobilidade e conveniência, mas estão vulneráveis a diversos problemas de segurança digital. Essas vulnerabilidades incluem roubo, invasão e acesso remoto não autorizado, sniffing, ataques man in the middle e ataques contra o desempenho e a disponibilidade.

- A melhor forma de proteger uma rede sem fio é usar autenticação e criptografia. O padrão sem fio original, 801.11, introduziu dois tipos de autenticação, como mostrado na figura:

- **Autenticação de** sistema aberto – Qualquer dispositivo sem fio pode se conectar à rede sem fio. Use esse método em situações em que a segurança não seja uma preocupação.

- **Autenticação** de chave compartilhada – Fornece mecanismos para autenticar e criptografar dados entre um cliente sem fio e um AP ou um roteador sem fio.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos de Autenticação

O **protocolo de autenticação extensível (EAP)** é uma estrutura de autenticação usada em redes sem fio.

1. O usuário solicita a conexão à rede sem fio através de um access point.
2. O access point solicita dados de identificação (nome de usuário) do usuário, que é então enviado para um servidor de autenticação.
3. O servidor de autenticação solicita a prova de que a ID é válida.
4. O access point solicita prova de que a ID é válida do usuário, na forma de uma senha.
5. O usuário fornece a senha ao access point. O access point envia de volta para o servidor de autenticação.
6. O servidor confirma que o nome de usuário e a senha estão corretos e passa essas informações para o access point e o usuário.
7. Conecte-se à rede sem fio

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos de Autenticação (Cont.)

Quatro protocolos usados com EAP para fornecer autenticação para redes sem fio são:

EAP-TLS
Requer certificado de cliente: Sim
Requer certificado de servidor: Sim
Implantável facilmente:
Dificuldade de segurança : Alta

EAP-TTLS
Requer certificado de cliente: Não
Requer certificado de servidor: Sim
Implantável facilmente: Dificuldade de
Segurança: Média

PEAP
Requer certificado de cliente: Não
Requer certificado de servidor: Sim
Implantável facilmente: Dificuldade de
Segurança: Média

EAP-FAST
Requer certificado de cliente: Não
Requer certificado de servidor : Não
Implantável facilmente: Dificuldade de
Segurança: Média

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação Mútua

Sua rede sem fio e seus dados confidenciais estão sujeitos a acesso não autorizado por hackers que usam uma conexão sem fio. Mas o que você pode fazer para evitar um ataque?

- **Pontos de acesso não autorizados (Rogue AP)**: um ponto de acesso é qualquer dispositivo de hardware que permite que outros dispositivos sem fio se conectem a uma rede com fio. Qualquer dispositivo que tenha uma interface transmissora sem fio e cabeada ligada a uma rede pode, possivelmente, agir como access point não autorizado.

- O access point não autorizado muitas vezes imita um access point autorizado, permitindo que os usuários se conectem à rede sem fio, mas potencialmente roubando seus dados ou realizando outras atividades nefastas no processo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação Mútua (Cont.)

Evitando ataques: Quando você se conecta a um access point não autorizado, o impostor que o configura pode solicitar e copiar dados do seu dispositivo.

A autenticação mútua é a autenticação de duas vias que pode impediraccess points não autorizados. É um processo no qual as duas entidades em um link de comunicação se autenticam antes de se conectarem.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Comunicação

Os dispositivos móveis se conectam e se comunicam das seguintes maneiras:

WiFi e Bluetooth

- Os dispositivos móveis podem usar sinais sem fio, como Wi-Fi e Bluetooth.

Comunicações de campo próximo (Near-Field)

- A comunicação de campo próximo (NFC) permite a comunicação sem contato entre dispositivos. Os chips NFC usam campos eletromagnéticos para permitir pagamentos sem contato, o que significa, por exemplo, que você só precisa manter seu dispositivo próximo a um terminal de pagamento para processar o pagamento.

Infravermelho

- Infravermelho (IR) fornece comunicação de curto alcance usando um receptor de IR. Por exemplo, o IR permite que você controle sua televisão pelo telefone celular.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Comunicação

ComunicaçãoUSB

- O único tipo de comunicação nessa lista com fio, a comunicação USB permite que você use seu smartphone para armazenamento de dados ou áudio.
- A conectividade USB também permite que um dispositivo móvelfuncione como um modem ou fax.
- Você pode conectar um dispositivo móvel a dispositivos de aquisição forense pela porta USB se precisar coletar informações para uma investigação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Blindagem (codificação) de dispositivos sem fio e móveis

Gerenciamento de dispositivos móveis (MDM)

- Um dispositivo móvel emitido por uma empresa pode conter dados pessoais e organizacionais; ele pode ser de propriedade da corporação ou habilitado pessoalmente (COPE).

- Uma empresa também pode ter uma opção de consumerização de TI (BYOD). As políticas de segurança e proteção de dados precisam ser aplicadas quando houver informações corporativas confidenciais no dispositivo do usuário.

Os métodos de gerenciamento de dispositivos móveis podem incluir:

Segmentação e conteinerização do armazenamento

- A segmentação do armazenamento e a conteinerização permitem separar o conteúdo pessoal e do trabalho em um dispositivo. Ele fornece uma área autenticada e criptografada que separa as informações confidenciais da empresa dos dados pessoais do usuário.

- A conteinerização também nos permite:
    - Isolar os aplicativos.
    - Controlar as funções do aplicativo.
    - Excluir as informações do container.
    - Limpar o dispositivo remotamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de Dispositivos Móveis (MDM) (Cont.)

Gerenciamento de conteúdo

- Uma empresa precisa considerar os riscos de segurança envolvidos no uso de aplicativos que compartilham dados, por exemplo, Dropbox, Box, Google Drive e iCloud. Um sistema de segurança de gerenciamento de identidades pode serusado para controlar quais dados um usuário pode acessar.

Gerenciamento de aplicativos

- A lista de permissão permite que você assine **digitalmente** as aplicações para que você possa autorizar as aplicações que os usuários podem instalar. Isso ajuda a garantir que as aplicações instaladas sejam provenientes de fontes confiáveis.
- A autenticação usando senhas fortes é uma prática recomendada para os aplicativos que exigem credenciais de usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteções de Dispositivo Móvel

Não importa se um dispositivo móvel é de propriedade da empresa ou é um dispositivo pessoal usado para o trabalho, medidas precisam ser implementadas para mantê-lo protegido contra ameaças digitais.

Quais são os riscos?

As ameaças a dispositivos móveis incluem:

- Roubo
- Perda
- Acesso não autorizado
- Riscos no sistema operacional
- Riscos de aplicativos
- Risco de rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento de dispositivos sem fio e móveis

Proteções de Dispositivo Móvel (Cont.)

- **Jailbreaking, root e sideload** são formas de contornar as limitações de um dispositivo para fazer coisas que o dispositivo está impedido de fazer. Os usuários podem tentar fazer **o jailbreak** (dispositivos da Apple) ou **root** (dispositivos Android) para executar um aplicativo que não está autorizado ou não está disponível na loja.

- O jailbreak remove a restrição de que apenas aplicativos autorizados pela Apple podem ser executados no dispositivo.

- O enraizamento ignora a arquitetura de segurança do Android para permitir acesso administrativo completo ao dispositivo. Ambos representam um risco para a empresa.

- Há soluções disponíveis que podem detectar um dispositivo com "jailbroken" ou "rooteado". Um dispositivo é então marcado como não compatível e removido da rede ou tem o acesso negado a aplicativos organizacionais.

- As lojas de aplicativos de terceiros também podem representar um risco para as empresas porque os aplicativos aos quais elas fornecem acesso não foram avaliados corretamente. O sideloading (carregamento lateral) ocorre quando o usuário percorre as configurações de aplicativo aprovado para instalar aplicativos não aprovados. Isso é menos invasivo do que fazer jailbreaking ou rooting, mas ainda é um risco.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Proteções de Dispositivo Móvel (Cont.)

Quais são as proteções?
As proteções contra ameaças a dispositivos móveis incluem:

- **Os bloqueios de tela** exigem uma senha, um PIN ou um padrão para acessar o dispositivo.
- **A autenticação biométrica** usa uma característica física exclusiva (impressão digital, face, íris ou voz).
- **A autenticação com reconhecimento de contexto** usa aprendizado de máquina para determinar o acesso com base no comportamento normal do usuário.
- **A limpeza remota** exclui os dados do dispositivo, caso ele seja roubado ou perdido.
- **A criptografia completa do dispositivo** pode criptografar todos os dados em um dispositivo móvel.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fortalecimento de dispositivos sem fio e móveis

Rastreamento de GPS

- **O GPS (Global Positioning System, Sistema de posicionamento Global)** usa satélites e computadores para determinar a localização de um dispositivo. A tecnologia de GPS é um recurso padrão em smartphones e oferece rastreamento de posição em tempo real que normalmente pode localizar um local a aproximadamente 5 metros.

- Muitos aplicativos de celular usam rastreamento por GPS para rastrear a localização do telefone.

- Às vezes, as notificações por push usam geolocalização e geofencing - isso permite que as organizações locais "empurrem" mensagens publicitárias com base nas configurações de localização do usuário. Infelizmente, os invasores digitais cada vez mais experientes começaram a usar notificações push para capturar dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.6 Resiliência em Cibersegurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Alta disponibilidade

- O termo alta disponibilidade descreve sistemas concebidos para evitar períodos de inatividade.
- A disponibilidade contínua de sistemas de informação é imprescindível, não só para as empresas, mas para a vida moderna, já que todos nós usamos e dependemos de computadores e sistemas de informação mais do que nunca.
- Sistemas de alta disponibilidade normalmente incluem três princípios de projeto: eliminar pontos únicos de falha, fornecer transição confiável e detectar falhas à medida que elas ocorrem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Alta disponibilidade

Eliminar pontos únicos de falha

- O primeiro princípio que define os sistemas de alta disponibilidade começa com a identificação de todos os dispositivos e componentes do sistema cuja falha resultaria em falha em todo o sistema.

- Os métodos para eliminação de pontos únicos de falhas incluem dispositivos de hot standby, componentes redundantes e várias conexões ou caminhos.

Fornecer transição confiável

- Fontes de alimentação redundantes, sistemasde energia de backup e sistemas de comunicação de backup proporcionam transição confiável.

Detectar falhas à medida que ocorrem

- O monitoramento ativo do dispositivo e do sistema detecta vários tipos de eventos, incluindo falhas do dispositivo e do sistema. Os sistemas de monitoramento podem até acionar o sistema de backup em caso de falha.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resiliência em Cibersegurança

Os Cinco Noves

- Toda empresa quer poder operar ininterruptamente, mesmo em condições extremas, como durante um ataque.

- Dentre as práticas mais populares de alta disponibilidade estão os cinco noves. Ela recebe esse nome do objetivo de atingir uma taxa de disponibilidade de 99,999%, ou seja, cinco noves em seguida. Isso significa que o período de inatividade é menos de 5,26 minutos por ano.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Os Cinco Noves (Cont.)

Etapas comuns tomadas para alcançar os cinco noves incluem:

Sistemas padronizados

- A padronização dos sistemas propicia que os sistemas usem os mesmos componentes. Os inventários de peças são mais fáceis de manter, e é possível trocar componentes durante uma emergência.
- Nas instalações com sistema de informação altamente seguro, guardas controlam o acesso a áreas confidenciais da empresa.
- O benefício do uso de guardas é que eles podem se adaptar mais do que sistemas automatizados.
- Guardas podem aprender e distinguir muitas condições e situações diferentes e tomar decisões imediatamente.

Clustering

- Clusters de vários dispositivos agrupados proporcionam um serviço que parece ser uma única entidade para um usuário. Se um dispositivo falhar, os outros dispositivos permanecem disponíveis.

Sistemas de componente compartilhado

- Os sistemas são criados para que um sistema completo possa substituir um que falhou.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ponto único de falha

- Únicos pontos de falha são links fracos na cadeia que podem provocar interrupção das operações da empresa.
  - Um único ponto de falha é qualquer parte da operação da empresa cuja falha significa falha completa de todo o sistema - em outras palavras, se falhar, o sistema inteiro falhará.
  - Um ponto de falha único pode ser uma parte específica do hardware, um processo, uma parte específica de dados ou até mesmo um utilitário essencial.
  - Geralmente, a solução para um ponto único de falha é modificar a operação crítica, de modo que esta não confie em um único elemento.
  - A empresa também pode criar componentes redundantes na operação crítica, com o objetivo de assumir o processo, caso algum desses pontos falhem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Redundância N+1

- A redundância N+1 garante a disponibilidade do sistema, no caso de falha de um componente. Os componentes (N) precisam ter, no mínimo, um componente de backup (+1).
- Uma boa maneira de pensar sobre isso é que, no caso de um piso plano, um carro tem quatro pneus (N) e um sobressalente (+1) no porta-malas.
- Embora um sistema N + 1 contenha equipamento redundante, não é um sistema totalmente redundante.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Redundância de N+1

- Em um data center, a redundância N + 1 significa que o design do sistema pode suportar a perda de um componente.
- O N refere-se a cada componente diferente da infraestrutura que faz parte do sistema.
- O + 1 é o componente ou sistema adicional que está em espera, pronto para entrar em ação, se necessário.
- A redundância de N + 1 em um data center que consiste nos elementos acima significa que temos um servidor, uma fonte de alimentação, um switch e um roteador em standby, prontos para entrar em linha se algo acontecer com o servidor principal, a fonte de alimentação principal, switch ou roteador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

RAID

Como funciona?

- O RAID obtém os dados normalmente armazenados em um único disco e os espalha entre várias unidades. Se qualquer disco único RAID0 for perdido, o usuário poderá recuperar os dados de outros discos que também hospedam os dados.

- O RAID também pode aumentar a velocidade da recuperação de dados, já que várias unidades recuperarão os dados solicitados mais rapidamente do que um disco fazendo o mesmo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

RAID (Cont.)

Armazenamento de dados RAID

- Uma solução RAID pode ser baseada em software ou hardware. Uma solução baseada em hardware requer um controlador de hardware especializado, no sistema que contenha as unidades RAID.

Os termos a seguir descrevem as várias maneiras pelas quais o RAID pode armazenar dados na matriz de discos.

- **Espelhamento** - Armazena dados duplicados em uma segunda unidade.
- **Distribuição** - Grava dados em várias unidades para que segmentos consecutivos sejam armazenados em unidades diferentes.
- **Paridade** - mais precisamente, tirar a paridade. Após a distribuição, as somas de verificação são geradas para verificar se não há erros nos dados distribuídos. Essas somas de verificação são armazenadas em uma terceira unidade.

Existem outras arquiteturas RAID, que combinam principalmente os elementos acima.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resiliência em Cibersegurança

Spanning Tree

- A redundância aumenta a disponibilidade da infraestrutura da rede, protegendo-a de um ponto único de falha, como um cabo ou um switch com falha na rede.

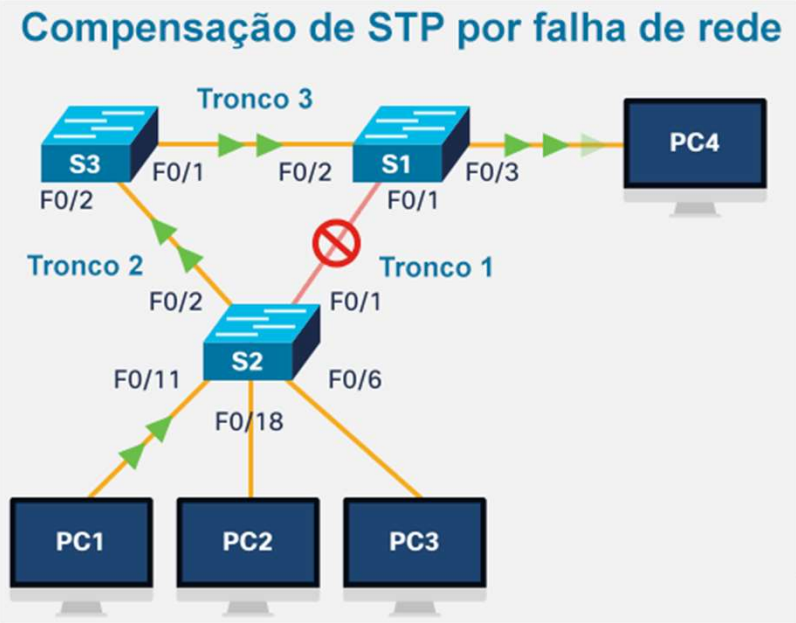
- O Spanning Tree Protocol (STP) soluciona esses problemas. O STP garante que os links físicos redundantes estejam livres de loop e que apenas um caminho lógico seja executado entre todos os destinos na rede.
  - Bloquear os caminhos redundantes é fundamental para evitar loops na rede.Se um cabo ou switch da rede falhar, o STP recalculará os caminhos e desbloqueará as portas necessárias, para permitir que o caminho redundante se torne ativo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Spanning Tree (Cont.)

Esta animação mostra os estágios de STP quando ocorre uma falha.

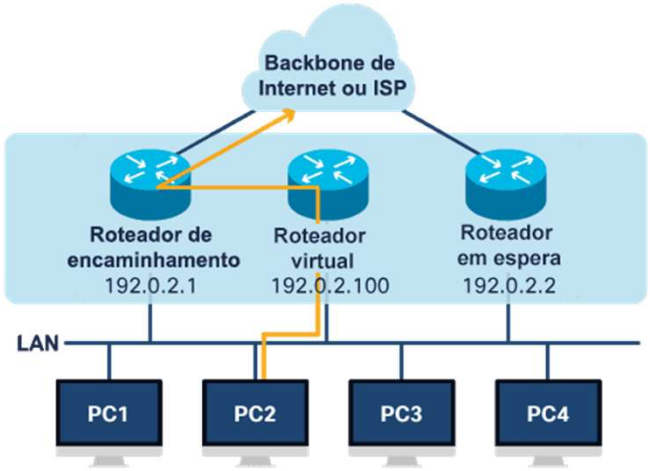
1. O PC1 envia um broadcast para a rede.
2. O trunk link entre S2 e S1 falha, resultando em interrupção do caminho original.
3. O S2 desbloqueia a porta anteriormente bloqueada do Tronco2 e permite que o tráfego de broadcast siga o caminho alternativo na rede, permitindo que a comunicação continue.
4. Se o link entre S2 e S1 voltar a funcionar, o STP bloqueará novamente o link entre S2 e S3.



/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Redundância de roteador

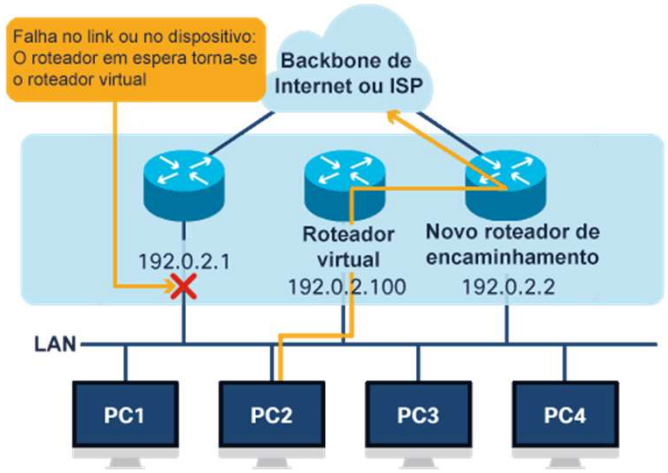
- O gateway padrão é normalmente o roteador que proporciona acesso dos dispositivos ao resto da rede ou à Internet.
  - Se houver somente um roteador como gateway padrão, é um ponto único de falha.
  - A empresa pode escolher instalar um roteador de standby adicional.



- Um protocolo de redundância determina qual roteador deve assumir o papel ativo no encaminhamento do tráfego; o roteador de encaminhamento ou o roteador em espera.
  - Cada roteador está configurado com um endereço IP físico e um endereço IP do roteador virtual.
  - Dispositivos finais usam o endereço IP virtual como o gateway padrão, que é 192.0.2.100.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Redundância de Roteador (Cont.)



- O roteador de encaminhamento e o roteador standby usam seus endereços IP físicos para trocar mensagens periódicas. O objetivo dessas mensagens é ter certeza de que os dois ainda estão on-line e disponíveis.
- Se o roteador em espera parar de receber essas mensagens periódicas do roteador de encaminhamento, ele perceberá que é o único roteador disponível e assumirá a função de encaminhamento.

- A capacidade de uma rede de se recuperar dinamicamente da falha de um dispositivo que atua como um gateway padrão é conhecida como redundância de primeiro salto.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Redundância de local

Uma empresa pode precisar pensar em redundância de local, dependendo de suas necessidades.

Reputação Síncrona:

- Sincroniza os dois locais em tempo real
- Requer alta largura de banda
- Os locais devem ser próximos um do outro, para reduzir a latência

Reputação Assíncrona:

- Não sincronizados em tempo real, mas muito próximo disso
- Requer menos largura de banda
- Os sites podem estar mais distantes, pois a latência é o menor dos problemas

Point-in-time-Replication (Replicação de um ponto no tempo)

- Atualiza periodicamente a localização dos dados de backup
- Mais conservador em termos de largura de banda, pois não exige uma conexão constante

O equilíbrio correto entre custo e disponibilidade determinará a escolha correta para uma empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Design resiliente

Resiliência é o nome dado para os métodos e configurações usados para tornarem um sistema ou rede tolerante a falhas.

- **Exemplo:** uma rede pode ter links redundantes entre switches que executam o STP.
- Embora o STP proporcione um caminho alternativo pela rede se o link falhar, a transição pode não ser imediata, se a configuração não for ideal.

- Os protocolos de roteamento também proporcionam resiliência, mas o ajuste fino pode melhorar a transição, para que os usuários da rede não percebam.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Design Resiliente (Cont.)

Resiliência de aplicativo é a capacidade do aplicativo reagir a problemas em um de seus componentes sem parar de funcionar.

- Umadministrador precisará, eventualmente, desativar aplicativos para aplicações de patches, atualizações de versão ou para implantar novas funcionalidades.
- Alcançar a resiliência da infraestrutura de aplicativos significa evitar a perda de clientes, de funcionários ou de negócios devido a uma falha de aplicativo.
- A figura mostra três soluções de disponibilidade para abordar a resiliência de aplicativos.
  - **Hardware** tolerante a falhas (mais complexo e mais caro) é um sistema projetado com a colocação de múltiplos componentes essenciais em um mesmo computador.
  - **Arquitetura de cluster é** um grupo de servidores que funcionam como se fossem um único sistema.
  - **Backup e restauração Cópias de backup de** arquivos com a finalidade de poder restaurá-los se ocorrer perda de dados (menos complexo e menos caro).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Design Resiliente (Cont.)

Resiliência do IOS

- O IOS (Interwork Operating System, Sistema operacional Interwork) para roteadores e switches Cisco incluem um atributo resiliente de configuração.
  - Permite recuperação mais rápida se alguém, intencionalmente ou não, reformatar a memória flash ou apagar o arquivo de configuração de inicialização.
  - Este atributo mantém uma cópia de trabalho segura do arquivo de imagem do IOS do roteador e uma cópia do arquivo de configuração de execução.
  - O usuário não pode remover esses arquivos seguros, também conhecidos como o bootset primário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Resiliência em Cibersegurança

Sistema e backups de dados

- Uma empresa pode perder dados se os criminosos digitais o roubarem, se o equipamento falhar, ou se ocorrer um desastre ou outro erro, então é importante fazer backup dos dados regularmente.

- Um backup dos dados armazena uma cópia das informações de um computador na mídia de backup removível. Quando essa mídia é removível, o operador armazena essa mídia de backup em um local seguro.

- Fazer backup de dados é uma das formas mais eficazes de proteção contra perda de dados. Se houver falha no hardware do computador, o usuário pode restaurar os dados do backup, depois que o sistema estiver funcional.

- Uma política de segurança sólida deve incluir backups de dados regulares. Os backups de dados são, normalmente, armazenados em outro local, para proteger a mídia de backup, se algo acontecer com a instalação principal.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Backup de Sistemas e Dados

Considerações adicionais para backups de dados incluem:

Frequência

- Frequência - Os backups podem levar muito tempo. Às vezes é mais fácil fazer um backup completo mensal ou semanal, e depois backups parciais frequentes de todos os dados que tiverem mudado, desde o último backup completo. No entanto, ter muitos backup parciais aumenta o tempo necessário para restaurar os dados.

Armazenamento

- Para segurança adicional, os backups devem ser transportados para um local de armazenamento externo aprovado em uma rotação diária, semanal ou mensal, conforme estipulado pela política de segurança.

Segurança

- Proteja os backups com senhas. Em seguida, o operador digita a senha, antes de restaurar os dados na mídia de backup.

Validação

- Valide sempre os backups para garantir a integridade dos dados e

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Projetar um sistema de alta disponibilidade

A alta disponibilidade incorpora três grandes princípios para atingir a meta de acesso ininterrupto aos dados e serviços:

Eliminação ou redução de pontos únicos de falha

- É importante compreender as maneiras de abordar um ponto único de falha. Um ponto único de falha pode incluir roteadores centrais ou switches, serviços de rede e, até mesmo, uma equipe de TI altamente qualificada.
- O que torna esses pontos únicos de falha é o fato de que uma perda ou falha desse sistema, processo ou pessoa teria um impacto muito disruptivo em todo o sistema, o que deve ser evitado.

- Clusters de alta disponibilidade é uma maneira de proporcionar redundância.
  - Esses clusters consistem em um grupo de computadores que têm acesso ao mesmo armazenamento compartilhado e têm configurações de rede idênticas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Projetar um sistema de alta disponibilidade

Tolerânciaa falhas

- Tolerância a falhas permite que um sistema continue funcionando, se um ou mais componentes falharem.
  - Espelhamento de dados é um exemplo de tolerância a falhas.

Resiliência do sistema

- Resiliência de sistemas refere-se à capacidade de manter a disponibilidade de dados e de processamento operacional, apesar de ataques ou de eventos de interrupção.
  - Geralmente, isso requer sistemas redundantes, em termos de energia e de processamento, para que, se um sistema falhar, o outro possa assumir as operações, sem nenhuma interrupção no serviço.
  - Resiliência do sistema é mais do que a blindagem de dispositivos. Requer que os dados e serviços estejam disponíveis, mesmo quando sob ataque.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Alimentação

- Uma questão crítica na proteção de sistemas de informação são os sistemas de energia elétrica e as considerações sobre energia. Um fornecimento contínuo de energia elétrica é fundamental nas enormes instalações de armazenamento de dados e de servidores atuais.

Aqui estão algumas regras gerais na construção de sistemas eficazes de alimentação elétrica:

- Data centers devem estar em uma fonte de alimentação diferente do resto do edifício
- Fontes de alimentação redundantes: dois ou mais feeds (fontes de alimentação) provenientes de duas ou mais subestações elétricas
- Condições de alimentação
- Backup de sistemas de energia são, muitas vezes, necessários
- Uma UPS deve estar disponível para sistemas de desligamento normais

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Potência (Cont.)

Alguns termos padrão vinculados a eventos do sistema de energia elétrica.

Excesso de energia

- Pico: alta tensão momentânea
- Sobrecarga: alta tensão prolongada

Perda de energia

- Falha: perda momentânea de energia
- Blackout - Perda completa de energia

Degradação de energia

- Sag/dip: baixa tensão momentânea
- Queda de energia: baixa tensão prolongada
- Corrente de Inrush (Pico de Corrente): sobrecarga inicial de energia

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Aquecimento, ventilação e ar-condicionado (HVAC)

Sistemas HVAC são críticos para a segurança de pessoas e sistemas de informação nas instalações da empresa. Ao projetar instalações modernas de TI, esses sistemas desempenham um papel muito importante na segurança geral.

- **Os sistemas** de HVAC controlam o ambiente, incluindo a temperatura, a umidade e o fluxo de ar. Isso deve ser gerenciado com componentes de dados como hardware, cabeamento, armazenamento de dados, proteção contra incêndio, sistemas de segurança física e energia, e suas necessidades.

- **Um documento de especificações do produto**
  - Quase todos os dispositivos de hardware de computador físicos vêm com requisitos ambientais que incluem temperatura aceitável e faixas de umidade.
  - Os requisitos ambientais estão em um documento de especificações do produto ou em um guia de planejamento físico.
  - É fundamental manter esses requisitos ambientais para evitar falhas de sistema e prolongar a vida dos sistemas de TI.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Aquecimento, ventilação e ar-condicionado (HVAC) (Cont.)

Contratante do sistemade HVAC

- Sistemas HVAC comerciais e outros sistemas de gerenciamento de edifício agora se conectam à Internet para monitoramento e controle remotos.
- Mas os eventos recentes mostraram que esses sistemas "inteligentes" também geram grandes problemas de segurança, pois eles são acessados e gerenciados por fornecedores de sistemas HVAC ou de terceiros.

Riscos à segurança da empresa

- Como os técnicos de HVAC precisam conseguir encontrar informações rapidamente, dados vitais tendem ser armazenados em diferentes lugares, tornando-os acessíveis para um número ainda maior de pessoas.
- Essa situação permite que uma ampla gama de indivíduos, inclusive associados de empreiteiros, obtenham acesso às credenciais de um sistema HVAC.
- Mas, quanto mais as pessoas têm acesso, menos seguros são esses sistemas, enquanto sua interrupção pode representar um risco considerável para a segurança da empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controle de ameaças a instalações físicas

As empresas podem implementar várias medidas para controlar ameaças a instalações físicas:

Por exemplo:

- Implementar controle de acesso e cobertura de circuito fechado de TV (CCTV) em todas as entradas.
- Estabelecer políticas e procedimentos para os convidados que visitam as instalações.
- Testar a segurança do edifício usando meios cibernéticos e físicos para obter acesso de forma secreta
- Implementar a criptografia de crachá para acesso de entrada
- Planejamento de recuperação de desastres
- Planejamento da continuidade dos negócios
- Treinamento e conscientização de segurança
- Sistema de marcação de ativos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.7 Sistemas Embarcados e Especializados

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças a setores importantes de indústrias

- Ao longo da última década, ataques cibernéticos como Stuxnet provaram que um ataque cibernético pode destruir ou interromper infraestruturas essenciais.
  - O ataque Stuxnet, especificamente, foi direcionado ao sistema SCADA (Supervisory Control and Data Acquisition, Controle de supervisão e aquisição de dados) e foi usado para controlar e monitorar processos industriais. O SCADA e outros sistemas de controle industrial (ICSs) são usados nos sistemas de manufatura, produção, energia e comunicação.

Como os ataques digitais como esses, podem afetar os setores da indústria e quais ações podem ser tomadas para impedir que esses ataques ocorram?

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ameaças a setores importantes de indústrias (Cont.)

Stuxnet: Um ataque digital como esse pode derrubar ou interromper instalações essenciais, como telecomunicações, sistemas de transporte ou usinas de energia elétrica. Também poderia interromper o setor de serviços financeiros.

- Os ambientes que usam o SCADA são vulneráveis.
- Quando a arquitetura SCADA foi desenvolvida, os designers não a conectaram ao ambiente de TI tradicional e à Internet.
- Portanto, eles não consideraram corretamente a segurança cibernética durante a fase de desenvolvimento desses sistemas.
- Para evitar ataques a esses sistemas, você deve segregar as redes internas e externas para separar a rede SCADA da LAN da empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O surgimento da Internet das coisas

- A Internet das coisas (IoT) é o conjunto de tecnologias que permitem a conexão de vários dispositivos à Internet.
- As tecnologias da IoT permitem que as pessoas conectem bilhões de dispositivos, como carros, máquinas industriais, robôs, dispositivos, bloqueios, motores e dispositivos de entretenimento, para citar apenas alguns.
- Com o surgimento da IoT, há muito mais dados a serem gerenciados e protegidos.
- Os dispositivos IoT expandem muito a superfície de ataque cibernético.
- Na IoT, milhares de novos dispositivos requerem acesso a redes para enviar dados e serem gerenciados e operados.
- Dispositivos inteligentes conectados à Internet foram infectados com malware e usados para lançar alguns dos maiores ataques DDoS da história.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados

- Sistemas embarcadoscapturam, armazenam e acessam dados. Eles apresentam desafios de segurança exclusivos devido à ampla adoção pelo mundo corporativo e pelo consumidor. Eles são usados em Smart TVs, sistemas de controle de HVAC, dispositivos médicos e até mesmo automóveis.

Por que os sistemas embarcados estão vulneráveis a ataques?

- Os ataques contra sistemas embarcados exploram vulnerabilidades de segurança nos componentes de software e hardware.
  - Eles são suscetíveis a ataques de tempo, em que os invasores descobrem vulnerabilidades estudando quanto tempo o sistema leva para responder a diferentes entradas.
  - Um ataque de tempo é considerado um ataque de canal lateral.
    - Esse tipo de ataque se baseia nas informações obtidas com a implementação de um sistema, e não nos pontos fracos do software.
    - Informações de tempo, consumo de energia, vazamentos eletromagnéticos ou até mesmo som podem ser essa fonte de informações.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados(Cont.)

Como os sistemas embarcados podem ser protegidos?

- Uma técnica é usar a tecnologia System on Chip (SoC). A tecnologia SoC é um módulo de hardware "Small Form Factor" (SFF). Exemplos de clientes incluem dispositivos como Raspberry Pi e Arduino. Esses dispositivos são computadores de placa única que podem ser implementados usando um "Field-Programmable Gate Array" (FGPA), um circuito integrado que pode ser programado ou modificado em campo. Isso significa que o usuário pode fazer alterações após a implantação do dispositivo.

- Esses dispositivos têm um bom poder de processamento fornecido em um espaço reduzido.
- O SoC integra um microcontrolador, uma aplicação ou microprocessador e periféricos como uma GPU, um módulo de Wi-Fi ou um coprocessador.
- Muitos desses dispositivos de SoC têm autenticação ruim e / ou não podem ser atualizados ou corrigidos.
    - Devido à natureza desses dispositivos, um nível de confiança implícita é necessário, pois não há nenhum programa formal para verificar os controles de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados e Especiais

Internet das Coisas (IoT)

- Um dos setores mais rápidos da tecnologia da informação é o uso de sensores e dispositivos inteligentes. O setor de informática identifica esse setor como a Internet das Coisas (IoT).

- Empresas e consumidores usam dispositivos de IoT para automação de processos, monitoramento de condições ambientais e sistema de alerta ao usuário sobre condições adversas.
  - A maioria dos dispositivos de IoT se conecta a uma rede por meio de tecnologia sem fio.
  - A maioria dos dispositivos IoT se conectam a uma rede via tecnologia sem fio e incluem câmeras, fechaduras, sensores de proximidade, luzes e outros tipos de sensores usados para coletar informações sobre o ambiente ou o status de um dispositivo.
  - Vários fabricantes de dispositivos usam IoT para informar os usuários que precisam substituir peças, que componentes estão falhando ou que suprimentos estão acabando.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Internet das Coisas (IoT) (Cont.)

- As empresas usam esses dispositivos para controlar inventário, veículos e pessoal.
- Os dispositivos IoT contêm sensores geoespaciais.
  - Um usuário pode localizar, monitorar e controlar globalmente as variáveis ambientais, como temperatura, umidade e iluminação.
  - As aplicações de IoT usam um sistema operacional em tempo real (RTOS), um pequeno sistema operacional que permite a troca rápida de tarefas que se concentram no tempo e não na taxa de transferência.

- O setor de IoT constitui um enorme desafio para profissionais de segurança da informação, pois muitos dispositivos IoT capturam e transmitem informações confidenciais.
- As vulnerabilidades associadas ao RTOS incluem injeção de código, ataques de DoS e inversão de prioridade (onde uma tarefa de prioridade mais alta é antecipada por uma tarefa de prioridade mais baixa).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protegendo Dispositivos IoT

- Usar um scanner de IoT, como a Shodan, é uma maneira fácil de saber se um dispositivo de automação residencial está vulnerável a ataques.
- Os dispositivos de IoT se comunicam usando métodos de curto, médio ou longo alcance e incluem celular (4G, 5G), rádio e Zigbee.
- O Zigbee é um conjunto sem fio de protocolos para redes pessoais de área (WPANs).

- Para proteger dispositivos de IoT:
  - Proteção da rede sem fio
  - Saiba exatamente quais dispositivos estão se comunicando em sua rede.
  - Saiba o que cada um dos dispositivos de IoT na sua rede faz.
  - Instale o software de segurança nos dispositivos sempre que possível.
  - Proteja smartphones e aplicativos móveis usados para se comunicar com dispositivos de IoT.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Equipamento VoIP

Voz sobre IP (VoIP) usa redes como a Internet para fazer e receber chamadas de telefone.

De que equipamento você precisa?
Você precisa de uma conexão com a Internet e um telefone para VoIP.

- Várias opções estão disponíveis como configuração do telefone:
  - Um telefone tradicional, com um adaptador (o adaptador atua como uma interface de hardware entre um telefone tradicional, analógico e uma linha digital VoIP)
  - Um telefone ativado para VoIP
  - Software VoIP instalado em um computador

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Equipamento VoIP (Cont.)

O VoIP é seguro?

- A maioria dos serviços de VoIP do consumidor usam a Internet para chamadas de telefone. A segurança de VoIP só é confiável se houver uma segurança de rede subjacente. Os criminosos virtuais direcionam esses sistemas para obter acesso a serviços de telefone gratuitos, espionar telefonemas, ou para afetar o desempenho e a disponibilidade.

Como você pode proteger seu serviço de VoIP?

Implemente as seguintes contramedidas para proteger o VoIP:

- Criptografe os pacotes de mensagens de voz para proteger contra espionagem.
- Use o SSH para proteger gateways e switches.
- Altere todas as senhas padrão.
- Use um sistema de detecção de invasão para detectar ataques, como envenenamento ARP.
- Use autenticação forte para mitigar o spoofing de registro (os criminosos virtuais roteiam todas as chamadas recebidas da vítima para eles), representação de proxy (engana a vítima para se comunicar com um proxy falso configurado pelos criminosos virtuais) e sequestro de chamadas (a chamada é interceptada e reencaminhada para um caminho diferente, antes de chegar ao destino).
- Implemente firewalls que reconhecem VoIP para monitorar os streams e filtrar sinais anormais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados de Finalidade Específica

- Os sistemas embarcados funcionam em diversos setores. Você pode encontrar dispositivos embarcados para fins especiais em setores como o médico, automotivo e de aviação.

Dispositivos Médicos

- Dispositivos como marca-passos, bombas de insulina, implantes médicos e desfibriladores são capazes de conectividade sem fio, monitoramento remoto e comunicação de campo próximo (NFC).

- Vulnerabilidades nesses dispositivos médicos podem levar a problemas de segurança do paciente, vazamentos de prontuários médicos ou o risco de conceder acesso à rede aos criminosos digitais, que o percorrerão em busca de um alvo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados de Finalidade Específica

Automotivo

- Os sistemas no veículo produzem e armazenam os dados necessários para a operação do veículo, juntamente com sua manutenção, proteção de segurança e transmissão de contato de emergência.

- Normalmente, uma interface sem fio se conecta à Internet e a uma interface de diagnóstico integrada.

- Muitos veículos registram manobras de velocidade, localização e frenagem e podem enviar os dados coletados para a seguradora do motorista.

- Os riscos às comunicações no veículo incluem rastreamento não autorizado, interferência sem fio e spoofing.

- Para dar segurança a sistemas dentro do veículo implemente as seguintes contramedidas
  - Práticas de design de software de sistema seguro
  - Criptografia básica para toda a comunicação entre controladores
  - Implementação de firewall

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados de Finalidade Específica

Aviação

- Uma aeronave tem muitos sistemas de controle integrados, como seu sistema de controle de voo e sistema de comunicação. Os problemas de segurança incluemo uso de credenciais de logon codificadas, protocolos inseguros e backdoors.

- Na mesma categoria, os veículos aéreos não tripulados (UAVs), mais comumente chamados de drones, têm sido usados em aplicações militares, agrícolas e de cartografia, entre outras.

- Drones são suscetíveis a sequestros, ataques de Wi-Fi, ataques de spoofing de GPS, bloqueios e ataques de autenticação, que podem permitir que um invasor intercepte ou desative um drone e acesse seus dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tecnologias de Dissimulação

- As empresas usam tecnologias de dissimulação para distrair os invasores das redes de produção. Eles também os usam para aprender os métodos de um invasor e para alertar sobre possíveis ataques que poderiam ser lançados contra a rede. A dissimulação adiciona uma camada falsa à infraestrutura da empresa.

- Um **honeypot** é um sistema de isca configurado para imitar um servidor na rede da empresa. Ela é intencionalmente deixada exposta para atrair invasores. Quando um invasor vai atrás do honeypot, suas atividades são registradas e monitoradas para posterior análise. O honeypot distrai o invasor dos recursos de rede reais da empresa.

- Uma empresa pode até criar uma rede de mel, uma coleção de honeypots (**honeynet**), para imitar sua rede e distrair os invasores. Enquanto isso, os arquivos Honey são arquivos falsos que atraem um invasor, mas não contêm informações reais.

- Um **sinkhole DNS** impede a resolução de nomes de host para URLs específicas e pode afastar os usuários de recursos mal-intencionados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas Embarcados e Especializados

Packet Tracer - Implementar segurança física com dispositivos de IoT

Nesta atividade do Packet Tracer, você atingirá os seguintes objetivos:

- Parte 1: Conexão dos dispositivos de IoT à rede
- Parte 2: Adicionar dispositivos de IoT ao servidor de registro
- Parte 3: Explore a funcionalidade dos dispositivos de segurança da IoT

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

2.8 Resumo Defesa de Sistemas e Redes

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 3: Controle de Acesso

Defesa de rede

Objetivos do módulo

Título do Módulo: Controle de Acesso

Objetivo do Módulo: Configurar o controle de acesso local e baseado em servidor.

Título do Tópico	Objetivo do Tópico
Controles de acesso	Configurar o acesso seguro em um host.
Conceitos de controle de acesso	Explicar como o controle de acesso protege os dados da rede.
Gerenciamento de contas	Explicar a necessidade de estratégias de gerenciamento de contas e controle de acesso.
Uso e operação AAA	Configurar a autenticação baseada no servidor com TACACS+ e RADIUS

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.1 Controles de Acesso

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso físico

- **Controles de acesso físico** são barreiras reais implantadas para evitar o contato direto com os sistemas.

- A meta é prevenir que usuários não autorizados acessem fisicamente as instalações, equipamentos e outros ativos organizacionais.

- Alguns exemplos de controles de acesso físicos são:
  - Guardas para monitorar a instalação
  - Cercas para proteger o perímetro
  - Detectores de movimento para detectar objetos em movimento
  - Bloqueios de laptop para proteger equipamentos portáteis
  - Portas trancadas para impedir o acesso não autorizado
  - Cartões de acesso para permitir o acesso a uma área restrita
  - Cães de guarda para proteger a instalação
  - Câmeras de vídeo para monitorar uma instalação coletando e gravando imagens
  - Sistemas de entrada estilo Mantrap para escalonar o fluxo de pessoas na área protegida e prender visitantes indesejados
  - Alarmes para detectar intrusão

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso lógicos

- **Controles de acesso lógico** são as soluções de hardware e software usadas para gerenciar o acesso aos recursos e sistemas.

- Essas soluções baseadas em tecnologia incluem ferramentas e protocolos que os sistemas de computador usam para identificação, autenticação, autorização e auditoria.

- Exemplos de controle de acesso lógico
  - A criptografia é o processo de pegar o texto claro e criar o texto codificado.
  - Os cartões inteligentes possuem um microchip integrado.
  - As senhas são strings de caracteres protegidos.
  - A biometria se refere às características físicas dos usuários.
  - As listas de controle de acesso (ACLs) definem o tipo de tráfego permitido em uma rede.
  - Os protocolos são conjuntos de regras que regem a troca de dados entre os dispositivos.
  - Os firewalls impedem o tráfego de rede indesejado.
  - Os roteadores conectam pelo menos duas redes.
  - Os sistemas de detecção de invasão monitoram as atividades suspeitas de uma rede.
  - Os níveis de corte são determinados pelos limites permitidos para erros antes de acionar uma bandeira vermelha.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso administrativos

- **Controles de Acesso Administrativo** são as políticas e procedimentos definidos pelas empresas para implementar e aplicar todos os aspectos de controle de acesso não autorizado.

- Os controles administrativos focam em práticas pessoais e de negócios.

- Exemplos de controles administrativos
  - As políticas são declarações de intenções.
  - Os procedimentos são os passos detalhados necessários para realizar uma atividade.
  - As práticas de contratação envolvem as etapas seguidas por uma empresa para encontrar funcionários qualificados.
  - As verificações de antecedentes se referem a uma triagem admissional que inclui as informações de verificação de histórico profissional, histórico de crédito e antecedentes criminais.
  - A classificação de dados categoriza os dados com base na confidencialidade.
  - O treinamento em segurança ensina os funcionários sobre as políticas de segurança de uma empresa.
  - As análises críticas avaliam o desempenho de trabalho do funcionário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso administrativo em detalhes

- O conceito de controles de acesso administrativo envolve três serviços de segurança: autenticação, autorização e contabilidade (AAA).

- Esses serviços fornecem a estrutura principal para controlar o acesso, impedindo o acesso não autorizado a um computador, rede, banco de dados ou outro recurso de dados.

- **Autenticação:**
  - Verifica a identidade de um usuário, para evitar acesso não autorizado.
  - Os usuários provam sua identidade com um nome de usuário ou um ID.
  - Além disso, os usuários precisam verificar sua identidade fornecendo um dos seguintes:
    - Algo que saibam (como uma senha)
    - Algo que tenham (como um token ou cartão)
    - Algo que eles são (como uma impressão digital)
    - No caso da autenticação de dois fatores, que está se tornando cada vez mais a regra, o sistema requer uma combinação de duas das alternativas acima, em vez de apenas uma, para verificar a identidade de alguém.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso administrativo em detalhes (cont.)

- **Autorização**:
  - Determina quais recursos os usuários podem acessar, juntamente com as operações que os usuários podem realizar.
  - Alguns sistemas fazem isso usando uma lista de controle de acesso, ou uma ACL.
    - Uma ACL determina se um usuário tem certos privilégios de acesso depois de se autenticar.
    - Pode controlar quando um usuário tem acesso a um recurso específico.

- **Contabilidade:**
  - Mantém controle sobre o que os usuários fazem — , incluindo o que acessam, a quantidade de tempo que acessam os recursos e as alterações que eles realizaram.
  - Os serviços de contabilidade de segurança cibernética rastreiam cada transação de dados e fornecem resultados de auditoria.
  - Os administradores de sistema podem configurar políticas de computador para habilitar a auditoria do sistema.
  - O Accounting controla e monitora em tempo real.

- O conceito de AAA é como um uso de cartão de crédito que identifica quem pode usá-lo, determina quanto o usuário pode gastar e contabiliza os itens ou serviços que o usuário comprou.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso

O que é identificação?

- Ela aplica as regras estabelecidas pela política de autorização.
- Sempre que o acesso a um recurso é solicitado, os controles de acesso determinam se o acesso deve ser concedido ou negado.
- Um identificador único assegura a devida associação entre as atividades permitidas e os indivíduos.
- Um nome de usuário é o método mais comum usado para identificar um usuário.
- Um nome de usuário pode ser uma combinação alfanumérica, um número de identificação pessoal (PIN), um cartão inteligente ou a biometria, como uma impressão digital, escaneamento da retina ou reconhecimento de voz.
- Um identificador único assegura que um sistema possa identificar cada usuário individualmente; portanto, permite que um usuário autorizado realize as ações apropriadas em um recurso específico.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de Identidade Federada

- Refere-se a várias empresas que permitem que seus usuários usem as mesmas credenciais de identificação para obter acesso às redes de todas as empresas do grupo.
- Infelizmente, isso amplia o escopo e aumenta a probabilidade de um efeito em cascata caso ocorra um ataque.
- Uma identidade federada vincula a identidade eletrônica de um sujeito em sistemas de gerenciamento de identidade separados, como a possibilidade de acessar vários sites usando as mesmas credenciais de login social
- O objetivo do gerenciamento de identidades federadas é compartilhar informações de identidade automaticamente entre fronteiras.
- Na perspectiva do usuário individual, isso significa um início de sessão universal na Web.
- É imprescindível que as organizações examinem as informações de identificação compartilhadas com os parceiros, mesmo dentro do mesmo grupo corporativo, por exemplo.
- O compartilhamento de números de CPF, nomes e endereços pode permitir que ladrões de identidade roubem essas informações de um parceiro para cometer fraudes.
- A forma mais comum de proteger identidades federadas é vincular a habilidade de login a um dispositivo autorizado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Autenticação

- Os usuários provam sua identidade com um nome de usuário ou ID e precisam verificar sua identidade fornecendo um dos seguintes.

O que você sabe:

- Senhas, frases secretas ou PINs são exemplos de algo que o usuário conhece.
- Os termos frase secreta, código de acesso, chave de acesso ou PIN são chamados genericamente de senha — uma cadeia de caracteres usada para provar a identidade de um usuário
- As senhas devem ter ao menos 8 caracteres e conter uma combinação de letras maiúsculas e minúsculas, números e caracteres especiais.
- Os usuários precisam usar senhas diferentes para sistemas diferentes porque, se um criminoso quebrar a senha do usuário uma vez, o criminoso terá acesso a todas as contas do usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Autenticação (Cont.)

O que você tem:

- Cartões inteligentes e chaveiros de segurança são exemplos de algo que os usuários possuem e que podem ser usados para fins de autenticação.

- Um cartão inteligente é um pequeno cartão de plástico, do tamanho de um cartão de crédito, com um pequeno chip embutido, que é capaz de processar, armazenar e proteger dados.

- Um chaveiro de segurança é um dispositivo pequeno o suficiente para ser anexado a um chaveiro.

- Na maioria dos casos, as chaves de segurança são usadas para autenticação de dois fatores (2FA), que é muito mais segura do que uma combinação de nome de usuário e senha.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Métodos de Autenticação (Cont.)

Quem é você:

- A segurança biométrica compara as características físicas aos perfis armazenados para autenticar os usuários.

- Existem dois tipos de identificadores biométricos:
  - **Características fisiológicas** – impressões digitais, DNA, rosto, mãos, retina ou ouvido
  - **Características comportamentais** - padrões de comportamento como gestos, voz, andar ou ritmo de digitação.

- A biometria está se tornando cada vez mais popular em sistemas de segurança pública, dispositivos eletrônicos do consumidor e aplicações de ponto de venda.

- A implementação da biometria envolve um leitor ou dispositivo de escaneamento, um software que converte as informações escaneadas em formato digital e um banco de dados que possui dados biométricos armazenados para comparação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso

Autenticação multifator

- Utiliza pelo menos dois métodos de verificação - como uma senha e algo que você possui, por exemplo, um chaveiro de segurança
- Isso pode ser levado um passo adiante adicionando algo que você é, como uma verificação de impressão digital.
- A autenticação multifator pode reduzir a incidência de roubo de identidade online porque significa que saber uma senha não dará aos cibercriminosos acesso à conta de um usuário.
- Observe que a autenticação de dois fatores (2FA) é um método de autenticação de vários fatores que envolve dois fatores em particular, mas os dois termos são frequentemente usados de forma alternada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autorização

A autorização controla o que um usuário pode e não pode fazer na rede após a autenticação com sucesso.

- Depois que um usuário prova sua identidade, o sistema verifica quais recursos de rede o usuário pode acessar e o que pode fazer com os recursos.

Quando implementar a autorização

- A autorização usa um conjunto de atributos que descreve o acesso do usuário à rede para responder à pergunta: "Quais privilégios de leitura, cópia, edição, criação e exclusão esse usuário tem?"
- O sistema compara esses atributos com as informações contidas no banco de dados de autenticação, determina um conjunto de restrições para aquele usuário e o entrega ao dispositivo local onde o usuário está conectado.
- A autorização é automática e não exige que os usuários executem etapas adicionais após a autenticação.
- Os administradores do sistema configuraram a rede para implementar a autorização imediatamente após a autenticação do usuário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autorização (Cont.)

Usando autorização

- Definir as regras de autorização é a primeira etapa no controle de acesso.
- Uma política de autorização estabelece essas regras.
- Uma política de associação baseada em grupo define a autorização com base nos membros de um grupo específico.
- Todos os funcionários de uma empresa podem ter um cartão de furto, por exemplo, que fornece acesso às instalações, mas pode não permitir o acesso a uma sala do servidor.
- Uma política de nível de autoridade define as permissões de acesso com base na posição de um funcionário na organização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Configure o Controle de Acesso

Nesta atvidade do Packet Tracer, você completará os seguintes objetivos:

Parte 1: Configurar e usar credenciais de autenticação AAA
Parte 2: Configurar e Verificar Serviços de E-mail
Parte 3: Configurar e usar serviços de FTP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Implementação de Auditabilidade

- **O que é accountability (auditabilidade)?**
  - A auditabilidade rastreia uma ação de volta a uma pessoa ou processo que faz essa mudança em um sistema.
  - A Contabilidade então coleta essas informações e relata os dados de uso.
  - A empresa pode usar esses dados para determinadas finalidades, como auditoria ou cobrança.
- **Implementação de Auditabilidade**
  - A implementação da auditabilidade consiste em tecnologias, políticas, procedimentos e educação.
  - Os arquivos de log fornecem as informações de detalhes com base nos parâmetros escolhidos.
  - As políticas e procedimentos da organização especificam quais ações devem ser registradas e como os arquivos de log são gerados, revisados e armazenados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Implementando Responsabilidade (cont.)

- **Fornecendo contabilidade.**
  - A retenção de dados, eliminação de mídia e requisitos de conformidade geram contabilidade.
  - Muitas leis exigem a implementação de medidas para proteger diferentes tipos de dados.
  - Essas leis orientam uma empresa sobre o caminho certo para manusear, armazenar e eliminar dados.
  - A educação e conscientização das políticas, procedimentos e leis relacionadas de uma empresa também contribuem com a auditabilidade.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controles de acesso

Laboratório - Configurar autenticação e autorização no Linux

Neste laboratório, você completará os seguintes objetivos:

Parte 1: Adicionar um novo grupo para usuários
Parte 2: Adicionar usuários ao novo grupo
Parte 3: Alternar usuários e modificar permissões
Parte 4: Modificar permissões no modo absoluto

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.2 Conceitos de controle de acesso

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança Zero Trust

- **Zero Trust** é uma abordagem abrangente para proteger todo o acesso em redes, aplicações e ambientes.
- Essa abordagem ajuda a proteger o acesso de usuários, dispositivos de usuário final, APIs, IoT, microsserviços, contêineres e muito mais.
- Uma estrutura de segurança de confiança zero ajuda a impedir acesso não autorizado, conter violações e reduzir o risco de movimento lateral de um invasor através de uma rede.
- Tradicionalmente, o perímetro da rede (borda) era o limite entre dentro e fora, ou confiável e não confiável.
- Numa abordagem de confiança zero, qualquer local em que seja necessária uma decisão de controle de acesso deve ser considerado um perímetro.
- Isso significa que, embora um usuário ou outra entidade possa ter passado com êxito o controle de acesso anteriormente, eles não são confiáveis para acessar outra área ou recurso até que sejam autenticados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de Zero Trust (cont.)

Os três pilares do Zero Trust são força de trabalho**,** cargas de trabalho e **local de trabalho.**

Confiança zero para a força de trabalho

- Este pilar consiste em pessoas (por exemplo, funcionários, prestadores de serviços, parceiros e fornecedores) que acessam aplicativos de trabalho usando seus dispositivos pessoais ou gerenciados por empresas.
- Ele garante que apenas os usuários certos e dispositivos seguros possam acessar aplicativos, independentemente da localização.

Confiança zero para cargas de trabalho

- Esse pilar está preocupado com aplicativos que estão sendo executados na nuvem, em data centers e outros ambientes virtualizados que interagem uns com os outros.
- Ele se concentra no acesso seguro quando uma API, um microsserviço ou um contêiner está acessando um banco de dados dentro de um aplicativo.

Confiança zero para o local de trabalho

- Este pilar se concentra no acesso seguro para todos os dispositivos, inclusive Internet das Coisas (IoT), que se conectam a redes empresariais, como endpoints de usuário, servidores físicos e virtuais, impressoras, câmeras, sistemas HVAC, quiosques, bombas de infusão, sistemas de controle industrial e muito mais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Modelos de controle de acesso

- Uma organização deve implementar controles de acesso adequados para proteger seus recursos de rede, recursos do sistema de informações e informações.

- Um analista de segurança deve entender os diferentes modelos básicos de controle de acesso para ter uma melhor compreensão de como os invasores podem quebrar os controles de acesso.

- O modelo de controle de acesso único é o princípio do privilégio mínimo, que especifica uma abordagem limitada conforme a necessidade de conceder direitos de acesso de usuários e processos a informações e ferramentas específicas.

- Uma exploração comum é conhecida como escalação de privilégios.
  - Vulnerabilidades em servidores ou sistemas de controle de acesso são exploradas para conceder a um usuário não autorizado, ou processo de software, níveis de privilégio mais altos do que deveriam.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Conceitos de controle de acesso

Modelos de controle de acesso (cont.)

Modelos de controle de acesso	Descrição
Discretionary access control (DAC)	Este é o modelo menos restritivo e permite que os usuários controlem o acesso aos seus dados como proprietários desses dados.O DAC pode usar ACLs ou outros métodos para especificar quais usuários ou grupos de usuários têm acesso às informações.
Controle de acesso obrigatório (MAC)	Isso aplica o controle de acesso mais rigoroso e é normalmente usado em aplicações militares ou de missão crítica. Ele atribui rótulos de nível de segurança às informações e permite que os usuários tenham acesso com base em sua autorização de nível de segurança.
Controle de acesso por função (RBAC)	As decisões de acesso são baseadas nas funções e responsabilidades de um indivíduo dentro da organização. Diferentes funções recebem privilégios de segurança e indivíduos são atribuídos ao perfil RBAC para a função. As funções podem incluir diferentes posições, classificações de cargo ou grupos de classificações de emprego.Também conhecido como um tipo de controle de acesso não discricionário.
Controle de acesso baseado em atributos (ABAC)	O ABAC permite o acesso com base em atributos do objeto (recurso) a ser acessado, o sujeito (usuário) acessando o recurso e fatores ambientais sobre como o objeto deve ser acessado, como a hora do dia.
Rule-based access control (RBAC)	A equipe de segurança de rede especifica conjuntos de regras ou condições associadas ao acesso a dados ou sistemas. Essas regras podem especificar endereços IP permitidos ou negados, ou determinados protocolos e outras condições.Também conhecido como RBAC Baseado em Regras.
Controle de acesso baseado em tempo (TAC)	TAC Permite o acesso a recursos de rede com base na hora e no dia.

Sistemas de controle de acesso à rede (NAC)

- Eles suportam o gerenciamento de acesso aplicando políticas organizacionais em relação às pessoas e dispositivos que estão tentando acessar a rede.

- Os sistemas NAC permitem que os profissionais de segurança cibernética monitorem os usuários e dispositivos conectados à rede e controlem manualmente o acesso conforme necessário.

- Os sistemas de controle de acesso à rede fornecem os seguintes recursos:
  - Aplicação rápida de políticas de acesso que foram criadas para diferentes condições operacionais.
  - Reconhecer e criar perfis de usuários e dispositivos conectados para evitar que softwares mal-intencionados em sistemas não compatíveis causem danos.
  - Fornecer acesso seguro a convidados da rede, geralmente por meio de portais de registro.
  - Avaliar a conformidade do dispositivo com as políticas de segurança por tipo de usuário, tipo de dispositivo e sistema operacional antes de permitir o acesso à rede.
  - Mitigação de incidentes de segurança bloqueando, isolando ou reparando dispositivos não compatíveis.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sistemas de controle de acesso à rede (NAC) (cont.)

- Como a rede BYOD e IoT expande muito a superfície de ataque da rede, os recursos de automação do sistema NAC tornam prático o controle focado do acesso à rede por esses dispositivos.
- O sistema NAC é configurado para impor políticas organizacionais.
- As políticas relevantes são aprovadas para permitir ou negar o acesso à rede de acordo com uma ampla gama de fatores que o sistema NAC detecta nos dispositivos que estão tentando acessar.
- Sem os sistemas NAC, seria impossível para o pessoal de segurança cibernética avaliar os milhares de dispositivos que poderiam tentar acessar a rede.
- O NAC é um componente importante de uma arquitetura de segurança de confiança zero que reforça a conformidade da política de segurança com todos os dispositivos e usuários que tentam acessar a rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.3 Gestão de contas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Conta

- Uma organização não deve compartilhar contas para usuários privilegiados, administradores ou aplicativos.
- A conta de administrador só deve ser usada para administrar um sistema.
- Se um usuário acessar um site infectado por malware ou abrir um e-mail mal-intencionado enquanto estiver usando a conta de administrador, isso colocaria a empresa em risco.
- Os administradores devem estar cientes do grupo padrão e das contas de usuário que podem ser instaladas por um sistema operacional.
- Conhecer essas contas ajudará um administrador a decidir qual delas deve ser permitida e qual delas deve ser desativada.
- As contas padrão, como as contas de convidado ou administrador, podem ser um risco de segurança em sistemas mais antigos, pois os invasores estão familiarizados com as configurações padrão usadas.
- Para melhorar a segurança, sempre substitua as contas padrão e verifique se todos os tipos de conta exigem uma senha.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de contas

Tipos de conta (cont.)

É importante gerenciar as contas corretamente para manter a segurança.

- Ao contratar um novo funcionário, crie um perfil de identidade, registre o computador e os dispositivos móveis do funcionário e permita o acesso à rede da empresa.Como provedor de identidade (IdP), a empresa é responsável por autenticar identidade deles.
- Desative ou desative as contas que não são mais necessárias e recupere dados organizacionais ou aplicativos dos dispositivos do usuário.
- Conceda a um usuário o acesso necessário para executar tarefas atribuídas (privilégio mínimo).
- Analise o acesso do usuário para identificar os ajustes de controle de acesso que precisam ser feitos.
- Use as restrições de horário do dia para controlar quando um usuário pode fazer login.
- Use restrições de local para controlar de onde um dispositivo ou usuário pode fazer login.
    - A delimitação geográfica é usada para acionar uma ação quando um usuário entra ou sai de um limite geográfico.
    - A localização geográfica identifica um dispositivo com base em sua localização geográfica.
    - A marcação geográfica adiciona um identificador a algo com base na localização (como uma foto tirada em um smartphone marcada com as coordenadas de onde a foto foi tirada).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de contas

Contas privilegiadas

- Os cibercriminosos visam contas privilegiadas porque são as contas mais poderosas da organização com acesso elevado e irrestrito aos sistemas.
- Os administradores usam essas contas para implantar e gerenciar sistemas operacionais, aplicativos e dispositivos de rede.
- Proteger e bloquear continuamente contas privilegiadas é fundamental para a segurança da organização. Avalie regularmente este processo e ajuste para melhorar a proteção.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Contas privilegiadas (cont.)

As organizações devem adotar práticas robustas para proteger contas privilegiadas.

- Identificar e reduzir o número de contas com privilégios
- Aplicação do princípio do privilégio mínimo. O princípio significa que usuários, sistemas e processos só têm acesso aos recursos (redes, sistemas e arquivos) que são necessários para executar sua função atribuída.
- Revogar os direitos de acesso quando os funcionários deixarem ou mudarem de emprego.
- Eliminar contas compartilhadas com senhas que não expiram
- Proteger o armazenamento de senha.
- Eliminar as credenciais compartilhadas por vários administradores
- Alterar automaticamente as senhas de contas com privilégio a cada 30 ou 60 dias
- Registro de sessões com privilégios
- Implementar um processo para alterar senhas incorporadas para scripts e contas de serviço
- Registrar todas as atividades do usuário
- Gerar alertas para comportamento incomum
- Desativar contas inativas com privilégios
- Use a autenticação de vários fatores para todos os acessos administrativos
- Implemente um gateway entre o usuário final e os ativos confidenciais para limitar a exposição da rede a malware.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de contas

Controle de acesso de arquivos

- **As permissões** são regras configuradas para limitar o acesso a pastas ou arquivos para um indivíduo ou um grupo e podem ajudar a proteger os dados.
- Permissões são regras definidas para limitar o acesso a um indivíduo ou grupo.
- Pode ser mais fácil fornecer acesso a toda a unidade, mas é mais seguro limitar o acesso apenas à pasta necessária.
- Este é o princípio do menor **privilégio** e está intimamente ligado ao conceito de acesso "necessário saber".
- Limitar o acesso aos recursos também impede que os cibercriminosos acessem esses recursos se o computador do usuário for infectado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controle de acesso a arquivos (cont.)

Níveis de permissão disponíveis para arquivos e pastas

Controle total: os usuários podem:

- Veja o conteúdo de um arquivo ou pasta.
- Alterar e excluir arquivos e pastas existentes
- Criar novos arquivos e pastas
- Executar programas em uma pasta.

Modificar - os usuários podem alterar e excluir arquivos e pastas existentes, mas não podem criar novos.

Ler e Executar - os usuários podem visualizar o conteúdo de arquivos e pastas existentes e podem executar programas em uma pasta.

Gravar - os usuários podem criar novos arquivos e pastas e fazer alterações nos arquivos e nas pastas existentes.

Ler - os usuários podem visualizar o conteúdo de uma pasta e abrir arquivos e pastas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Controle de acesso a arquivos (cont.)

- Se um administrador negar permissões individuais ou de grupo para um compartilhamento de rede, isso substituirá quaisquer outras configurações de permissão.
  - O usuário não pode acessar esse compartilhamento, mesmo que seja o administrador ou faça parte do grupo de administradores.

- A política de segurança local deve descrever quais recursos e o tipo de acesso são permitidos para cada usuário e grupo.

- Depois que as permissões da pasta pai forem definidas, as pastas e os arquivos criados dentro da pasta pai herdam suas permissões.

- Além disso, a localização dos dados e a ação realizada nos dados determinam como as permissões são propagadas:
  - Os dados movidos para o mesmo volume manterão as permissões originais.
  - Os dados copiados para o mesmo volume herdarão novas permissões.
  - Os dados movidos para um volume diferente herdarão novas permissões.
  - Os dados copiados para um volume diferente herdarão novas permissões.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de contas

Políticas de conta no Windows

- Na maioria das redes que usam computadores Windows, um administrador configura o Active Directory com domínios em um servidor Windows.
- Os computadores Windows que ingressam no domínio se tornam membros do domínio.
- O administrador configura uma **Política de Segurança de Domínio** que se aplica a todos os computadores que ingressam no domínio.
- Quando um computador não faz parte de um domínio do Active Directory, o usuário configura políticas por meio da Política de Segurança Local do Windows
- Em todas as versões do Windows exceto na Home Edition, digite secpol. msc no comando Executar para abrir a ferramenta de Política de Segurança Local.

Configurando Políticas de Segurança:

- **Política de senhas**
  - Um administrador pode configurar políticas de conta de usuário, como políticas de senha e políticas de bloqueio.
  - As senhas devem conter oito caracteres e três das quatro categorias a seguir: letras maiúsculas, letras minúsculas, números e símbolos.
  - Por último, o usuário pode reutilizar uma senha somente depois de 24 senhas exclusivas.
  - Diferentes políticas de senha podem ser definidas, dependendo dos requisitos e necessidades organizacionais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Diretivas de conta no Windows (cont.)

- **Política de bloqueio de conta**
  - Uma política de bloqueio de conta bloqueia uma conta por um período definido quando ocorrem muitas tentativas de login incorretas.
  - Por exemplo, uma política permite que um usuário insira o nome de usuário e/ou senha errados cinco vezes.
    - Depois de cinco tentativas, a conta é bloqueada por 30 minutos.
    - Depois de 30 minutos, o número de tentativas é redefinido para zero e o usuário pode tentar entrar novamente.

- **Política de auditoria**
  - Mais configurações de segurança estão disponíveis selecionando a pasta 'políticas locais' no Windows.
  - Uma política de auditoria cria um arquivo de log de segurança usado para rastrear os seguintes eventos:
    - Eventos de login da conta.
    - Gestão de contas de auditoria.
    - Acesso ao serviço de diretório.
    - Acesso a objetos.
    - Mudanças de política.
    - Privilégio de utilização.
    - Acompanhamento de processos.
    - Eventos do sistema.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de Autenticação

- Os problemas de autenticação e autorização incluem credenciais não criptografadas, permissões incorretas e violações de acesso.

- O gerenciamento de autenticação tem como objetivo garantir a entrada segura, proporcionando facilidade de uso.
  - Uma solução de **logon único (SSO)** permite que o usuário use um conjunto de credenciais de login para autenticar em vários aplicativos. Dessa forma, o usuário só precisa lembrar uma senha forte.
  - **OAuth** é um padrão que permite que as informações de conta de um usuário sejam usadas por serviços de terceiros, como o Facebook ou o Google.
  - Um **cofre de senha** pode proteger e armazenar as credenciais do usuário com uma única senha forte necessária para acessá-las.
  - Muitas empresas implementam a **autenticação baseada em conhecimento (KBA)** para fornecer uma redefinição de senha caso um usuário esqueça sua senha. A KBA é baseada em informações pessoais conhecidas pelo usuário ou em uma série de perguntas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Hash-Based Message Authentication Code (HMAC)

- O HMAC usa uma chave de criptografia com uma função de hash para autenticar um usuário da Web.
  - Usando o HMAC, o usuário envia um identificador com chave privada e um HMAC.
  - O servidor procura a chave privada do usuário e cria um HMAC.
  - O HMAC do usuário deve ser compatível com o calculado pelo servidor.

- Muitos serviços da Web usam a autenticação básica, que não criptografa o nome de usuário e a senha durante a transmissão.

- As VPNs que usam IPsec contam com as funções HMAC para autenticar a origem de cada pacote e fornecer a verificação de integridade de dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Código de autenticação de mensagem baseado em hash (HMAC) (cont.)

- Os produtos da Cisco usam hash para fins de autenticação de entidade, integridade de dados e autenticidade de dados.
- Os roteadores Cisco IOS usam o hash com chaves secretas de maneira semelhante ao HMAC, para adicionar informações de autenticação às atualizações do protocolo de roteamento.
- Os IPsec gateways e clientes usam os algoritmos hash, como MD5 e SHA-1 no modo de HMAC, para proporcionar a integridade e a autenticidade do pacote.
- As imagens de software Cisco na página da Cisco.com disponibilizam uma soma de verificação de MD5, para que os clientes possam verificar a integridade das imagens baixadas.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos e tecnologias de autenticação

- Um protocolo de autenticação autentica os dados entre duas entidades para impedir o acesso não autorizado.
- A palavra “entidade” pode se referir a qualquer dispositivo ou sistema dentro de uma empresa.
- Um protocolo descreve o tipo de informação que precisa ser compartilhada para autenticação e conexão.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de contas

Protocolos e tecnologias de autenticação

Protocolo de autenticação extensível (EAP)	Uma senha do cliente é enviada usando um hash para o servidor de autenticação. O servidor de autenticação tem um certificado (o cliente não precisa de um certificado).
PAP (Password Authentication Protocol)	Um nome de usuário e uma senha são enviados para um servidor de acesso remoto em texto sem formatação. A maioria dos servidores remotos de sistema operacional de rede é compatível com PAP.
protocolo de autenticação por desafio de identidade (CHAP)	Ele valida a identidade de clientes remotos usando uma função hash unidirecional criada pelo cliente. O serviço também calcula o valor esperado de hash. O servidor (o autenticador) compara os dois valores. Se os valores coincidirem, a transmissão continua.
802.1X	Uma empresa autentica sua identidade e autoriza o acesso à rede. Sua identidade é determinada com base em credenciais ou em um certificado confirmado por um servidor RADIUS.
RADIUS	Use-o para aceitar ou negar acesso quando for necessária uma autenticação simples de nome de usuário/senha. Ele criptografa apenas a senha do usuário do cliente para o servidor.
TACACS+	Ele criptografa todos os dados (nome de usuário, senha, contabilidade e serviços autorizados) entre o cliente e o servidor.
Kerberos	Ele usa criptografia forte, solicitando que um cliente prove sua identidade para um servidor, com o servidor, por sua vez, autenticando-se para o cliente.

Aplicações de funções hash criptográficas

- As funções de hash criptográfico nos ajudam a garantir a integridade dos dados e verificar a autenticação.

- As funções de hash criptográfico são usadas nas seguintes situações:
  - Para fornecer prova de autenticidade quando usado com uma chave de autenticação secreta simétrica, como segurança IP (IPsec) ou autenticação de protocolo de roteamento.
  - Fornecer autenticação gerando respostas únicas e unidirecionais aos desafios nos protocolos de autenticação.
  - Para fornecer prova de verificação de integridade da mensagem (como os usados em contratos assinados digitalmente) e certificados de infraestrutura de chave pública (PKI) (como os aceitos ao acessar um site seguro).

- Ao escolher um algoritmo de hash, use o SHA-256 ou superior, pois são os mais seguros atualmente. Evite SHA-1 e MD5 devido a falhas de segurança que foram descobertas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de contas

Estratégias de controle de acesso

Controle de acesso obrigatório	Ele restringe as ações que um usuário pode executar em um objeto (um arquivo, uma porta ou um dispositivo). Uma regra de autorização impõe se um usuário pode acessar o objeto.As organizações o utilizam onde existem diferentes níveis de classificações de segurança.Cada objeto tem uma etiqueta e cada usuário tem uma autorização. Seu sistema restringe um usuário com base na classificação de segurança do objeto e na etiqueta anexada ao usuário.
Controle de acesso discricionário	Em sistemas que os empregam, o proprietário de um objeto pode decidir quais usuários podem acessar esse objeto e qual acesso específico eles podem ter.Permissões e listas de controle de acesso podem ser usadas para implementá-lo. O proprietário de um arquivo pode especificar quais permissões (leitura, gravação ou execução) outros usuários podem ter.Uma ACL usa regras para determinar qual tráfego pode entrar ou sair de uma rede.
Controle de acesso por função	Depende da função ou função de trabalho do usuário. Ele pode funcionar em combinação com controles de acesso discricionários ou controles de acesso obrigatórios, aplicando as políticas de qualquer um deles. Ajuda a implementar a administração de segurança em grandes organizações com centenas de usuários e milhares de permissões possíveis.
Controle de acesso baseado em regras	Ele usa ACLs para ajudar a determinar se deve conceder acesso. Uma série de regras está contida na ACL e a decisão de conceder acesso depende dessas regras. Assim como no controle de acesso obrigatório, os usuários não podem alterar as regras de acesso. As empresas podem combinar o controle de acesso por função com outras estratégias para a implementação de restrições de acesso.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.4 Uso e operação de AAA

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação AAA

- Uma rede deve ser projetada para controlar quem tem permissão para se conectar a ela e o que eles têm permissão para fazer quando estão conectados.
- Estes requisitos de design são identificados na política de segurança de rede.
- A política especifica como administradores de rede, usuários corporativos, usuários remotos, parceiros de negócios e clientes acessam recursos de rede.
- A política de segurança de rede também pode exigir a implementação de um sistema de contabilidade que rastreie quem efetuou login, quando e o que fizeram durante o login.
- O protocolo **AAA (Authentication, Authorization and Accounting)** fornece a estrutura necessária para habilitar a segurança de acesso escalável.
- As três funções de segurança independentes fornecidas pela estrutura arquitetônica AAA são autenticação, autorização e contabilidade.
- Este conceito é como o uso de um cartão de crédito.
    - O cartão de crédito identifica quem pode utilizá-lo, estipula um limite de uso e mantém o controle dos itens comprados pelo usuário, como mostrado na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação AAA (cont.)

As três funções de segurança independentes fornecidas pela estrutura de arquitetura AAA.

Componente AAA	Descrição
Autenticação	Os usuários e administradores devem provar quem são. A autenticação pode ser estabelecido usando combinações de nome de usuário e senha, perguntas de desafio e resposta, cartões de token e outros métodos. A autenticação AAA fornece uma maneira centralizada de controlar o acesso à rede.
Autorização	Após a autenticação do usuário, os serviços de autorização determinam quais recursos o usuário pode acessar e quais operações ele tem permissão para executar. Um exemplo é "O usuário 'aluno' pode acessar o servidor host XYZ usando apenas SSH".
Accounting (Contabilidade)	O accounting registra o que o usuário faz, incluindo o que é acessado, a quantidade de tempo em que o recurso é acessado e todas as alterações efetuadas. A contabilidade controla como os recursos da rede são usados. Um exemplo é "O usuário 'aluno' acessou o servidor host XYZ usando SSH por 15 minutos".

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Uso e operação do AAA

autenticação AAA

- A Autenticação AAA pode ser usada para autenticar usuários para acesso administrativo ou acesso remoto à rede.

- A Cisco oferece dois métodos comuns para implementar os serviços AAA:
  - **Autenticação AAA local:** às vezes é conhecida como autenticação independente porque autentica os usuários em relação a nomes de usuário e senhas armazenados localmente. Ideal para pequenas redes.
  - **Autenticação AAA baseada em servidor:** Este método autentica em um servidor AAA central que contém os nomes de usuário e senhas de todos os usuários. É apropriado para redes de médio a grande porte.

- O AAA centralizado é mais escalável e gerenciável do que a autenticação AAA local e é a implementação AAA preferida.
  - Seu sistema pode manter bancos de dados de forma independente para autenticação, autorização e contabilidade.
  - Ele pode aproveitar o Active Directory ou o LDAP para autenticação do usuário e participação em grupos, enquanto mantém seus próprios bancos de dados de autorização e contabilidade.

- Os dispositivos se comunicam com o servidor AAA centralizado usando os protocolos RADIUS ou TACACS+.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação AAA (cont.)

A tabela lista as diferenças entre os dois protocolos.

	TACACS+	RADIUS
Funcionalidade	Ele separa as funções de autenticação, autorização e contabilidade de acordo com a arquitetura AAA, permitindo a modularidade da implementação do servidor de segurança.	Ele combina autenticação e autorização, mas separa a contabilidade, permitindo menos flexibilidade na implementação do que o TACACS+.
Padrão	Principalmente com suporte Cisco	Padrão aberto/RFC
Transporte	Porta TCP 49	Portas UDP 1812/1813 ou 1645/1646
Protocolo CHAP	Desafio bidirecional e resposta conforme usado no CHAP.	Desafio unidirecional e resposta do servidor de segurança RADIUS para o cliente RADIUS.
Confidencialidade	Criptografa todo o corpo do pacote, mas deixa um cabeçalho TACACS+ padrão.	Criptografa somente a senha no pacote de solicitação de acesso do cliente para o servidor. O restante do pacote não é criptografado.
Personalização	Fornece autorização de comandos de roteador por usuário ou por grupo.	Não tem opção para autorizar comandos de roteador por usuário ou por grupo.
Accounting	Limitado	Extensivo

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

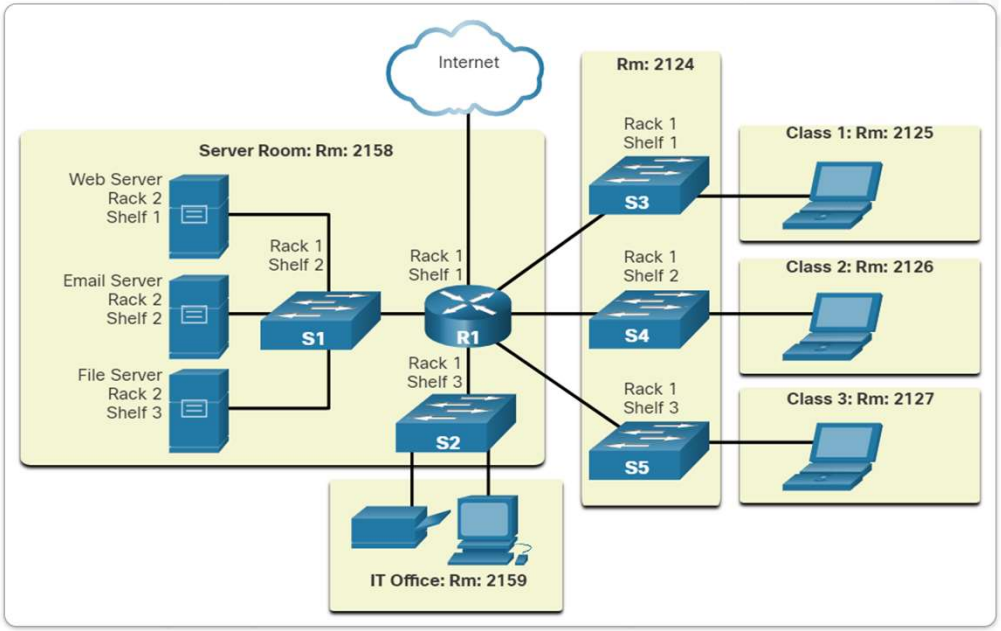
Registros de Contabilidade AAA

- O AAA centralizado também permite o uso do método de contabilidade.
- Os registros contábeis de todos os dispositivos são enviados para repositórios centralizados, o que simplifica a auditoria das ações do usuário.
- A Contabilidade AAA coleta e relata dados de uso em logs AAA que são úteis para auditoria de segurança.
- Os dados coletados podem incluir os horários de conexão inicial e final, comandos executados, número de pacotes e número de bytes.
- Um uso amplamente difundido da contabilidade é combiná-lo com a autenticação AAA.
- Isso ajuda a gerenciar o acesso a dispositivos de interrede pela equipe administrativa da rede.
- Contabilidade fornece mais segurança do que apenas autenticação.
- Os servidores AAA mantêm um registro detalhado de exatamente o que o usuário autenticado faz no dispositivo.
- O log contém vários campos de dados, incluindo o nome de usuário, a data e a hora, e o comando real que foi inserido pelo usuário.
- Esta informação é útil na solução de problemas de dispositivos. Ele também fornece evidências contra indivíduos que realizam ações maliciosas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Uso e operação do AAA

Logs de Contabilidade AAA (Cont.)



1. Quando um usuário realiza autenticação, o processo de contabilização AAA gera uma mensagem inicial para iniciar a contabilização.

2. Quando o usuário termina, uma mensagem de parada é inserida e o processo contábil finaliza.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Contabilidade AAA (Cont.)

A tabela exibe os vários tipos de informações auditáveis que podem ser coletadas.

Tipo de informação contábil	Descrição
Contabilidade de Rede	Ele captura informações para todas as sessões PPP, incluindo contagem de pacotes e bytes.
Contabilidade de Conexão	Ele captura informações sobre todas as conexões de saída feitas do cliente AAA, como por SSH
Contabilidade EXEC	Ele captura informações sobre as sessões do terminal do usuário EXEC (shells do usuário) no servidor de acesso à rede, incluindo nome de usuário, data, horário de início e término e o endereço IP do servidor de acesso.
Contabilidade do Sistema	Ele captura informações sobre todos os eventos no nível do sistema (por exemplo, quando o sistema reinicia ou quando a contabilidade é ativada ou desativada).
Contabilidade de Comando	Ele captura informações sobre os comandos do shell EXEC para um nível de privilégio especificado, bem como a data e hora em que cada comando foi executado e o usuário que o executou.
Contabilidade de Recursos	A implementação da Cisco de contabilidade AAA captura o suporte de registro de “iniciar” e “parar” para conexões que passaram pela autenticação do usuário. O recurso adicional de geração de registros de “parada” para conexões que falham na autenticação como parte da autenticação do usuário também é suportado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Configurar autenticação baseada em servidor com TACACS+ e RADIUS

Nesta atividade do Packet Tracer, você atingirá os seguintes objetivos:

- Configurar a autenticação AAA baseada no servidor usando o TACACS+.
- Verifique a autenticação AAA baseada em servidor do cliente PC-B.
- Configurar a autenticação AAA baseada no servidor usando o RADIUS.
- Verifique a autenticação AAA baseada em servidor do cliente PC-C.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

3.5 Resumo do controle de acesso

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 4: Listas de Controle de Acesso

Defesa de rede

Objetivos do Módulo

Título do Módulo: Listas de Controle de Acesso

Objetivo do Módulo: Implementar listas de controle de acesso (ACLs) para filtrar o tráfego e mitigar ataques de rede.

Título do Tópico	Objetivo do Tópico
Introdução à Listas de Controle de Acesso	Descreva ACLs IPv4 padrão e estendidos.
Máscaras Curingas	Explicar como as ACLs usam máscaras curinga.
Configurar ACLs	Explique como configurar o ACLs.
Modificar ACLs.	Usar números de sequência para editar as atuais ACLs IPv4 padrão.
Implementar ACLs	Implementar ACLs.
Mitigar Ataques com ACLs	Use ACLs para mitigar ataques de rede comuns.
ACLs IPv6	Configure o IPv6 ACLs usando o CLI.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.1 Introdução às Listas de Controle de Acesso

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Introdução à Listas de Controle de Acesso

O que é uma ACL?

- Uma ACL é uma série de comandos do IOS usados para filtrar pacotes com base nas informações encontradas no cabeçalho do pacote.
- Por padrão, um roteador não tem nenhuma ACLs configurada.
- Entretanto, quando uma ACL for aplicada a uma interface, o roteador executará a tarefa adicional de avaliar todos os pacotes de rede que passam pela interface para determinar se o pacote pode ser enviado.
- Uma ACL usa uma lista sequencial de instruções de permissão ou negação, conhecidas como entradas de controle de acesso (ACEs).
- Quando o tráfego da rede passa através de uma interface configurada com uma ACL, o roteador compara as informações no pacote com cada ACE, em ordem sequencial, para determinar se o pacote corresponde a uma das ACEs.

Nota: As ACEs também são comumente chamadas de instruções ACL.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O que é uma ACL? (Cont.)

Várias tarefas executadas por roteadores exigem o uso de ACLs para identificar o tráfego. A tabela lista algumas dessas tarefas com exemplos.

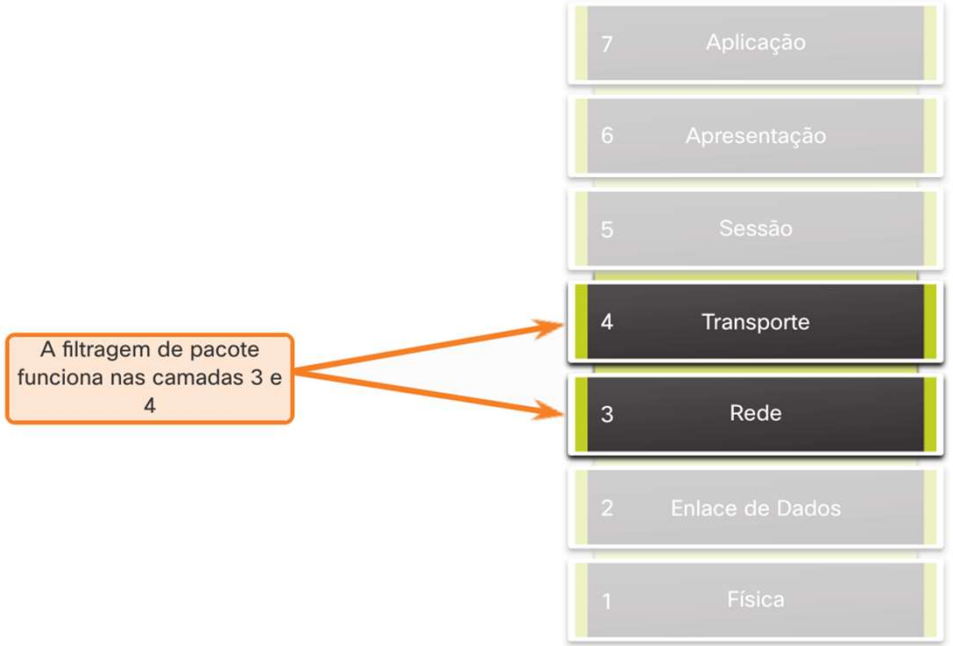
Tarefa	Exemplo
Limitar o tráfego da rede para aumentar o desempenho da rede	Tráfego de vídeo é proibido na rede para reduzir a carga da rede. Uma política pode ser aplicada usando ACLs para bloquear o tráfego de vídeo.
Fornecer controle de fluxo de tráfego	O tráfego do protocolo de roteamento deve ser limitado apenas a determinados links. Uma política pode ser implementada usando ACLs para restringir a entrega de atualizações de roteamento apenas para aqueles que vêm de uma fonte conhecida.
Fornecer um nível básico de segurança para acesso à rede	O acesso à rede de Recursos Humanos deve ser restrito apenas para usuários autorizados Uma política pode ser aplicada usando ACLs para limitar o acesso a redes especificadas.
Filtrar o tráfego com base no tipo de tráfego	Tráfego de e-mail deve ser permitido em uma rede, mas que o acesso Telnet seja negado. Uma política pode ser implementada usando ACLs para filtrar tráfego por tipo.
Screen hosts para permitir ou negar acesso aos serviços de rede	Acesso a alguns tipos de arquivo (por exemplo, FTP ou HTTP) deve ser limitado a grupos de usuários. Uma política pode ser implementada usando ACLs para filtrar o acesso ao usuário aos serviços.
Fornecer prioridade a determinadas classes de tráfego de rede	Tráfego de voz deve ser encaminhado tão rápido quanto possível para evitar qualquer interrupção. Uma política pode ser implementada usando serviços ACLs e QoS para identificar o tráfego de voz e processá-lo imediatamente.

Filtragem de pacotes

- A filtragem de pacotes controla o acesso a uma rede analisando os pacotes de entrada e saída e encaminhando ou rejeitando-os com base nos critérios fornecidos.

- A filtragem de pacote pode ocorrer na camada 3 ou 4.

- Os roteadores Cisco suportam dois tipos de ACLs:
  - **ACLs padrão** - ACLs somente filtram na Camada 3 usando apenas o endereço IPv4 de origem.
  - **ACLs estendidas** - ACLs filtram na Camada 3 usando o endereço IPv4 de origem e/ou/ou destino.
    - Eles também podem filtrar na Camada 4 usando TCP, portas UDP e informações de tipo de protocolo opcional para controle mais fino.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs Numeradas e Nomeadas

- **ACLs Numeradas**
  - ACLs de número 1 a 99, ou 1300 a 1999, são ACLs padrão.
  - ACLs de número 100-199, ou 2000 a 2699, são ACLs estendidas.

```
R1(config)# access-list ?
  <1-99>        IP standard access list
  <100-199>     IP extended access list
  <1100-1199>   Extended 48-bit MAC address access list
  <1300-1999>   IP standard access list (expanded range)
  <200-299>     Protocol type-code access list
  <2000-2699>   IP extended access list (expanded range)
  <700-799>     48-bit MAC address access list
  rate-limit    Simple rate-limit specific access list
  template      Enable IP template acls
R1(config)# access-list
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs Numeradas e Nomeadas (Cont.)

- **ACLs Nomeadas**
  - É o método preferido a ser usado ao configurar ACLs.
  - Especificamente, as ACLs padrão e estendidas podem ser nomeadas para fornecer informações sobre a finalidade da ACL.
  - O comando de configuração global **ip access-list** é usado para cria uma ACL nomeada.

```
R1(config)# ip access-list extended FTP-FILTER
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq ftp
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq ftp-data
R1(config-ext-nacl)#
```

- Regras a serem seguidas para ACLs nomeadas:
  - Atribua um nome para identificar o objetivo da ACL.
  - Os nomes podem conter caracteres alfanuméricos.
  - Os nomes não podem conter espaços ou pontuação.
  - Sugerimos que o nome seja escrito em LETRAS MAIÚSCULAS.
  - É possível adicionar ou excluir entradas na ACL.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação ACL

- As listas de acesso expressam o conjunto de regras que permitem maior controle dos pacotes que chegam às interfaces de entrada, pacotes que são retransmitidos através do roteador e pacotes que saem das interfaces do roteador.
- ACLs podem ser configuradas para serem aplicadas a tráfego de entrada e saída:



- ACL de entrada
  - Uma ACL de entrada filtra pacotes antes de serem roteados para a interface de saída.
  - Ela é eficiente porque salva a sobrecarga de pesquisas de roteamento se o pacote é descartado.
  - Se o pacote for permitido pela ACL, ele será processado para roteamento.
  - Melhor usado para filtrar pacotes quando a rede conectada a uma interface de entrada é a única fonte de pacotes que precisa ser examinada.

- ACL de Saída
  - Melhor usado para filtrar pacotes quando a rede conectada a uma interface de entrada é a única fonte de pacotes que precisa ser examinada.
  - Pacotes de entrada são roteados para a interface de saída e são processados através da ACL de saída.
  - São mais usadas quando o mesmo filtro é aplicado aos pacotes que vêm de várias interfaces de entrada antes de saírem da mesma interface de saída.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operações com ACL (Cont.)

- Quando uma ACL é aplicada a uma interface, ela segue um procedimento operacional específico.
- As etapas operacionais que ocorrem quando o tráfego entra em uma interface de roteador, com uma ACL IPv4 padrão de entrada configurada, são:
  1. O roteador extrai o endereço IPv4 de origem do cabeçalho do pacote.
  2. O roteador inicia na parte superior da ACL e compara o endereço IPv4 de origem a cada ACE em uma ordem sequencial.
  3. Quando houver correspondência, o roteador realizará a instrução, permitindo ou negando o pacote.
  4. Se o endereço IPv4 de origem não corresponder a nenhuma ACEs na ACL, o pacote será descartado porque há uma ACE de negação implícita aplicada automaticamente a todas as ACLs.

- A última instrução ACE de uma ACL é sempre uma negação implícita que bloqueia todo o tráfego e é automaticamente implícita no final de uma ACL, mesmo que esteja oculta e não seja exibida na configuração.

Nota: Uma ACL deve ter pelo menos uma declaração de permissão, caso contrário, todo o tráfego será negado devido à declaração de negação ACE implícita.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.2 Máscara Curinga

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Máscaras curinga

Visão geral da máscara curinga

- Uma ACE IPv4 usa uma máscara curinga de 32 bits para determinar quais bits do endereço examinar para uma correspondência.
- As máscaras curinga também são usadas pelo protocolo de roteamento Open Shortest Path First (OSPF).
- Uma máscara curinga é como uma máscara de sub-rede em que ele usa o processo AND para identificar quais bits em um endereço IPv4 correspondem.
- No entanto, eles diferem na forma como combinam 1s e 0s binários.
- Diferente de uma máscara de sub-rede, na qual o binário 1 é igual a uma correspondência e o binário 0 não é uma correspondência, em uma máscara curinga, o inverso é verdadeiro.
- As máscaras curinga utilizam as seguintes regras para corresponder ao binário 1s e 0s:
  - **Máscara curinga bit 0** - Corresponder ao valor do bit correspondente no endereço
  - **Máscara curinga bit 1** - Ignore o valor do bit correspondente no endereço

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão Geral de Máscara Curinga (Cont.)

A tabela lista alguns exemplos de máscaras curinga e o que eles identificariam.

Máscara Curinga	Último octeto (em binário)	Significado (0 - correspondência, 1 - ignorar)
0.0.0.0	00000000	Combine todos os octetos.
0.0.0.63	00111111	Combine os três primeiros octetos Combine os dois restantes bits do último octeto Ignore os últimos 6 bits
0.0.0.15	00001111	Combine os três primeiros octetos Combine os quatro restantes bits do último octeto Ignorar os últimos 4 bits do último octeto
0.0.0.252	11111100	Combine os três primeiros octetos Ignorar os seis restantes mais bits do último octeto Combine os últimos dois bits
0.0.0.255	11111111	Combine os três primeiros octetos Ignorar o último octeto

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de máscara curinga

- Suponha que a ACL 10 precisa de uma ACE que permita apenas o host com endereço IPv4 192.168.1.1.
- “0” é igual a uma correspondência e “1” é igual a ignorar.
- Para corresponder a um endereço IPv4 de host específico, é necessário uma máscara 0.0.0.0.
- A ACE resultante na ACL 10 seria **access-list 10 permit 192.168.1.1 0.0.0.0** .

	Decimal	Binário
Endereço IPv4	192.168.1.1	11000000.10101000.00000001.00000001
Máscara Curinga	0.0.0.0	00000000.00000000.00000000.00000000
Endereço IPv4 permitido	192.168.1.1	11000000.10101000.0000001.0000001

- A ACL 10 precisa de uma ACE que permita todos os hosts na rede 192.168.1.0/24.
- A máscara curinga 0.0.0.255 estipula que os três primeiros octetos devem corresponder exatamente, mas o quarto octeto não.
- A ACE resultante na ACL 10 seria a **access-list 10 permit 192.168.1.0 0.0.0.255** .

	Decimal	Binário
Endereço IPv4	192.168.1.1	11000000.10101000.00000001.00000001
Máscara Curinga	0.0.0.255	00000000.00000000.00000000.11111111
Endereços IPv4 do Host Permitido	192.168.1.1 até 192.168.1.254	11000000.10101000.00000001.00000001 11000000.10101000.00000001.11111111

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Máscara de Curinga (Cont.)

- A ACL 10 precisa de uma ACE que permita todos os hosts nas redes 192.168.16.0/24, 192.168.17.0/24,..., 192.168.31.0/24.
- A máscara curinga 0.0.15.255 filtraria corretamente esse intervalo de endereços.
- Os bits de máscara curinga realçados identificam quais bits do endereço IPv4 devem corresponder.
- A ACE resultante na ACL 10 seria **access-list 10 permit 192.168.16.0 0.0.15.255.**

	Decimal	**Binário**
Endereço IPv4	192.168.16.0	11000000.10101000.00010000.0000000
Máscara Curinga	0.0.15.255	00000000.00000000.00001111.11111111
Endereços IPv4 do Host Permitido	192.168.16.1 até 192.168.31.254	11000000.10101000.00010000.00000000 11000000.10101000.00011111.11111111

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Cálculo da Máscara Curinga

- Neste exemplo, suponha que você desejasse uma ACE na ACL 10 para permitir o acesso à rede para os 14 usuários na sub-rede 192.168.3.32/28.
- Subtraia a sub-rede (i.e., 255.255.255.240) de 255.255.255.255, conforme mostrado na tabela.
- Esta solução produz a máscara curinga 0.0.0.15.
- Portanto, a ACE seria **access-list 10 permit 192.168.3.32 0.0.0.15.**

Valor inicial	**255.255.255.255**
Subtrair a máscara de sub-rede	- 255.255.255.240
Máscara curinga resultante	0.0.0.15

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Cálculo da Máscara Curinga (Cont.)

- Neste exemplovocê precisa de um ACL número 10 para corresponder a redes no intervalo entre 192.168.16.0/24 a 192.168.31.0/24.
- Esse intervalo de rede pode ser resumido como 192.168.16.0/20, que é uma máscara de sub-rede de 255.255.240.0.
- Portanto, subtraia 255.255.240.0 máscara de sub-rede de 255.255.255.255, conforme mostrado na tabela.
- Esta solução produz a máscara curinga 0.0.15.255.
- Portanto, a ACE seria **access-list 10 permit 192.168.16.0 0.0.15.255.**

Valor inicial	**255.255.255.255**
Subtrair a máscara de sub-rede	- 255.255.240.0
Máscara curinga resultante	0.0.15.255

Palavras-chave de máscara curinga

- O Cisco IOS fornece duas palavras-chave para identificar os usos mais comuns de máscara curinga.
  - **host** - Ela substitui a máscara 0.0.0.0 Essa máscara indica que todos os bits do endereço IPv4 precisam corresponder para filtrar apenas um endereço de host.
  - **any** - Ela substitui a máscara 255.255.255.255 Essa máscara instrui o sistema a ignorar todo o endereço IPv4 ou a aceitar qualquer endereço.

- No exemplo, a ACE na ACL 10 permite somente o host 192.168.10.10 e a ACE na ACL11 permite todos os hosts.

```
R1(config)# access-list 10 permit 192.168.10.10  0.0.0.0
R1(config)# access-list 11 permit  0.0.0.0 255.255.255.255
R1(config)#
```

- As palavras-chave **host** e **any** poderiam ter sido usadas para substituir a saída destacada, realizando a mesma tarefa dos comandos anteriores.

```
R1(config)# access-list 10 permit  host  192.168.10.10
R1(config)# access-list 11 permit  any
R1(config)#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.3 Configurar ACLs

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar ACLs

Criar uma ACL

- Todas as ACLs devem ser planejadas, especialmente as ACLS que requerem várias ACEs.

- Ao configurar uma ACL complexa, sugere-se que você:
  - Use um editor de texto e escreva as especificidades da política a ser implementada.
  - Adicione os comandos de configuração do IOS para realizar essas tarefas.
  - Incluir observações para documentar a ACL.
  - Copie e cole os comandos no dispositivo.
  - Sempre teste minuciosamente uma ACL para garantir que ela aplica corretamente a política desejada.

- Essas recomendações permitem que você crie a ACL cuidadosamente sem afetar o tráfego na rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar ACLs

Sintaxe de ACLs IPv4 padrãonumerada

- Para criar uma ACL padrão numerada, use o seguinte comando de configuração global:
  Router(config)# **access-list** *access-list-number* {**deny** | **permit** | **remark** *text*} *source* [*source-wildcard*] [**log**]
- Use o **no access-list** *access-list-number* comando de configuração global para removê-la.
- A tabela fornece uma explicação detalhada da sintaxe para uma ACL padrão.

Parameter	Description
access-list-number	O número decimal da ACL.O intervalo de números ACL padrão é de 1 a 99 ou de 1300 a 1999.
deny	Nega o acesso se as condições corresponderem.
permit	Permite o acesso se as condições corresponderem.
remark text (Optional)	Isso adiciona uma entrada de texto (comentários) para fins de documentação. Os comentários são extremamente úteis, especialmente em ACLs mais longas ou mais complexas. Cada comentário é limitado a 100 caracteres.
source	Isso identifica a rede de origem ou o endereço do host a ser filtrado. Utilize **qualquer** palavra-chave para especificar todas as redes. Use a palavra chave **host** ip-address ou simplesmente insira um ip-addresspara identificar um endereço IP específico.
source-wildcard (opcional)	Uma máscara curinga de 32 bits a ser aplicada à origem. Se omitido, uma máscara padrão 0.0.0.0 é assumida.
Log (Optional)	Esta palavra-chave gera uma mensagem informativa sempre que o ACE é correspondido.

Sintaxes ACLs IPv4 padrão nomeada

- Para criar uma ACL padrão nomeada, use o seguinte comando de configuração global:

  Router(config)# **ip access-list standard** *access-list-name*

- Esse comando entra no modo de configuração padrão nomeado onde você configura as ACL ACEs.

- Os nomes das ACLs são alfanuméricos, diferenciam maiúsculas de minúsculas e devem ser exclusivos.

- Não é necessário nomear as ACLs com letras maiúsculas, porém dessa forma elas se destacam na exibição da saída running-config.

- Isso torna menos provável a criação acidental de duas ACLs diferentes com o mesmo nome, mas com uso diferente de maiúsculas e minúsculas.

Nota: Use o comando **no ip access-list standard** access-list-name no modo de configuração global para remover uma ACL IPv4 padrão nomeada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintaxes ACLs IPv4 padrão nomeada (Cont.)

- No exemplo, é criada uma ACL IPv4 padrão denominada NO-ACCESS.
- Observe que o prompt muda para o modo de configuração de ACL padrão nomeado.
- As instruções ACE são inseridas no modo de subconfiguração ACL padrão nomeado.
- Use o recurso de ajuda para exibir todas as opções de ACL padrão nomeadas.
- As três opções realçadas são configuradas de forma semelhante à ACL padrão numerada.
- Ao contrário do método ACL numerado, não há necessidade de repetir o comando **ip access-list** para cada ACE.

```
R1(config)# ip access-list standard NO-ACCESS
R1(config-std-nacl)# ?
Standard Access List configuration commands:
  <1-2147483647> Sequence Number
  default        Set a command to its defaults
  deny           Specify packets to reject
  exit           Exit from access-list configuration mode
  no             Negate a command or set its defaults
  permit         Specify packets to forward
  remark         Access list entry comment
R1(config-std-nacl)#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintax ACLs IPv4 Estendida

- ACL estendida é configurada em primeiro lugar e é ativada em uma interface.
- Para criar uma ACL estendida numerada, use o seguinte comando de configuração global:

Router(config)# **access-list** *access-list-number* {**deny** | **permit** | **remark** *text*} *protocol source source-wildcard* [*operator* {*port*}] *destination destination-wildcard* [*operator* {*port*}] [**established**] [**log**]

- Use o comando de configuração global **no access-list** *access-list-number* para remover uma ACL estendida.
- O comando para aplicar uma ACL IPv4 estendida a uma interface é o mesmo usado para ACLs IPv4 padrão.

Router(config-if)# **ip access-group** {*access-list-number* | *access-list-name*} {**in** | **out**}

- Para remover uma ACL em uma interface, primeiro digite o comando **no ip access-group** na interface.
- Para remover a ACL do roteador, use o comando de configuração global **no access-list** .

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar ACLs

Sintaxe de ACL IPv4 Estendida Numerada (Cont.)

Parameter	Description
access-list-number	O intervalo de número de ACL estendida é de 100 a 199 e de 2000 a 2699.
deny	Nega o acesso se as condições corresponderem.
permit	Permite o acesso se as condições corresponderem.
remark text (Opt.)	Isso adiciona uma entrada de texto (comentários) para fins de documentação.Cada comentário é limitado a 100 caracteres.
protocolo	Nome ou número de um protocolo da Internet.
source	A rede de origem ou o endereço do host a ser filtrado.
source-wildcard	(Opcional) Uma máscara curinga de 32 bits aplicada à fonte.
destino	A rede de destino ou o endereço do host a ser filtrado.
destination-wildcard	(Opcional) Trata-se de uma máscara curinga de 32 bits aplicada ao destino.
operator	(Opcional) Compara as portas de origem ou de destino. Alguns operadores: **lt, gt, eq, neq**.
port (Optional)	O número decimal ou o nome de uma porta TCP ou UDP.
established (Opt.)	Apenas para o protocolo TCP. Este é um recurso de firewall de 1a geração.
Log (Optional)	Esta palavra-chave gera uma mensagem informativa sempre que o ACE é correspondido.

Protocolos e Números de Porta

- As ACLs estendidas podem filtrar em vários tipos diferentes de protocolos e portas da Internet.

- **Opções de protocolo**
  - Os quatro protocolos destacados são as opções mais populares.

Nota: Use o **?** para obter ajuda ao inserir uma ACE complexa. Se um protocolo de Internet não estiver listado, o número do protocolo IP poderá ser especificado.

```
R1(config)# access-list 100 permit ?
<0-255>            An IP protocol number
ahp                Authentication Header Protocol
dvmrp              dvmrp
eigrp              Cisco's EIGRP routing protocol
esp                Encapsulation Security Payload
gre                Cisco's GRE tunneling
icmp               Internet Control Message Protocol
igmp               Internet Gateway Message Protocol
ip                 Any Internet Protocol
ipinip             IP in IP tunneling
nos                KA9Q NOS compatible IP over IP tunneling
object-group       Service object group
ospf               OSPF routing protocol
pcp               Payload Compression Protocol
pim               Protocol Independent Multicast
tcp               Transmission Control Protocol
udp               User Datagram Protocol
R1(config)# access-list 100 permit
```

e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos e Números de Portas (Cont.)

- **Opções de palavra-chave da porta**
  - Selecionar um *protocolo* influencia *as opções de porta* . Por exemplo, selecionando a opção:
    tcp protocol forneceria opções de portas relacionadas ao protocolo TCP
    udp protocol forneceria opções de portas relacionadas ao UDP**.**
    icmp protocol Forneceria opções de portas relacionadas ao ICMP (ou seja, mensagem)

  - As portas destacadas são opções populares.

  - Os nomes ou números das portas podem ser especificadas, mas os nomes das portas facilitam a compreensão da finalidade de uma ACE.

```
R1(config)# access-list 100 permit tcp any any eq ?
<0-65535>        Port number
bgp              Border Gateway Protocol (179)
chargen          Character generator (19)
cmd              Remote commands (rcmd, 514)
daytime          Daytime (13)
discard          Discard (9)
domain           Domain Name Service (53)
echo             Echo (7)
exec             Exec (rsh, 512)
finger           Finger (79)
ftp              File Transfer Protocol (21)
ftp-data         FTP data connections (20)
gopher           Gopher (70)
hostname         NIC hostname server (101)
ident            Ident Protocol (113)
irc              Internet Relay Chat (194)
klogin           Kerberos login (543)
kshell           Kerberos shell (544)
login            Login (rlogin, 513)
lpd              Printer service (515)
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Exemplos de configuração de protocolos e números de porta

- As ACLs estendidas podem filtrar em diferentes opções de número de porta e nome de porta.
- Este exemplo configura uma ACL 100 estendida para filtrar tráfego HTTP.
- A primeira ACE utiliza o nome de porta **www**.
- A segunda ACE usa o número de porta **80**. As duas ACEs atingem exatamente o mesmo resultado.

```
R1(config)# access-list 100 permit tcp any any eq www
R1(config)# !or...
R1(config)# access-list 100 permit tcp any any eq 80
```

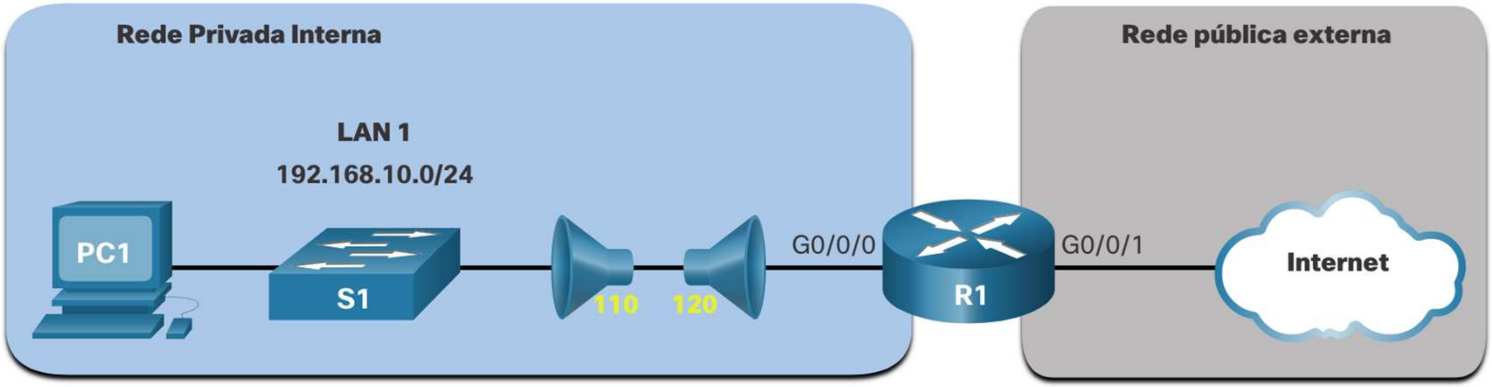
- A configuração do número da porta é necessária quando não há um nome de protocolo específico listado, como SSH (porta número 22) ou HTTPS (porta número 443), conforme mostrado no exemplo seguinte.

```
R1(config)# access-list 100 permit tcp any any eq 22
R1(config)# access-list 100 permit tcp any any eq 443
R1(config)#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACL Estendida TCP Estabelecido

- O TCP também pode executar serviços básicos de firewall com estado usando a palavra-chave TCP **established**, que permite que o tráfego interno saia da rede privada interna e permite que o tráfego de resposta de retorno entre na rede privada interna.
- O tráfego TCP gerado por um host externo e a tentativa de se comunicar com um host interno é negada.
- A palavra-chave **established** pode ser usada para permitir apenas o tráfego HTTP de retorno de sites solicitados, enquanto negar qualquer outro tipo de tráfego.
- A topologia mostra a ACL 110 (previamente configurada) que filtrará o tráfego da rede privada interna.
- ACL 120, usando a palavra-chave **established**, filtrará o tráfego que entra na rede privada interna da rede pública externa.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACL Estendida TCP Established (Cont.)

- A ACL 120 está configurada para permitir apenas o tráfego de retorno Web para os hosts internos, e então é aplicada na interface de saída G0/0/0 de R1.
- O comando **show access-lists** exibe ambas ACLs.
- As estatísticas de correspondências mostram que os hosts internos têm acessado os recursos web seguros da Internet.

```
R1(config)# access-list 120 permit tcp any 192.168.10.0 0.0.0.255 established
R1(config)# interface g0/0/0
R1(config-if)# ip access-group 120 out
R1(config-if)# end
R1# show access-lists
Extended IP access list 110
    10 permit tcp 192.168.10.0 0.0.0.255 any eq www
    20 permit tcp 192.168.10.0 0.0.0.255 any eq 443 (657 matches)
Extended IP access list 120
    10 permit tcp any 192.168.10.0 0.0.0.255 established (1166 matches)
R1#
```

- O parâmetro **established** permite que apenas as respostas para o tráfego originário da rede 192.168.10.0/24 retornem a essa rede.
- Uma correspondência ocorre se o segmento TCP de retorno tem os bits das flags ACK ou reset (RST) setados.
- Sem o parâmetro **established** na instrução ACL, todo o tráfego seria permitido.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintaxe ACLs IPv4 Estendida Nomeada

- Para criar uma ACL estendida nomeada, use o seguinte comando de configuração global:

  Router(config)# **ip access-list extended** *access-list-name*

- Este comando entra no modo de configuração de ACL estendida nomeada.

- Os nomes das ACLs são alfanuméricos, diferenciam maiúsculas de minúsculas e devem ser exclusivos.

- No exemplo, uma ACL estendida nomeada chamada NO-FTP-ACCESS é criada e o prompt foi alterado para o modo de configuração de ACL estendida nomeada.

- As instruções ACE são inseridas no modo de subconfiguração de ACL estendida nomeado.

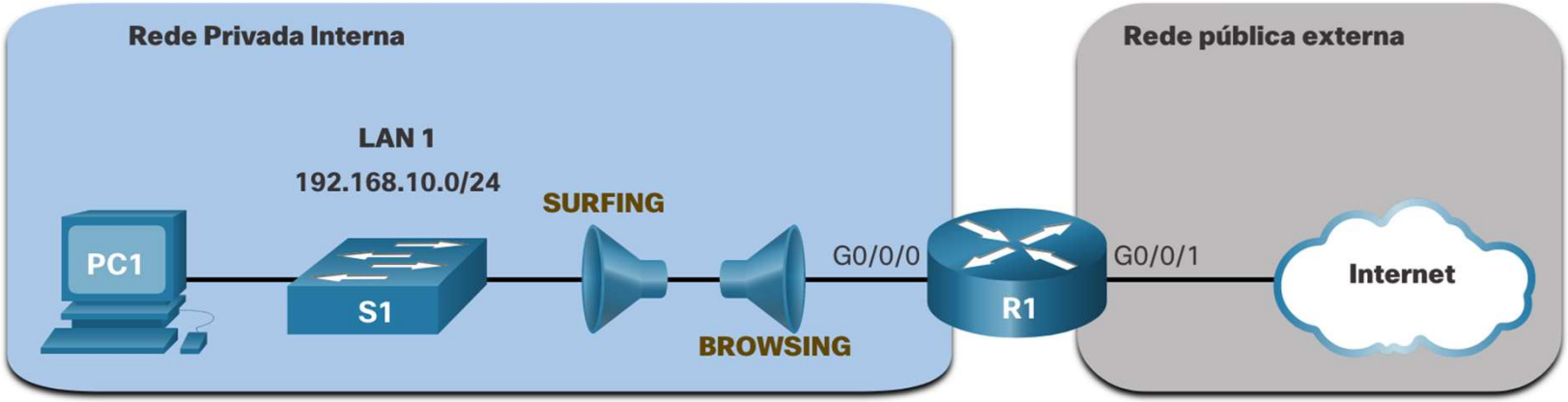
```
R1(config)# ip access-list extended NO-FTP-ACCESS
R1(config-ext-nacl)#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Exemplo de ACL IPv4 estendida nomeada

- As ACLs estendidas nomeadas são criadas essencialmente da mesma forma que as ACL padrão.

- A topologia demonstrar a configuração e aplicação de duas ACLs IPv4 estendidas nomeadas à uma interface:
  - **SURFING-** Isso permitirá que o tráfego HTTP e HTTPS saia para a Internet.
  - **BROWSING -** Isso só permitirá retornar tráfego da Web para os hosts internos enquanto todo o tráfego que sai da interface R1 G0/0/0 é negado implicitamente.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Exemplos de ACL IPv4 Estendidas Nomeadas (Cont.)

- A ACL SURFING permite que o tráfego HTTP e HTTPS de usuários internos saia da interface G0 / 0/1 conectada à Internet.
- O tráfego da Web retornando da Internet é permitido de volta para a rede privada interna pela ACL BROWSING.
- A ACL SURFING é aplicado na entrada e o ACL BROWSING é aplicado na saída da interface R1 G0/0/0.
- Os hosts internos têm acesso aos recursos Web seguros da Internet.
- O comando **show access-lists** é usado para verificar as estatísticas de ACL.
- Os contadores HTTPS seguros de permissão (ou seja, eq 443) na ACL SURFING e os contadores de retorno estabelecidos na ACL BROWSING aumentaram.

```
R1(config)# ip access-list extended SURFING
R1(config-ext-nacl)# Remark Permits inside HTTP and HTTPS traffic
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq 80
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq 443
R1(config-ext-nacl)# exit
R1(config)#
R1(config)# ip access-list extended BROWSING
R1(config-ext-nacl)# Remark Only permit returning HTTP and HTTPS traffic
R1(config-ext-nacl)# permit tcp any 192.168.10.0 0.0.0.255 established
R1(config-ext-nacl)# exit
R1(config)# interface g0/0/0
R1(config-if)# ip access-group SURFING in
R1(config-if)# ip access-group BROWSING out
R1(config-if)# end
R1# show access-lists
Extended IP access list SURFING
    10 permit tcp 192.168.10.0 0.0.0.255 any eq www
    20 permit tcp 192.168.10.0 0.0.0.255 any eq 443 (124 matches)
Extended IP access list BROWSING
    10 permit tcp any 192.168.10.0 0.0.0.255 established (369 matches)
R1#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.4 Sintaxe ACLs IPv4 Padrão Nomeada

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dois métodos para modificar uma ACL

- Depois que uma ACL é configurada, ela pode precisar ser modificada.
- ACLs com várias ACEs podem ser complexas de configurar. Às vezes, a ACE configurada não produz os comportamentos esperados.
- Por esses motivos, as ACLs podem inicialmente exigir um pouco de tentativa e erro para alcançar o resultado de filtragem desejado.
- Esta seção discutirá dois métodos a serem usados ao modificar uma ACL:
  - Use um editor de texto
  - Use números de sequência

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintaxes ACLs IPv4 padrão nomeada

Método do Editor de Texto

- ACLs com várias ACEs devem ser criadas em um editor de texto.
- Isso permite planejar as ACEs necessárias, criar a ACL e colá-la na interface do roteador.
- Ele também simplifica as tarefas para editar e corrigir uma ACL.
- Por exemplo, suponha que a ACL 1 foi inserida incorretamente usando **19** em vez de **192** para o primeiro octeto, como mostrado na configuração em execução.

```
R1# show run | section access-list
access-list 1 deny 19.168.10.10
access-list 1 permit 192.168.10.0 0.0.0.255
R1#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintaxe ACLs IPv4 Padrão Nomeada

Método do Editor de Texto (Cont.)

- A primeira ACE deveria ter sido para negar o host em 192.168.10.10., mas foi digitada incorretamente.

- Para corrigir o erro:
  - Copie a ACL da configuração em execução e cole-a no editor de texto.
  - Faça as alterações necessárias.
  - Remova a ACL configurada anteriormente no roteador. Caso contrário, colar os comandos ACL editados só acrescentará (isto é, adicionará) às Aces ACL existentes no roteador.
  - Copie e cole a ACL editada de volta para o roteador.

- Suponha que a ACL 1 foi corrigida. A ACL incorreta deve ser excluída e as instruções ACL 1 corrigidas devem ser coladas no modo de configuração global, conforme mostrado na saída.

```
R1(config)# no access-list 1
R1(config)#
R1(config)# access-list 1 deny 19.168.10.10
R1(config)# access-list 1 permit 192.168.10.0 0.0.0.255
R1(config)#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintaxe ACLs IPv4 Padrão Nomeada

Método do Número de Sequência

- Uma ACL ACE também pode ser excluída ou adicionada usando os números de sequência ACL. Os números de sequência são atribuídos automaticamente quando uma ACE é inserida.

- Esses números são listados no comando **show access-lists** . O comando **show running-config** não exibe a sequência de números.

- No exemplo anterior, a ACE incorreta para ACL 1 está usando o número de seqüência 10, como mostrado no exemplo.

```
R1# show access-lists
Standard IP access list 1
    10 deny 19.168.10.10
    20 permit 192.168.10.0, wildcard bits 0.0.0.255
R1#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sintaxe ACLs IPv4 Padrão Nomeada

Método do Número de Sequência (Cont.)

- Utilize o comando **ip access-list standard** para editar uma ACL. As instruções não podem ser substituídas usando o mesmo número de sequência que uma instrução existente.
- Portanto, a afirmação atual deverá excluir os primeiros com o comando **no 10**.
- Em seguida, a ACE correta pode ser adicionada usando o número de sequência 10 é configurado.
- Verifique as mudanças utilizando o comando **show access-lists**, como mostrado no exemplo.

```
R1# conf t
R1(config)# ip access-list standard 1
R1(config-std-nacl)# no 10
R1(config-std-nacl)# 10 deny host 192.168.10.10
R1(config-std-nacl)# end
R1# show access-lists
Standard IP access list 1
    10 deny 192.168.10.10
    20 permit 192.168.10.0, wildcard bits 0.0.0.255
R1#
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.5 Implementar ACLs

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Guia de Configurações de ACLs

- Uma ACL é composta de uma ou mais entradas de controle de acesso (ACEs) ou instruções.

- Ao configurar e aplicar uma ACL, esteja ciente das diretrizes resumidas nesta lista:
  - Crie um ACL globalmente e aplique-a.
  - Garanta que a última instrução seja **deny any** ou **deny ip any any.**
  - Ordem das instruções é importante porque as ACLs são processadas de cima para baixo.
  - Assim que uma instrução é correspondida, a ACL é encerrada.
  - Sempre filtre o mais específico para o mais genérico.
  - Apenas uma ACL é permitida por interface, por protocolo, por direção.
  - Novas instruções para uma ACL existente são adicionadas, por padrão, à parte inferior da ACL.
  - Pacotes gerados por roteador não são filtrados por ACLs de saída.
  - Coloque as ACL padrão o mais próximo possível do destino.
  - Coloque as ACLs estendidas o mais próximo possível da fonte.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

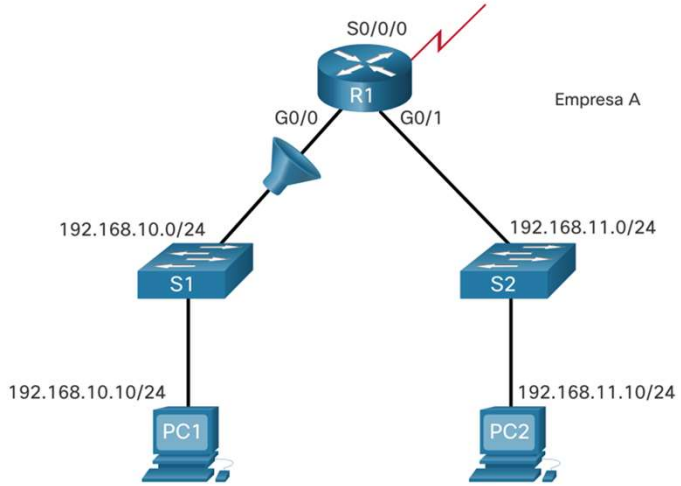
Aplicar um ACL

- A sintaxe de comando para aplicar uma ACL a uma interface ou para as linhas VTY.

  Router(config-if)# **ip access-group** {*acl-#* | *name*} {**in** | **out**}
  Router(config-line)# **ip access-class** {*acl-#* | *name*} {**in** | **out**}

- Para remover uma ACL em uma interface, primeiro digite o comando **no ip access-group** na interface.
- Para remover a ACL do roteador, use o comando de configuração global **no access-list**.

Exemplo de ACL Padrão Nomeada

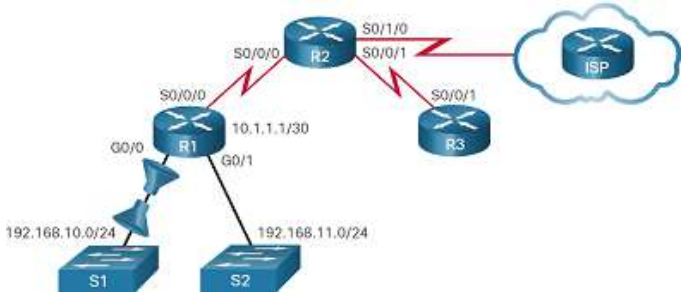



```
R1(config)# ip access-list standard NO_ACCESS
R1(config-std-nacl)# deny host 192.168.11.10
R1(config-std-nacl)# permit any
R1(config-std-nacl)# exit
R1(config)# interface g0/0
R1(config-if)# ip access-group NO_ACCESS out
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Aplicar uma ACL (Cont.)

Exemplo de ACL estendida nomeada




```
R1(config)# ip access-list extended SURFING
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq 80
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq 443
R1(config-ext-nacl)# exit
R1(config)# ip access-list extended BROWSING
R1(config-ext-nacl)# permit tcp any 192.168.10.0 0.0.0.255 established
R1(config-ext-nacl)# exit
R1(config)# interface g0/0
R1(config-if)# ip access-group SURFING in
R1(config-if)# ip access-group BROWSING out
```

ACL Nomeada em linhas VTY com Log



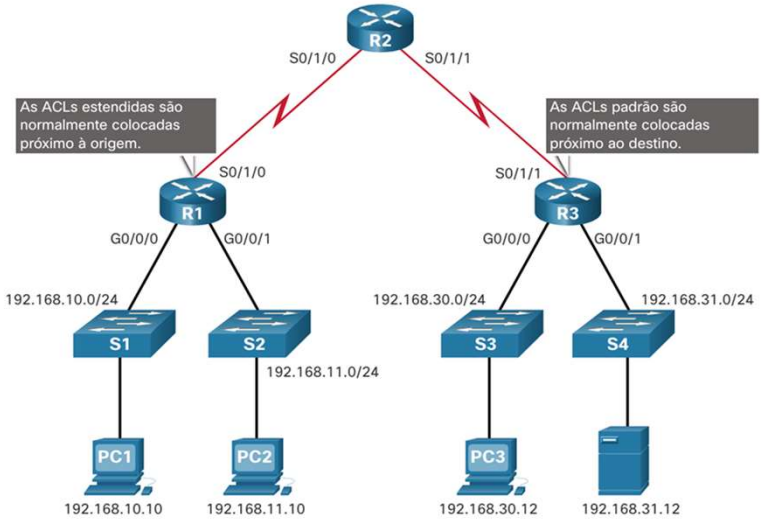

```
R1(config)# ip access-list standard VTY_ACCESS
R1(config-std-nacl)# permit 192.168.10.10 log
R1(config-std-nacl)# deny any
R1(config-std-nacl)# exit
R1(config)# line vty 0 4
R1(config-line)# access-class VTY_ACCESS in
R1(config-line)# end
R1#
R1# !The administrator accesses the vty lines from 192.168.10.10
R1#
*Feb 26 18:58:30.579: %SEC-6-IPACCESSLOGNP: list VTY_ACCESS permitted 0
192.168.10.10 -> 0.0.0.0, 5 packets
R1# show access-lists
Standard IP access list VTY_ACCESS
   10 permit 192.168.10.10 log (6 matches)
   20 deny any
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Onde posicionar as ACLs

- Cada ACL deve ser colocado onde é mais eficiente.

- Assuma que o objetivo é impedir o tráfego que se origina na rede 192.168.10.0/24 de atingir a rede 192.168.30.0/24.



- As ACLs estendidas devem estar localizadas o mais perto possível da origem do tráfego a ser filtrada.
  - O tráfego indesejável é negado próximo à rede de origem sem cruzar a infraestrutura de rede.

- As ACLs padrã odevem ser localizadas o mais perto possível do destino.
  - Se uma ACL padrão foi colocada na origem do tráfego, a “permissão” ou “negação” ocorrerá com base no endereço de origem especificado, independentemente do destino do tráfego.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Onde Colocar ACLs (Cont.)

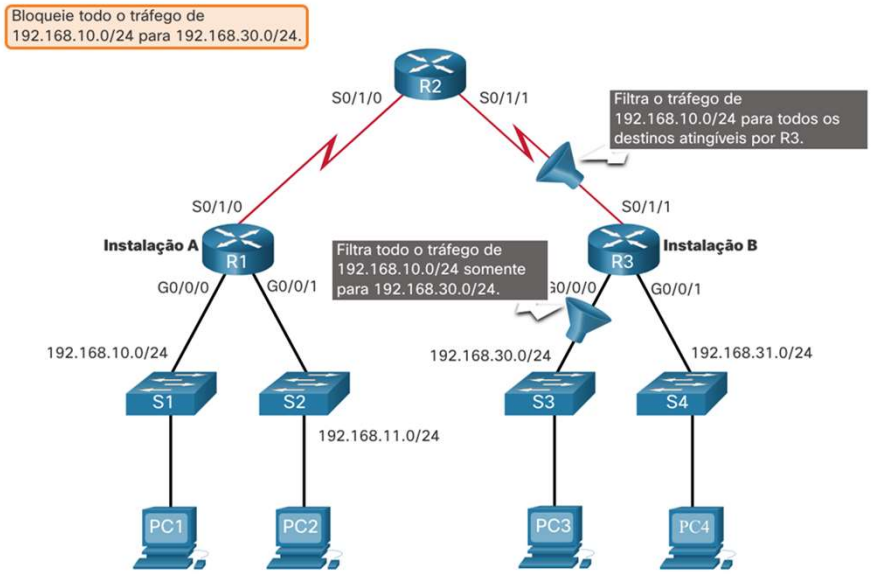
- O posicionamento da ACL e, portanto, o tipo de ACL usado, também pode depender de uma variedade de fatores, conforme listado na tabela .

Fatores que influenciam o posicionamento da ACL	Explicação
A extensão do controle organizacional	O posicionamento da ACL pode depender se a organização tem ou não controle das redes de origem e de destino.
Largura de banda das redes envolvidas	Pode ser desejável filtrar o tráfego indesejado na origem para evitar a transmissão de tráfego que consome largura de banda.
Fácil configuração	Pode ser mais fácil implementar uma ACL no destino, mas o tráfego usará largura de banda desnecessariamente. Uma ACL estendida pode ser usada em cada roteador onde o tráfego é originado. Isso economizaria largura de banda filtrando o tráfego na origem, mas exigiria a criação de ACLs estendidas em vários roteadores.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Exemplo da colocação de ACL Padrão

- As ACLs padrão devem ser localizadas o mais perto possível do destino.
- Na Figura, o administrador deseja impedir que o tráfego originado na rede 192.168.10.0/24 acesse a rede 192.168.30.0/24.



Duas interfaces possíveis no R3 para aplicar a ACL padrão:

- **Interface S0/1/1 de R3 (entrada)**
  - Se aplicado desta forma para negar o tráfego da rede .10, também filtraria o tráfego .10 para a rede 192.168.31.0/24 (.31 neste exemplo).
  - A ACL padrão não deve ser aplicada a essa interface.

- **Interface G0/0/0 de R3(saída)**
  - Se aplicado dessa forma, não afetará outras redes que podem ser acessadas por R3, portanto, os pacotes da rede .10 ainda poderão alcançar a rede .31.
  - Essa é a melhor interface para colocar a ACL padrão para atender aos requisitos de tráfego.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento Confidencial da Cisco

Packet Tracer - Configuração de ACLs IPv4 Padrão Nomeada

Neste Packet Tracer, você atingirá os seguintes objetivos:

- Parte 1: Configurar e aplicar uma ACL padrão nomeada
- Parte 2: Verificar a implementação da ACL

O administrador de rede sênior solicitou que você crie uma ACL padrão nomeada para impedir o acesso a um servidor de arquivos.Todos os clientes de uma rede e uma estação de trabalho específica de uma rede diferente, devem ter acesso negado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Implementar ACLs

Packet Tracer - Configurar ACLs IPv4 Padrão Numeradas

Neste Packet Tracer, você atingirá os seguintes objetivos:

- Parte 1: Planejar uma implementação de ACL
- Parte 2: Configurar, aplicar e verificar uma ACL padrão

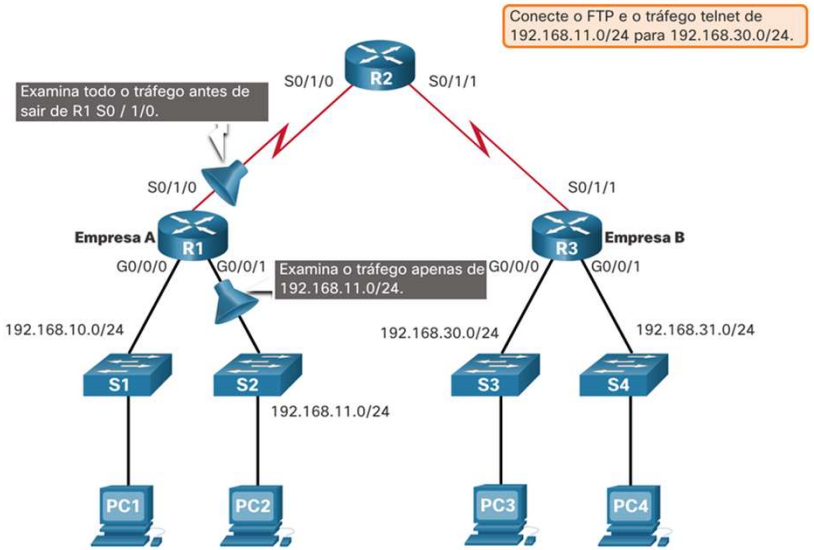
- Listas de controle de acesso padrão são scripts de configuração do roteador que controlam se um roteador permite ou nega pacotes com base no endereço de origem.
- Esta atividade se concentra em definir critérios de filtragem, configuração das ACLs padrão, aplicação de ACLs às interfaces do roteador e verificação e teste da implementação da ACL. Os roteadores já estão configurados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Exemplo de posicionamento de ACL estendida

- As ACLs estendidas devem estar localizadas o mais próximo possível da origem, mas a organização só pode colocar ACLs em dispositivos que elas controlam.

- Na figura, por exemplo, a Empresa A quer negar tráfego Telnet e FTP para a rede 192.168.30.0/24 da Empresa B a partir de sua rede 192.168.11.0/24 enquanto permite todo o tráfego.



Duas interfaces possíveis no R1 para aplicar a ACL estendida:

- **interface S0/1/0 de R1 (saída) -** Ela processará todos os pacotes que saem do R1, incluindo pacotes de 192.168.10.0/24.

- **Interface G0/0/1 de R1 (entrada) -** apenas os pacotes da rede 192.168.11.0/24 estão sujeitos ao processamento da ACL no R1
  - Como o filtro deve ser limitado apenas a esses pacotes que saem da rede 192.168.11.0/24, aplicando a ACL estendida para G0 / 0/1 é a melhor solução.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Configurar ACLs Estendidas Cenário 1

Nesta atividade do Packet Tracer, você atingirá os seguintes objetivos:

- Parte 1: Configurar, Aplicar e Verificar uma ACL IPv4 Estendida Numerada
- Parte 2: Configurar, Aplicar e Verificar uma ACL IPv4 Estendida Nomeada

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Configurar ACLs Estendidas Cenário 2

Nesta atividade do Packet Tracer, você atingirá os seguintes objetivos:

- Parte 1: Configurar uma ACL IPv4 Estendida Nomeada
- Parte 2: Aplicar e Verificar a ACL IPv4 Estendida

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.6 Mitigar Ataques com ACLs

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigar Ataques Spoofing

- As ACLs podem ser usadas para mitigar muitas ameaças de rede, como falsificação de endereço IP e ataques de negação de serviço (DoS).
- A maioria dos ataques usa algum tipo de falsificação.
- Spoofing de endereço IP substitui o processo de criação de pacotes normais inserindo um cabeçalho IP personalizado com um endereço IP de origem diferente.
- Os invasores podem esconder sua identidade, falsificando o endereço IP de origem.
- Existem muitas classes conhecidas de endereços IP que nunca devem ser vistas como endereços IP de origem para o tráfego que entram na rede de uma organização.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigar Ataques Spoofing (Cont.)

- A interface S0/0/0 está conectada à Internet e nunca deve aceitar pacotes de entrada de endereços todo zero, endereços de broadcast, 127.0.0.0/8, 169.254.0.0/16, endereços privados reservados (RFC 1918) e 224.0.0.0 /4
- A rede 192.168.1.0/24 está conectada à interface G0/0 de R1, que deve permitir apenas a entrada de pacotes com endereço de origem dessa rede.
- A ACL para G0/0 mostrada na figura só permitirá pacotes de entrada da rede 192.168.1.0/24. Todos os outros serão descartados.



Entrada em S0/0/0

```
R1(config)# access-list 150 deny ip host 0.0.0.0 any
R1(config)# access-list 150 deny ip 10.0.0.0 0.255.255.255 any
R1(config)# access-list 150 deny ip 127.0.0.0 0.255.255.255 any
R1(config)# access-list 150 deny ip 172.16.0.0 0.15.255.255 any
R1(config)# access-list 150 deny ip 192.168.0.0 0.0.255.255 any
R1(config)# access-list 150 deny ip 224.0.0.0 15.255.255.255 any
R1(config)# access-list 150 deny ip host 255.255.255.255 any
```

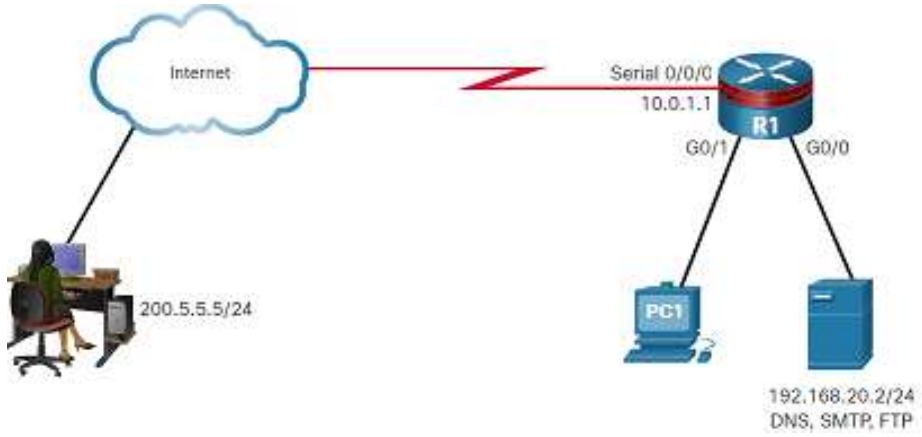
Entrada em G0/0:

```
R1(config)# access-list 105 permit ip 192.168.1.0 0.0.0.255 any
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Permitir tráfego necessário através de um Firewall

- Uma estratégia eficaz para mitigar ataques: permitir explicitamente apenas alguns tipos de tráfego através de um firewall.
- DNS, SMTP e FTP são serviços que geralmente devem ser permitidos por meio de um firewall.
- Configure um firewall para permitir o acesso remoto dos administradores por meio do firewall.
- SSH, Syslog e SNMP são exemplos de serviços que um roteador pode precisar incluir.
- Enquanto muitos desses serviços são úteis, eles devem ser controlados e monitorados.
- A exploração desses serviços leva a vulnerabilidades de segurança.
- Um exemplo de topologia com configurações de ACL para permitir serviços específicos na interface Serial 0/0/0 é mostrado.



Entrada em S0/0/0:

```
R1(config)# access-list 180 permit udp any host 192.168.20.2 eq domain
R1(config)# access-list 180 permit tcp any host 192.168.20.2 eq smtp
R1(config)# access-list 180 permit tcp any host 192.168.20.2 eq ftp
R1(config)# access-list 180 permit tcp host 200.5.5.5 host 10.0.1.1 eq 22
R1(config)# access-list 180 permit udp host 200.5.5.5 host 10.0.1.1 eq syslog
R1(config)# access-list 180 permit udp host 200.5.5.5 host 10.0.1.1 eq snmptrap
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigar Ataques ICMP

- Tanto as mensagens do ICMP Echo e Redirect devem ser bloqueadas de entrada pelo roteador.

- Várias mensagens ICMP devem ser permitidas na rede interna:
  - **Echo reply -** Permite que os usuários façam ping em hosts externos.
  - **Source quench -** Solicita que o remetente diminua a taxa de tráfego das mensagens.
  - **Unreachable -** Gerado para pacotes que são negados administrativamente por uma ACL.

- Várias mensagens ICMP devem ter permissão para sair da rede:
  - **Echo -** Permite que os usuários façam ping em hosts externos.
  - **Parameter problem -** Informa o host sobre problemas de cabeçalho de pacote.
  - **Packet too big -** Habilita a descoberta da unidade máxima de transmissão do pacote (MTU).
  - **Source quench -** Estrangulamentos para baixo do tráfego quando necessário.

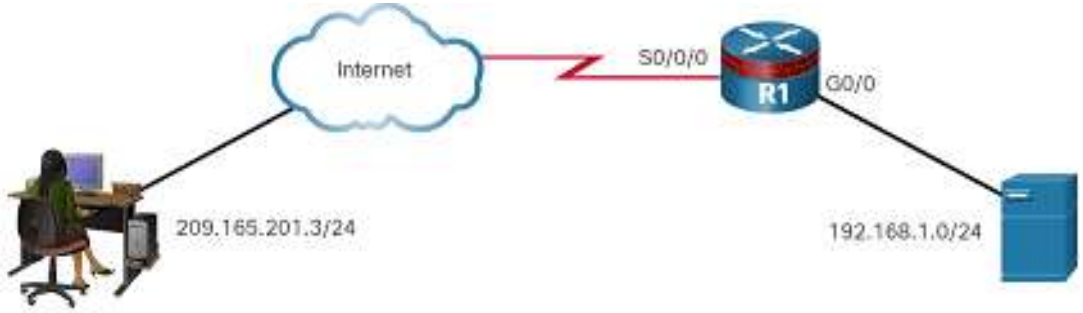
- Como regra, bloqueie todos os outros tipos de mensagens ICMP de saída.

- ACLs são usadas para bloquear o Spoofing de Endereços IP, permitem marcar seletivamente serviços específicos por meio de um firewall e permitir que somente as mensagens ICMP necessárias.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigar Ataques ICMP (Cont.)

- A figura mostra uma topologia e possíveis configurações de ACL para permitir serviços específicos do ICMP nas interfaces G0/0 e S0/0/0.



Entrada em S0/0/0:

```
R1(config)# access-list 112 permit icmp any any echo-reply
R1(config)# access-list 112 permit icmp any any source-quench
R1(config)# access-list 112 permit icmp any any unreachable
R1(config)# access-list 112 deny icmp any any
R1(config)# access-list 112 permit ip any any
```

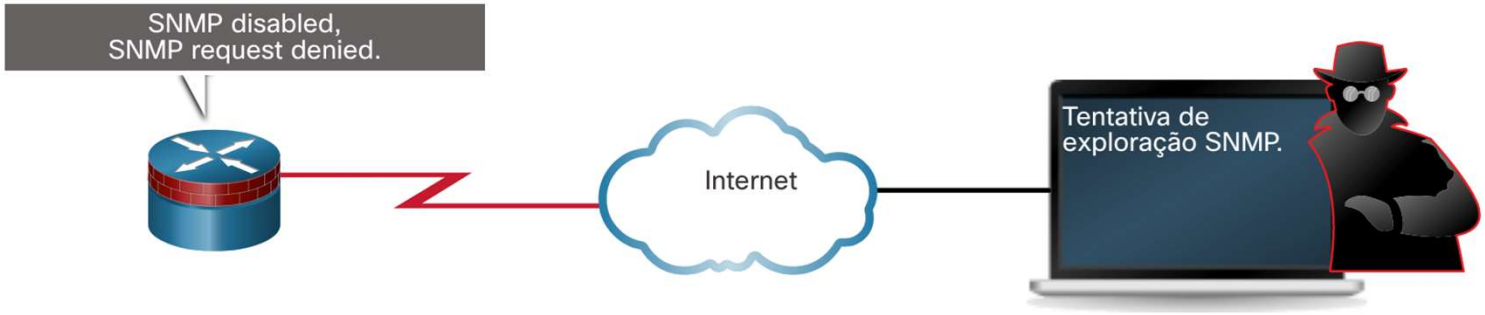
Entrada em S0/0/0:

```
R1(config)# access-list 114 permit icmp 192.168.1.0 0.0.0.255 any echo
R1(config)# access-list 114 permit icmp 192.168.1.0 0.0.0.255 any parameter-problem
R1(config)# access-list 114 permit icmp 192.168.1.0 0.0.0.255 any packet-too-big
R1(config)# access-list 114 permit icmp 192.168.1.0 0.0.0.255 any source-quench
R1(config)# access-list 114 deny icmp any any
R1(config)# permit ip any any
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Mitigar Ataques SNMP

- Protocolos de gerenciamento são úteis para monitoramento remoto e gerenciamento de dispositivos em rede, mas eles podem ser explorados.
- Se o SNMP for necessário, a exploração de vulnerabilidades SNMP pode ser mitigada aplicando ACLs de interface para filtrar pacotes SNMP de sistemas não autorizados.
- Uma exploração ainda pode ser possível se o pacote SNMP for provido de um endereço que foi falsificado e é permitido pela ACL.
- Os meios mais eficazes de prevenção de exploração é desativar o servidor SNMP em dispositivos iOS para os quais não é necessário.
  - Use Router(config)# **no snmp-server** para desatiar os serviços SNMP nos dispositivos Cisco IOS.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Packet Tracer - Configurar ACLs IP para Mitigar Ataques

Neste Packet Tracer, você atingirá os seguintes objetivos:

- Verifique a conectividade entre dispositivos antes da configuração da ACL.
- Use ACLs para garantir que o acesso remoto ao Roteadores esteja disponível somente na estação de gerenciamento PC-C.
- Configurar ACLs no R1, R2 e R3 para mitigar ataques.
- Modificar ACLs
- Verificar funcionamento da ACL

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

4.7 ACLs IPv6

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs IPv6

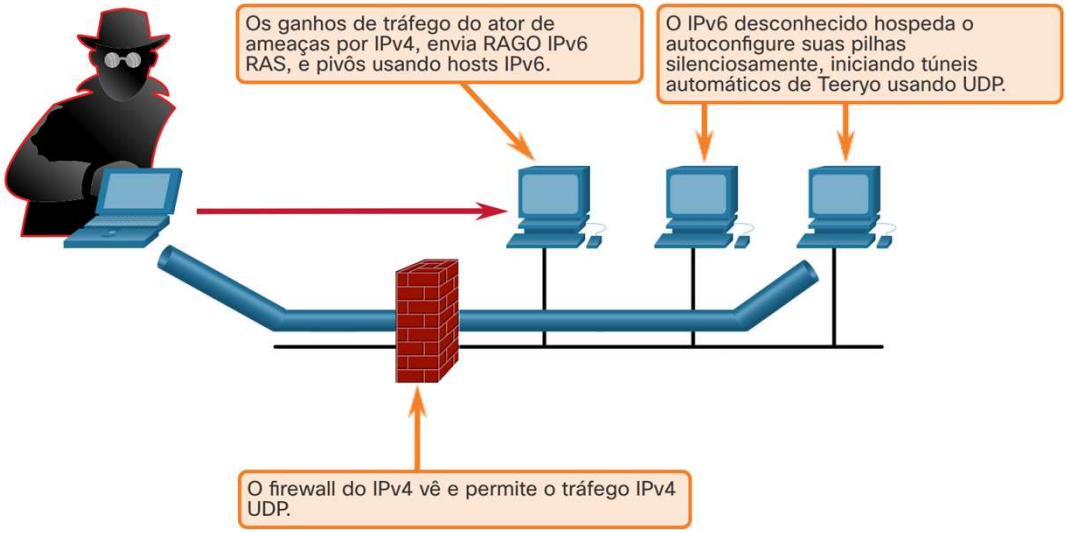
Visão Geral da ACL IPv6

- O IPv4 coexistirá com o IPv6 e, em seguida, será gradualmente substituído pelo IPv6.
- Um exemplo de uma preocupação de segurança é que os atores de ameaça que alavancam o IPv4 para explorar o IPv6 em ambientes de pilha dupla.
- Em dispositivos de ambiente de pilha dupla operam com duas pilhas de protocolo IP.
- O agente de ameaças pode realizar ataques furtivos que resultam em exploração de confiança usando hosts de pilha dupla, mensagens NDP não autorizadas e técnicas de tunelamento.
- O Teredo Tunneling, por exemplo, é uma tecnologia de transição IPv6 que fornece atribuição automática de endereços IPv6 quando os hosts IPv4/ IPv6 estão localizados por trás dos dispositivos NAT.
- Ele realiza isso incorporando os pacotes IPv6 dentro dos pacotes IPv4 UDP.
- O ator de ameaça ganha uma posição na rede IPv4.
- O host comprometido envia RAs não autorizados, que acionam hosts de pilha dupla para obter um endereço IPv6.
- O ator de ameaças pode então usar essa posição para se movimentar ou pivotar, dentro da rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão Geral ACL IPv6(Cont.)

- O ator de ameaças pode comprometer anfitriões adicionais antes de enviar o tráfego de volta da rede, conforme mostrado na figura.



- É necessário desenvolver e implementar uma estratégia para mitigar ataques contra infraestruturas e protocolos IPv6.
  - Esta estratégia de mitigação deve incluir filtrar na borda usando várias técnicas, como ACLs IPv6.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs IPv6

Sintaxe da ACL IPv6.

- A ACLs IPv6 permitem filtrar com base nos endereços de origem e de destino que estão viajando de entrada e saída para uma interface específica.
- Eles também suportam filtragem de tráfego com base em cabeçalhos de opção IPv6 e opcional, tipo de protocolo de camada superior tipo informação para granularidade mais fina de controle, como ACLs estendidos no IPv4.
- Para configurar uma ACL IPv6, use o comando **ipv6 access-list** para entrar no modo de configuração da ACL IPv6, e use a sintaxe mostrada na figura para configurar cada entrada da lista de acesso para permitir ou negar especificamente o tráfego.
- A sintaxe mostrada é uma versão simplificada da sintaxe de uma ACE IPv6, mas há opções adicionais.
- Aplique uma ACL IPv6 a uma interface com o comando **ipv6 traffic-filter** .

```
Router(config)# ipv6 access-list access-list-name
Router(config-ipv6-acl)# deny | permit protocol {source-ipv6-prefix / prefix-length |
any | host source-ipv6-address} [ operator [ port-number ]] { destination-ipv6-prefix
/ prefix-length | any | host destination-ipv6-address } [ operator [ port-number ]] [
dscp value ] [ fragments ] [ log ] [ log-input ] [ sequence value ] [ time-range name
]
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs IPv6

Sintaxe ACL IPv6 (Cont.)

Parameter	Description
deny | permit	Especifica se o pacote será permitido ou recusado.
protocol	Insira o nome ou número de um protocolo de internet ou um número inteiro representando um número de protocolo IPv6.
source-ipv6-prefix / prefix-length destination-ipv6-addr / prefix-length	A rede IPv6 de origem ou destino, ou classe de redes para a qual definir condições de permissão ou recusa.
any	Digite any como uma abreviatura para o prefixo IPv6 :: / 0. Isso corresponde a todos os endereços.
host	O endereço IPv6 do host de origem ou destino para o qual definir condições de negação ou permissão
Operator (Opcional)	Um operando que compara as portas origem ou destino do protocolo especificado.
port-number (Opcional)	Número decimal ou o nome de uma porta TCP ou UDP para filtrar TCP ou UDP, respectivamente.
Dscp (Opcional)	Corresponde a um valor de ponto de código de serviços diferenciados em relação ao valor da classe de tráfego no campo Classe de tráfego de cada cabeçalho de pacote IPv6. O intervalo aceitável é de 0 a 63.
Fragmentos (Opcional)	Ccorresponde aos pacotes fragmentados não iniciais, onde o cabeçalho de extensão de fragmentos contém um deslocamento de fragmento diferente de zero.
Log (opcional)	Gera uma mensagem de registro informacional sobre o pacote que corresponde à entrada, para ser enviada à console.
log input (Opcional)	Fornece a mesma função que a palavra-chave log, exceto que a mensagem de registro também inclui a interface de entrada.
sequence value	(Opcional) Especifica o valor do número de sequência para a instrução da lista de acesso.
time-range name	(Opcional) Especifica o intervalo de tempo que se aplica à instrução de permissão.

Configurar ACLs IPv6

- Uma ACL IPv6 contém uma instrução implícita **deny ipv6 any any**.
- Cada IPv6 ACL também contém regras de licença implícitas para permitir a descoberta vizinha do IPv6.
- O IPv6 NDP requer o uso da camada de rede IPv6 para enviar NAs e NSs.
- Se um administrador configurar o comando **deny ipv6 any any** sem explicitamente permitir descoberta de vizinhos, o NDP será desativado.
- Na figura, R1 está permitindo o tráfego de entrada em G0/0 vindo da rede 2001: DB8: 1: 1 :: / 64.
- Os pacotes NA e NS são explicitamente permitidos.
- O tráfego proveniente de qualquer outro endereço IPv6 é explicitamente negado.
- Se o administrador configurasse apenas a primeira instrução de permissão, a ACL teria o mesmo efeito.



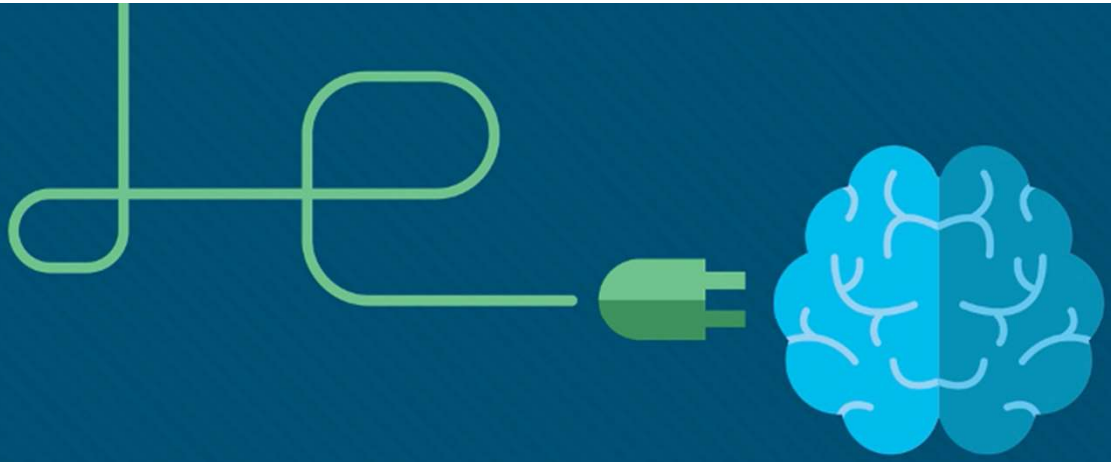

```
R1(config)# ipv6 access-list LAN_ONLY
R1(config-ipv6-acl)# permit 2001:db8:1:1::/64 any
R1(config-ipv6-acl)# permit icmp any any nd-na
R1(config-ipv6-acl)# permit icmp any any nd-ns
R1(config-ipv6-acl)# deny ipv6 any any
R1(config-ipv6-acl)# end
R1# show ipv6 access-list
IPv6 access list LAN_ONLY
    permit ipv6 2001:DB8:1:1::/64 any sequence 10
    permit icmp any any nd-na sequence 20
    permit icmp any any nd-ns sequence 30
    deny ipv6 any any sequence 40
R1#
```

Packet Tracer - Configurar ACLs IPv6

Neste Packet Tracer, você atingirá os seguintes objetivos:

- Configurar, aplicar e verificar uma ACL IPv6
- Configurar, aplicar e verificar uma segunda ACL IPv6

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 5: Tecnologias de Firewall



Defesa de rede

Objetivos do Módulo

Título do módulo: Tecnologias de Firewall

Objetivo do Módulo: Explique como os firewalls são implementados para fornecer segurança de rede.

Título do Tópico	Objetivo do Tópico
Proteger redes com firewalls	Explicar como os firewalls são usados para ajudar a proteger redes.
Firewalls em Design de Rede	Explicar as considerações de design para implementação de tecnologias de firewall

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.1 Redes Seguras com Firewalls

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Firewalls

Um firewall é um sistema ou grupo de sistemas que aplica uma política de controle de acesso entre redes. Recursos de firewall incluem:

Recursos de firewall	Descrição
Propriedades comuns do Firewall	• Os firewalls são resistentes a ataques de rede. • Os firewalls são o único ponto de trânsito entre redes corporativas internas e redes externas. • Firewalls reforçam a política de controle de acesso.
Benefícios do firewall	• Eles impedem a exposição de hosts, recursos e aplicações sensíveis a usuários não confiáveis. • Eles sanitizam o fluxo do protocolo, o que impede a exploração de falhas no protocolo. • Eles bloqueiam dados maliciosos de servidores e clientes. • Eles reduzem a complexidade do gerenciamento de segurança descarregando a maior parte do controle de acesso à rede para alguns firewalls na rede.
Limitações do Firewall	• Um firewall mal configurado pode ter sérias conseqüências para a rede. • Os dados de muitos aplicativos não podem ser transmitidos por firewalls com segurança. • Os usuários podem procurar proativamente maneiras de contornar o firewall para receber material bloqueado, o que expõe a rede a possíveis ataques. • O desempenho da rede pode diminuir. • O tráfego não autorizado pode ser encapsulado ou escondido como tráfego legítimo através do firewall.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

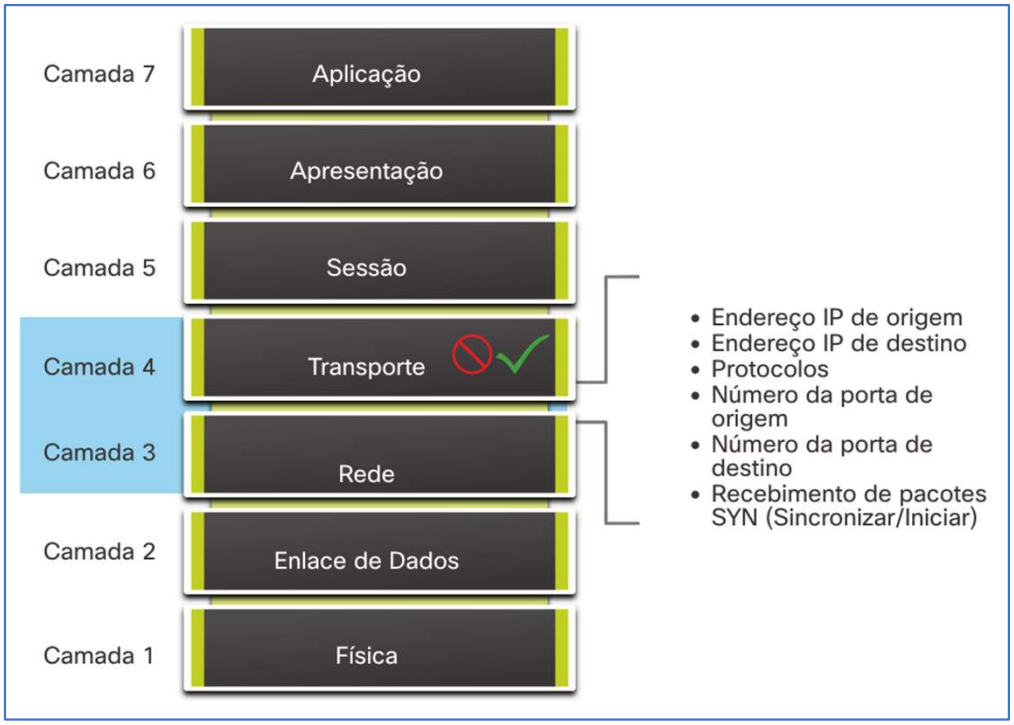
Tipos de Firewalls

Os tipos comuns de firewall incluem filtragem de pacotes, stateful, gateway de aplicativo e firewalls de próxima geração.

Firewall de filtragem de pacotes (sem estado)

- Os firewalls de filtragem de pacotes geralmente fazem parte de um firewall de roteador, que permite ou nega tráfego com base nas informações da Camada 3 e da Camada 4.

- Eles são firewalls sem estado que usam uma simples pesquisa de tabela de políticas que filtra o tráfego com base em critérios específicos.

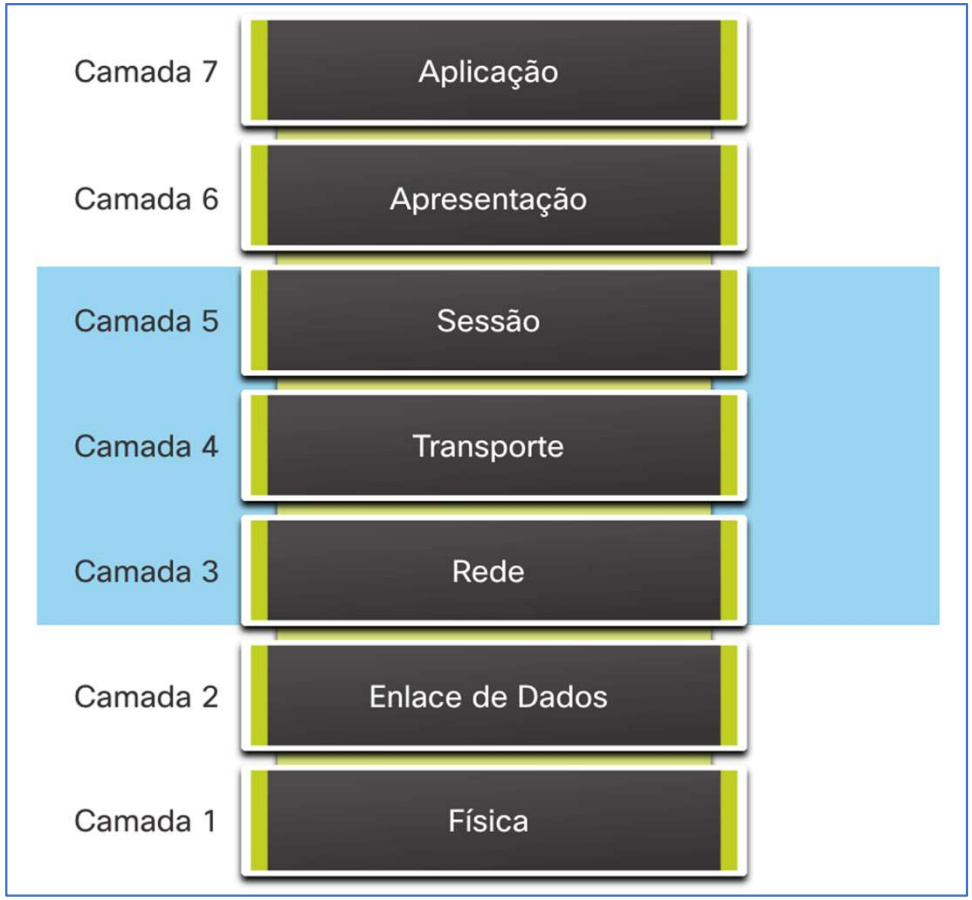


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Firewalls (Cont.)

Firewall com Estado

- Firewalls com estado (Stateful) são as tecnologias de firewall mais versáteis e mais comuns em uso.
- Os firewalls com estad fornecem filtragem de pacotes stateful usando informações de conexão mantidas em uma tabela de estado.
- Filtragem com estado é uma arquitetura de firewall classificada na camada de rede.
- Ele também analisa o tráfego na camada 4 da OSI e na camada 5.

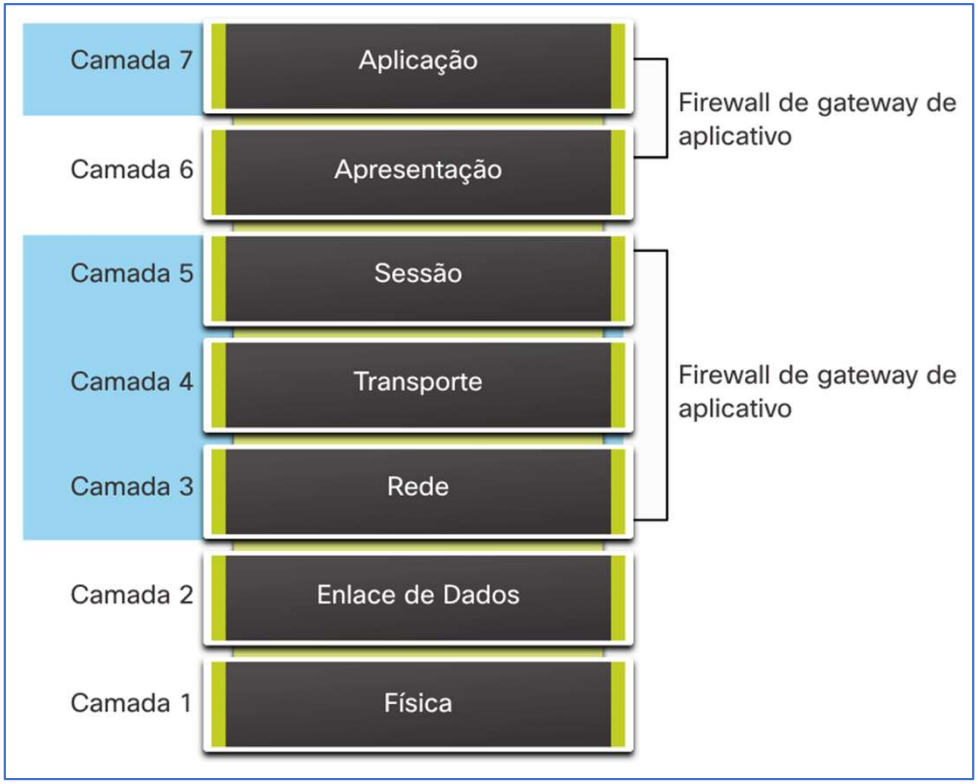


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Firewalls (Cont.)

Firewall de Gateway de Aplicação

- Um firewall de gateway de aplicação (proxy firewall) filtra informações nas Camadas 3, 4, 5 e 7 do modelo de referência OSI.
- A maior parte do controle e filtragem do firewall é feita em software.
- Quando um cliente precisa acessar um servidor remoto, ele se conecta a um servidor proxy.
- O servidor proxy se conecta ao servidor remoto em nome do cliente.
- Portanto, o servidor só vê uma conexão do servidor proxy.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Firewalls (Cont.)

Firewall de última geração

Os firewalls de última geração (NGFW) vão além dos firewalls de estado, fornecendo:



- Prevenção de intrusão integrada
- Reconhecimento e controle de aplicativos para ver e bloquear aplicativos arriscados
- Caminhos de atualização para incluir futuros feeds de informações
- Técnicas para lidar com ameaças de segurança em evolução

Outros métodos de implementação de firewalls incluem:

- **Firewall baseado em host (servidor e pessoal)** - Um PC ou servidor com software de firewall em execução nele.
- **Firewall transparente** - Filtra o tráfego IP entre um par de interfaces em ponte.
- **Firewall híbrido** - Uma combinação dos vários tipos de firewalls. Por exemplo, um firewall de inspeção de aplicações combina um firewall com estado com um firewall de gateway de aplicação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Benefícios e limitações do firewall de filtragem de pacotes

As vantagens e desvantagens de um firewall de filtragem de pacotes incluem:

Firewall de filtragem de pacotes	Descrição
Benefícios dos Firewalls de Filtragem de Pacotes:	• Filtros de pacote implementam conjuntos de regras de permissão simples ou negam. • Filtros de pacotes têm um baixo impacto no desempenho da rede. • Filtros de pacotes são fáceis de implementar e são suportados pela maioria dos roteadores. • Filtros de pacote fornecem um grau inicial de segurança na camada de rede. • Filtros de pacotes executam quase todas as tarefas de um firewall high-end a um custo muito menor.
Limitações dos firewalls de filtragem de pacotes:	• Filtros de pacote de informação são suscetíveis à falsificação de IP. Os atores de ameaça podem enviar pacotes arbitrários que atendem aos critérios ACL e passam pelo filtro. • Filtros de pacotes não filtram de forma confiável pacotes fragmentados. Como os pacotes IP fragmentados carregam o cabeçalho TCP no primeiro fragmento e filtro de filtros de pacote na informação de cabeçalho TCP, todos os fragmentos após o primeiro fragmento são passados incondicionalmente. As decisões de usar filtros de pacote supõem que o filtro do primeiro fragmento impõe com precisão a política. • Os filtros de pacotes usam ACLs complexas, que podem ser difíceis de implementar e manter. • Os filtros de pacotes não podem filtrar dinamicamente determinados serviços. Por exemplo, as sessões que usam negociações de porta dinâmica são difíceis de filtrar sem abrir o acesso a toda uma variedade de portas.

Benefícios e limitações do Firewall com estados

Alguns benefícios e limitações do uso de um firewall com estado incluem:

Firewall com Estado	Descrição
Benefícios	• Firewalls com estado são frequentemente usados como um meio primário de defesa, filtrando tráfego indesejado ou desnecessário. • Firewalls com estado fortalecem a filtragem de pacotes fornecendo um controle mais rigoroso sobre a segurança. • Firewalls com estado melhoram o desempenho em relação aos filtros de pacotes ou servidores proxy. • Firewalls com estado se defendem contra ataques de falsificação e DoS, determinando se os pacotes pertencem a uma conexão existente ou são de uma origem não autorizada. • Firewalls com estado fornecem mais informações de log do que um firewall de filtragem de pacotes.
Limitações	• Firewalls com estado não podem evitar ataques à camada de aplicativo porque não examinam o conteúdo real da conexão HTTP. • Nem todos os protocolos são stateful. Por exemplo, o UDP e o ICMP não geram informações de conexão para uma tabela de estado e, portanto, não conseguem tanto suporte para filtragem. • É difícil rastrear conexões que usam negociação de porta dinâmica. Algumas aplicações abrem várias conexões. Isso requer uma nova gama de portas que devem ser abertas para permitir esta segunda conexão. • Firewalls com estado não suportam autenticação de usuário.

5.2 Firewalls em Projetos de Redes

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

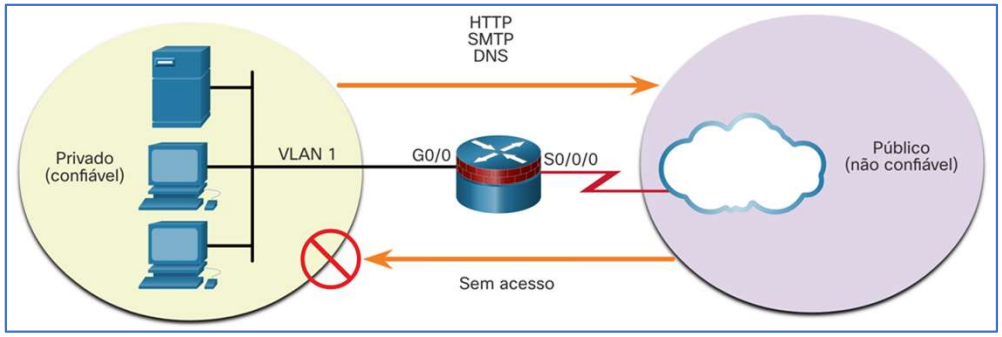
Arquiteturas de Segurança Comuns

O design do firewall é principalmente sobre interfaces de dispositivo que permitem ou negam tráfego com base na origem, no destino e no tipo de tráfego. Três projetos comuns de firewall são:

Privado e Público

A rede pública (ou rede externa) não é confiável e a rede privada (ou rede interna) é confiável. Normalmente, um firewall com duas interfaces é configurado da seguinte forma:

- O tráfego proveniente da rede privada é permitido e inspecionado à medida que viaja em direção à rede pública. É permitido o tráfego inspecionado que retorna da rede pública e associado ao tráfego originado da rede privada.
- O tráfego originado da rede pública e que viaja para a rede privada geralmente é bloqueado.



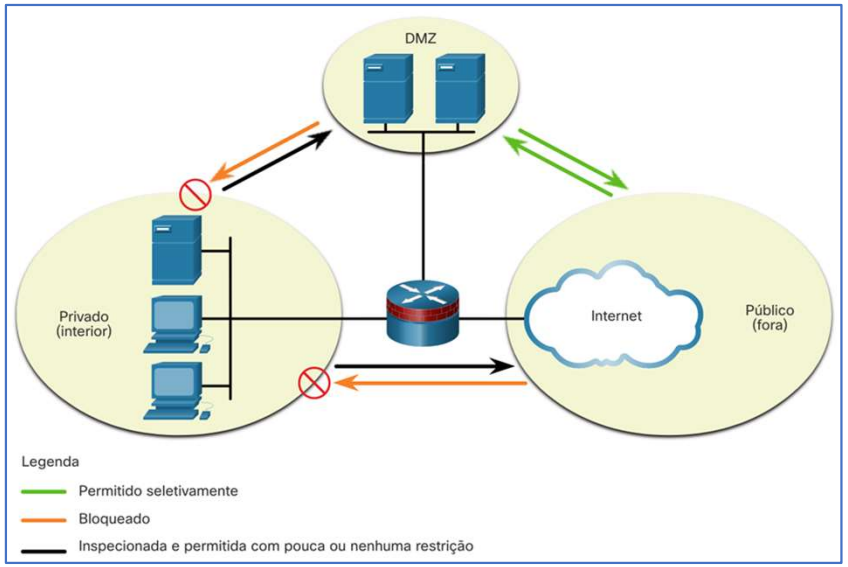
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Arquiteturas de Segurança Comuns (Cont.)

Zona Desmilitarizada (DMZ)

Um projeto de firewall onde normalmente há uma interface interna conectada à rede privada, uma interface externa conectada à rede pública e uma interface DMZ.

- O tráfego proveniente da rede privada é inspecionado à medida que ele viaja para a rede pública ou DMZ. Tráfego inspecionado que retorna da DMZ ou da rede pública para a rede privada é permitido.
- O tráfego originado da rede DMZ e que viaja para a rede privada geralmente é bloqueado.
- O tráfego originado da rede DMZ e viajando para a rede pública é permitido seletivamente com base nos requisitos de serviço.
- O tráfego proveniente da rede pública e que viaja em direção à DMZ é seletivamente permitido e inspecionado.



- O tráfego originado da rede pública e que viaja para a rede privada está bloqueado.

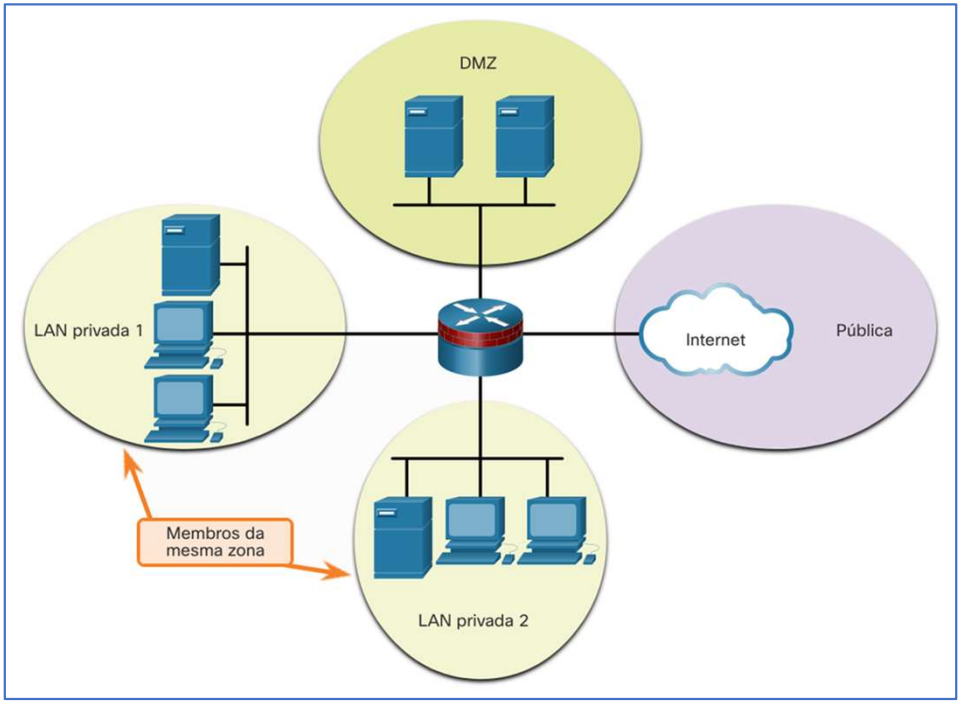
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Arquiteturas de Segurança Comuns (Cont.)

Firewalls de Políticas Baseadas em Zona (ZPFs)

ZPFs usam zonas para fornecer flexibilidade adicional. Uma zona é um grupo de uma ou mais interfaces que têm funções ou recursos semelhantes. As zonas ajudam a especificar onde uma política ou uma regra de firewall do Cisco IOS deve ser aplicada.

- As políticas de segurança para LAN 1 e LAN 2 são semelhantes e podem ser agrupadas em uma zona para firewall.
- Por padrão, o tráfego entre interfaces na mesma zona não está sujeito a nenhuma política e passa livremente.
- Todo o tráfego de zona para zona está bloqueado. Para permitir o tráfego entre as zonas, uma política que permite ou inspeciona o tráfego deve ser configurada.
- A única exceção a esse padrão que **denying any** política é a própria zona do roteador .



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Camadas

Uma defesa em camadas usa diferentes tipos de firewalls que são combinados em camadas para adicionar profundidade à segurança de uma organização. Por exemplo:

- **Segurança do núcleo da rede** - Protege contra software malicioso e anomalias de tráfego, impõe políticas de rede e garante capacidade de sobrevivência
- **Segurança de perímetro** - Protege limites entre zonas
- **Segurança de comunicações** - fornece garantia de informações
- **Segurança do endpoint** - Fornece identidade e conformidade com a política de segurança**do dispositivo**

As políticas podem ser aplicadas entre as camadas e dentro das camadas. Estes pontos de aplicação da política determinam se o tráfego é encaminhado ou descartado.

Se permitido pela política, o tráfego vai ao Firewall selecionado ou ao sistema bastion host que aplica mais regras ao tráfego e descarta pacotes suspeitos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Defesa em Camadas (cont.)

Uma abordagem de defesa em camadas é opcional para garantir uma rede interna segura. Um administrador de rede deve considerar muitos fatores ao construir uma defesa completa em profundidade:

- Os firewalls normalmente não interrompem as intrusões provenientes de hosts dentro de uma rede ou zona.
- Firewalls não protegem contra instalações de ponto de acesso desonestos.
- Os firewalls não substituem os mecanismos de backup e recuperação de desastres resultantes de ataques ou falhas de hardware.
- Os firewalls não substituem administradores e usuários informados.

Essa lista parcial de práticas recomendadas pode servir como ponto de partida para uma política de segurança de firewall.

- Posicione firewalls nos limites de segurança.
- Negue todo o tráfego por padrão e permita apenas os serviços necessários.
- Assegure-se de que o acesso físico ao firewall esteja controlado.
- Monitore regularmente logs de firewall.
- Pratique o gerenciamento de alterações para alterações de configuração de firewall.
- Lembre-se de que os firewalls protegem principalmente contra ataques técnicos originários do exterior.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

5.3 Resumo das Tecnologias de Firewall

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 6: Firewalls com Políticas Baseadas em Zonas (ZPF)

Defesa de rede

Objetivos do módulo

Título do módulo: Firewalls de Política Baseados em Zona

Módulo Objetivo: Implemente o Firewall de Política Baseados em Zona usando o CLI.

Título do Tópico	Objetivo do Tópico
Visão geral da ZPF	Explique como os Firewalls com Políticas Baseadas em Zonas (ZPF) são usados para ajudar a proteger uma rede.
Operação ZPF.	Explicar a operação de um Firewall de Política Baseado em Zona-baseado
Configure um ZPF.	Configure um firewall de política baseado em zona com o CLI.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

6.1 Visão geral do ZPF

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

Benefícios de um ZPF

Há dois modelos de configuração para o Cisco IOS Firewall:

- **Firewall clássico** - O modelo de configuração tradicional em que a política de firewall é aplicada em interfaces.
- **Firewall de Política Baseado em Zona** (ZPF) - O modelo de configuração na qual as interfaces são atribuídas a zonas de segurança, e a política de firewall é aplicada ao tráfego em movimento entre as zonas.

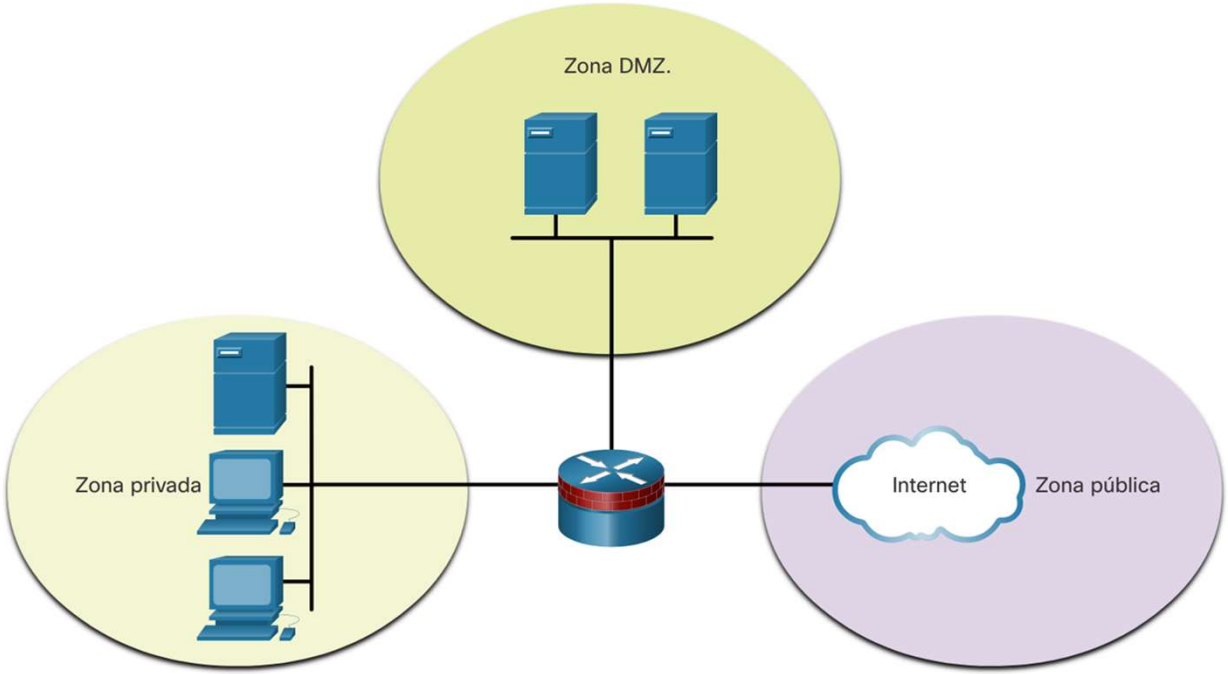
As principais motivações para profissionais de segurança de rede migram para o modelo ZPF são estrutura e facilidade de uso. A abordagem estruturada é útil para documentação e comunicação.

A facilidade de uso torna as implementações de segurança de rede mais acessíveis a uma comunidade maior de profissionais de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

Benefícios de um ZPF (Cont.)



- Se uma interface adicional for adicionada à zona privada, os hosts conectados à nova interface na zona privada podem passar tráfego para todos os hosts na interface existente na mesma zona.
- Uma rede simples de três zonas é mostrada na figura.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

Benefícios de um ZPF (Cont.)

Existem vários benefícios de um ZPF:

- Não é dependente de ACL.
- A postura de segurança do roteador é bloquear a menos que explicitamente permitido.
- As políticas são fáceis de ler e pesquisar defeitos com o Cisco Common Classification Policy Language (C3PL).
- C3PL é um método estruturado para criar políticas de tráfego com base em eventos, condições e ações. Isto fornece a escalabilidade porque uma política afeta todo o tráfego dado, em vez de precisar de ACLs múltiplos e ações da inspeção para tipos diferentes de tráfego.
- Interfaces virtuais e físicas podem ser agrupadas em zonas.
- As políticas são aplicadas ao tráfego unidirecional entre zonas.

Ao decidir se deseja implementar o IOS Classic Firewall ou um ZPF, é importante observar que ambos os modelos de configuração podem ser ativados simultaneamente em um roteador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

Projeto ZPF

Projetar ZPFs envolve várias etapas:

Passo 1: Determine a Zona:

- O administrador se concentra na separação da rede em zonas.
- Zonas estabelecem as fronteiras de segurança de uma rede.
- Uma zona define um limite onde o tráfego é submetido a restrições políticas à medida que cruza para outra região da rede.

Passo 2: Estabeleça políticas entre as zonas:

- Para cada par 'origem-destino' das zonas, defina as sessões que os clientes nas zonas de origem podem solicitar dos servidores nas zonas de destino.
- Essas sessões são mais frequentemente as sessões TCP e UDP, mas também podem ser sessões ICMP, como o ICMP ECHO.
- Para o tráfego que não é baseado no conceito de sessões, o administrador deve definir fluxos de tráfego unidirecionais da fonte para o destino e vice-versa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

Projeto ZPF (Cont.)

Passo 3: Projetar a infraestrutura física:

- Após as zonas terem sido identificadas e os requisitos de tráfego entre eles documentados, o administrador deve projetar a infraestrutura física.
- O administrador deve considerar os requisitos de segurança e disponibilidade ao projetar a infraestrutura física.
- Isso inclui ditar o número de dispositivos entre zonas mais seguras e menos seguras e determinar dispositivos redundantes.

Passo 4: Identifique subconjuntos dentro das zonas e mescle os requisitos de tráfego:

- Para cada dispositivo de firewall no projeto, o administrador deve identificar subconjuntos de zonas que estão conectados às suas interfaces e mesclar os requisitos de tráfego para essas zonas.
- Por exemplo, várias zonas podem ser ligadas indiretamente a uma única interface de um firewall.Isso resultaria em uma política interzona específica do dispositivo.
- Embora uma consideração importante, os subconjuntos de zona de implementação estão além do escopo deste currículo.

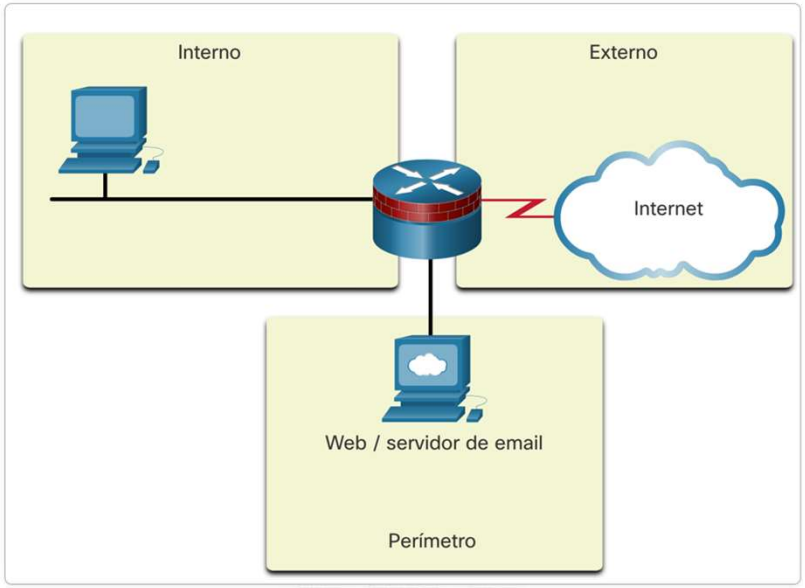
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

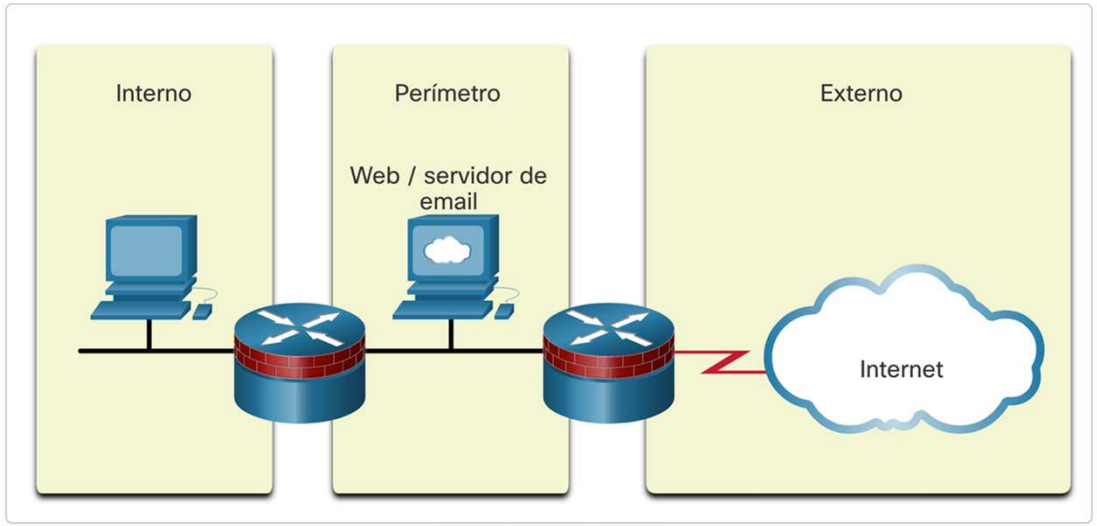
Projeto ZPF (Cont.)

Exemplos de Projetos ZPF

Firewall-with-public-servers-1



Firewall-with-public-servers-2

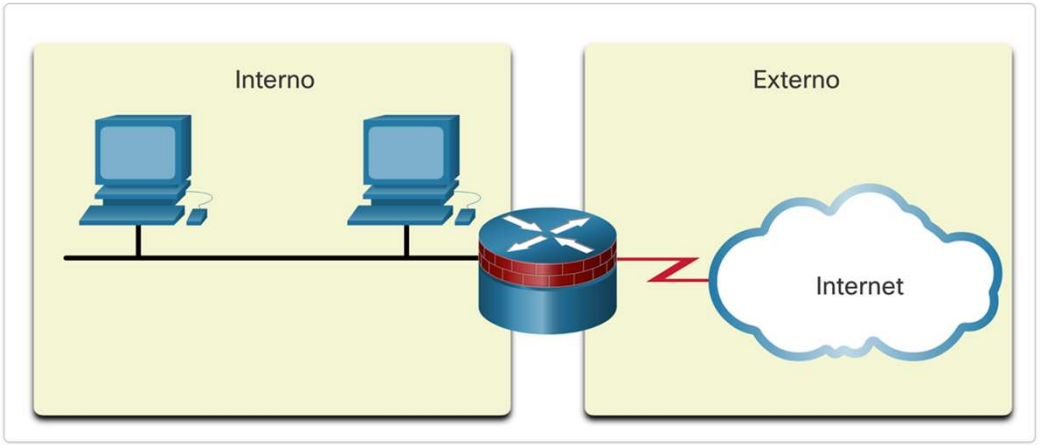


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

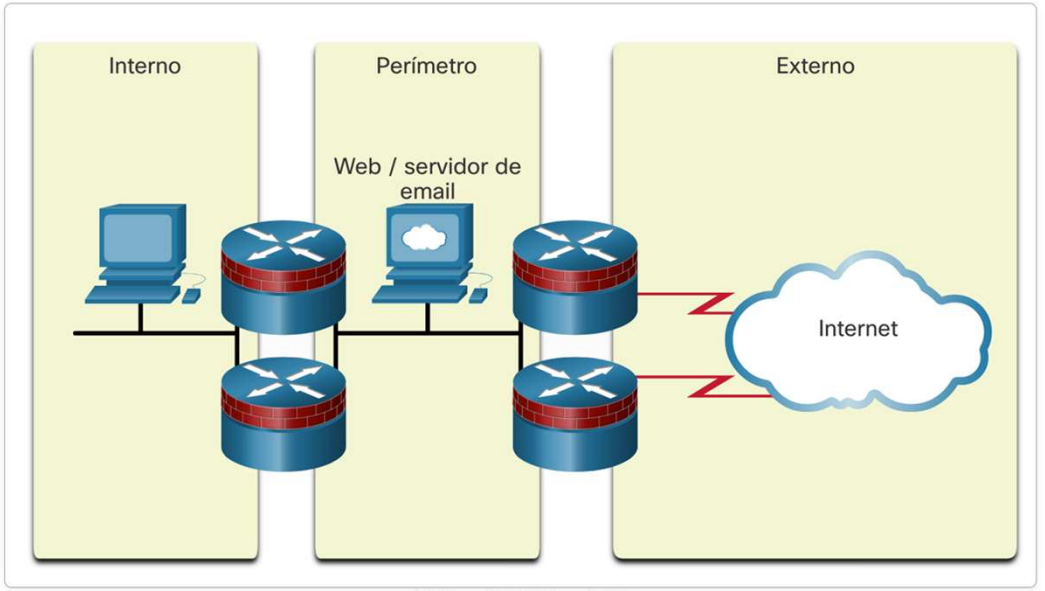
Visão geral do ZPF.

Projeto ZPF (Cont.)

Lan-to-internet



Firewall redundante

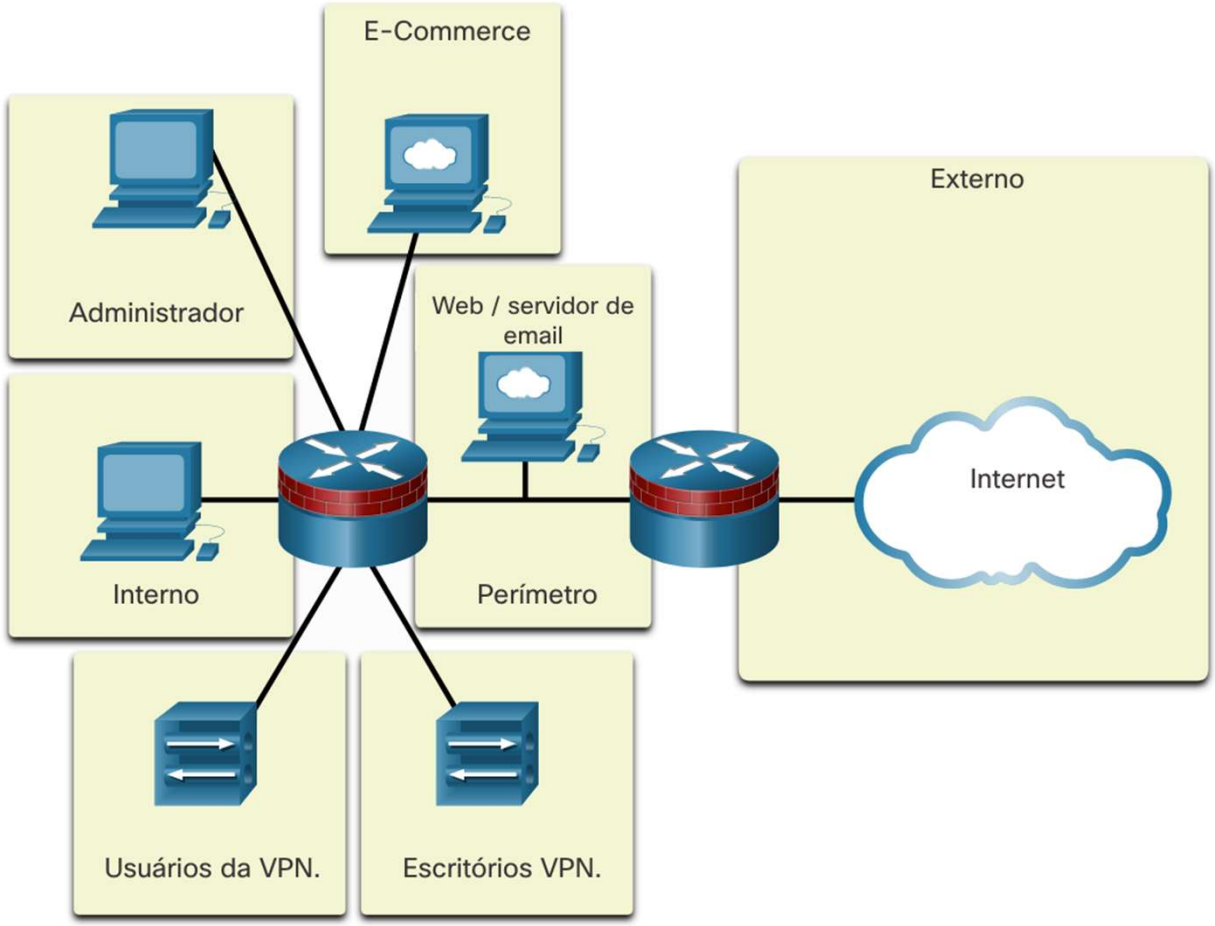


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral do ZPF.

Projeto ZPF (Cont.)

Firewall complexo



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

6.2 Operação ZPF

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação ZPF.

Ações ZPF

As políticas identificam ações que o ZPF executará no tráfego de rede.

Três ações possíveis podem ser configuradas para processar o tráfego por protocolo, origem, zonas de destino (pares de zonas) e outros critérios.

- **inspect** - Isso realiza inspeção de pacotes de estado de Cisco IOS.
- **drop** - Isso é análogo a deny uma **declaração** em uma ACL. Uma opção de log está disponível para **registrar os** pacotes rejeitados.
- **pass** - é análogo a uma **declaração permit** em uma ACL. A ação pass não rastreia o estado de conexões ou sessões dentro do tráfego.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação ZPF.

Regras para tráfego de trânsito

As regras dependem se as interfaces de entrada e saída e saída são membros da mesma zona:

- Se nenhuma das relações é um membro da zona, a seguir a ação resultante é passar o tráfego.
- Se ambas as relações são membros da mesma zona, a seguir a ação resultante é passar o tráfego.
- Se uma relação é um membro da zona, mas a outra não é, a seguir a ação resultante é deixar cair o tráfego apesar de um zona-par existir.
- Se ambas as relações pertencem ao mesmo zona-par e uma política existe, a seguir a ação resultante é inspecionar, permitir, ou cair conforme definido pela política.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação ZPF.

Regras para Tr[afego de Trânsito (Cont.)

A tabela resume as regras para o tráfego de trânsito.

Interface de origem Membro da Zona?	Membro da interface de destino da zona?	Zona-par existe?	Política existe?	Resultado
NÃO	NÃO	N/D	N/D	APROVADO
SIM	NÃO	N/D	N/D	DROP
NÃO	SIM	N/D	N/D	DROP
SIM (privado)	SIM (privado)	N/D	N/D	APROVADO
Sim (privado)	SIM (público)	NÃO	N/D	DROP
Sim (privado)	SIM (público)	SIM	NÃO	APROVADO
Sim (privado)	SIM (público)	SIM	SIM	INSPECT

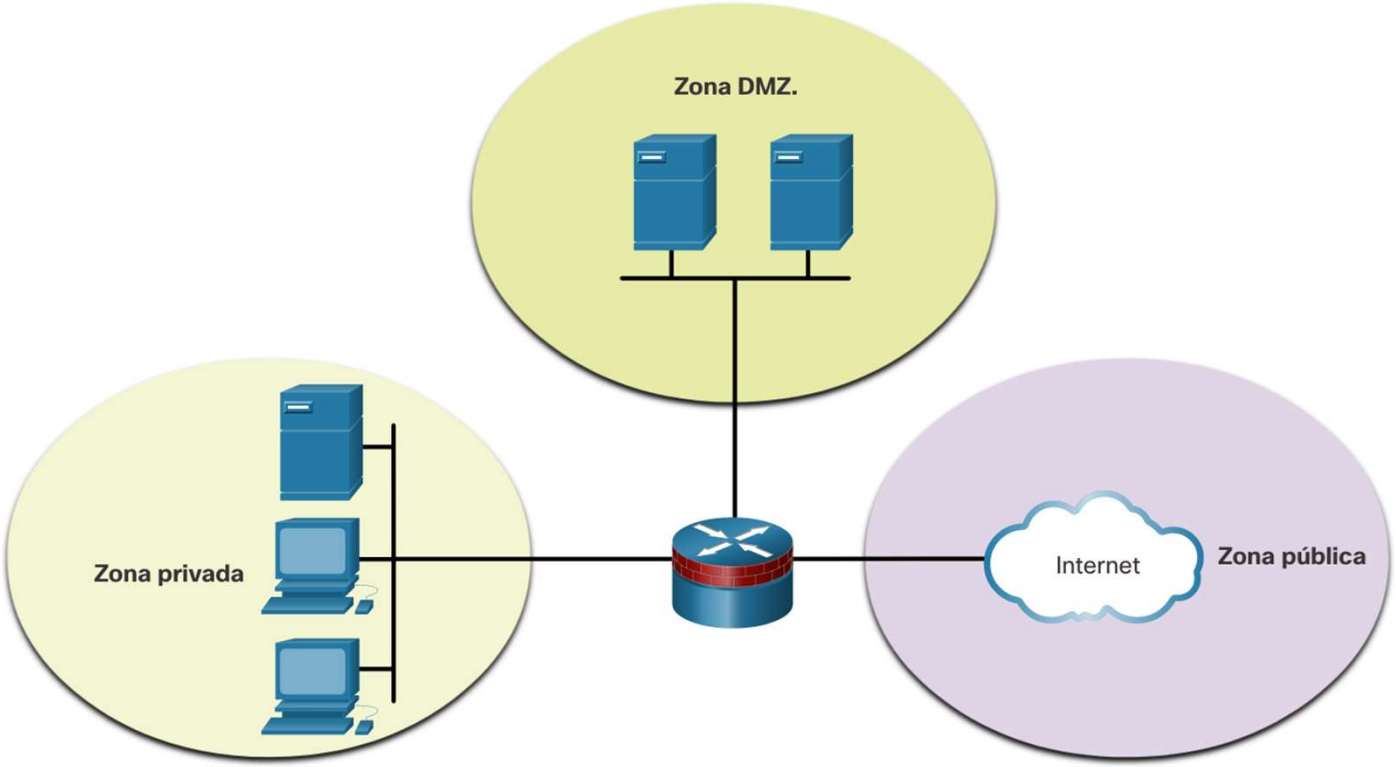
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação ZPF.

Regras para tráfego de trânsito

O tráfego que transita através das interfaces de roteador está sujeito a diversas regras que regem o comportamento da interface. Para o exemplo de tráfego de trânsito, consulte a topologia mostrada na figura.

Topologia básica da zona de segurança



Operação ZPF.

Regras para Tráfego para a Zona Self

- A zona self é o próprio roteador e inclui todos os endereços IP atribuídos às interfaces do roteador.
  - Este é o tráfego que se origina no roteador ou é endereçado a uma interface de roteador.
  - Especificamente, o tráfego é para o gerenciamento de dispositivos, por exemplo, SSH ou controle de encaminhamento de tráfego, como o tráfego de protocolo de roteamento.
  - As regras para um ZPF são diferentes para a autoza.

- As regras para uma ZPF são diferentes para a self-zone.
  - Se o roteador for a fonte ou o destino, todo o tráfego será permitido.
  - A única exceção é se a origem e o destino são um par de zona com uma política específica de serviço.
  - Nesse caso, a política é aplicada a todo o tráfego.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação ZPF.

Regras de Trânsito para Self-Zone (zona própria) (Cont.)

Interface de origem Membro da Zona?	Membro da interface de destino da zona?	Zona-par existe?	Política existe?	Resultado
SIM (zona self)	SIM	NÃO	N/D	APROVADO
SIM (zona self)	SIM	SIM	NÃO	APROVADO
SIM (zona self)	SIM	SIM	SIM	INSPECT
SIM	SIM (zona self)	NÃO	N/D	APROVADO
SIM	SIM (zona self)	SIM	NÃO	APROVADO
SIM	SIM (zona self)	SIM	SIM	INSPECT

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

6.3 Configurar um ZPF

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Configure um ZPF.

Etapa 1: crie as zonas.

Etapa 2: Identifique o tráfego com um class-map

Etapa 3: Defina uma ação com um policy-map.

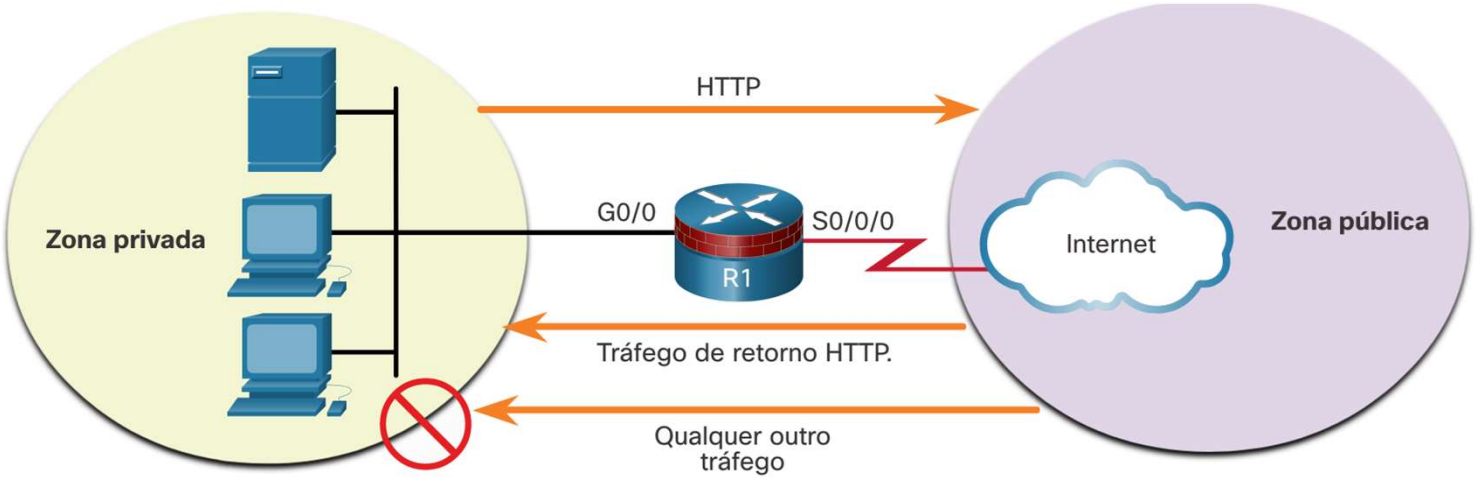
Etapa 4: Identifique um par de zonas e combine-o a um policy-map.

Etapa 5: Atribua zonas às interfaces apropriadas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configure um ZPF.

A topologia mostrada na figura será usada durante todo o restante deste tópico para demonstrar a configuração do ZPF. A sequência de etapas não é necessária. No entanto, algumas configurações devem ser concluídas em ordem. Por exemplo, você deve configurar um mapa de classe antes de atribuir um mapa de classe a um mapa de política. Da mesma forma, você não pode atribuir um mapa de política a um par de zonas até que tenha configurado a política. Se você tentar configurar uma seção que depende de outra parte da configuração que ainda não configurou, o roteador responde com uma mensagem de erro.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Passo 1. Crie as zonas

O primeiro passo, é criar as zonas. No entanto, antes de criar as zonas, responda a algumas perguntas:

- Quais interfaces devem ser incluídas nas zonas?
- Qual será o nome para cada zona?
- Que tráfego é necessário entre as zonas e em que direção?

Na topologia de exemplo, temos duas interfaces, duas zonas e tráfego fluindo em uma direção. O tráfego proveniente da zona pública não será permitido. Crie as zonas privadas e públicas para o firewall com o comando zone security, segundo as indicações aqui.

```
Router(config)# zone security zone-name
```

```
R1(config)# zone security PRIVATE
R1(config-sec-zone)# exit
R1(config)# zone security PUBLIC
R1(config-sec-zone)# exit
R1(config)#
```

ireitos reservados. Documento confidencial da Cisco

Etapa 2. Identifique o tráfego

A segunda etapa é usar um mapa de classe para identificar o tráfego a que uma política será aplicada.

- Uma classe é uma maneira de identificar um conjunto de pacotes com base em seus conteúdos usando condições de "correspondência". Normalmente, você define uma classe para que você possa aplicar uma ação ao tráfego identificado que reflita uma política. Uma classe é definida com mapas de classe.

- O exemplo abaixo mostra a sintaxe do comando **class-map**. Existem vários tipos de mapas de classe. Para uma configuração ZPF, use a palavra-chave **inspect** para definir um class-map. Determine como os pacotes são avaliados quando existem vários critérios de correspondência. Os pacotes devem atender a um dos critérios de correspondência **(match-any)** ou a todos os critérios de correspondência **(match-all)** para serem considerados membros da classe.

```
Router(config)# class-map type inspect [match-any |
match-all] class-map-name
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Etapa 2. Identificar tráfego (Cont.)

Parameter	Description
match-any	Os pacotes devem atender a um dos critérios de correspondência para serem considerados membros da classe.
match-all	Os pacotes devem atender a todos os critérios de correspondência para serem considerados um membro da classe.
class-map-name	Nome do mapa de classe que será usado para configurar a política para a classe no mapa de políticas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Etapa 2. Identificar tráfego (Cont.)

O exemplo abaixo mostra a sintaxe para as instruções de correspondência no modo de subconfiguração do **class-map**. Combine o tráfego a um ACL, a um protocolo específico, ou mesmo a outro mapa de classe.

```
Router(config-cmap)# match access-group {acl-# | acl-name
}
Router(config-cmap)# match protocol protocol-name
Router(config-cmap)# match class-map class-map-name
```

Parameter	Description
match access-group	Configura os critérios de correspondência para um mapa de classe baseado no número ou nome ACL especificado.
match protocol	Configura os critérios de correspondência para um mapa de classe baseado no protocolo especificado.
match class-map	Usa outro mapa de classe para identificar o tráfego.

Etapa 2. Identificar tráfego (Cont.)

Na topologia, o tráfego HTTP pode atravessar R1 da zona PRIVATE para a zona PUBLIC.

- Ao permitir o tráfego HTTP, é recomendável incluir espectros especificamente HTTPS e DNS, conforme mostrado no exemplo abaixo.

- O tráfego pode corresponder a qualquer uma das declarações para se tornar um membro da classe HTTP-Traffic.

```
R1(config)# class-map type inspect match-any HTTP-TRAFFIC
R1(config-cmap)# match protocol http
R1(config-cmap)# match protocol https
R1(config-cmap)# match protocol dns
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Etapa 3. Definir uma ação

A terceira etapa é usar um mapa de política para definir que ação deve ser tomada para o tráfego que é um membro de uma classe.

O exemplo abaixo mostra a sintaxe de comando para configurar um mapa de políticas. Uma ação é uma funcionalidade específica. É associado tipicamente a uma classe de tráfego. Por exemplo, **inspect**, **drop**, e **pass** são ações.

```
R1(config)# policy-map type inspect policy-map-name
R1(config-pmap)# class type inspect class-map-name
R1(config-pmap-c)# {inspect | drop | pass}
```

Parameter	Description
inspect	Uma ação que oferece controle de tráfego baseado em estado. O roteador mantém informações de sessão para TCP e UDP e permite o tráfego de retorno.
drop	Descarta tráfego indesejado
pass	Uma ação sem estado que permite ao roteador encaminhar o tráfego de uma zona para outra

Etapa 3. Definir uma ação (cont.)

O exemplo abaixo mostra um exemplo de uma configuração de política de políticas.

- A classe HTTP-TRAFFIC que foi configurada na etapa anterior está associada a um novo policy-map chamado PRIV-TO-PUB-POLICY.
- O terceiro comando **inspect** configura R1 para manter informações de estado para todo o tráfego que é membro do tráfego da classe HTTP-TRAFFIC.

```
R1(config)# policy-map type inspect PRIV-TO-PUB-POLICY
R1(config-pmap)# class type inspect HTTP-TRAFFIC
R1(config-pmap-c)# inspect
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Etapa 3. Definir uma ação (cont.)

- **inspect** - Esta ação oferece controle de tráfego baseado em estado. Por exemplo, se o tráfego que viaje da zona privada para a zona pública for inspecionado, o roteador mantém informações de conexão ou sessão para o tráfego TCP e UDP. O roteador permitiria então o tráfego de retorno enviado de hospedeiros de zona pública em resposta às solicitações de conexão de zona privada.

- **drop** - Esta é a ação padrão para todo o tráfego. Semelhante ao deny any implícito no final de cada ACL, há um drop explícito aplicado pelo IOS ao fim de cada policy−map. Ele é listado como classe class-default na última seção de qualquer configuração de policy-map. Outros mapas de classe dentro de um mapa de políticas também podem ser configurados para diminuir o tráfego indesejado. Ao contrário do ACLs, o tráfego é silenciosamente descartado, e nenhuma mensagem inacessível ICMP é enviada para a origem do tráfego.

- **pass** - Essa ação permite que o roteador encaminhe o tráfego de uma zona até a outra. A ação de aprovação não rastreia o estado das conexões. Pass só permite o tráfego em uma direção. Uma política correspondente deve ser aplicada para permitir que o tráfego de retorno passe na direção oposta. A ação de passe é ideal para protocolos seguros com comportamento previsível, como IPsec. No entanto, a maior parte do tráfego de aplicativos é melhor tratada no ZPF com a ação de inspeção.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Etapa 4. Identificar um Zona-Par e combinar a uma política

A quarta etapa é identificar um par de zonas e associar esse par de zonas a um mapa de política.

O exemplo abaixo mostra a sintaxe do comando. Crie um par de zonas (zone-pair) com o comando **zone-pair security**. Em seguida, utilize o comando "**service-policy type inspect** " para anexar uma policy-map e sua ação associada ao zone-pair.

```
Router(config)# zone-pair security zone-pair-name source
{source-zone-name | self} destination {destination-zone-
name | self}
Router(config-sec-zone-pair)# service-policy type inspect
policy-map-name
```

Parameter	Description
source source-zone-name	Especifica o nome da zona da qual o tráfego é originado.
destination destination-zone-name	Especifica o nome da zona à qual o tráfego está destinado.
self	Especifica a zona definida pelo sistema. Indica se o tráfego vai para ou do próprio roteador.

Configurar um ZPF

Etapa 4. Identificar um zone-pair e combiná-lo a uma política (Continuação).

- O exemplo abaixo mostra um exemplo de uma configuração de par de zona. Um par de zona nomeado PRIP-PUB é criado com privado atribuído como a zona de origem e o público atribuído como a zona de destino. Em seguida, o mapa de políticas criado na etapa anterior está associado ao par de zona.

- Depois que a política do firewall tiver sido configurada, o administrador a aplica ao tráfego entre um par de zonas usando o comando de segurança do par de zona. Para aplicar uma política, ela é atribuída a um par de zona. O par de zona precisa especificar a zona de origem, a zona de destino e a política de lidar com o tráfego entre as zonas de origem e destino.

```
R1(config)# zone-pair security PRIV-PUB source PRIVATE
destination PUBLIC
R1(config-sec-zone-pair)# service-policy type inspect
PRIV-TO-PUB-POLICY
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Etapa 5. Atribuir zonas a interfaces

A quinta etapa é atribuir zonas às interfaces apropriadas.

- Associar uma zona a uma interface aplicará imediatamente a política de serviço que foi associada à zona.
- Se nenhuma serviço-política é configurada ainda para a zona, todo o tráfego de trânsito será deixado cair.
- Utilize o comando "zone-member security" para atribuir uma zona a uma interface, conforme mostrado no exemplo abaixo.

```
Router(config-if)# zone-member security zone-name
```

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Etapa 5. Atribuir zonas a interfaces

- No exemplo a seguir, GigabiteEthernet 0/0 é atribuído a zona PRIVADA, e Serial 0/0/0 é atribuído a zona PUBLIC.

```
R1(config)# interface GigabitEthernet 0/0
R1(config-if)# zone-member security PRIVATE
R1(config-if)# interface Serial 0/0/0
R1(config-if)# zone-member security PUBLIC
```

- A política de serviço agora está ativa. O tráfego HTTP, HTTPS e DNS fornecido da zona privada e destinado à zona pública será inspecionado. O tráfego proveniente da zona pública e destinado à zona privada só será permitido se for parte das sessões inicialmente iniciadas por hosts de zona privada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Verifique uma configuração do ZPF

```
R1# show run | begin class-map
!
<some output omitted>
!
class-map type inspect match-any HTTP-TRAFFIC
 match protocol http
 match protocol https
 match protocol dns
!
policy-map type inspect PRIV-TO-PUB-POLICY
 class type inspect HTTP-TRAFFIC
  inspect
 class class-default
  drop
!
zone security PRIVATE
zone security PUBLIC
zone-pair security PRIV-PUB source PRIVATE destination PUBLIC
 service-policy type inspect PRIV-TO-PUB-POLICY
!
interface GigabitEthernet0/0
 zone-member security PRIVATE
!
interface Serial0/0/0
 zone-member security PUBLIC
!
```

- Verifique uma configuração ZPF visualizando a configuração em execução. Observe que o mapa de classe está listado primeiro. Então o mapa de política faz uso do mapa de classe. Também observe a ”**class class-default**" destacada que irá descartar todo o tráfego que não seja membro da classe "HTTP-TRAFFIC".

- As configurações de zona seguem as configurações do mapa de política com nomeação de zona, emparelhamento de zonas e associando uma política de serviço ao par de zonas. Finalmente, as interfaces são zonas atribuídas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Verifique uma configuração ZPF (Cont .)

```
R1# show policy-map type inspect zone-pair sessions

policy exists on zp PRIV-PUB
  Zone-pair: PRIV-PUB

  Service-policy inspect : PRIV-TO-PUB-POLICY

   Class-map: HTTP-TRAFFIC (match-any)
      Match: protocol http
        12 packets, 384 bytes
        30 second rate 0 bps
      Match: protocol https
        5 packets, 160 bytes
        30 second rate 0 bps
      Match: protocol dns
        0 packets, 0 bytes
        30 second rate 0 bps

Inspect

  Number of Established Sessions = 1
  Established Sessions
   Session 2204E220 (192.168.1.3:1049)=>(10.1.1.2:443) https:tcp
  SIS_OPEN/TCP_CLOSEWAIT
          Created 00:00:14, Last heard 00:00:11
          Bytes sent (initiator:responder) [821:1431]

   Class-map: class-default (match-any)
     Match: any
     Drop
       4 packets, 160 bytes
R1#
```

- O exemplo abaixo mostra informações de verificação após um teste da configuração do ZPF.
- Um host de zona privado 192.168.1.3 estabeleceu uma sessão HTTPS com um servidor da Web às 10.1.1.2.
- Observe ainda mais para baixo na saída do comando que quatro pacotes deram match com a classe class-default.
- Esta informação de verificação foi gerada por ter host 192.168.1.3 ping no servidor web em 10.1.1.2.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configurar um ZPF

Verifique uma configuração ZPF (Cont .)

```
R1# show class-map type inspect
Class Map type inspect match-any HTTP-TRAFFIC (id 1)
   Match protocol http
   Match protocol https
   Match protocol dns

R1# show zone security
zone self
Description: System Defined Zone

zone PRIVATE
 Member Interfaces:
 GigabitEthernet0/0

zone PUBLIC
 Member Interfaces:
 Serial0/0/0

R1# show zone-pair security
Zone-pair name PRIV-PUB
    Source-Zone PRIVATE Destination-Zone PUBLIC
    service-policy PRIV-TO-PUB-POLICY

R1# show policy-map type inspect
Policy Map type inspect PRIV-TO-PUB-POLICY
    Class HTTP-TRAFFIC
      Inspect
    Class class-default
      Drop
```

- O exemplo mostra quatro outros comandos de verificação do ZPF que permitem uma exibição de partes específicas da configuração do ZPF.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Considerações de configuração do ZPF.

Ao configurar um ZPF com o CLI, há vários fatores a considerar:

- O roteador nunca filtra o tráfego entre interfaces na mesma zona.
- Uma interface não pode pertencer a várias zonas. Para criar uma união de zonas de segurança, especifique uma nova zona e um mapa de política apropriado e pares de zonas.
- O ZPF pode coexistir com o Firewall clássico embora não possa ser usado na mesma interface. Remova o comando de configuração "**ip inspect**" interface antes de aplicar o comando "**zone-member security**".
- O tráfego nunca pode fluir entre uma interface atribuída a uma zona e uma interface sem uma atribuição de zona. A aplicação do comando de configuração "**zone-member**" sempre resulta em uma interrupção temporária do serviço até que o outro membro da zona seja configurado.
- A política entre zonas padrão é deixar cair todo o tráfego a menos que especificamente permitido de outra forma pela serviço-política configurada para o zona-par.
- O comando "**zone-member**" não protege o próprio roteador (o tráfego de e para o roteador não é afetado) a menos que os zone-pairs sejam configurados usando a zona predefinida "self".

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Configure um ZPF.

TRACER PACKET - Configure um ZPF

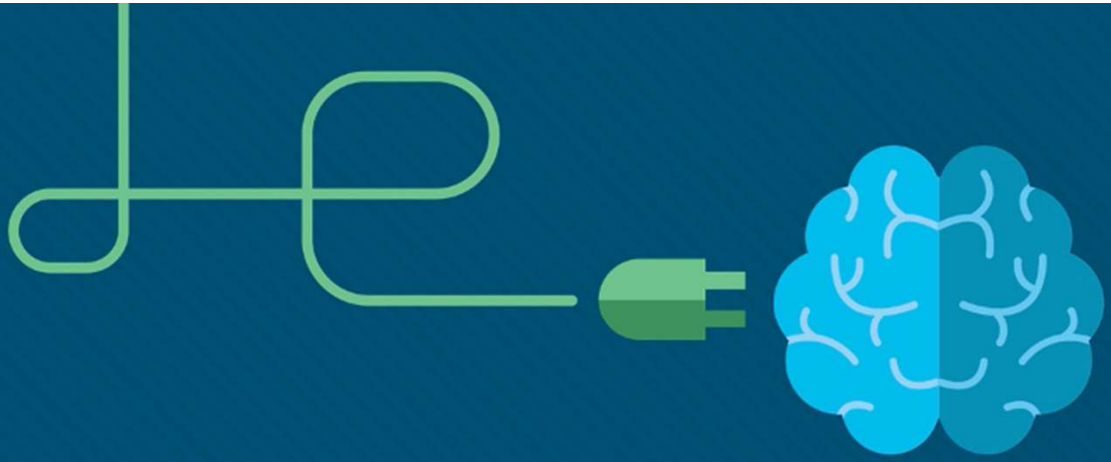
Neste Packet Tracer, você atingirá os seguintes objetivos:

- Verifique a conectividade entre dispositivos antes da configuração do firewall.
- Configurar um ZPF no roteador R3.
- Verifique a funcionalidade ZPF usando o ping, o telnet, e um navegador da Web.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

6.4 Resumo de Firewalls Baseados em Zonas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 7: Segurança em Nuvem



Defesa de rede

Objetivos do módulo

Título do Módulo: Segurança na Nuvem

Objetivo do Módulo: Recomendar requisitos de segurança na nuvem com base em um determinado cenário de nuvem.

Título do Tópico	Objetivo do Tópico
Virtualização e computação em nuvem	Descrever maneiras de gerenciar ameaças à nuvem privada e pública.
Os Domínios de Segurança na Nuvem	Explicar os domínios de segurança da nuvem.
Segurança de Infraestrutura em Nuvem	Explicar a mitigação de ameaças à infraestrutura da plataforma em nuvem.
Segurança de Aplicações em Nuvem	Recomendar as aplicações de segurança em nuvem.
Segurança de Dados em Nuvem	Explicar como proteger os dados em nuvem.
Protegendo VMs	Explicar como proteger as instâncias de VM.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.1 Virtualização e Computação em Nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O ambiente virtual

A virtualização beneficia uma empresa ao diminuir o número de máquinas físicas (por exemplo, servidores e estações de trabalho) necessárias no ambiente de TI.

Máquinas virtuais

Um hypervisor é um programa de software ou hardware que permite executar vários sistemas operacionais independentes em um sistema físico. Ele é um componente chave da virtualização. Existem dois métodos de virtualização:

- Virtualização de hardware (hypervisor tipo 1) - o sistema operacional convidado é executado diretamente em uma plataforma de hardware, sob o controle do sistema host.
- Virtualização hospedada (hypervisor tipo II) - um aplicativo em execução na máquina host é usado para criar máquinas virtuais que consistem totalmente em software e não contêm componentes de hardware.

Os ambientes de máquinas virtuais usam um sistema operacional, portanto, eles precisam ser corrigidos. As máquinas virtuais compartilham hardware e são executadas com privilégios muito altos. Esteja ciente de que um invasor que comprometa uma máquina virtual pode comprometer a máquina host.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Ambiente Virtual (cont.)

Contêineres

- Ao contrário de uma máquina virtual, um contêiner consiste apenas noaplicativo e suas dependências. Um contêiner usa um mecanismo para emulação de sistema operacional. O Docker é uma plataforma aberta que usa a virtualização no SO para distribuir software em pacotes (contêineres). Você pode facilmente mover contêineres e o aplicativo será executado. Um software especializado como o Kubernetes permite gerenciar seus contêineres.

- Se um usuário ou aplicativo tiver privilégios elevados em um contêiner, o sistema operacional subjacente poderá ser comprometido.

Infraestrutura de Desktops Virtuais (VDI)

- Os ambientes de desktop do usuário podem ser armazenados remotamente em um servidor usando thin client ou desktops virtuais. Isso torna muito fácil criar, excluir, copiar, arquivar ou baixar configurações com rapidez em uma rede. A virtualização de desktop requer alta disponibilidade e capacidade de armazenamento.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tecnologia baseada em nuvem

As tecnologias baseadas em nuvem permitem que empresas como @Apollo acessem computação, armazenamento, software e servidores pela Internet. Ele move o componente de tecnologia da organização para o provedor de nuvem.

Vamos recapitular do Módulo 1 os três principais modelos de serviços de computação, conhecidos coletivamente como XaaS ("anything as a service" "qualquer coisa como serviço").

Software as a Service (SaaS) permite que os usuários acessem software de aplicativos e bancos de dados. Os provedores de nuvem gerenciam a infraestrutura enquanto os usuários armazenam dados nos servidores do provedor de nuvem.

Platform as a Service (PaaS) permite que uma organização acesse remotamente as ferramentas e serviços de desenvolvimento usados para entregar tais aplicativos, por assinatura.

Infrastructure as a Service (IaaS) fornece recursos de computação virtualizados pela Internet. O provedor hospeda o hardware, software, servidores e componentes de armazenamento, e o usuário paga por uma assinatura para usar esses recursos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Computação em Nuvem

As classificações da computação em nuvem baseiam-se na implantação dos modelos de serviço.

Nuvem privada

- Também chamada de nuvem interna, corporativa ou empresarial, uma nuvem privada é hospedada em uma plataforma privada.
- Uma nuvem privada oferece à empresa mais controle sobre seus dados, mas pode ser mais caro do que outros serviços de nuvem devido aos custos de infraestrutura, manutenção e administração.

Nuvem pública

- Uma nuvem pública é hospedada por um provedor de serviços em uma instalação externa.
- Os usuários pagam uma taxa de uso mensal ou anual para acessar a nuvem. Essa opção custa menos à empresa para infraestrutura, manutenção e administração. No entanto, a empresa tem menos controle sobre seus dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Computação em Nuvem

Nuvem híbrida

- Uma nuvem híbrida combina a nuvem privada e pública ao oferecer o controle de dados organizacionais, que ainda são hospedados em uma nuvem pública.

Nuvem comunitária

- Uma nuvem da comunidade é um esforço colaborativo no qual mais de uma empresa compartilha e usa a mesma plataforma.
- Esse tipo de nuvem é voltado para as necessidades de um setor, como saúde ou energia.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fog e Edge Computing

A explosão dos dispositivos de IoT levou à computação em neblina (fog computing) e à computação de borda (edge computing).

A Fog Computing (computação em neblina) distribui a computação entre o dispositivo e o data center em nuvem. Ela desempenha um papel fundamental em aplicações onde milissegundos são importantes, como veículos autônomos, linhas aéreas e aplicações de manufatura.

- Na fog computing, os dados são processados dentro de um gateway de IoT, ou fog node, que fica na rede de área local.

- Na edge computing (computação de borda), os dados são processados no dispositivo ou no sensor sem serem transferidos para um data center.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Principais ameaças à computação em nuvem

A computação em nuvem é suscetível às muitas ameaças que afetam as redes físicas da empresa. No entanto, o ambiente de nuvem também apresenta ameaças exclusivas.

Por exemplo, se um agente de ameaça comprometer um recurso de nuvem, ele poderá fazer o seguinte:

- Use os recursos de computação em nuvem para atingir outras entidades online.
- Hospede malware em provedores de nuvem respeitados que parecerão inofensivos ou até mesmo legítimos.
- Abusa dos serviços em nuvem para lançar ataques de DDoS, hospedar conteúdo pirata, enviar spam de e-mail e realizar campanhas de phishing.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Virtualização e computação em nuvem

Principais ameaças à computação em nuvem

Veja a seguir algumas ameaças associadas à computação em nuvem.

Ameaça	Descrição
Violação de dados	Isso ocorre quando dados confidenciais protegidos são acessados por uma entidade não autorizada.
Configuração incorreta de nuvem	Isso ocorre quando o recurso de computação em nuvem é configurado incorretamente, tornando-o vulnerável a ataques.
Estratégia de arquitetura de segurança de nuvem ruim	A segurança da nuvem privada é de responsabilidade da empresa. No entanto, a segurança para nuvens públicas, nuvens híbridas e nuvens da comunidade se torna uma responsabilidade compartilhada entre a empresa e o provedor. Isso pode introduzir vulnerabilidades se a arquitetura de segurança da nuvem não for totalmente compreendida ou implementada corretamente.
Credênciais de contas comprometidas	Isso ocorre quando contas de usuário ou privilégios de acesso não são devidamente protegidos e são invadidas por agentes de ameaças. Isso pode levar a uma grande ameaça à segurança se a conta tiver altos privilégios. Por exemplo, em nuvens públicas, uma conta de serviço tem o maior privilégio de acessar e gerenciar ativos de nuvem. Uma conta de serviço sequestrada permitiria que um agente de ameaças controlasse todos os recursos da nuvem.

Principais ameaças à computação em nuvem (cont.)

Veja a seguir algumas ameaças associadas à computação em nuvem.

Ameaça	Descrição
Ameaça interna	Isso ocorre quando um funcionário, empreiteiro ou parceiro de negócios compromete o serviço em nuvem de forma mal-intencionada ou não.
Interface de usuário de software (UI) insegura ou interface de programação de aplicativo (API)	A computação em nuvem usa UIs e APIs de software para que os clientes interajam com seus serviços em nuvem. Essas interfaces são os pontos mais expostos à Internet e, portanto, são alvos dos agentes de ameaças.
Visibilidade limitada do uso da nuvem	Isso ocorre quando o cliente de nuvem não tem visibilidade completa do serviço em nuvem, dificultando a identificação de arquivos seguros ou mal-intencionados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.2 Os Domínios da Segurança em Nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Domínios da Segurança na Nuvem

Há muitos recursos disponíveis que promovem a segurança da computação em nuvem.

- Um recurso amplamente respeitado e mencionado é o documento Guia de segurança para áreas de foco essenciais na computação em nuvem v4.
- Desenvolvido pela Cloud Security Alliance (CSA), ele promove as melhores práticas para oferecer garantia de segurança nos domínios da computação em nuvem.
- Especificamente, o documento abrange 14 domínios de segurança de nuvem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Os Domínios de Segurança na Nuvem

Domínios da Segurança na Nuvem

Título de domínio	Descrição
Conceitos e arquiteturas de Computação em Nuvem	O domínio define a terminologia da computação em nuvem e detalha as estruturas lógicas e arquitetônicas gerais usadas no documento de orientações de segurança.
Governança e Gerenciamento de Riscos Corporativos	O domínio descreve quatro áreas afetadas pela computação em nuvem: • Governança • Gerenciamento de riscos empresariais • Gerenciamento de riscos de informações • Segurança da Informação.
Questões jurídicas, contratos e descoberta eletrônica	O domínio descreve questões legais associadas à computação em nuvem, incluindo a transferência de dados para a nuvem, a contratação de provedores de serviços em nuvem e o gerenciamento de solicitações de descoberta eletrônica em litígios.
Gerenciamento de conformidade e auditoria	O domínio descreve os desafios de disponibilizar, medir e comunicar a conformidade quando as empresas migram dos data centers tradicionais para a nuvem.
Governança da informação	O domínio descreve a necessidade de garantir que o uso de dados e informações esteja em conformidade com as políticas, os padrões e a estratégia da empresa, incluindo os objetivos regulatórios, contratuais e comerciais.

Domínios da Segurança na Nuvem

Título de domínio	Descrição
Plano de gerenciamento e continuidade dos negócios	O domínio descreve a necessidade de proteger o plano de gerenciamento da computação em nuvem (ou seja, os protocolos e os recursos usados para gerenciar a nuvem). Ele também descreve a continuidade dos negócios e os procedimentos de recuperação de desastres que devem ser usados pelo provedor e pelo cliente em nuvem.
Segurança como Serviço	O domínio abrange os serviços de segurança em constante evolução fornecidos pela nuvem.
Segurança de infraestrutura	O domínio descreve aspectos específicos da nuvem da segurança de infraestrutura e a base para operar com segurança na nuvem.
Virtualização e Contêineres	O domínio descreve a necessidade de proteger a tecnologia de virtualização e os ativos virtuais que são a base para a computação em nuvem.
Resposta a incidentes	O domínio descreve os aspectos críticos da resposta a incidentes (IR), incluindo o ciclo de vida de resposta a incidentes e considerações para respondentes enquanto trabalham em um ambiente de nuvem.
Segurança de aplicações	O domínio oferece orientação sobre como criar e implantar aplicações com segurança em ambientes de computação em nuvem, especificamente para PaaS e IaaS.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Domínios da Segurança na Nuvem

Título de domínio	Descrição
Segurança e criptografia de dados	A segurança de dados deve ser baseada em risco, pois não é apropriado proteger tudo de forma igual. O domínio descreve os controles relacionados à proteção dos próprios dados, dos quais a criptografia é uma das mais importantes.
Gerenciamento de identidade, direito e acesso (IAM)	O domínio descreve como a identidade de nuvem é diferente do gerenciamento de identidade tradicional.
Tecnologias relacionadas	O domínio fornece informações e recomendações para tecnologias que dependem quase exclusivamente da computação em nuvem para operar e para tecnologias que não dependem necessariamente da nuvem, mas são comumente vistas em implantações em nuvem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.3 Segurança de infraestrutura da nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de infraestrutura

- O domínio Segurança da infraestrutura descreve aspectos específicos da nuvem da segurança da infraestrutura e a base para operar com segurança na nuvem.

- A infraestrutura de nuvem é a base sobre a qual recursos de nuvem virtualizados, como computação, rede e armazenamento de dados, são criados e implantados.

- Há duas camadas principais de infraestrutura na computação em nuvem:

    - A computação física e lógica (CPU, memória, etc), as redes e o armazenamento são combinados para criar uma nuvem.
    - A infraestrutura virtual gerenciada por um usuário da nuvem, ou seja, a computação, a rede e os recursos de armazenamento que eles acessam nos pools de recursos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de infraestrutura (cont.)

- Devido à natureza da computação em nuvem, as medidas tradicionais de segurança de infraestrutura baseadas no controle de caminhos físicos de comunicação e inserção de dispositivos de segurança não funcionam.

- Ferramentas de segurança de nuvem personalizadas incluem dispositivos virtuais e agentes de software que são usados para proteger ambientes virtuais. No entanto, essas ferramentas podem apresentar gargalos ao acessar recursos ou levar à sobrecarga do processador. Portanto, o uso de dispositivos virtuais deve ser cuidadosamente avaliado e implantado.

- As redes definidas por software (SDN) permitem novos tipos de controles de segurança e proporcionam um ganho geral para a segurança de rede, incluindo:

    - Fácil isolamento de rede sem restrições de hardware físico
    - Firewalls SDN (grupos de segurança em computação em nuvem) aplicados a ativos com base em critérios mais flexíveis do que os firewalls de hardware

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Responsabilidades de segurança na nuvem

- A computação em nuvem envolve clientes e provedores de serviços de nuvem (CSPs). Portanto, a segurança da nuvem funciona em um modelo de responsabilidade compartilhada.

- Um CSP é responsável pelos serviços em nuvem para o cliente, mas o cliente é responsável pelo restante dos serviços. O compartilhamento de responsabilidades varia de acordo com o tipo de implantação da nuvem.

- A tabela a seguir exibe a responsabilidade de implementação de segurança entre um cliente e um CSP em diferentes modelos de serviço em nuvem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Responsabilidades de segurança na nuvem (cont.)

A tabela a seguir exibe a responsabilidade de implementação de segurança entre um cliente e um CSP em diferentes modelos de serviço em nuvem.

Responsabilidade de Segurança	No local	Iaas	PaaS	SaaS
Dados	Cliente	Cliente	Cliente	Cliente
Endpoints	Cliente	Cliente	Cliente	Compartilhado
Gerenciamento de identidades	Cliente	Cliente	Compartilhado	Compartilhado
Aplicação	Cliente	Cliente	Compartilhado	CSP
Controle de rede	Cliente	Cliente	Compartilhado	CSP
Sistema Operacional	Cliente	Cliente	CSP	CSP
Infraestrutura física	Cliente	CSP	CSP	CSP

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Outras considerações de segurança de infraestrutura de nuvem

Políticas de segurança da empresa

- Uma empresa pode permitir que os usuários baixem ferramentas de software desconhecidas.
- Aplicativos não sancionados podem aumentar a produtividade dos funcionários, permitindo que eles baixem e usem suas ferramentas de software favoritas.
- Aplicativos não monitorados podem criar falhas de segurança e pontos cegos.
- Políticas de segurança da empresa estabelecidas e bem definidas e conscientização dos usuários são formas eficazes de gerenciar aplicativos desconhecidos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Outras considerações sobre segurança da infraestrutura na nuvem (cont.)

Segurança em camadas

- Os recursos de nuvem podem ser visualizados em quatro camadas: camadas de hardware, infraestrutura, plataforma e aplicações. Estratégias de defesa em profundidade podem ser aplicadas a cada uma dessas camadas.

- Algumas opções de segurança em camadas são:
  - As plataformas de nuvem normalmente têm segurança integrada na plataforma para proteger os recursos de nuvem do cliente. Por exemplo, alguns CSPs fornecem serviço de DDoS integrado que os clientes não precisam configurar.
  - Uma nuvem privada virtual aloca sub-redes privadas que são logicamente isoladas da Internet.
  - Embora os clientes não tenham acesso para configurar dispositivos físicos de firewall, os CSPs normalmente oferecem funções equivalentes de firewall, ou firewalls virtuais, como negar e permitir regras e grupos de segurança de host.
  - Os logs de fluxo são usados para monitorar o tráfego que atravessa as interfaces de rede individuais.
  - As VPNs são usadas para fornecer acesso de usuário remoto aos recursos de nuvem, bem como conexões de site para site usadas em cenários de várias nuvens ou conexões entre uma nuvem e data centers locais.
  - Os serviços de gerenciamento de identidade e acesso (IAM) oferecem gerenciamento de credenciais de usuário e gerenciamento de autenticação e autorização de usuário. O uso adequado do IAM é fundamental para proteger os recursos de nuvem contra abusos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Outras considerações sobre segurança da infraestrutura na nuvem (cont.)

Microssegmentação

- Também conhecida como hipersegregação, a microssegmentação aproveita as topologias de rede virtual para executar redes múltiplas, menores e mais isoladas sem incorrer em custos adicionais de hardware.
- Como as redes são totalmente definidas em software sem muitos dos problemas de endereçamento tradicionais, é muito mais viável executar esses vários ambientes definidos por software.
- As técnicas de microssegmentação permitem um controle mais granular da segurança do tráfego e dos fluxos de trabalho na nuvem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.4 Segurança de Aplicativos em Nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Desenvolvimento de aplicativos (cont.)

Para manter a segurança em todos os estágios do desenvolvimento do aplicativo, o seguinte processo robusto precisa ser seguido.

Desenvolvimento e teste

- O software é desenvolvido e atualizado em um ambiente de desenvolvimento, onde pode ser desenvolvido, testado e depurado antes de ser implantado.
- Um ambiente de desenvolvimento é menos restritivo do que o ambiente ativo e tem um nível de segurança mais baixo.
- O software de controle de versão ajuda a rastrear e gerenciar alterações no código do software.
- Os desenvolvedores também podem trabalhar em um ambiente de sandbox para que o código não seja substituído à medida que o desenvolve.
- Durante o teste, os desenvolvedores analisam como o código interage com o ambiente normal.
    - A garantia de qualidade (QA) pode encontrar falhas no software. É muito mais fácil corrigir qualquer defeito encontrado nessa fase.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Desenvolvimento de aplicações

Provisionamento e desprovisionamento

- Provisionamento é a criação ou atualização de software.
- O desprovisionamento é sua remoção.
- Uma empresa pode usar um portal de autoatendimento para automatizar o desprovisionamento e o provisionamento de software.

Preparo e produção

- Os ambientes de preparação devem corresponder ao ambiente de produção da empresa.
- Ao testar em um ambiente intermediário, os desenvolvedores podem verificar se o software é executado sob as configurações de segurança necessárias.
- Depois que o desenvolvedor executa e testa a segurança, o programa pode ser implantado em produção.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Técnicas de Codificação Segura

Ao codificar aplicativos, os desenvolvedores usam várias técnicas para validar se todos os requisitos de segurança foram atendidos.

A normalização é usada para organizar dados em um banco de dados e ajudar a manter a integridade dos dados. A normalização converte uma sequência de entrada em sua forma mais simples conhecida para garantir que todas as sequências tenham representações binárias exclusivas e que qualquer entrada mal-intencionada seja identificada.

Procedimento armazenado: Um procedimento armazenado é um grupo de instruções SQL pré-compiladas armazenadas em um banco de dados que executam uma tarefa. Se você usar um procedimento armazenado para aceitar parâmetros de entrada de clientes que usam dados de entrada diferentes, reduzirá o tráfego de rede e obterá resultados mais rápidos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Técnicas de codificação segura (cont.)

Ofuscação e camuflagem

Um desenvolvedor pode usar a ofuscação e a camuflagem para impedir que o software seja reprojetado. A ofuscação oculta dados originais com caracteres ou dados aleatórios. A camuflagem substitui os dados confidenciais por dados fictícios realistas.

A reutilização de código significa usar o software atual para criar um novo software, economizando tempo e custos de desenvolvimento. É preciso ter cuidado, no entanto, para evitar a introdução de vulnerabilidades.

SDKs: bibliotecas de terceiros e kits de desenvolvimento de software (SDKs) fornecem um repositório de código útil para tornar o desenvolvimento de aplicativos mais rápido e barato. A desvantagem é que qualquer vulnerabilidade em SDKs ou bibliotecas de terceiros pode afetar muitos aplicativos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Validação de entrada

Controlar o processo de entrada de dados é fundamental para manter a integridade do banco de dados. Muitos ataques são executados em um banco de dados e inserem dados malformados.O ataque pode confundir, falhar ou fazer com que o aplicativo divulgue informações demais para o invasor.

Exemplo de ataque de entrada automatizado:

- Por exemplo, os usuários preenchem um formulário usando um aplicativo da Web para assinar uma newsletter.
- Um aplicativo de banco de dados gera e envia automaticamente confirmações por e-mail para os clientes.
- Quando os usuários recebem as confirmações de e-mail com um link URL, para confirmar a assinatura, os invasores modificam o link URL.
- Essas modificações podem alterar o nome de usuário, o endereço de e-mail ou o status da assinatura dos clientes quando eles clicam para confirmar a assinatura.
- Os hackers podem automatizar o ataque para inundar o aplicativo da Web com milhares de assinantes inválidos no banco de dados da newsletter.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Sobre as Regras de Validação

Uma regra de validação verifica se os dados estão nos parâmetros definidos pelo projetista de banco de dados. Uma regra de validação ajuda a garantir a integridade, a precisão e a consistência dos dados. Os critérios usados na regra de validação incluem o seguinte:

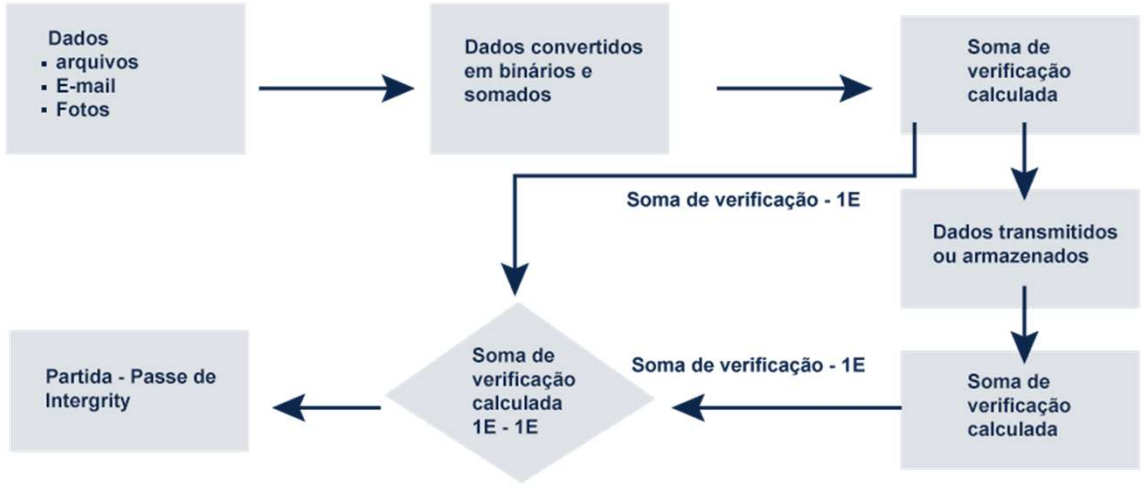
- **Tamanho** – verifica o número de caracteres em um item de dados
- **Formato** – verifica se os dados estão de acordo com um formato**especificado**
- **Consistência** – verifica a consistência dos códigos nos itens de dados relacionados
- **Intervalo** – verifica se os dados estão dentro de valores mínimo e máximo
- **Dígito de verificação** – efetua um cálculo extra para gerar um dígito de verificação para detecção de erros

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificações de integridade

Dados comprometidos podem ameaçar a segurança de seus dispositivos e sistemas.

Uma **verificação de integridade** pode medir a consistência dos dados em um arquivo, imagem ou registro para garantir que eles não tenham sido corrompidos. A verificação de integridade executa uma **função hash** para obter um instantâneo de dados e, em seguida, usa esse instantâneo para garantir que os dados permaneçam inalterados. Um **checksum** é um exemplo de uma função hash.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificações de Integridade (Cont.)

O processo de soma de verificação inclui:

- **Como funciona um Checksum:** Uma soma de verificação verifica a integridade dos arquivos, ou sequências de caracteres, antes e depois de serem transferidos entre dispositivos em uma rede local ou na Internet.
    - As checksum simplesmente convertem cada conjunto de informações para um valor e soma o total.
    - Para testar a integridade de dados, um sistema de recebimento apenas repete o processo.
    - Se as duas somas forem iguais, os dados são válidos.
    - Caso contrário, uma alteração ocorreu em algum lugar ao longo do caminho.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verificações de Integridade (Cont.)

O processo de soma de verificação inclui:

- **Funções de hash:** funções de hash comuns incluem MD5, SHA-1, SHA-256 e SHA-512. Eles usam algoritmos matemáticos complexos para comparardados com um valor de hash.

- **Controle de versão:** as organizações usam o controle de versão para impedir que usuários autorizados façam alterações acidentais. O controle de versão significa que dois usuários não podem atualizar o mesmo objeto, como um arquivo, registro de banco de dados ou transação, ao mesmo tempo.

- **Backups:** backups precisos ajudam a manter a integridade dos dados se os dados forem corrompidos. Uma organização precisa verificar seu processo de backup para garantir a integridade do backup.

- **A autorização** determina quem tem acesso aos recursos da empresa, de acordo com a necessidade de cada um.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Outras práticas de segurança de aplicativos

Como você pode ter certeza de que um software que você está instalando é autêntico ou que as informações são seguras ao navegar na Internet?

- **A assinatura** de código ajuda a provar que um software é autêntico.
  - Os executáveis projetados para instalar e executar em um dispositivo são assinados digitalmente para validar a identidade do autor e fornecer garantia de que o código de software não foi alterado desde que foi assinado.

- **Cookies seguros:** o uso de cookies seguros protege as informações armazenadas nos cookies contra hackers.
  - Quando seu sistema cliente interage com um servidor, o servidor envia uma resposta HTTP que instrui seu navegador a criar pelo menos um cookie.
  - O cookie armazena dados para solicitações futuras enquanto você estiver navegando no site.
  - Os desenvolvedores da Web devem usar cookies com HTTPS para proteger os cookies e impedir que eles sejam transmitidos por HTTP não criptografado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Segurança de Aplicações em Nuvem

Laboratório - Recomendar uma solução de segurança para nuvem

Neste laboratório, você completará os seguintes objetivos:

- Parte 1: Pesquisar e recomendar um modelo de nuvem e um modelo de serviço em nuvem
- Parte 2: Identificar a responsabilidade compartilhada por serviços em nuvem e segurança na nuvem
- Parte 3: Identificar cinco ameaças de segurança relacionadas à computação em nuvem
- Parte 4: Identifique cinco medidas de segurança para implantar o comércio eletrônico na nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.5 Segurança de Dados na Nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estados dos dados

Os Estados do Data Domain descrevem controles relacionados à proteção dos dados, dos quais criptografia e hash são os mais importantes.

Os dados do cliente devem ser protegidos nos três estados a seguir:

- **Dados** em repouso: refere-se aos dados que estão armazenados.
  - Os dados estão nesse estado quando nenhum usuário ou processo os acessa, solicita ou altera.
  - Os dados inativos podem ser armazenados em dispositivos locais, como um disco rígido em um computador ou uma rede centralizada, como um servidor da empresa.
  - Na computação em nuvem, os dados inativos podem ser armazenados em uma nuvem e podem ser acessados em qualquer computador conectado à Internet, geralmente com assinatura.
  - Todos os dados que não estão em trânsito nem em andamento são considerados dados inativos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estados de dados (cont.)

- **Dados em trânsito:** Refere-se aos dados que estão sendo transmitidos.
  - Os dados não estão em repouso, nem estão sendo processados.
  - A transmissão pode ocorrer em um único servidor ao longo das linhas de barramento da placa-mãe, entre dispositivos em uma única rede ou entre redes e, possivelmente, através da Internet.
  - Usar a criptografia e o hash para proteger dados em trânsito é essencial para a computação em nuvem.

- **Dados em processo:** refere-se aos dados durante a entrada inicial, modificação, computação ou saída.
  - Os dados estão nesse estado quando não estão em trânsito nem em repouso.
  - São dados que estão sendo processados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Criptografia

- **A criptografia** é a ciência de criar e quebrar códigos.
  - Ao armazenar e transmitir dados criptografados, apenas o destinatário pretendido pode lê-los ou processá-los e somente se eles tiverem o conhecimento adequado do segredo usado no algoritmo de criptografia.

- **A encriptação** é o processo de embaralhamento de dados para impedir que uma pessoa não autorizada leia os dados com facilidade.
  - Ao habilitar a encriptação, os dados legíveis são chamados de texto simples ou texto claro, enquanto a versão criptografada é chamada de texto criptografado ou texto cifrado.
  - A criptografia converte a mensagem legível de texto claro em texto codificado, que é a mensagem ilegível disfarçada. A descriptografia reverte o processo.
  - A encriptação também precisa de uma chave, que desempenha um papel crítico para criptografar e descriptografar uma mensagem. A pessoa que possui a chave pode descriptografar o texto codificado para texto claro.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Criptografia (cont.)

Há duas classes de algoritmos de criptografia:

- **Os algoritmos** simétricos usam a mesma chave pré-compartilhada para criptografar e descriptografar dados, um método também conhecido como criptografia com chave privada.
  - O Advanced Encryption Standard (AES) é um algoritmo de criptografia simétrica que possui um tamanho de bloco fixo de 128 bits com um tamanho de chave de 128, 192 ou 256 bits.
  - O governo norte-americano usa o AES para proteger as informações confidenciais.

- **A criptografia assimétrica**, também chamada de criptografia de chave pública, utiliza uma chave de criptografia que é diferente da chave usada para descriptografia .
  - Os algoritmos de criptografia assimétrica incluem Rivest-Shamir-Adleman (RSA), Diffie-Hellman, EIGamal e Elliptic Curve Cryptography (ECC).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Hashing

- **O hash** é uma ferramenta que garante a integridade dos dados ao considerar dados binários (por exemplo, uma mensagem) e produzir uma representação de comprimento fixo chamada de valor de hash (por exemplo, um message digest).

- **Hashes** são usados para verificar e garantir a integridade dos dados.
  - A ferramenta de hash também pode verificar a autenticação.
  - Ele funciona usando uma função de hash criptográfico para substituir senhas de texto simples ou chaves de criptografia.
  - Uma função hash criptográfica tem as seguintes propriedades:
    - A entrada pode ser de qualquer comprimento.
    - A saída tem um comprimento fixo.
    - A função hash é unidirecional e não é reversível.
    - Dois valores de entrada diferentes quase nunca resultarão no mesmo hash.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.6 Proteção de VMs

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protegendo máquinas virtuais

- Máquinas virtuais (VMs ou instâncias de VM), como um computador físico, exigem correções, atualizações e medidas antimalware para protegê-las contra ameaças externas.

- A nuvem oferece opções de segurança adicionais, dependendo das ferramentas específicas disponíveis em uma plataforma de nuvem, para proteger as VMs, incluindo:

  Planeje o posicionamento da sub-rede: Escolha cuidadosamente a sub-rede para cada instância para que ela tenha apenas o acesso necessário ao mundo externo.

  Desabilitar portas e serviços desnecessários: Habilite apenas portas e serviços necessários para reduzir a exposição desnecessária ao exterior.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protegendo máquinas virtuais (cont.)

Aplicar gerenciamento e políticas de contas: O sistema operacional em uma VM tem contas de usuário padrão.Desative todas as contas de usuário padrão e crie contas de usuário com políticas de gerenciamento de conta de práticas recomendadas, como complexidade de senha e acesso com menos privilégios.

Instale software antivírus/antimalware e mantenha-o atualizado: Isso pode ser feito por meio do sistema operacional da VM ou pode estar disponível como um serviço na plataforma de nuvem.

Instalar firewall baseado em host/software e IDP/IPS: Isso pode ser feito por meio do sistema operacional da VM ou pode estar disponível como um serviço da plataforma de nuvem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protegendo VMs contra ataques de expansão de VM

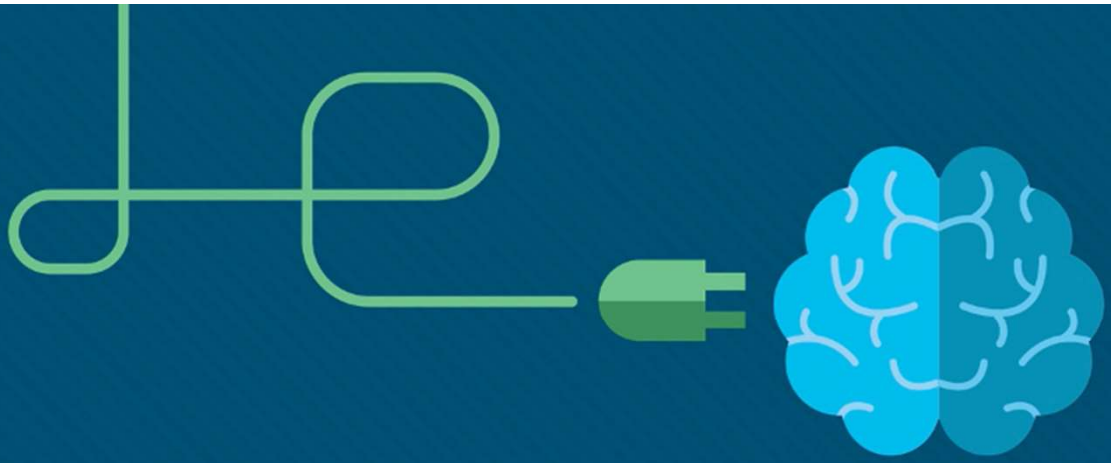
- Criar instâncias de VM em uma nuvem é um processo relativamente fácil.
  - Isso pode levar a um problema de expansão de VM, em que uma organização tem muitas instâncias de VM que não são gerenciadas adequadamente.
  - Se essas instâncias em execução não forem monitoradas e mantidas, elas poderão se tornar desatualizadas e vulneráveis a ataques.

- Um cliente de computação em nuvem deve implementar políticas para registrar e auditar os recursos de nuvem que estão sendo usados.
  - A expansão de VM não apenas apresenta riscos potenciais, mas também consome serviços em nuvem desnecessariamente, como instâncias de VM, armazenamento e endereços IP públicos não atribuídos.
  - Ao registrar o uso de recursos de nuvem, monitorar as VMs em execução e auditar o uso real, uma empresa pode gerenciar e proteger melhor as VMs de que realmente precisa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

7.7 Resumo de Segurança em Nuvem

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 8: Criptografia



Defesa de rede

Objetivos do Módulo

Título do Módulo: Criptografia

Objetivo do Módulo: Explicar como usar as ferramentas de hash.

Título do Tópico	Objetivo do Tópico
Confidencialidade.	Determinar o algoritmo de criptografia a ser usado de acordo com os requisitos.
Ocultação de dados	Usar uma técnica para ocultar os dados.
Integridade e Autenticidade	Explique a função da criptografia para garantir a integridade e autenticidade dos dados.
Usando Hashes	Use ferramentas de hash para fazer o hash de um arquivo de texto e verificar a integridade de um arquivo diferente.
Criptografia de chave pública	Usar uma assinatura digital.
Autoridades e o Sistema de Confiança PKI	Usar o hash para detectar a interceptação de rede.
Aplicações e impactos da criptografia	Explicar como o uso da criptografia afeta as operações de segurança cibernética.

8.1 Confidencialidade.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade dos dados

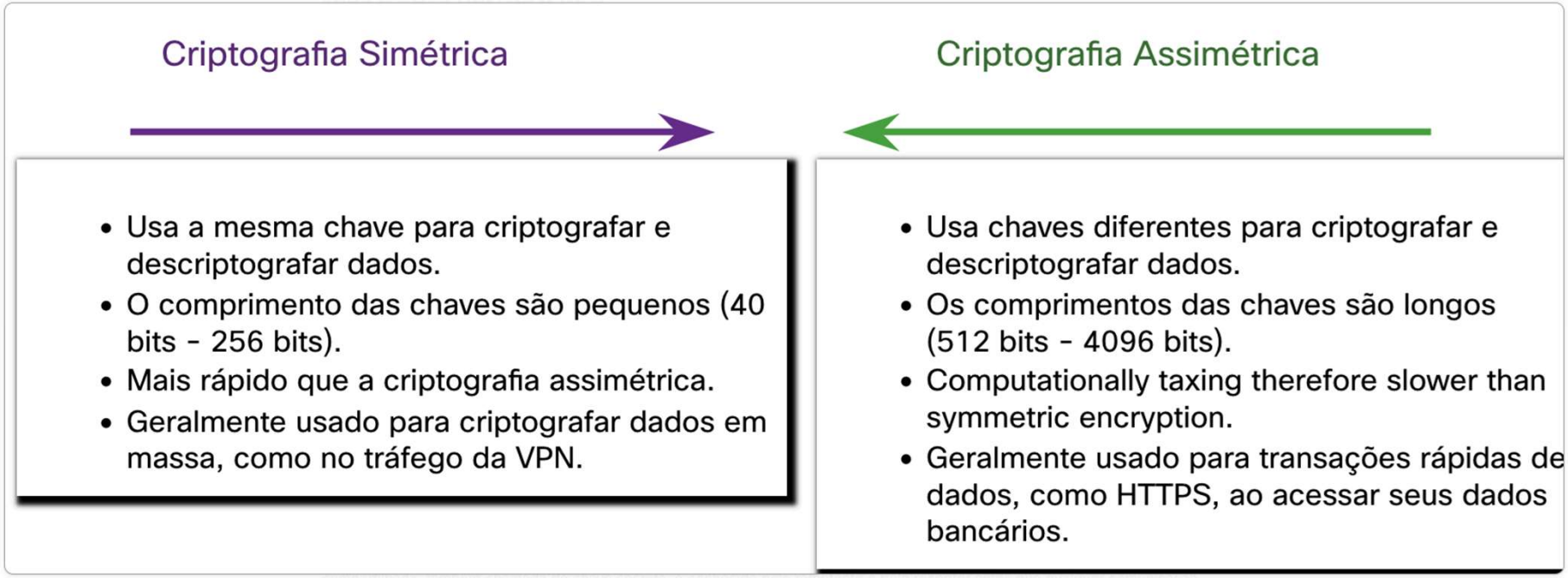
- Existem duas classes de criptografia usadas para fornecer confidencialidade de dados; assimétrico e simétrico.
- Essas duas classes diferem na maneira como usam as chaves.
- Algoritmos de criptografia simétrica, como Data Encryption Standard (DES), 3DES e Advanced Encryption Standard (AES), baseiam-se na premissa de que cada parte que se comunica conhece a chave pré-compartilhada.
- A confidencialidade dos dados também pode ser garantida usando algoritmos assimétricos, incluindo Rivest, Shamir e Adleman (RSA) e a infraestrutura de chave pública (PKI).

Nota: O DES é um algoritmo legado e não deve ser usado. 3DES deve ser evitado, se possível.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade dos dados (Cont.)

- A figura destaca algumas diferenças entre criptografia simétrica e assimétrica.

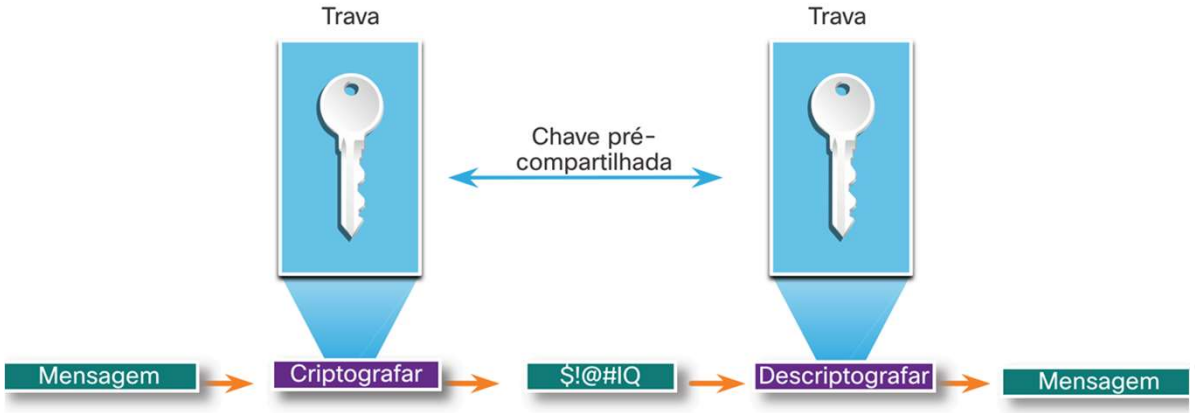


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Criptografia Simétrica

- Os algoritmos simétricos usam a mesma chave pré-compartilhada para criptografar e decriptografar dados.
- Uma chave pré-compartilhada (chave secreta) é conhecida pelo remetente e pelo receptor antes que qualquer comunicação criptografada possa ocorrer.
- Algoritmos de criptografia simétrica são comumente usados com tráfego VPN, porque usam menos recursos de CPU do que algoritmos de criptografia assimétrica, permitindo que a criptografia e decriptografia de dados sejam rápidas ao usar uma VPN.
- Ao usar algoritmos de criptografia simétrica, como qualquer outro tipo de criptografia, quanto maior a chave, mais tempo levará para alguém descobrir a chave.
- A maioria das chaves de criptografia tem entre 112 e 256 bits, mas para garantir que a criptografia seja segura, um comprimento mínimo de chave de 128 bits deve ser usado.

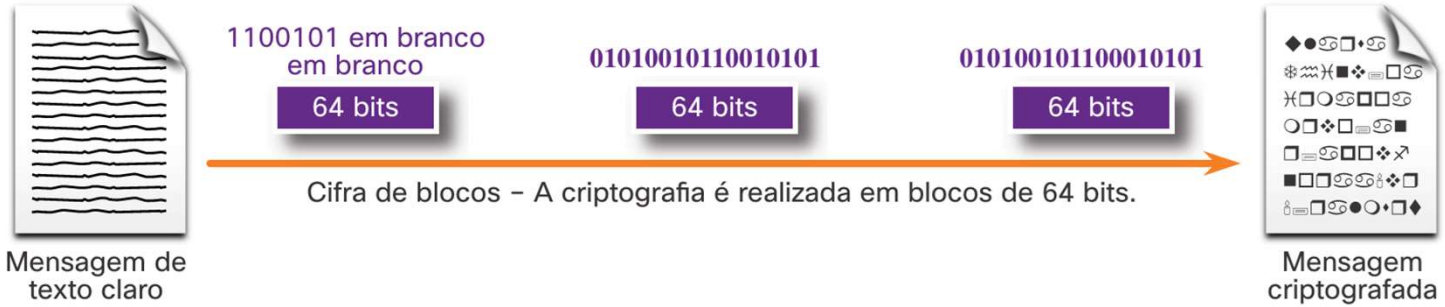


direitos reservados. Documento confidencial da Cisco

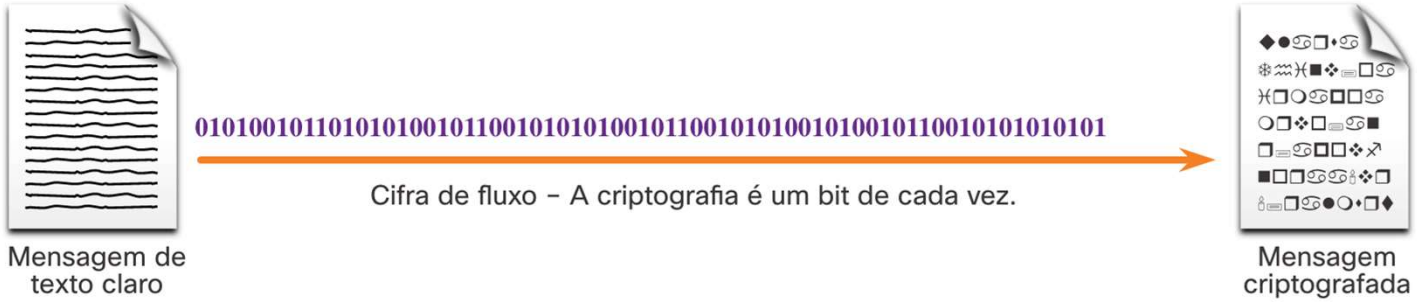
Criptografia Simétrica (Cont.)

Algoritmos de criptografia simétrica às vezes são classificados como uma cifra de bloco ou uma cifra de fluxo.

- **As cifras de bloco** transformam um bloco de texto simples de comprimento fixo em um bloco comum de texto cifrado de 64 ou 128 bits.



- **As cifras de fluxo** criptografam o texto sem formatação um byte ou um bit por vez e geralmente são mais rápidas do que as cifras de bloco porque os dados são criptografados continuamente.



Confidencialidade

Criptografia Simétrica (Cont.)

Algoritmos de criptografia simétrica mais conhecidos são descritos na tabela.

Algoritmos de criptografia simétrica	Descrição
Padrão de criptografia de dados (DES)	Um algoritmo de criptografia simétrica legado. Ele usa um comprimento de chave curto que o torna inseguro para a maioria dos usos atuais.
3DES (Triple DES)	O substituto do DES e repete o processo do algoritmo DES três vezes. Deve ser evitado, se possível, uma vez que está programado para ser aposentado em 2023. Se implementado, use durações de chave muito curtas.
AES (Advanced Encryption Standard)	Um algoritmo de criptografia simétrica popular e recomendado. Ele oferece combinações de chaves de 128, 192 ou 256 bits para criptografar blocos de dados de 128, 192 ou 256 bits.
Software-Optimized Encryption Algorithm (SEAL)	Alternativa mais rápida de algoritmo de criptografia simétrica para AES. É uma cifra de fluxo que usa uma chave de criptografia de 160 bits e tem um impacto menor na CPU em comparação com outros algoritmos baseados em software.
Algoritmos da série Rivest ciphers (RC)	Diversas variações foram desenvolvidas, mas o RC4 foi o mais prevalente em uso. RC4 é uma cifra de fluxo usada para proteger o tráfego da web. Verificou-se que tem múltiplas vulnerabilidades que o tornaram inseguro. O RC4 não deve ser utilizado.

Confidencialidade

Criptografia Assimétrica

- Algoritmos assimétricos (algoritmos de chave pública) são projetados para que a chave usada para criptografia seja diferente da chave usada para decriptografia.
- A chave de decriptografia não pode, em uma quantidade razoável de tempo, ser calculada a partir da chave de criptografia e vice-versa.



- Algoritmos assimétricos usam uma chave pública e uma chave privada, e ambas as chaves são capazes do processo de criptografia, mas a chave emparelhada complementar é necessária para a decriptografia.
- O processo também é reversível, portanto, os dados criptografados com a chave pública requerem a chave privada para serem decriptografados.
- Algoritmos assimétricos alcançam confidencialidade e autenticidade usando este processo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Criptografia Assimétrica (Cont.)

- A criptografia assimétrica pode usar comprimentos de chave entre 512 e 4.096 bits.

- Comprimentos de chave maiores ou iguais a 2.048 bits podem ser confiáveis, enquanto comprimentos de chave de 1.024 ou menores são considerados insuficientes.

- Exemplos de protocolos que usam algoritmos de chave assimétrica incluem:
  - **Internet Key Exchange (IKE)** -Componente fundamental das VPNs IPsec.
  - **Secure Socket Layer (SSL)** - Ele é implementado agora como padrão IETF Transport Layer Security (TLS)
  - **Secure Shell (SSH)** - Ele fornece uma conexão segura de acesso remoto a dispositivos de rede.
  - **Pretty Good Privacy (PGP)** - Ele fornece privacidade e autenticação criptográficas.

- Os algoritmos assimétricos são substancialmente mais lentos do que os algoritmos simétricos, por isso são normalmente usados em mecanismos criptográficos de baixo volume, como assinaturas digitais e troca de chaves.

- No entanto, o gerenciamento de chaves de algoritmos assimétricos tende a ser mais simples que os algoritmos simétricos, porque geralmente uma das duas chaves de criptografia ou decriptografia pode ser tornada pública.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Criptografia Assimétrica (Cont.)

Algoritmo de criptografia assimétrica	comprimento da chave	Descrição
Diffie-Hellman (DH)	512, 1024, 2048, 3072, 4096	Este permite que duas partes concordem sobre uma chave que podem usar para criptografar as mensagens que desejam enviar uma para a outra. A segurança desse algoritmo depende da suposição de que é fácil aumentar um número para uma determinada potência, mas difícil calcular qual potência foi usada, dado o número e o resultado.
Padrão de Assinatura Digital (DSS) e Algoritmo de Assinatura Digital (DSA)	512 - 1024	O DSS especifica o DSA como o algoritmo para assinaturas digitais. DSA é um algoritmo de chave pública baseado no esquema de assinatura ElGamal. A velocidade de criação de assinatura é como RSA, mas é 10 a 40 vezes mais lenta para verificação.
Algoritmos de criptografia Rivest, Shamir e Adleman (RSA)	512 até 2048	RSA é para criptografia de chave pública com base na dificuldade atual de fatorar números muito grandes. Acredita-se que seja seguro, com chaves suficientemente longas e o uso de implementações atualizadas.
ElGamal	512 - 1024	Usado para criptografia de chave pública com base no contrato de chave DH. Sua desvantagem é que a mensagem cifrada fica muito grande, cerca de duas vezes o tamanho da mensagem original e por isso só é utilizada para mensagens pequenas tais como chaves secretas.
Técnicas de curva elíptica	224 ou superior	Ele pode ser usado para adaptar muitos algoritmos criptográficos (DH ou ElGamal).

Criptografia Assimétrica - Confidencialidade

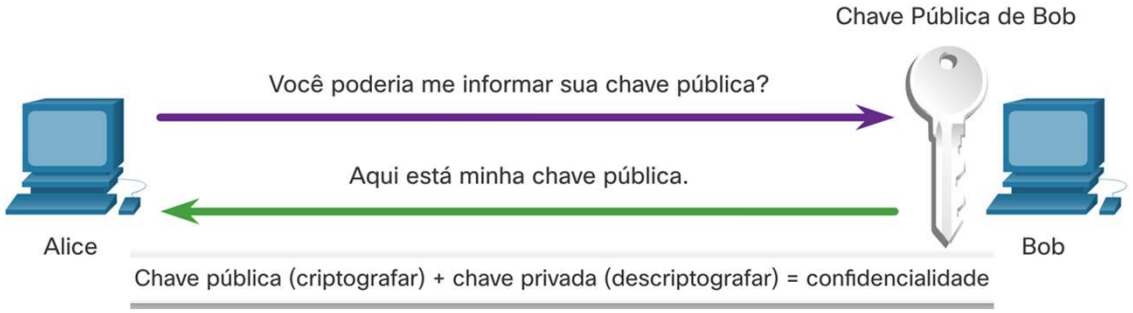
- Algoritmos assimétricos são usados para fornecer confidencialidade sem pré-compartilhar uma senha.
- O objetivo de confidencialidade é iniciado quando o processo de criptografia é iniciado com a chave pública.
- O processo pode ser resumido usando a fórmula:

Chave pública (criptografar) + chave privada (decriptografar) = confidencialidade

- Quando a chave pública é usada para criptografar os dados, a chave privada deve ser usada para decriptografar os dados.
- Apenas um host tem a chave privada; portanto, a confidencialidade é alcançada.
- Se a chave privada estiver comprometida, outro par de chaves deve ser gerado para substituir a chave comprometida.

Exemplo: Bob e Alice Trocam Dados - Confidencialidade

- Alice solicita e obtém a chave pública de Bob.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

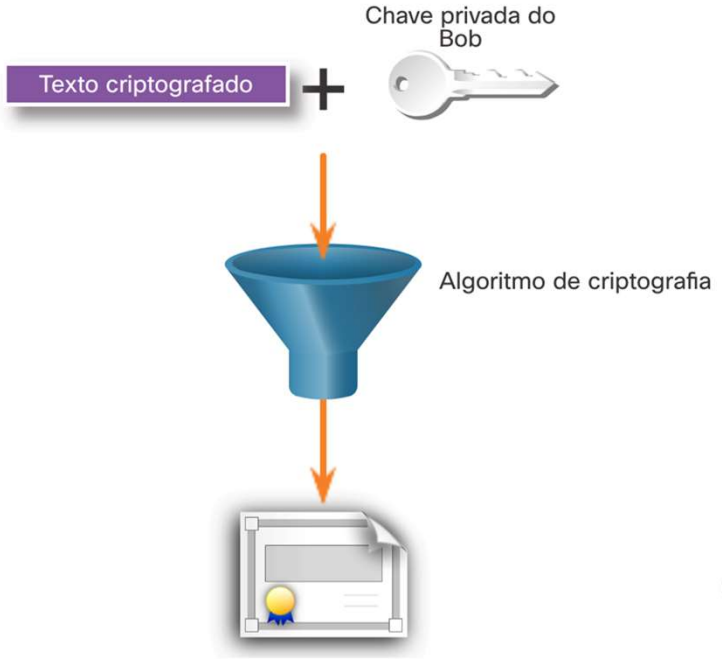
Criptografia Assimétrica -Confidencialidade (Cont.)

Exemplo: Bob e Alice Trocam Dados - Confidencialidade

- Alice usa a chave pública de Bob para criptografar uma mensagem usando um algoritmo acordado.
- Alice envia a mensagem criptografada para Bob.



- Bob então usa sua chave privada para decriptografar a mensagem.
- Como Bob é o único com a chave privada, a mensagem de Alice só pode ser decriptografada por Bob e, portanto, a confidencialidade é alcançada.



Criptografia Assimétrica - Autenticação

- O objetivo de autenticação de algoritmos assimétricos é iniciado quando o processo de criptografia é iniciado com a chave privada.
- O processo pode ser resumido usando a fórmula:

Chave Privada (criptografar) + Chave Pública (decriptografar) = Autenticação

- Quando a chave privada é usada para criptografar os dados, a chave pública correspondente deve ser usada para decriptografar os dados.
- Apenas um host possui a chave privada, portanto, apenas esse host poderia ter criptografado a mensagem, fornecendo autenticação do remetente.
- Quando um host decriptografa uma mensagem com êxito usando uma chave pública, é confiável que a chave privada criptografou a mensagem, o que verifica quem é o remetente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

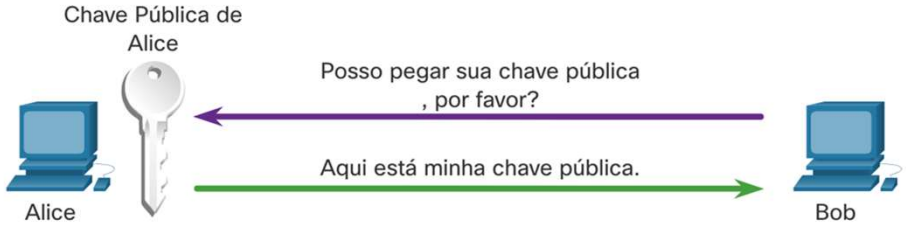
Criptografia Assimétrica -Autenticação (Cont.)

Exemplo: Bob e Alice Trocam Dados - Autenticação

- Alice criptografa uma mensagem usando sua chave privada.
- Alice envia a mensagem criptografada para Bob.
- Bob precisa autenticar que a mensagem realmente veio de Alice.

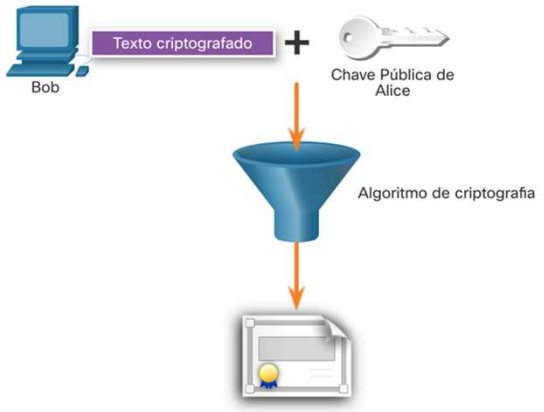


Chave privada (criptografar) + chave pública (descriptografar) = autenticação



- Bob solicita a chave pública de Alice para autenticar a mensagem.

Bob precisa verificar se a mensagem realmente veio de Alice. Ele solicita e adquire a chave pública de Alice.



- Bob usa a chave pública de Alice para descriptografar a mensagem.

Bob usa a chave pública para descriptografar a mensagem com sucesso e autenticar que a mensagem veio, de fato, de Alice.

© 2020 Cisco e/ou su

Criptografia assimétrica - integridade

- Combinar os dois processos de criptografia assimétrica fornece confidencialidade, autenticação e integridade da mensagem.
- Neste exemplo, uma mensagem será cifrada usando a chave pública de Bob e um hash cifrado será criptografado usando a chave privada de Alice para fornecer confidencialidade, autenticidade e integridade.

Exemplo: Bob e Alice Trocam Dados - Integridade

- Alice quer enviar uma mensagem para Bob assegurando que só Bob pode ler o documento.
- Alice quer garantir a confidencialidade da mensagem.
- Alice usa a chave pública de Bob para cifrar a mensagem.
- Só Bob será capaz de decifrá-lo usando sua chave privada.

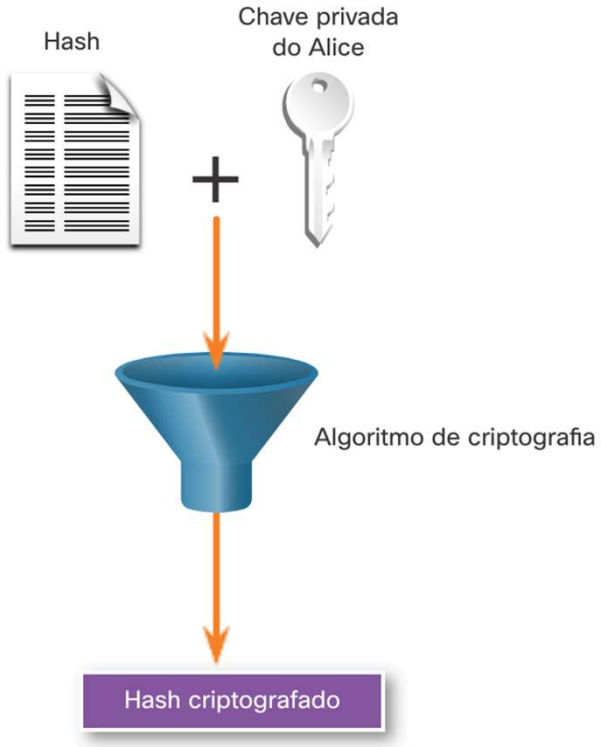


© 2020

Criptografia assimétrica -Integridade (Cont.)

Exemplo: Bob e Alice Trocam Dados - Integridade

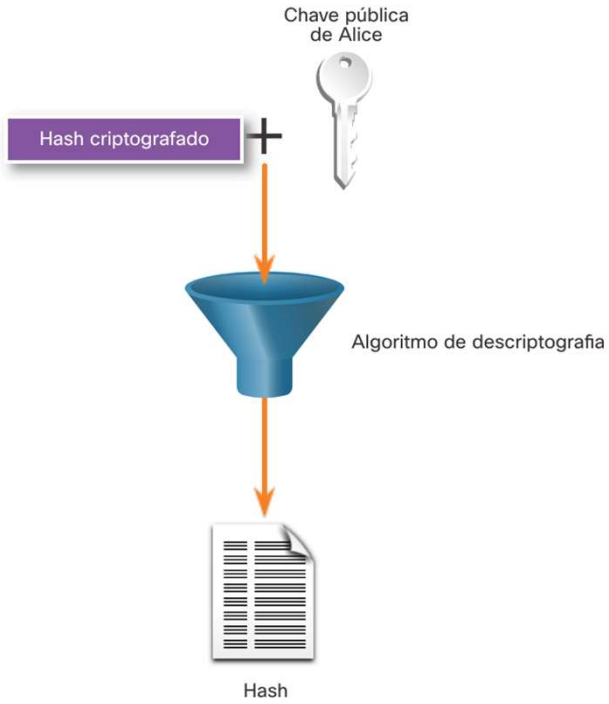
- Alice também quer garantir a autenticação e integridade da mensagem.
- A autenticação garante ao Bob que o documento foi enviado por Alice, e a integridade garante que ele não foi modificado.
- Alice usa sua chave privada para cifrar um hash da mensagem.
- Alice envia a mensagem criptografada com seu hash criptografado para Bob.



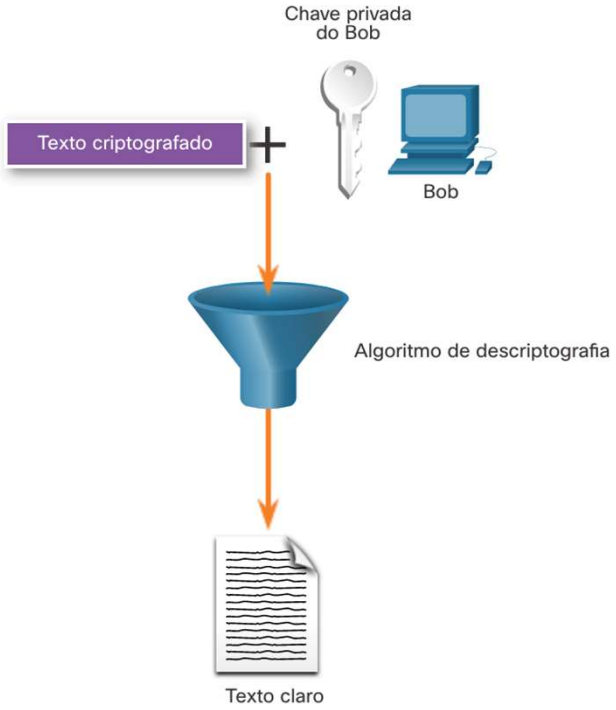
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Criptografia assimétrica -Integridade (Cont.)

Exemplo: Bob e Alice Trocam Dados - Integridade



- Bob usa a chave pública de Alice para verificar se a mensagem não foi modificada.
- O hash recebido é igual ao hash determinado localmente com base na chave pública de Alice.
- Isso verifica se Alice é o remetente da mensagem porque ninguém mais tem a chave privada de Alice.



- Bob usa sua chave privada para decifrar a mensagem.

© 2020 Cisco e/ou suas af

Confidencialidade

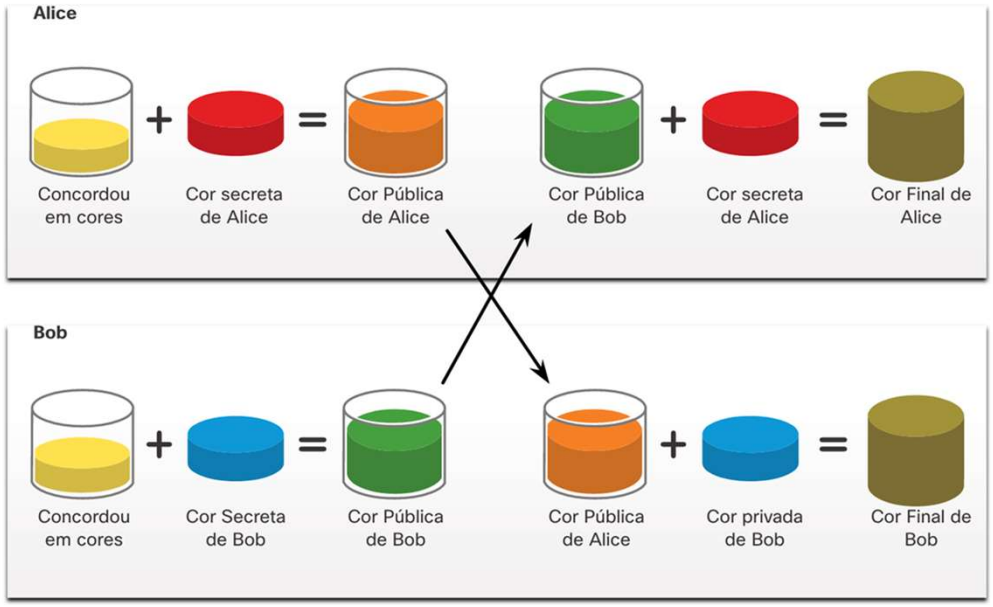
Diffie-Hellman

- Um algoritmo matemático assimétrico que permite que dois computadores gerem um segredo compartilhado idêntico, sem terem se comunicado antes.
- A nova chave compartilhada nunca é realmente trocada entre o remetente e o destinatário.
- No entanto, como as duas partes o conhecem, a chave pode ser usada por um algoritmo de criptografia para criptografar o tráfego entre os dois sistemas.
- Aqui estão dois exemplos de casos em que DH é comumente usado:
  - Dados são trocados usando uma VPN IPsec
  - Dados SSH são trocados

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Diffie-Hellman (Cont.)

As cores na figura serão usadas em vez de números longos complexos para simplificar o processo de contrato de chave DH.



- A troca de chaves DH começa com Alice e Bob concordando com uma cor comum arbitrária que não precisa ser mantida em segredo.(amarelo)
- As cores secretas escolhidas para nunca serem compartilhadas (Alice-vermelha, Bob-azul) representam a chave privada de cada parte.
- Alice irá misturar a cor comum compartilhada (amarelo) com sua cor vermelha para produzir uma cor pública laranja. Bob irá misturar o amarelo e o azul para produzir uma cor pública verde.
- Alice envia sua cor pública (laranja) para Bob e Bob envia sua cor pública (verde) para Alice.
- Alice e Bob misturam a cor que receberam com a sua própria cor secreta original (vermelho para Alice e azul para Bob). O resultado é uma mistura final de cor marrom que é idêntica à mistura de cor final do parceiro.
- A cor marrom representa a chave secreta compartilhada resultante entre Bob e Alice.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Diffie-Hellman (Cont.)

- A segurança do DH usa números muito grandes em seus cálculos.
- Diffie-Hellman usa diferentes grupos DH para determinar a força da chave que é usada no processo de acordo de chave.
- Os números de grupo mais altos são mais seguros, mas requerem mais tempo para calcular a chave.
- O seguinte identifica os grupos DH suportados pelo Cisco IOS Software e seu valor de número primo associado:
    - Grupo DH 1:768 bits
    - Grupo DH 2:1024 bits
    - Grupo DH 5:1536 bits
    - Grupo DH 14:2048 bits
    - Grupo DH 15:3072 bits
    - Grupo DH 16:4096 bits

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Laboratório - Use algoritmos de criptografia clássica e moderna

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Use um algoritmo de criptografia clássica
  - Parte 2: Use um algoritmo de criptografia simétrica moderna
  - Parte 3: Use um algoritmo de criptografia assimétrica moderna

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Laboratório - Criptografando e decriptografando dados usando OpenSSL

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Criptografando mensagens com OpenSSL
  - Parte 2: Decriptografando mensagens com OpenSSL

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Laboratório - Criptografando e decriptografando dados usando uma ferramenta de hacker

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Criar e criptografar arquivos
  - Parte 2: Recuperar senhas de arquivo zip criptografado

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Laboratório - Como Examinar Telnet e SSH com o Wireshark

- Nesse laboratório, você completará os seguintes objetivos:
  - Examinar uma Sessão Telnet com o Wireshark
  - Examinar uma Sessão SSH com o Wireshark

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Confidencialidade

Laboratório - Determinar o algoritmo de criptografia a ser usado

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Proteção de dados pessoais
  - Parte 2: Proteger dados sem fio
  - Parte 3: Proteção de dados corporativos entre sites

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.2 Ocultação de dados

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Técnicas de mascaramento de dados

- A tecnologia de mascaramento de dados protege dados, substituindo as informações confidenciais por uma versão pública.
- A versão não confidencial parece e atua como o original para que um processo organizacional possa usar dados não confidenciais sem nenhuma mudança necessária para as aplicações de suporte ou instalações de armazenamento de dados.
- No caso de uso mais comum, o mascaramento limita a propagação de dados sensíveis dentro de sistemas de TI, ao distribuir conjuntos de dados substitutos para teste e análise.
- As informações podem ser mascaradas dinamicamente, se o sistema ou aplicativo determinar que uma solicitação de informações confidenciais feita pelo usuário é arriscada.
- O mascaramento de dados pode substituir os dados sensíveis em ambientes não relativos à produção, para proteger as informações principais. Várias técnicas de mascaramento de dados podem ser usadas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ocultação de dados

Técnicas de mascaramento de dados (Cont.)

Todos os métodos abaixo garantem que os dados permaneçam significativos, mas sejam alterados o suficiente para protegê-los.

- **Substituição** troca os dados por valores que parecem autênticos para tornar os registros de dados anônimos.

- **Embaralhamento** origina um conjunto de substituição da mesma coluna de dados que um usuário deseja mascarar.
  - Esta técnica funciona bem para informações financeiras em um banco de dados de teste, por exemplo.

- **Anulação** aplica um valor nulo a um campo específico, que impede totalmente a visibilidade dos dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ocultação de dados

Esteganografia

- A esteganografia esconde dados (uma mensagem) em outro arquivo, como um gráfico, áudio ou outro arquivo de texto.
- A vantagem da esteganografia em relação à criptografia é que a mensagem secreta não atrai atenção especial.
- Ao visualizar o arquivo de forma eletrônica ou impressa, ninguém saberá que uma imagem, na realidade, contém uma mensagem secreta.
- Existem vários componentes envolvidos na ocultação de dados.
  - Primeiro, existem os dados integrados que compõem a mensagem secreta.
  - O texto de capa (ou imagem de capa ou áudio de capa) oculta os dados integrados, produzindo o estego-texto (ou estego-imagem ou estego-áudio).
  - Uma estego-chave (stego-key) controla o processo de ocultação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ocultação de dados

Esteganografia (Cont.)

Técnicas de Esteganografia	Usado para incorporar dados em uma imagem de capa usando bits menos significativos (LSB). Esse método usa os bits de cada pixel na imagem. Um pixel é a unidade básica de cor programável em uma imagem de computador. A cor específica de um pixel é uma mistura de três cores - vermelho, verde e azul (RGB). Três bytes de dados especificam a cor de um pixel (um byte para cada cor). Oito bits compõem um byte , portanto, um sistema de cores de 24 bits usa todos os três bytes. O LSB usa um pouco de cada um dos componentes das cores vermelho, verde e azul. Cada pixel pode armazenar 3 bits.
Esteganografia social	Ele oculta as informações , criando uma saída que pode ser lida de uma certa maneira por alguns para obter a mensagem secreta, com base em regras e/ou definições previamente definidas.Como resultado, aqueles que o visualizam normalmente não verão a mensagem. Os adolescentes nas redes sociais usam essa tática para se comunicar com seus amigos mais próximos, evitando que as outras pessoas, como seus pais, percebam o que a mensagem realmente significa. Indivíduos em países que censuram a mídia também a usam para divulgar suas mensagens, digitando palavras incorretamente de propósito ou fazendo referências obscuras que significam algo para quem sabe. Com efeito, eles se comunicam com públicos diferentes ao mesmo tempo, enviando duas mensagens diferentes: a mensagem aparente e a mensagem secreta.
Detecção	A esteganoanálise é a descoberta de que existem informações ocultas. O objetivo da esteganoanálise é descobrir as informações ocultas. Os padrões na estego-imagem levantam suspeita. Os utilitários de análise do disco podem relatar informações ocultas em clusters não utilizados de dispositivos de armazenamento. Os filtros podem capturar pacotes de dados que contêm informações ocultas nos cabeçalhos dos pacotes. Ambos os métodos usam assinatura de esteganografia Ao comparar uma imagem original à estego-imagem , um analista pode buscar padrões de repetição visual.

Ocultação de dados

Laboratório - Use a esteganografia para ocultar dados

- Neste laboratório, você usará o Steg hide, um programa de esteganografia de código aberto, para ocultar um arquivo de dados dentro de um arquivo de imagem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.3 Integridade e Autenticidade

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Integridade e Autenticidade

Comunicações Seguras

- As organizações devem fornecer suporte para proteger o tráfego interno e externo.

- Os quatro elementos das comunicações seguras:
  - **Integridade de dados** - garante que a mensagem não foi alterada e que alterações nos dados em trânto serão detectadas. A integridade é garantida pela implementação de SHA-2 ou SHA-3. O algoritmo MD5 message digest ainda está em uso, mas ele é inseguro e deve ser evitado.

  - **Autenticação de Origem** - garante que a mensagem não é uma falsificação e realmente vem de quem é declarada. Muitas redes modernas garantem autenticação com algoritmos como código de autenticação de mensagem baseado em hash (HMAC).

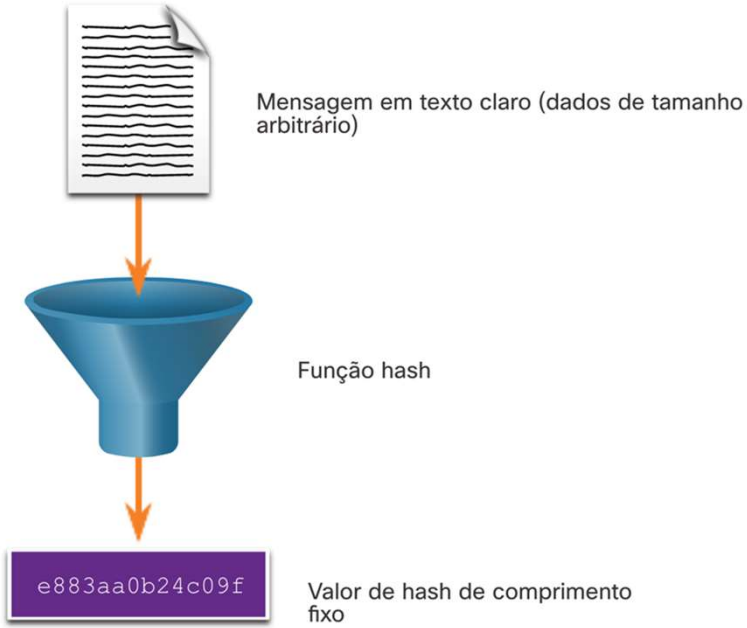
  - **Confidencialidade dos dados** - Garante que apenas usuários autorizados possam ler a mensagem. Se a mensagem for interceptada, ela não poderá ser decifrada dentro de um período de tempo razoável. A confidencialidade dos dados é implementada usando algoritmos de criptografia simétrica e assimétrica.

  - **Não Repúdio de Dados** - Garante que o remetente não pode repudiar ou refutar a validade de uma mensagem enviada. O não repúdio depende do fato de que apenas o remetente possui as características ou a assinatura exclusivas de como essa mensagem é tratada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Funções criptográficas de hash

- Os hashes são usados para verificar e garantir a integridade dos dados e são baseados em uma função matemática unidirecional relativamente fácil de calcular, mas significativamente mais difícil de reverter.
- A função de hash criptográfico também pode ser usada para verificar a autenticação.
- Uma função hash leva um bloco variável de dados binários (mensagem), e produz uma representação condensada de comprimento fixo (hash).
- Com funções hash, é computacionalmente inviável que dois conjuntos diferentes de dados apresentem a mesma saída hash.
- Cada vez que os dados são modificados ou alterados, o valor de hash também muda.
- A função hash criptográfico é aplicada em muitas situações diferentes para autenticação de entidade, integridade de dados e fins de autenticidade de dados.

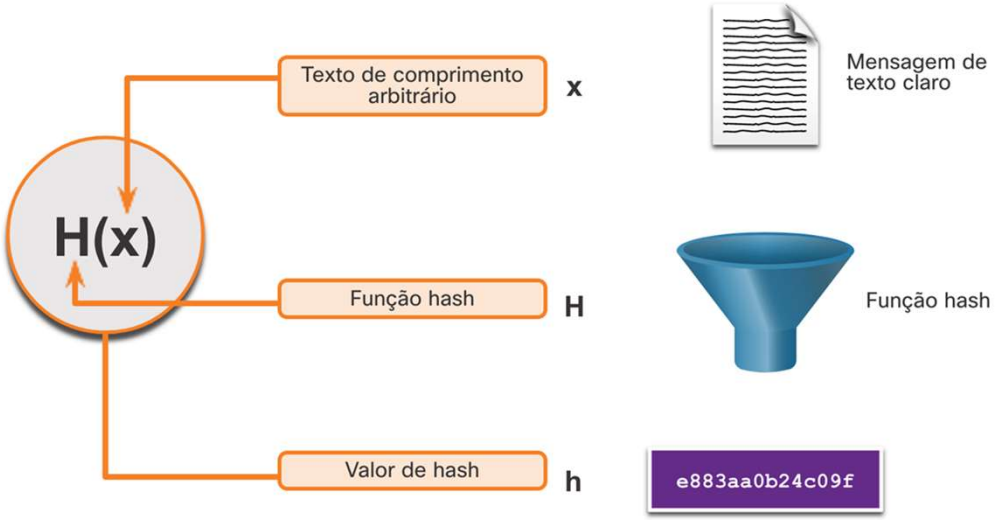


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Operação de hash criptográfico

- Matematicamente, a equação h= H (x)é usada para explicar como um algoritmo de hash opera. Conforme mostrado na figura, uma função de hash H recebe uma entrada x e retorna um valor h.

- Uma função hash criptográfica deve ter as seguintes propriedades:
  - A entrada pode ser de qualquer comprimento.
  - A saída tem um comprimento fixo.
  - H(x) é relativamente fácil de calcular para qualquer x.
  - H (x) é unidirecional e não reversível.
  - H(x) é livre de colisões, o que significa que dois valores de entrada diferentes resultarão em valores de hash diferentes.



- Difícil de inverter (hash unidirecional) significa que, dado um valor de hash h, é computacionalmente inviável encontrar uma entrada para x tal que h=H (x).

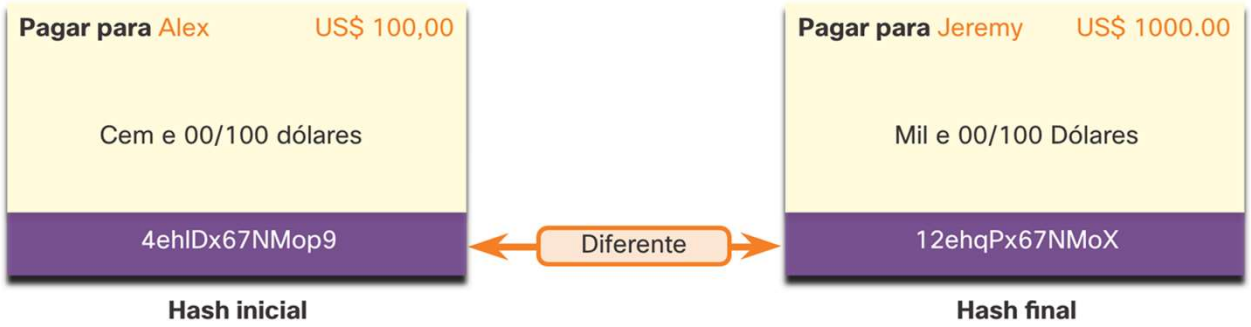
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Integridade e Autenticidade

MD5 e SHA

- As funções de hash são usadas para garantir a integridade da mensagem, para que os dados não sejam alterados acidental ou intencionalmente.
- Alterações deliberadas que são feitas por um agente de ameaça ainda são possíveis.

- Na figura, o remetente está enviando uma transferência de dinheiro de $ 100 para Alex e deseja garantir que a mensagem não seja acidentalmente alterada em seu caminho para o destinatário.



- O hashing pode ser usado para detectar alterações acidentais, mas não pode ser usado para proteger contra alterações deliberadas feitas por um agente de ameaça.

- Portanto, o hash é vulnerável a ataques MiTM e não fornece segurança aos dados transmitidos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

MD5 e SHA (Cont.)

- Existem quatro funções hash bem conhecidas:
  - **MD5 com resumo de 128 bits** - Uma função unidirecional que produz uma mensagem hash de 128 bits. É um algoritmo herdado e deve ser evitado e usado somente quando não houver alternativas melhores disponíveis. Recomenda- se que SHA-2 ou SHA-3 sejam usados em vez disso.

  - **SHA-1** - É muito semelhante às funções hash MD5. Existem várias versões. Ie cria uma mensagem hash de 160 bits e é um pouco mais lento que o MD5. Ele tem falhas conhecidas e é um algoritmo antigo.

  - **SHA-2** - Ele inclui SHA-224 (224 bits), SHA-256 (256 bits), SHA-384 (384 bits) e SHA-512 (512 bits). Se você estiver usando SHA-2, então os algoritmos SHA-256, SHA-384 e SHA-512 devem ser usados sempre que possível.

  - **SHA-3** - O mais novo algoritmo de hash e uma substituição alternativa e eventual para a família SHA-2 de algoritmos de hash. Ele inclui SHA3-224 (224 bits), SHA3-256 (256 bits), SHA3-384 (384 bits) e SHA3-512 (512 bits). A família SHA-3 são algoritmos de última geração e devem ser usados sempre que possível.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Integridade e Autenticidade

Autenticação de Origem

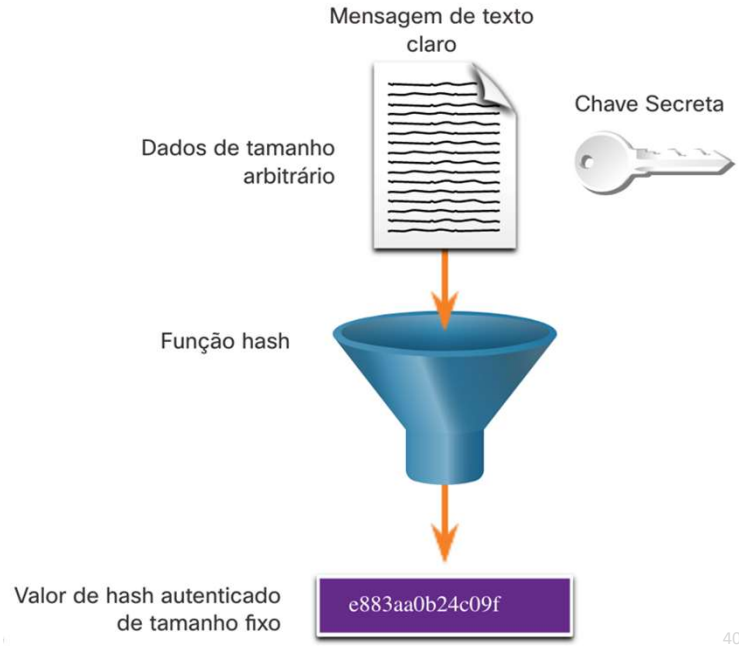
- Use um código de autenticação de mensagem de hash com chave (HMAC) para adicionar autenticação de origem e garantia de integridade.

- HMACs usam uma chave secreta adicional como entrada à função hash.

- **Algoritmo de hash HMAC**
  - O HMAC é calculado usando qualquer algoritmo criptográfico que combina uma função hash criptográfica com uma chave secreta.

  - Somente o remetente e o destinatário têm conhecimento da chave secreta e agora a saída da função hash depende dos dados de entrada e da chave secreta.

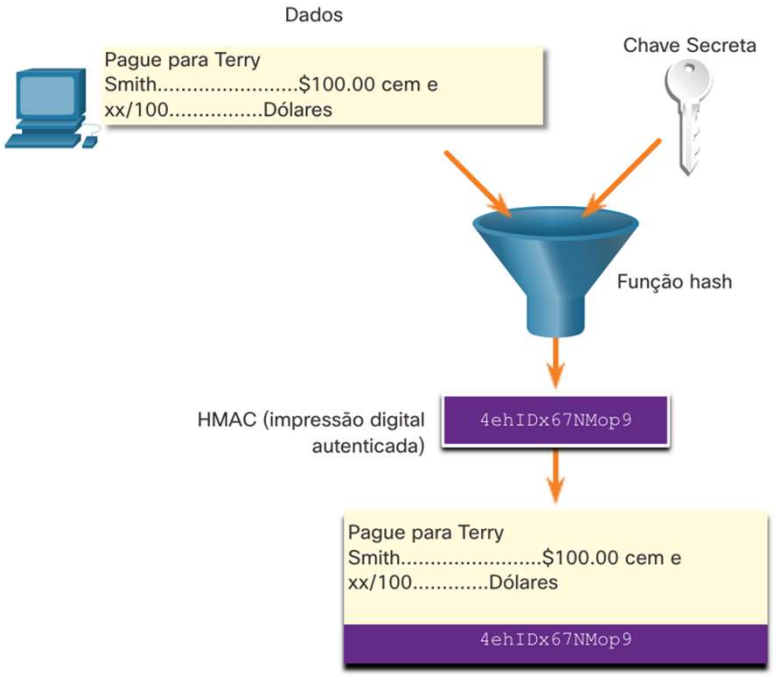
  - Se duas partes compartilham uma chave secreta e usam funções HMAC para autenticação, um resumo HMAC construído corretamente de uma mensagem que uma parte recebeu indica que a outra parte foi o originador da mensagem.



© 2020 Cisco

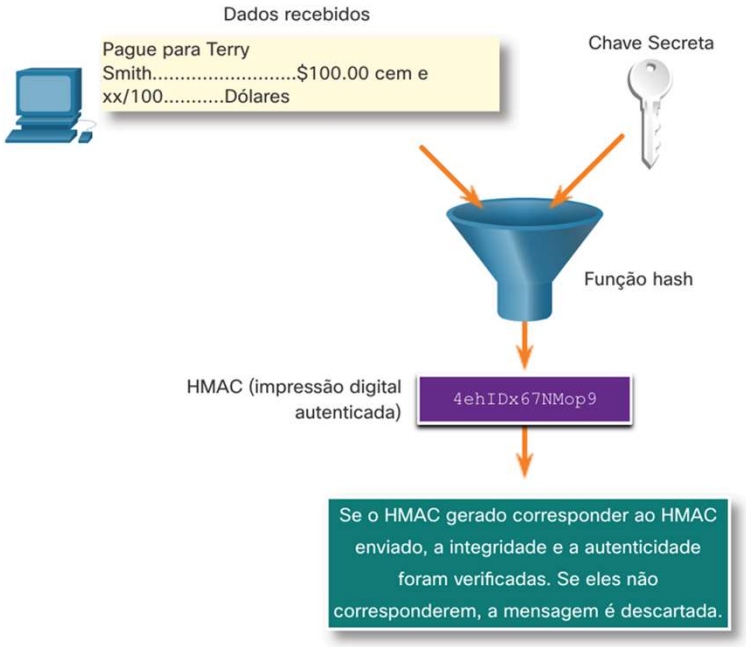
Autenticação de origem (Cont.)

- **Criação do valor de HMAC**
  - O dispositivo de envio insere dados (como o pagamento de $ 100 de Terry Smith e a chave secreta) no algoritmo de hash e calcula o resumo HMAC de comprimento fixo.
  - Esse Digest autenticado é anexado à mensagem e enviado ao destinatário.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação de origem (Cont.)



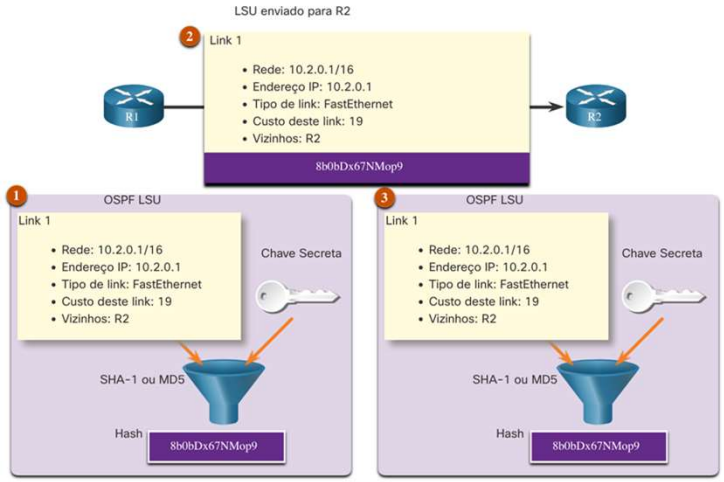
- **Verificação do valor de HMAC**
  - O dispositivo receptor remove o resumo da mensagem e usa a mensagem de texto simples com sua chave secreta como entrada na mesma função de hash.
  - Se o Digest calculado pelo dispositivo receptor for igual ao resumo enviado, a mensagem não foi alterada.
  - Adicionalmente, a origem da mensagem é autenticada porque apenas o remetente possui uma cópia da chave secreta compartilhada.
  - A função HMAC garantiu a autenticidade da mensagem.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Autenticação de origem (Cont.)

- A figura mostra como os HMACs são usados pelos roteadores Cisco configurados para usar a autenticação de roteamento Open Shortest Path First (OSPF).

- R1 está enviando uma atualização de estado do link (LSU) referente a uma rota para a rede 10.2.0.0/16:
  1. R1 calcula o valor do hash usando a mensagem LSU e a chave secreta.
  2. O valor do hash resultante é enviado com o LSU para o R2.
  3. R2 calcula o valor do hash usando o LSU e sua chave secreta. R2 aceita a atualização se os valores de hash corresponderem. Se eles não corresponderem, o R2 descartará a atualização.



2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

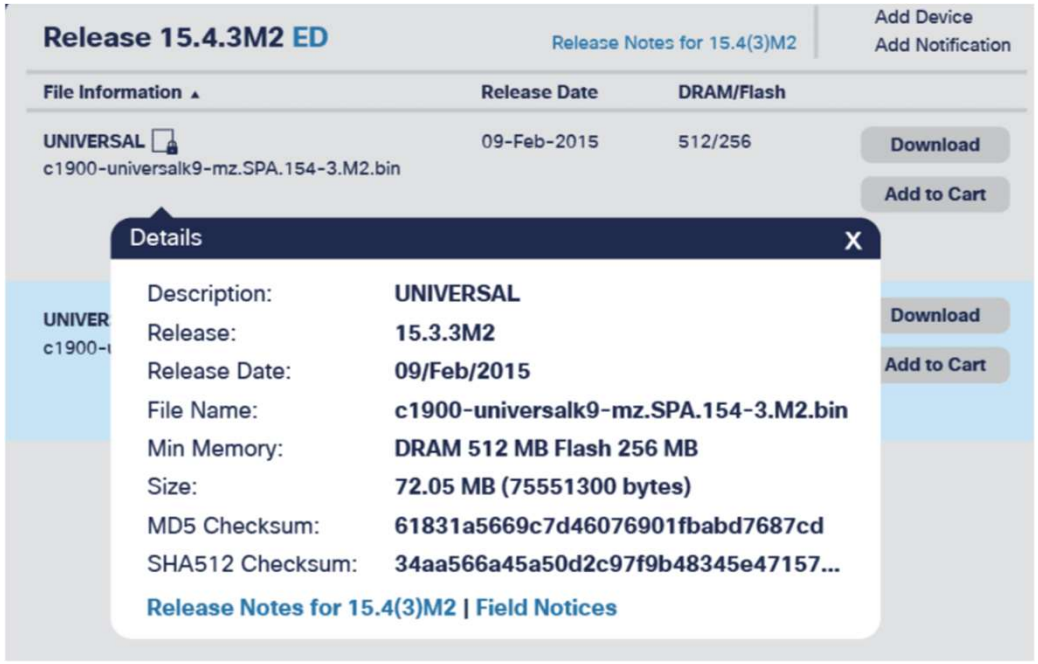
8.4 Usando hashes

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Hashes

Arquivos de hash e meios de comunicação digital

- A integridade assegura que os dados e informações estejam completos e inalterados no momento da aquisição.
- Para verificar a integridade de todas as imagens IOS, a Cisco oferece checksums MD5 e SHA no site de download de software da Cisco.
- O usuário pode fazer uma comparação deste resumo MD5 com o resumo MD5 de uma imagem Cisco IOS instalada em um dispositivo e pode ter certeza de que ninguém adulterou ou modificou o arquivo de imagem Cisco IOS.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Hashes

Arquivos de Hash e Mídia Digital (Cont.)

- O campo de computação forense digital usa o hash para verificar todas as mídias digitais que contêm arquivos.
- Por exemplo, o avaliador cria um hash e uma cópia de bit a bit da mídia que contém os arquivos, para produzir um clone digital.
- O examinador compara o hash da mídia original com a cópia e se os dois valores coincidirem, as cópias são idênticas.
- O fato de que um conjunto de bits é idêntico ao conjunto original de bits estabelece a invariabilidade.
- A invariabilidade ajuda a responder várias perguntas:
  - O avaliador tem os arquivos que ele esperava?
  - Os dados foram corrompidos ou alterados?
  - O avaliador pode comprovar que os arquivos não estão corrompidos?
- Agora o perito em computação forense pode avaliar as evidências digitais da cópia, enquanto deixa o original intacto e inalterado.

```
R1# verify / md5 flash:
c1900-universalk9-mz.SPA.154-3.M2.bin
.....
.....
.....
.....

.....MD5 of flash0:
c1900-universalk9-mz.SPA.154-3.M2.bin Done!
verify / md5 (flash0 : c1900-universalk9-mz . SPA .
154 - 3 . M@ . bin) -
61831a5669c7d46076901fbabd7687cd
```

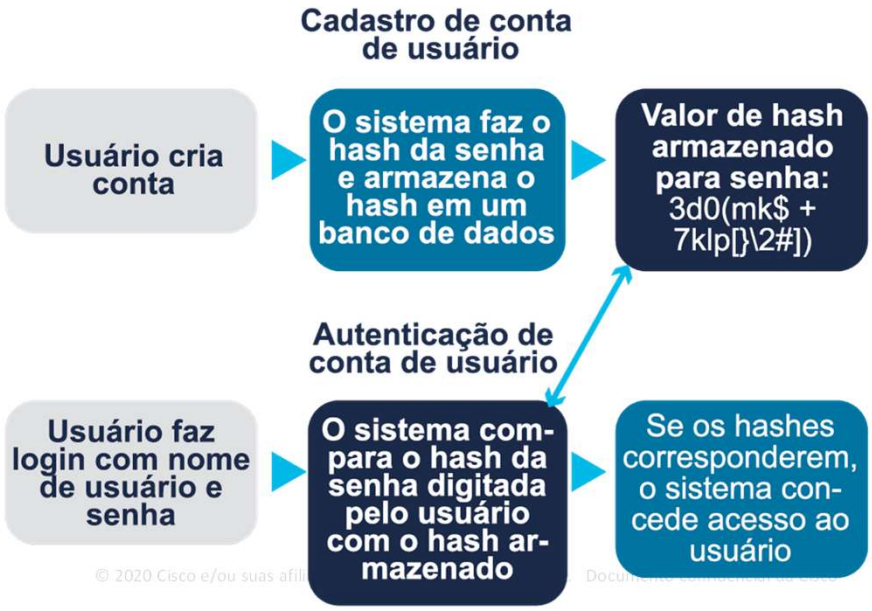
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Hashes

Senhas de hash

- Os algoritmos hash transformam qualquer quantidade de dados em um hash digital ou impressão digital de tamanho fixo.
- Ninguém pode reverter um hash digital para descobrir a entrada original.
- Se a entrada mudar completamente, o resultado será um hash diferente.
- Isso funciona para proteger as senhas.
- Um sistema precisa armazenar uma senha de modo a protegê-la, mas que ainda possa verificar se a senha do usuário está correta.

- Este diagrama mostra o fluxo de trabalho para a conta do usuário registro e autenticação usando um Sistema baseado em hash
- O sistema nunca registra a senha no disco rígid o, ele apenas armazena o hash digital.
- A senha é verdadeiramente conhecida apenas pelo usuário que a definiu.



© 2020 Cisco e/ou suas afili

Usando Hashes

Como decifrar hashes

- Para decifrar um hash, um invasor deve adivinhar a senha.

- Os dois principais ataques usados para adivinhar senhas são os ataques de dicionário e de força bruta:
  - Ataque de dicionário
    - Ele usa um arquivo que contém palavras, frases e senhas comuns.
    - O arquivo tem os hashes dessas senhas comuns calculados
    - Ele compara os hashes no arquivo com os hashes de senha e, se um hash corresponder, o invasor conhecerá um grupo de senhas potencialmente boas usadas neste sistema.
  - Ataques de força bruta
    - Ele tenta todas as combinações possíveis de caracteres até determinado tamanho.
    - Ele consome muito tempo e energia do processador.
    - Em teoria, é apenas uma questão de tempo até que esse método descubra a senha.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Hashes

Salting

- O salting torna o hash de senhas mais seguro.
- Se dois usuários têm a mesma senha, eles também terão os mesmos hashes de senha.
- Um salt, que é uma sequência aleatória de caracteres, é uma entrada adicional adicionada à senha antes do hash.
- Isso cria um resultado de hash diferente, mesmo quando as duas senhas são idênticas.
- Em seguida, o banco de dados armazena o hash e o satl.
- A mesma senha gera um hash diferente para usuários diferentes, porque o sal em cada instância é diferente.
- Enquanto isso, o salt não precisa ser secreto, pois é um número aleatório.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Implementação de salting

- Um Gerador Numérico Pseudo Randômico de Criptografia Segura "Cryptographically Secure Pseudo-Random Number Generator" (CSPRNG) é a melhor opção para gerar o salt.

- CSPRNGs geram um número aleatório que tem um alto nível de aleatoriedade e é completamente imprevisível, portanto, é criptograficamente confiável.

- As recomendações a seguir ajudarão a garantir a implementação bem-sucedida da salt:
  - O salt deve ser exclusivo para cada senha de usuário.
  - Nunca reutilize um salt.
  - O tamanho do salt deve corresponder ao tamanho da saída da função hash.
  - Sempre execute o hash no servidor em um aplicativo da Web.

- O alongamento de chaves faz com que as tentativas de descobrir senhas funcionem muito lentamente e é uma técnica que também ajudará a proteger contra ataques.

- Isso impede o hardware de ponta que pode calcular bilhões de hashes por segundo menos eficazes.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Implementação Salting (Cont.)

- **Para armazenar uma senha**
  - Use CSPRNG para gerar um salt longo e aleatório.
  - Adicione salt no começo da senha.
  - Execute o hash SHA-256, uma função hash criptográfica padrão.
  - Salve o salt e o hash como parte do registro do banco de dados do usuário.

- **Para validar uma senha**
  - Recupere o salt e hash de um usuário do banco de dados.
  - Adicione salt à senha e faça o hash com a mesma função hash.
  - Compare o hash da senha que acabou de ser enviada pelo usuário que está tentando fazer login com aquela armazenada no banco de dados.
  - Se os hashes não corresponderem, a senha com a qual o usuário acabou de tentar fazer login está incorreta.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Hashes

Como evitar ataques

- Salting impede que um invasor use um ataque de dicionário para tentar adivinhar senhas e impossibilita o uso de tabelas de pesquisa e tabelas rainbow para quebrar um hash.

Tabelas de pesquisa	Ele armazena os hashes de senhas pré-calculados em um dicionário de senhas, juntamente com a senha correspondente. Eles são uma estrutura de dados que processa centenas de pesquisas de hash por segundo.
Tabelas de pesquisa reversa	Esse ataque permite que o criminoso virtual lance um ataque de dicionário ou um ataque de força bruta em vários hashes, sem a tabela de pesquisa pré-calculada. O criminoso virtual cria uma tabela de pesquisa que traça cada hash de senha a partir do banco de dados da conta violada para uma lista de usuários. O c riminoso virtual executa um hash para cada palpite de senha e usa a tabela de pesquisa para obter uma lista de usuários cuja senha é compatível com o palpite do criminoso virtual, como mostrado na figura.
Rainbow tables	As rainbow tables sacrificam a velocidade de quebra de senha para diminuir o tamanho das tabelas de pesquisa. Uma tabela menor significa que a tabela pode armazenar as soluções para mais hashes na mesma quantidade de espaço.

Usando Hashes

Laboratório - Fazendo Hashes

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Hash de um arquivo de texto com OpenSSL
  - Parte 2: Verificando Hashhes

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.5 Criptografia de chave pública

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Uso de assinaturas digitais

- Assinaturas digitais são uma técnica matemática usada para fornecer autenticidade, integridade e não repúdio e possuem propriedades específicas que permitem autenticação de entidade e integridade de dados.

- Eles servem como prova legal de que a troca de dados ocorreu.

- As propriedades das assinaturas digitais são :
  - **Autêntica -** A assinatura não pode ser forjada e fornece prova de que o signatário, e ninguém mais, assinou o documento.
  - **Inalterável -** Depois que um documento é assinado, ele não pode ser alterado.
  - **Não reutilizável -** A assinatura do documento não pode ser transferida para outro documento.
  - **Não repudiada:** O documento assinado é o mesmo que um documento físico porque a assinatura é prova de que o documento foi assinado pela pessoa real.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Assinaturas Digitais (Cont.)

- As assinaturas digitais são comumente usadas nas duas situações a seguir:
  - **Assinatura de Código**
    - É usada para fins de integridade de dados e autenticação.
    - É usada para verificar a integridade de arquivos executáveis baixados de um site de fornecedor
    - Ela também usa certificados digitais assinados para autenticar e verificar a identidadedo site que é a origem dos arquivos.
  - **Certificados digitais**
    - Eles são como um cartão de identificação virtual e são usados para autenticar a identidade de um sistema com um site de fornecedor e estabelecer uma conexão criptografada para trocar dados confidenciais.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Usando Assinaturas Digitais (Cont.)

- Algoritmos de Padrão de Assinatura Digital (DSS) usados para gerar e verificar assinaturas digitais:
  - **Digital Signature Algorithm (DSA)** - **DSA** é o padrão original para gerar pares de chaves públicas e privadas e para gerar e verificar assinaturas digitais.
  - **Rivest-Shamir Adelman Algorithm (RSA) - RSA** é um algoritmo assimétrico comumente usado para gerar e verificar assinaturas digitais.
  - **Elliptic Curve Digital Signature Algorithm (ECDSA)** - ECDSA é uma variante mais recente de DSA e fornece autenticação de assinatura digital e não repúdio com os benefícios adicionais de eficiência computacional, tamanhos de assinatura pequenos e largura de banda mínima.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Assinaturas digitais para assinatura de código

- As assinaturas digitais são comumente usadas para garantir a autenticidade e integridade do código de software.

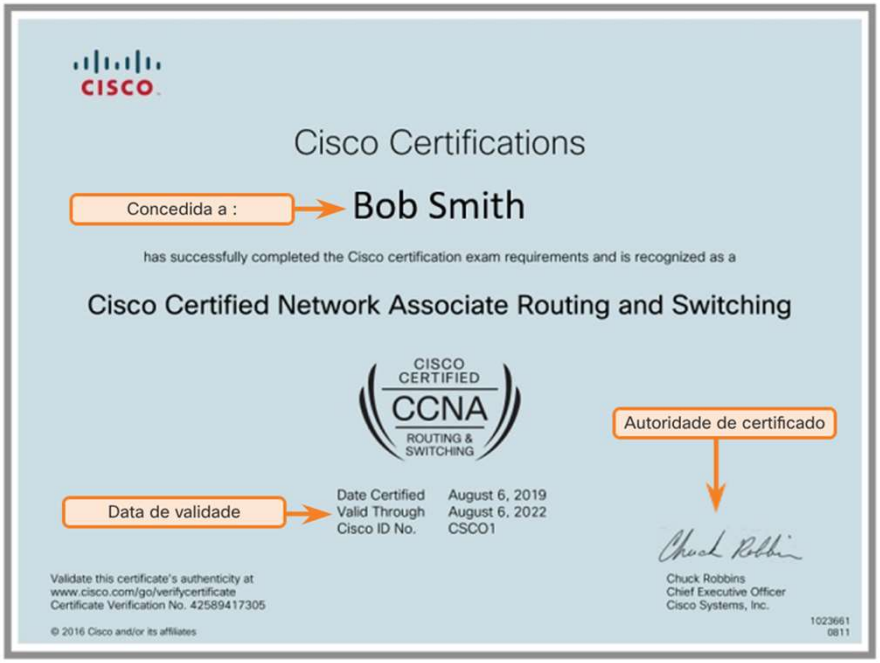
- Os arquivos executáveis são empacotados em um envelope assinado digitalmente, o que permite ao usuário final verificar a assinatura antes de instalar o software.

- Assinar digitalmente o código fornece várias garantias sobre o código:
  - O código é autêntico e é fornecido pelo editor.
  - O código não foi modificado desde que saiu do editor do software.
  - O editor publicou inegavelmente o código. Isso fornece não repúdio do ato de publicação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Assinaturas digitais para certificados digitais

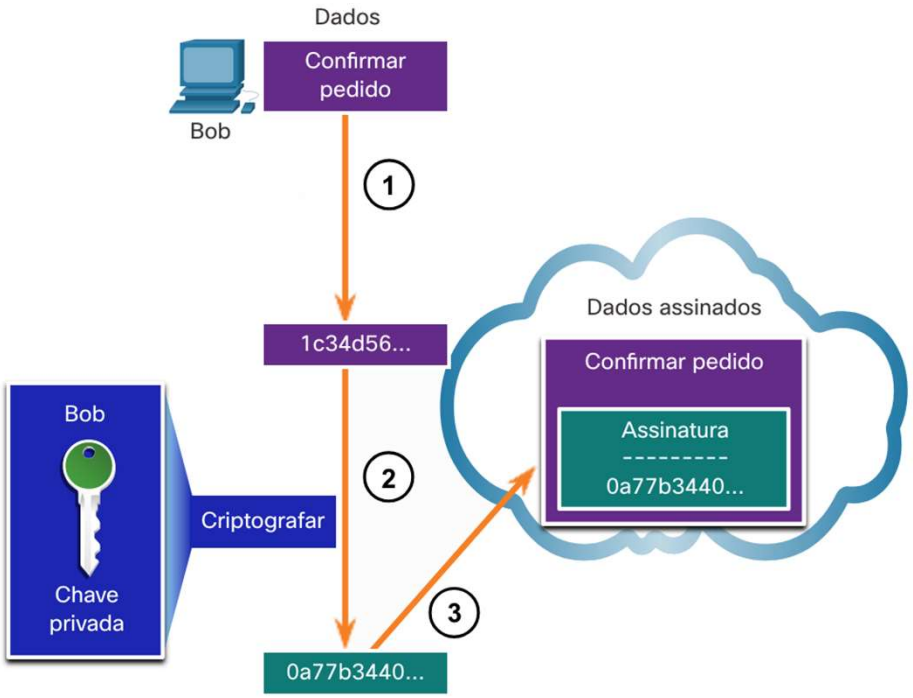
- Um **certificado digital** é equivalente a um passaporte eletrônico e permite que usuários, hosts e organizações troquem informações com segurança pela Internet.
- Especificamente, ele é usado para autenticar e verificar se um usuário que está enviando uma mensagem é quem afirma ser.
- Eles também podem ser usados para fornecer confidencialidade ao destinatário com os meios para criptografar uma resposta.
- Eles são como certificados físicos.
- Na figura, o certificado CCNA-S em papel identifica para quem o certificado foi emitido, quem autorizou o certificado e por quanto tempo o certificado é válido.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Assinaturas Digitais para Certificados Digitais (Cont.)

- Esse cenário ajudará você a entender como uma assinatura digital é usada.
  - Bob está confirmando um pedido com Alice .
  - Alice está comprando no site de Bob.
  - Alice se conectou com o site de Bob, e depois que o certificado foi verificado, o certificado de Bob é armazenado no site de Alice.
  - O certificado contém a chave pública de Bob que é usada para verificar a assinatura digital de Bob.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

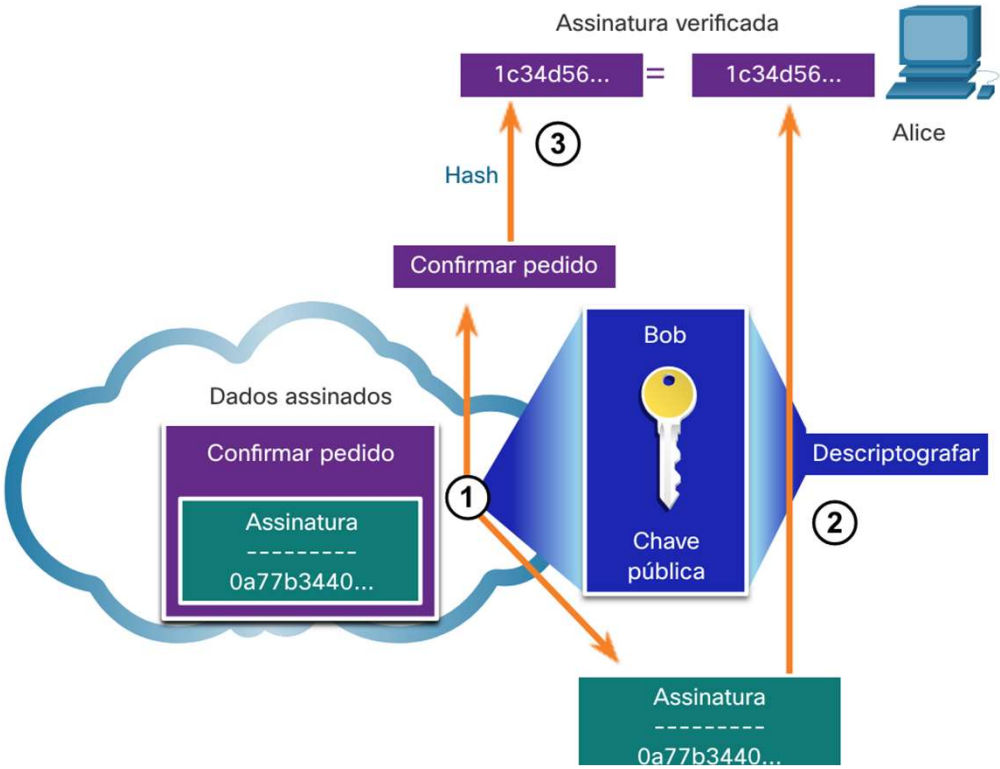
Assinaturas Digitais para Certificados Digitais (Cont.)

- Quando Alice recebe a assinatura digital, ocorre o seguinte processo.

1. O dispositivo receptor de Alice aceita a confirmação do pedido com a assinatura digital e obtém a chave pública de Bob.

2. O computador de Alice descodifica a assinatura usando a chave pública de Bob. Esta etapa revela o valor de hash assumido do dispositivo de envio.

3. O computador de Alice cria um hash do documento recebido, sem sua assinatura, e compara esse hash com o hash de assinatura decriptografado. Se os hashes corresponderem, o documento é autêntico. Isso significa que a confirmação foi enviada por Bob e que ela não mudou desde que foi assinada.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório - Gerar e usar uma assinatura digital

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Use o OpenSSL para gerar uma assinatura digital.
  - Parte 2: Assine um documento com a assinatura digital.
  - Parte 3: Verifique se um documento assinado foi alterado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.6 Autoridades e o sistema de confiança de PKI

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Gerenciamento de Chave Pública

- O tráfego da Internet consiste no tráfego entre duas partes. Ao estabelecer uma conexão assimétrica entre dois hosts, os hosts trocarão suas informações de chave pública.
- Um certificado SSL é um certificado digital que confirma a identidade de um domínio de site.
- Para implementar SSL em seu site, você compra um certificado SSL para seu domínio de um provedor de Certificado SSL.
- O empresa terceirizada de confiança faz uma investigação aprofundada antes da emissão das credenciais.
- Após essa investigação aprofundada, o terceiro emite credenciais (ou seja, certificado digital) que são difíceis de falsificar.
- Desse ponto em diante, todos os indivíduos que confiam no terceiro simplesmente aceitam as credenciais que o terceiro emite.
- Quando os computadores tentam se conectar a um site por HTTPS, o navegador da web verifica o certificado de segurança do site e verifica se ele é válido e se originou de uma autoridade de certificação (CA) confiável.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

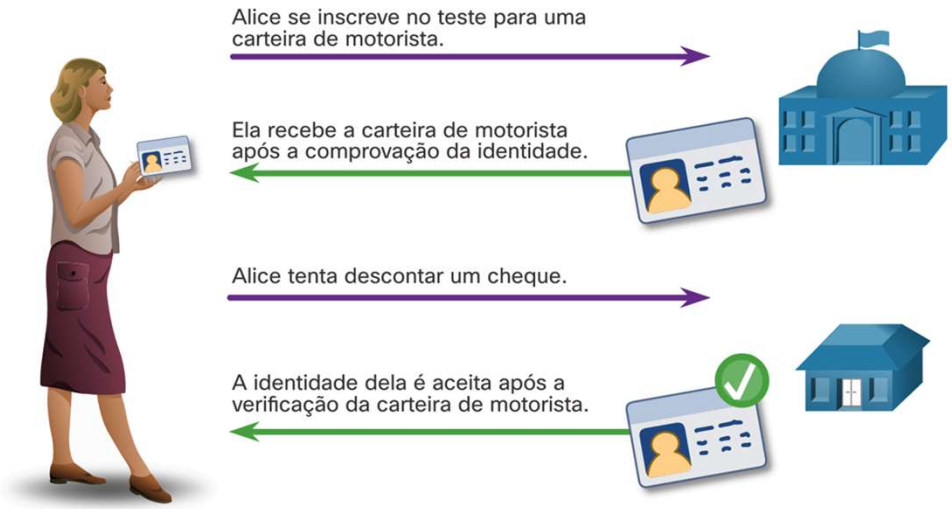
Gerenciamento de chave pública (cont.)

- Esses terceiros confiáveis fornecem serviços semelhantes aos escritórios de licenciamento governamentais.

- A figura ilustra como uma carteira de motorista é análoga a um certificado digital.
- A autoridade de certificação (CA) é uma organização que cria certificados digitais vinculando uma chave pública a uma identificação confirmada , como um site ou indivíduo.

- A Infraestrutura de Chave Pública (PKI) consiste em especificações, sistemas e ferramentas que são usados para criar, gerenciar, distribuir, usar, armazenar e revogar certificados digitais.

- O PKI é um sistema complexo que é projetado para proteger identidades digitais contra hackers até mesmo os atores de ameaças mais sofisticados ou estados-nação.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

A infraestrutura de chave pública

1. Os certificados PKI contêm:a chave pública de uma entidade ou de um indivíduo, a sua finalidade, a autoridade de certificação (AC) que validou e emitiu o certificado, o intervalo de datas durante o qual o certificado é válido e o algoritmo usado para criar a assinatura.

2. O armazenamento de certificados reside em um computador local e armazena certificados emitidos e chaves privadas.

3. O Certificado de Autoridade PKI (CA) é um terceiro confiável que emite certificados PKI para entidades e indivíduos após verificar sua identidade. Ele assina esses certificados usando sua chave privada.

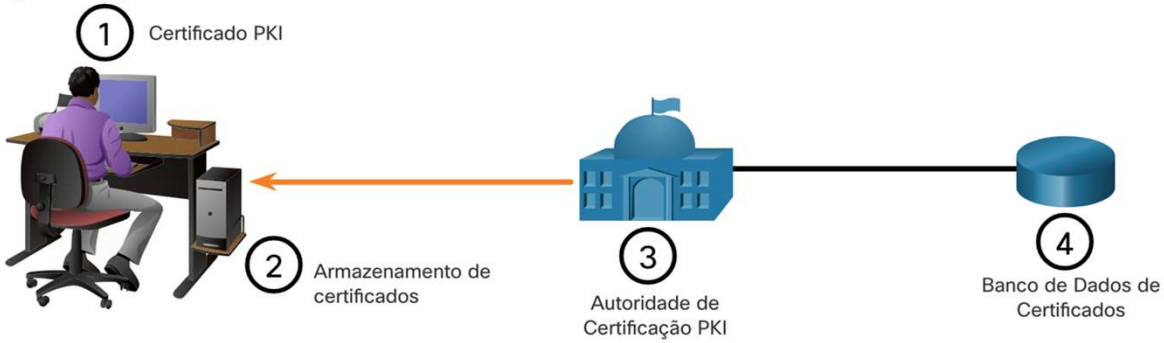
4. O banco de dados de certificados armazena todos os certificados aprovados pela autoridade de certificação.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Infraestrutura de chaves públicas (Cont.)

- A PKI é necessária para oferecer suporte à distribuição em larga escala e à identificação de chaves de criptografia públicas.
- A estrutura PKI facilita uma relação de confiança altamente escalável.
- Consiste em hardware, software, pessoas, políticas e procedimentos necessários para criar, gerenciar, armazenar, distribuir e revogar certificados digitais.

- A figura mostra os principais elementos da PKI.



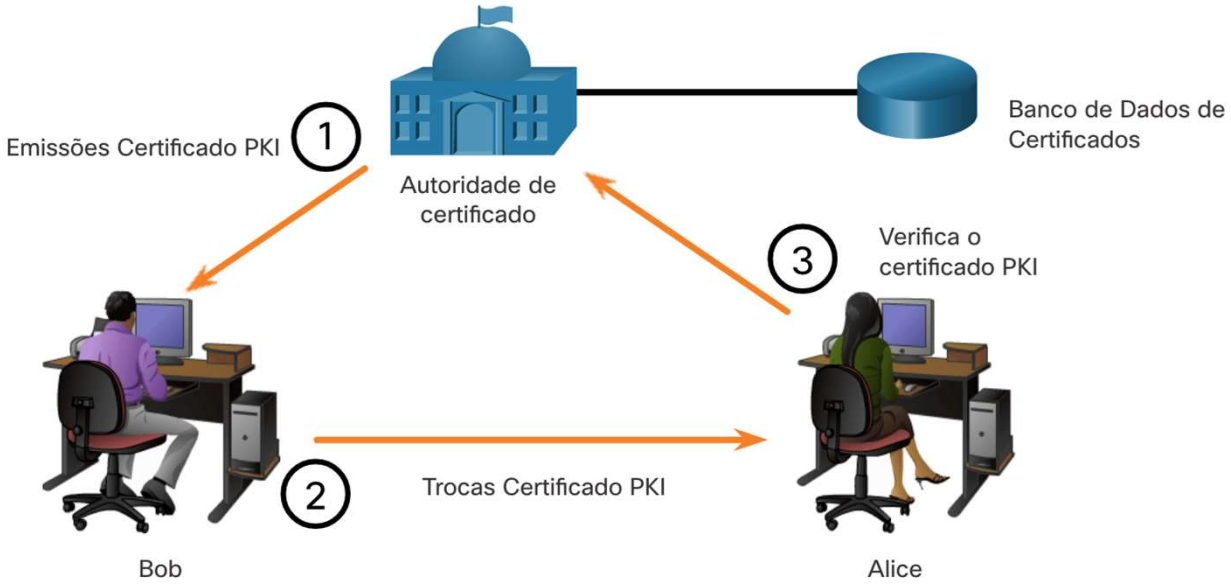
Observação: Nem todos os certificados PKI são recebidos diretamente de uma autoridade de certificação. Uma autoridade de registro (RA) é uma autoridade de certificação subordinada e é certificada por uma autoridade de certificação raiz para emitir certificados para usos específicos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Infraestrutura de chaves públicas (Cont.)

- A figura mostra como os elementos da PKI interoperam:

  - Bob recebeu seu certificado digital da CA.
  - Este certificado é usado sempre que Bob se comunica com outras partes.
  - Bob se comunica com Alice.
  - Quando Alice recebe o certificado digital de Bob, ela se comunica com a autoridade de certificação confiável para validar a identidade de Bob.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

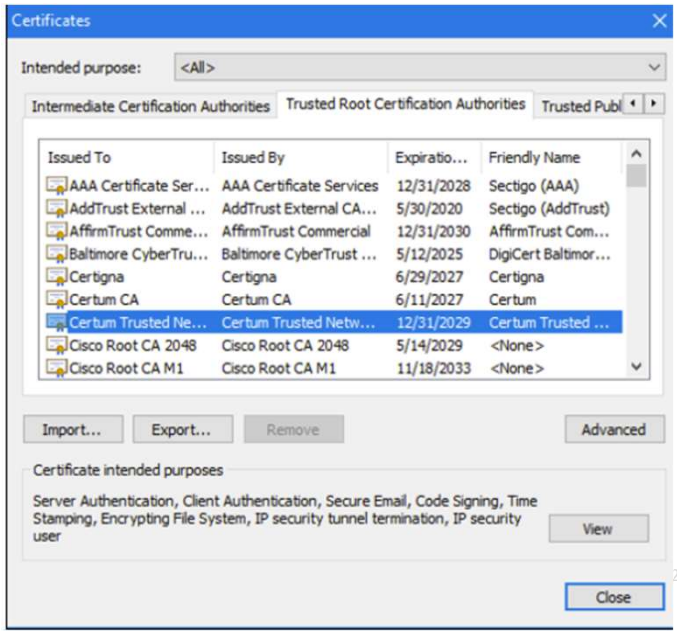
O Sistema de Autoridades PKI

- Muitos fornecedores fornecem servidores da CA como um serviço gerenciado ou como um produto de usuário final.
- As organizações também podem implementar PKIs privadas usando o Microsoft Server ou Open SSL.
- As autoridades de certificação, especialmente aquelas que são terceirizadas, emitem certificados baseados em classes que determinam a confiabilidade de um certificado.
- A tabela fornece uma descrição do número da classe que determina o quão rigoroso foi o procedimento que verificou a identidade do titular quando o certificado foi emitido.
- Quanto maior o número da classe, mais confiável será o certificado.

Classe	Descrição
0	Usado para testes em situações em que não foram realizadas verificações.
1	Usado por indivíduos que exigem verificação de e-mail.
2	Usado por organizações para as quais a prova de identidade é necessária.
3	Usado para servidores e assinatura de software. A autoridade certificadora procede à verificação e verificação independentes da identidade e da autoridade.
4	Usado para transações comerciais on-line entre empresas.
5	Usado para organizações privadas ou segurança do governo.

O Sistema de Autoridades PKI (Cont.)

- **Teste de componentes do iFrame**
  - Algumas chaves públicas da CA são pré-carregadas, como as listadas em navegadores da Web.
  - A figura exibe vários certificados VeriSign contidos no armazenamento de certificados no host.
  - Quaisquer certificados assinados por qualquer uma das autoridades de certificação na lista serão vistos pelo navegador como legítimos e serão confiáveis automaticamente.

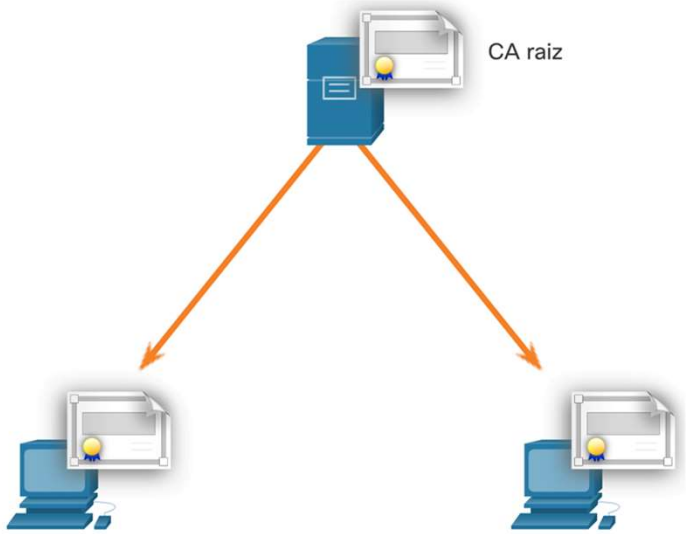


20 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Sistema de Confiança PKI

- As PKIs podem formar diferentes topologias de confiança e a mais simples é a topologia PKI de raiz única.
- Como mostrado na figura abaixo, uma única autoridade de certificação (CA raiz), emite todos os certificados para os usuários finais, que geralmente estão dentro da mesma organização.
- O benefício desta abordagem é a sua simplicidade.
- No entanto, é difícil dimensionar para um ambiente grande porque requer uma administração estritamente centralizada, o que cria um único ponto de falha.

Topologia PKI de raiz única



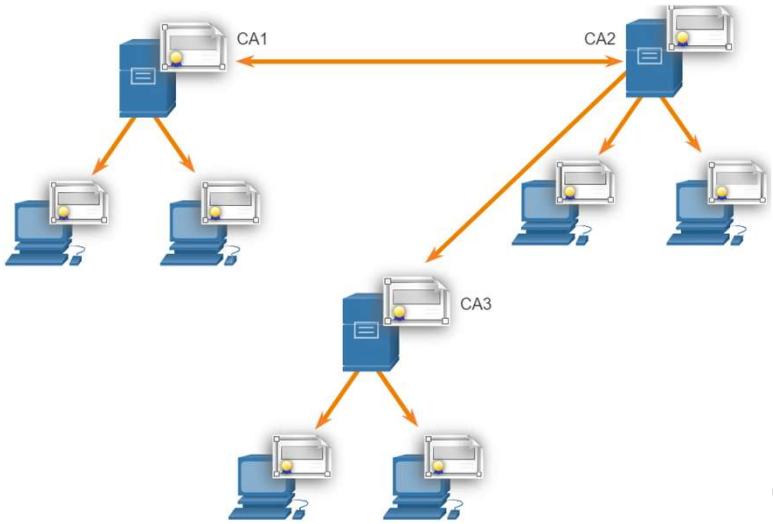
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O sistema de confiança PKI (Cont.)

Em redes maiores, as CAs PKI podem ser vinculadas usando duas arquiteturas básicas:

- **Topologias CA com certificação cruzada**
  - Conforme mostrado na figura, este é um modelo ponto a ponto no qual CAs individuais estabelecem relações de confiança com outras CAs por certificados de CA de certificação cruzada.
  - Os usuários em ambos os domínios da CA também têm a certeza de que podem confiar uns nos outros.
  - Isso fornece redundância e elimina o ponto único de falha.

CA com certificação cruzada

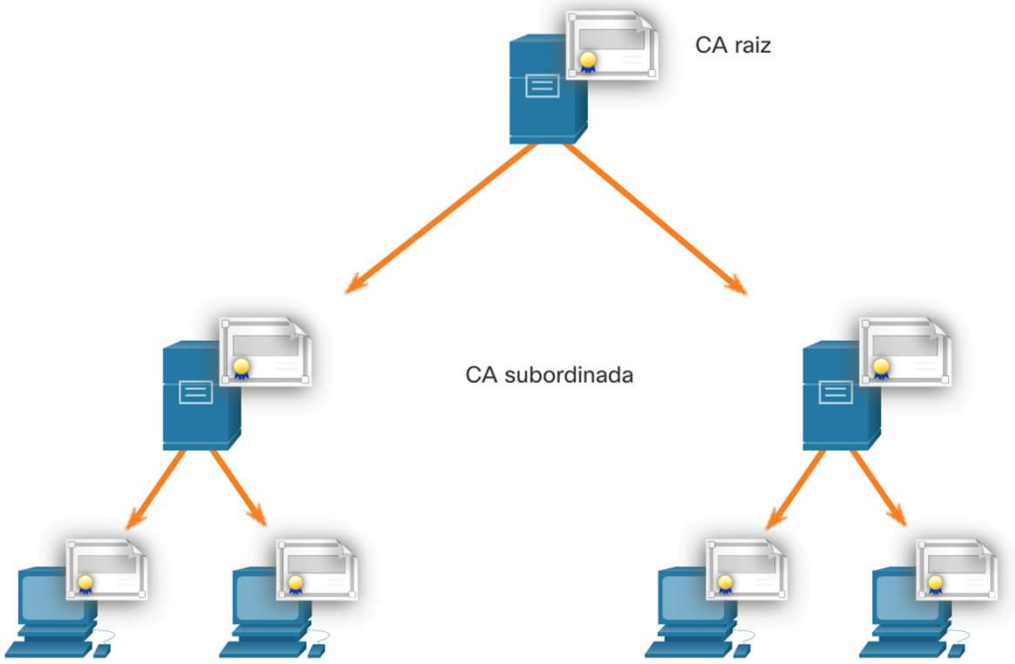


e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O sistema de confiança PKI (Cont.)

- **Topologias hierárquicas de CA**
  - A CA de nível mais alto (CA raiz) pode emitir certificados para usuários finais e para uma CA subordinada.
  - As subCAs podem ser criadas para suportar várias unidades de negócios, domínios ou comunidades de confiança.
  - A autoridade de certificação raiz mantém a "comunidade de confiança" estabelecida garantindo que cada entidade na hierarquia esteja em conformidade com um conjunto mínimo de práticas.
  - Os benefícios da topologia incluem maior escalabilidade e capacidade de gerenciamento. Ela funciona bem na maioria das grandes organizações.
  - Uma topologia hierárquica e de certificação cruzada pode ser combinada para criar uma infraestrutura híbrida.

CA hierárquica



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Interoperabilidade de diferentes fornecedores de PKI

1. **SSL** - Servidores Web seguros Use X.509.v3 para autenticação do site nos protocolos SSL e TLS, enquanto os navegadores da Web usam X.509v3 para implementar certificados de cliente HTTPS. SSL é a autenticação baseada em certificado mais utilizada.

2. **IPsec** - IPsec VPNS usa certificados X.509 quando a autenticação baseada em RSA é usada para a Intercâmbio de chaves da Internet (IKE).

3. **S/MIME** - agentes de correio do utilizador que suportam a proteção de correio com o protocolo S/MIME utilizam certificados X.509.

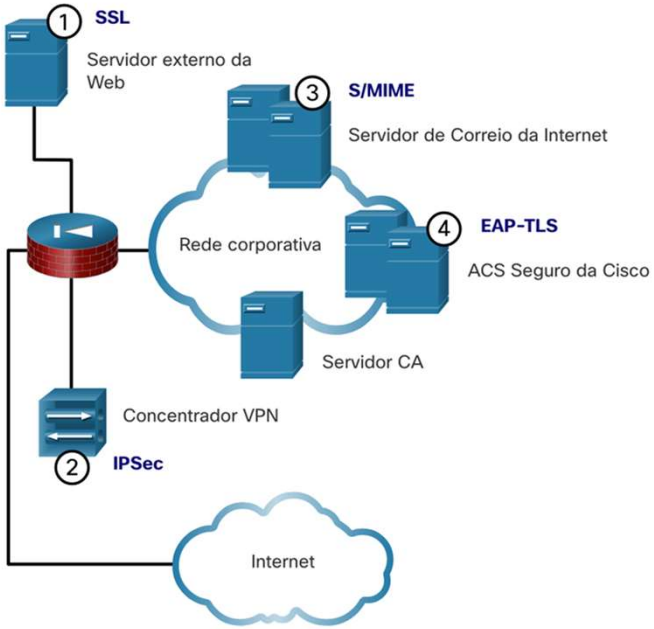
4. **EAP - TLS** - Os switches Cisco podem usar certificados para autenticar dispositivos finais que se conectam a portas LAN usando 802.1.x entre os dispositivos adjacentes A autenticação pode ser feita por proxy para um ACS central via EAP-TLS.

- A interoperabilidade entre uma PKI e seus serviços de suporte, como diretórios LDAP e X.500, é uma preocupação porque muitos fornecedores de CA propuseram e implementaram soluções proprietárias em vez de aguardar o desenvolvimento de padrões.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Interoperabilidade de diferentes fornecedores de PKI

- Para resolver esse problema de interoperabilidade, o IETF publicou Política de Certificação e Política de Infraestrutura de Chave Pública da Internet X.509 (RFC 2527).
- O padrão X.509 versão 3 (X.509 v3) define o formato de um certificado digital.
- Consulte a figura para obter mais informações sobre aplicativos X.509 v3.
- Como mostrado na figura, o formato X.509 já é amplamente utilizado na infra-estrutura da internet.



2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Inscrição, autenticação e revogação de certificados

- A primeira etapa no procedimento de autenticação da autoridade de certificação é obter com segurança uma cópia da chave pública da autoridade de certificação.
- Todos os sistemas que utilizam a PKI devem ter a chave pública da CA (certificado autoassinado).
- A chave pública da CA verifica todos os certificados emitidos pela autoridade de certificação e é vital para o bom funcionamento da PKI.
- Para muitos sistemas, como navegadores da Web, a distribuição de certificados de CA é processada automaticamente.
- O navegador da Web vem pré-instalado com um conjunto de certificados raiz de CA públicos.
- As organizações e seus domínios do site enviam seus certificados públicos para os visitantes do site.
- As autoridades de certificação e os registradores de domínio de certificado criam e distribuem certificados privados e públicos para clientes que compram certificados.
- O processo de registro de certificado é usado por um sistema host para se inscrever com uma PKI.
- Para fazer isso, os certificados de CA são recuperados em banda através de uma rede e a autenticação é feita fora de banda (OOB) usando o telefone.

Observação: somente uma autoridade de certificação raiz pode emitir um certificado autoassinado reconhecido ou verificado por outras autoridades de certificação dentro da PKI.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Registro, Autenticação e Revogação de certificados (Cont.)

- O registro do sistema com a PKI entra em contato com uma autoridade de certificação para solicitar e obter um certificado de identidade digital para si mesmo e para obter o certificado autoassinado da autoridade de certificação.
- O estágio final verifica se o certificado da autoridade de certificação foi autêntico e é executado usando um método fora de banda, como o POTS, para obter a impressão digital do certificado de identidade da autoridade de certificação válido.
- A autenticação não requer mais a presença do servidor da autoridade de certificação e cada usuário troca seus certificados contendo chaves públicas.
- Os certificados devem, por vezes, ser revogados.
- Os métodos mais comuns de revogação são:
  - **Lista de revogação de certificados (CRL) -** Uma lista de números de série de certificados revogados que foram invalidados porque expiraram. As entidades PKI pesquisam regularmente o repositório CRL para receber a CRL atual.
  - **Protocolo de Status de Certificado Online (OCSP) -** Um protocolo de Internet usado para consultar um servidor OCSP para o status de revogação de um certificado digital X.509. As informações de revogação são imediatamente enviadas para um banco de dados on-line.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Laboratório — Armazenamento de autoridade de certificação

- Neste laboratório, você completará os seguintes objetivos:
  - Parte 1: Certificados Confiáveis pelo Seu Navegador
  - Parte 2: Verificando o Man-In-Middle

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.7 Aplicações e impactos da criptografia

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Aplicações PKI

- Onde a PKI pode ser usada por uma empresa?

- Uma pequena lista de usos comuns de PKIs:
  - Autenticação de peer baseada em certificado SSL/TLS
  - Proteja o tráfego de rede usando VPNs IPsec
  - Tráfego da web HTTPS
  - Controle o acesso à rede usando a autenticação 802.1x
  - E-mail seguro usando o protocolo S/MIME
  - Mensagens instantâneas seguras
  - Aprovar e autorizar aplicativos com assinatura de código
  - Proteja os dados do usuário com o sistema de arquivos de criptografia (EFS)
  - Implementar autenticação de dois fatores com cartões inteligentes
  - Protegendo dispositivos de armazenamento USB

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Transações de rede criptográfica

- Alguns desses problemas podem ser evitados, pois os protocolos SSL/TLS são extensíveis e modulares.
- Isso é conhecido como um conjunto de cifras e seus principais componentes são o algoritmo MAC, o algoritmo de criptografia, o algoritmo de troca de chaves e o algoritmo de autenticação.
- Estes podem ser alterados sem substituir todo o protocolo e são muito úteis porque os diferentes algoritmos continuam a evoluir.
- Quando as versões do protocolo no conjunto de cifras mudam, o número da versão SSL/TLS também muda.
- Um analista de segurança deve ser capaz de reconhecer e resolver possíveis problemas relacionados à permissão de soluções relacionadas à PKI na rede corporativa.
- Considere como o aumento do tráfego SSL/TLS representa um grande risco de segurança para as empresas porque o tráfego é criptografado e não pode ser interceptado e monitorado por meios normais.
- Os usuários podem introduzir malware ou vazar informações confidenciais através de uma conexão SSL/TLS.
- Os atores de ameaças podem usar SSL/TLS para introduzir violações de conformidade regulatória, vírus, malware, perda de dados e tentativas de intrusão em uma rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

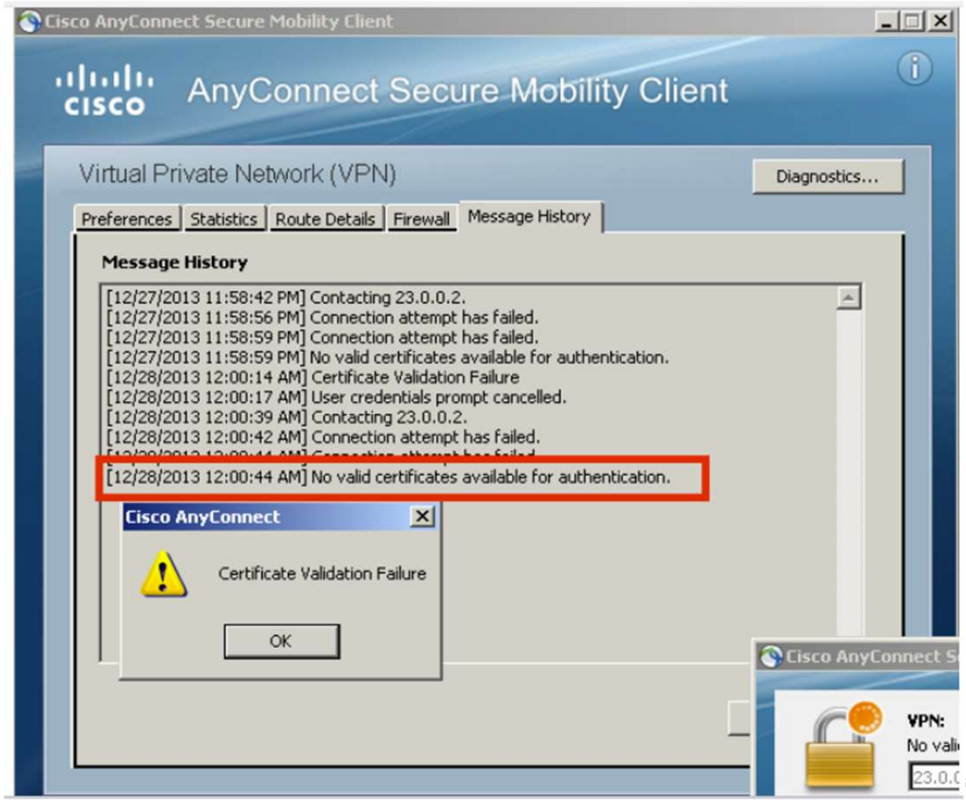
Transações de Rede Criptografadas (Cont.)

- Outros problemas relacionados a SSL/TLS podem estar associados à validação do certificado de um servidor Web.
- Quando isso ocorre, os navegadores da Web exibirão um aviso de segurança.
- Os problemas relacionados à PKI associados a avisos de segurança incluem:
  - **Intervalo de datas de validade -** os certificados X.509v3 especificam datas “não antes” e “não depois”. Se a data atual estiver fora do intervalo, o navegador da Web exibirá uma mensagem. Os certificados expirados podem simplesmente ser o resultado da supervisão do administrador, mas também podem refletir condições mais graves.
  - **Erro de validação de assinatura -** se um navegador não puder validar a assinatura do certificado, não há garantia de que a chave pública do certificado seja autêntica. A validação de assinatura falhará se o certificado raiz da hierarquia da autoridade de certificação não estiver disponível no armazenamento de certificados do navegador.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Transações de Rede Criptografadas (Cont.)

- A figura mostra um exemplo de erro de validação de assinatura com o Cisco AnyConnect Mobility VPN Client.



Criptografia e monitoramento de segurança

- O monitoramento de rede torna-se mais desafiador quando os pacotes são criptografados.
- Os analistas de segurança devem estar cientes desses desafios e enfrentá-los da melhor forma possível.
- O aumento do uso de HTTPS na rede empresarial introduz novos desafios.
- Como o HTTPS introduz tráfego HTTP criptografado de ponta a ponta (via TLS/SSL), não é tão fácil espiar o tráfego do usuário.
- Uma lista de algumas das coisas que um analista de segurança pode fazer:
  - Configurar regras para distinguir entre tráfego SSL e não-SSL, tráfego SSL HTTPS e não-HTTPS.
  - Melhorar a segurança através da validação de certificados de servidor utilizando CRLs e OCSP.
  - Implementar proteção antimalware e filtragem de URL de conteúdo HTTPS.
  - Implante um Cisco SSL Appliance para decriptografar o tráfego SSL e enviá-lo aos dispositivos IPS para identificar os riscos normalmente ocultos pelo SSL.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

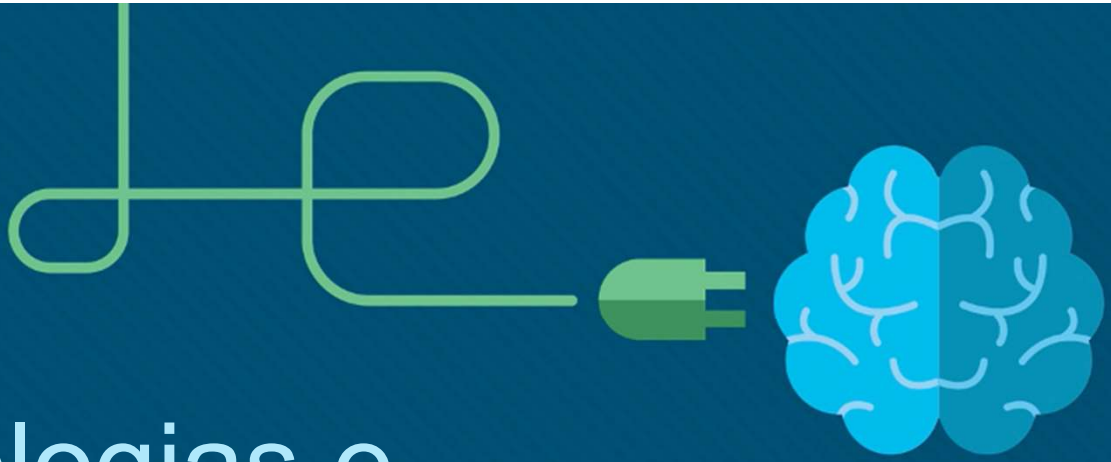
Criptografia e Monitoramento de Segurança (Cont.)

- A criptografia é dinâmica e está sempre mudando.
- Um analista de segurança deve manter um bom entendimento de algoritmos criptográficos e operações para ser capaz de investigar incidentes de segurança relacionados à criptografia.
- Há duas maneiras principais em que a criptografia afeta as investigações de segurança.
  - Primeiro, os ataques podem ser direcionados especificamente para os próprios algoritmos de criptografia. Depois que o algoritmo foi quebrado e o invasor obteve as chaves, todos os dados criptografados que foram capturados podem ser decriptografados pelo invasor e lidos, expondo assim os dados privados.
  - Em segundo lugar, a investigação de segurança também é afetada porque os dados podem ser escondidos , encriptando-os.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

8.8 Resumo da criptografia

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 9: Tecnologias e Protocolos



Material do instrutor

Defesa de rede

Materiais do instrutor - Guia de planejamento do módulo 9

Esta apresentação de PowerPoint é dividida em duas partes:

- Guia de planejamento do Instrutor
  - Informações para ajudá-lo a se familiarizar com o módulo
  - Material didático
- Apresentação para aulas
  - Slides opcionais que você pode usar em sala de aula
  - Começa no slide 9

Nota: Remova o Guia de Planejamento desta apresentação antes de compartilhá-la com alguém.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

O Que Esperar Neste Módulo

Para facilitar o aprendizado, os seguintes recursos da interface do usuário podem ser incluídos neste módulo:

Recurso	Descrição
Avatar	Um personagem virtual, representando um especialista no assunto, acrescenta informações contextuais adicionais às habilidades que os alunos aprenderam e os ajuda a ligar os pontos, fazendo perguntas de reflexão aberta.
Animações	Expor os alunos a novas competências e conceitos.
Vídeos	Exponha os alunos a novas habilidades e conceitos.
Verifique seu entendimento	Per topic online quiz to help learners gauge content understanding.
Atividades Interativas	Uma variedade de formatos para ajudar os alunos a avaliar a compreensão do conteúdo.
Verificador de Sintaxe	Pequenas simulações que expõem os alunos à linha de comando da Cisco para praticar habilidades de configuração.
Atividade do PT	Atividades de simulação e modelagem projetadas para explorar, adquirir, reforçar e expandir habilidades.

O Que Esperar Neste Módulo (Cont.)

Para facilitar o aprendizado, os seguintes recursos da interface do usuário podem ser incluídos neste módulo:

Recurso	Descrição
Laboratórios Práticos	Laboratórios projetados para trabalhar com equipamentos físicos.
Testes de módulo	Autoavaliações que integram conceitos e habilidades aprendidas ao longo da série de tópicos apresentados no módulo.
Resumo do módulo	Recapitula brevemente o conteúdo do módulo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Verifique seu entendimento

- As atividades "Verifique sua compreensão" são projetadas para permitir que os alunos determinem rapidamente se entendem o conteúdo e podem prosseguir ou se precisam revisar.
- Verifique se suas atividades de compreensão ***não*** afetam as notas do aluno.
- Não há slides separados para essas atividades no PPT. Elas estão listadas na área de anotações do slide que aparece antes dessas atividades.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 9: Atividades

Quais atividades estão associadas a este módulo?

Nº da página	Atividade de	Nome da atividade	Opcional?
9.1.7	Verifique seu entendimento	Identificar o Protocolo Monitorado	Recomendada
9.2.6	Verifique seu entendimento	Identificar o impacto da tecnologia na segurança e monitoramento	Recomendada
9.3.2	Teste do Módulo	Questionário sobre tecnologias e protocolos	Recomendada

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 9: Práticas recomendadas

Antes de ensinar o Módulo 9, o instrutor deve:

- Revise as atividades e avaliações para este módulo.
- Tente incluir o máximo de perguntas possível para manter os alunos envolvidos durante a apresentação em sala de aula.

Tópico 9.1

- Pergunte à turma:
  - Discuta a função e a aplicação do Syslog e pergunte por que o carimbo de data/hora é importante e, em seguida, peça aos alunos que listem alguns exemplos.
  - Revisão rápida da operação de DNS e, em seguida, explique um exemplo de exfiltração de DNS.
  - Explique iFrame e injeção de iFrame.
  - Compare e contraste HTTP e HTTPS.
  - Compare e diferencie diferentes protocolos de e-mail e problemas de segurança com eles.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Módulo 9: Melhores Práticas (cont.)

Tópico 9.2

- Discuta a função e a aplicação do ACL e pergunte por que o ACL sozinho não é bom o suficiente.
- Faça uma revisão rápida de NAT e PAT e peça aos alunos que descrevam os problemas de NAT/PAT relacionados à segurança.
- Revise o conceito de criptografia e as tecnologias que permitem/fornecem criptografia, peça aos alunos para listar os aplicativos que usam criptografia (HTTPS, VPN, etc.).
- Peça à classe para listar exemplos da rede P2P e se eles usam ou conhecem outras que usam P2P.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Module 9: Tecnologias e Protocolos

Defesa de rede

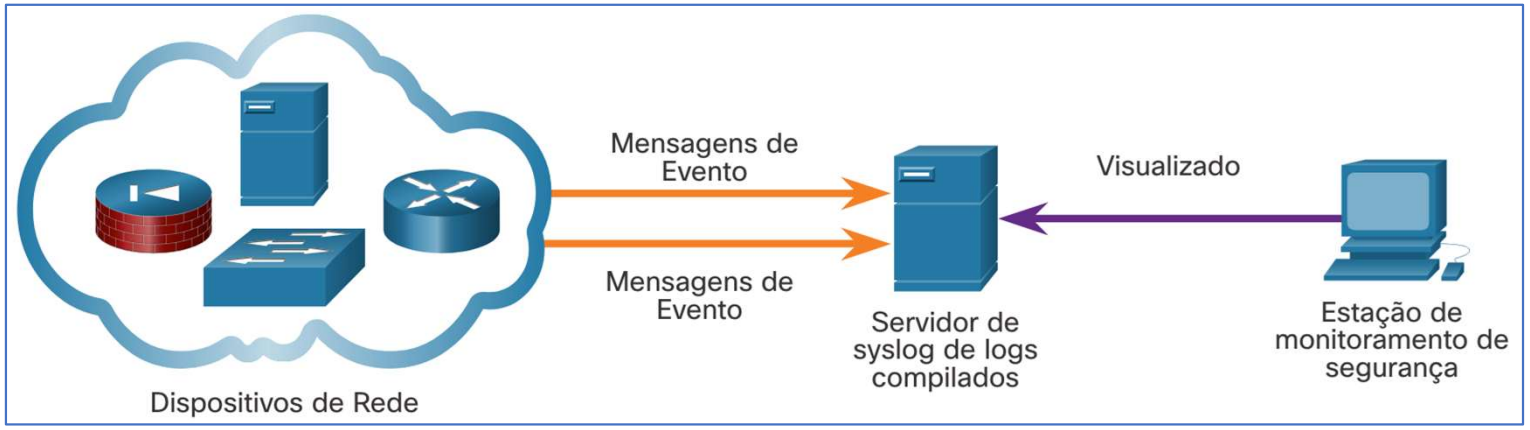
9.1 Protocolos comuns de monitoramento

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

Syslog e NTP

- O padrão syslog é usado para registrar mensagens de eventos de dispositivos de rede e endpoints.
- O padrão permite um meio neutro de sistema de transmissão, armazenamento e análise de mensagens.
- Muitos tipos de dispositivos de vários fornecedores diferentes podem usar syslog para enviar entradas de log para servidores centrais que executam um daemon syslog.
- Esta centralização da coleta de logs ajuda a tornar o monitoramento de segurança prático.
- Os servidores que executam syslog normalmente escutam na porta UDP 514.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

Syslog e NTP (cont.)

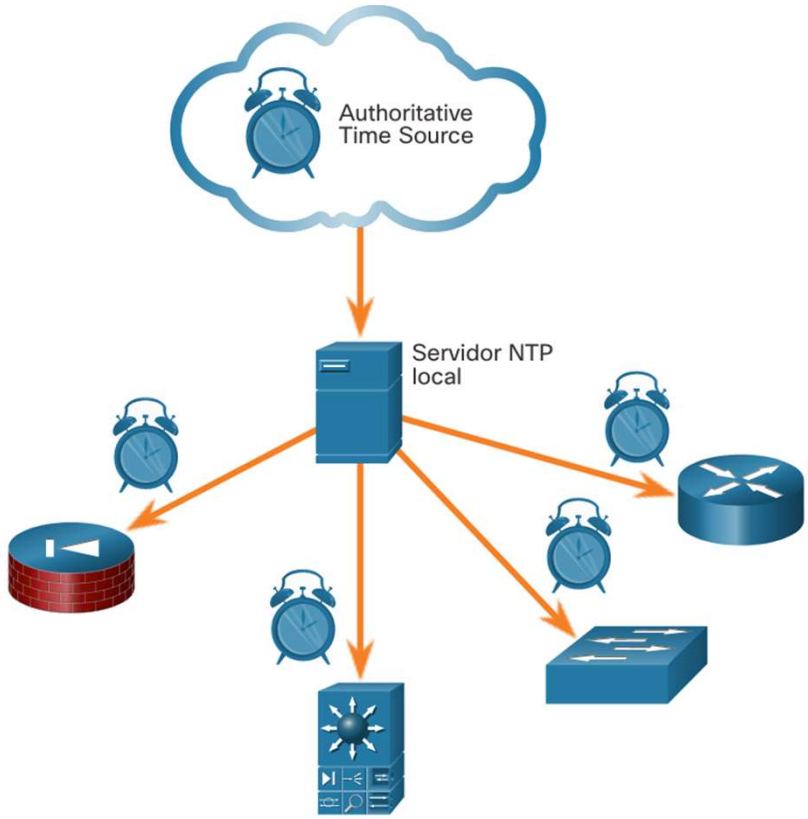
- Como o syslog é tão importante para o monitoramento de segurança, os servidores syslog podem ser um alvo para atores de ameaças.
- Algumas explorações, como as que envolvem exfiltração de dados, podem levar muito tempo para serem concluídas porque as formas pelas quais os dados são roubados secretamente da rede podem ser muito lentas.
- Os invasores de ameaças podem tentar ocultar o fato de que a exfiltração está ocorrendo. Eles atacam servidores syslog que contêm as informações que podem levar à detecção da exploração.
- Os hackers podem tentar bloquear a transferência de dados de clientes de syslog para servidores.
- Eles podem violar ou destruir dados de log ou o software que cria e transmite mensagens de log.
- A implementação do syslog de próxima geração (ng), (syslog-ng), oferece aprimoramentos que podem ajudar a evitar algumas das explorações que visam o syslog.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

NTP

- As mensagens do Syslog geralmente são carimbadas de data e hora.
- Isso permite que mensagens de diferentes fontes sejam organizadas pelo tempo para fornecer uma visão dos processos de comunicação de rede.
- Como as mensagens podem vir de muitos dispositivos, é importante que os dispositivos compartilhem um timeclock consistente.
- Uma maneira que isso pode ser alcançado é para os dispositivos usarem o Network Time Protocol (NTP).
- O NTP usa uma hierarquia de fontes de tempo autoritativas para compartilhar informações de tempo entre dispositivos na rede.
- O NTP opera na porta UDP 123.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

NTP (cont.)

- Como os eventos conectados a uma exploração podem deixar rastros em todos os dispositivos de rede em seu caminho para o sistema de destino, os carimbos de data/hora são essenciais para detecção.

- Atores de ameaças podem tentar atacar a infraestrutura NTP para corromper informações de tempo usadas para correlacionar eventos de rede registrados.

- Isso pode servir para ofuscar vestígios de explorações em curso.

- Além disso, os atores de ameaças têm sido conhecidos por usar sistemas NTP para direcionar ataques DDoS por meio de vulnerabilidades no software cliente ou servidor.

- Embora esses ataques não resultem necessariamente em dados de monitoramento de segurança corrompidos, eles podem interromper a disponibilidade da rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

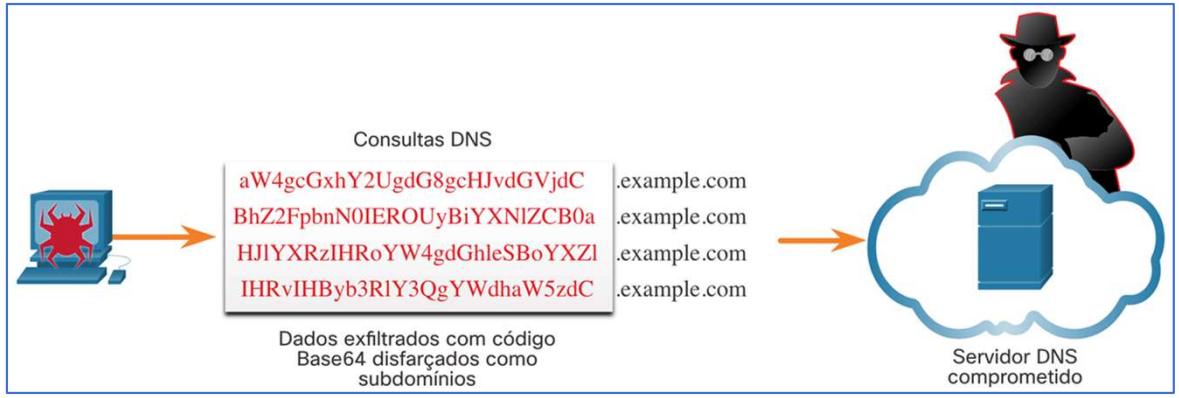
DNS

- O Serviço de Nome de Domínio (DNS) é usado por milhões de pessoas diariamente.
- Muitas organizações têm políticas menos rigorosas para proteger contra ameaças baseadas em DNS do que para proteger contra outros tipos de exploits.
- Os invasores reconheceram isso e geralmente encapsulam diferentes protocolos de rede no DNS para evitar dispositivos de segurança.
- O DNS agora é usado por muitos tipos de malware.
- Algumas variedades de malware usam DNS para se comunicar com servidores de comando e controle (CNC) e para exfiltrar dados no tráfego disfarçados como consultas DNS normais.
- Vários tipos de codificação, como Base64, binário de 8 bits e Hex podem ser usados para camuflar os dados e evitar medidas básicas de prevenção de perda de dados (DLP).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

DNS (cont.)

- Por exemplo, malware pode codificar dados roubados como a parte de subdomínio de uma pesquisa DNS para um domínio onde o servidor de nomes está sob controle de um invasor.
- Uma pesquisa de DNS para 'long string-of-exfiltrated-data.example.com' seria encaminhada para o servidor de nomes de example.com, que gravaria 'long string-of-exfiltrated-data' e responderia de volta ao malware com uma resposta codificada.
- Os dados exfiltrados são o texto codificado mostrado na caixa.
- O ator de ameaças coleta esses dados codificados, decodifica e combina e agora tem acesso a um arquivo de dados inteiro, como um banco de dados de nome de usuário/senha.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

DNS (cont.)

- É provável que a parte do subdomínio de tais solicitações seria muito mais longa do que as solicitações usuais.
- Analistas cibernéticos podem usar a distribuição dos comprimentos de subdomínios dentro de solicitações DNS para construir um modelo matemático que descreva a normalidade.
- Eles podem então usar isso para comparar suas observações e identificar um abuso do processo de consulta DNS.
- Consultas DNS para nomes de domínio gerados aleatoriamente, ou subdomínios com aparência aleatória extremamente longos, devem ser consideradas suspeitas, especialmente se a ocorrência deles aumentar drasticamente na rede.
- Os logs de proxy DNS podem ser analisados para detectar essas condições. Como alternativa, serviços como o serviço DNS passivo do Cisco Umbrella podem ser usados para bloquear solicitações para CNC suspeitos e domínios de exploração.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

HTTP e HTTPS

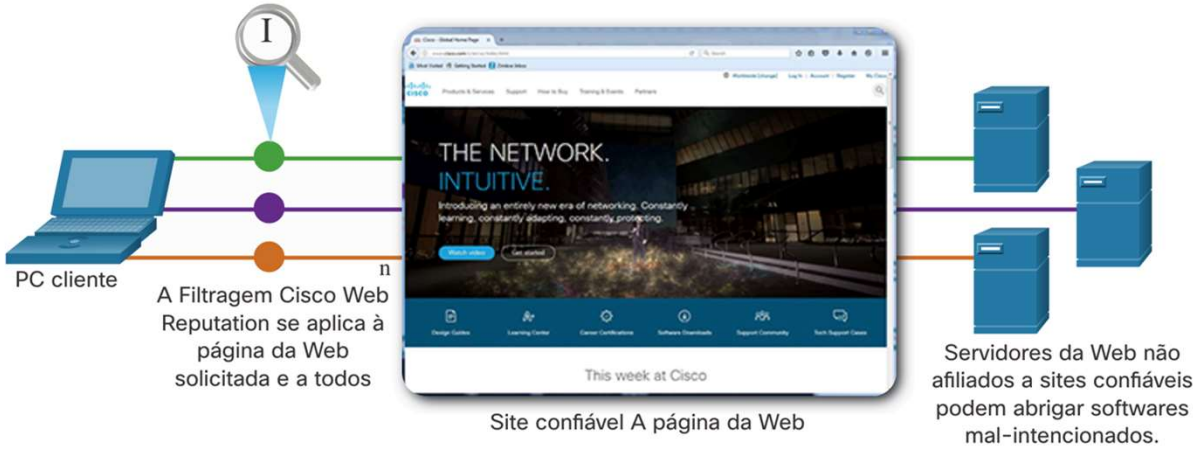
- O Hypertext Transfer Protocol (HTTP) é o protocolo de backbone da World Wide Web.
- No entanto, todas as informações transportadas em HTTP são transmitidas em texto simples do computador de origem para o destino na internet.
- O HTTP não protege os dados contra alteração ou interceptação por partes mal-intencionadas, o que é uma séria ameaça à privacidade, identidade e segurança das informações.
- Toda atividade de navegação deve ser considerada em risco.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

HTTP e HTTPS (cont.)

- Uma exploração comum de HTTP é chamada de injeção iFrame (quadro inline).
- Na injeção iFrame, um ator de ameaça compromete um servidor da Web e planta código malicioso que cria um iFrame invisível em uma página da Web comumente visitada.
- Quando o iFrame é carregado, o malware é baixado, freqüentemente de um URL diferente da página da Web que contém o código iFrame.
- Os serviços de segurança de rede, como a filtragem Cisco Web Reputation, podem detectar quando um site tenta enviar conteúdo de um site não confiável para o host, mesmo quando enviado de um iFrame.

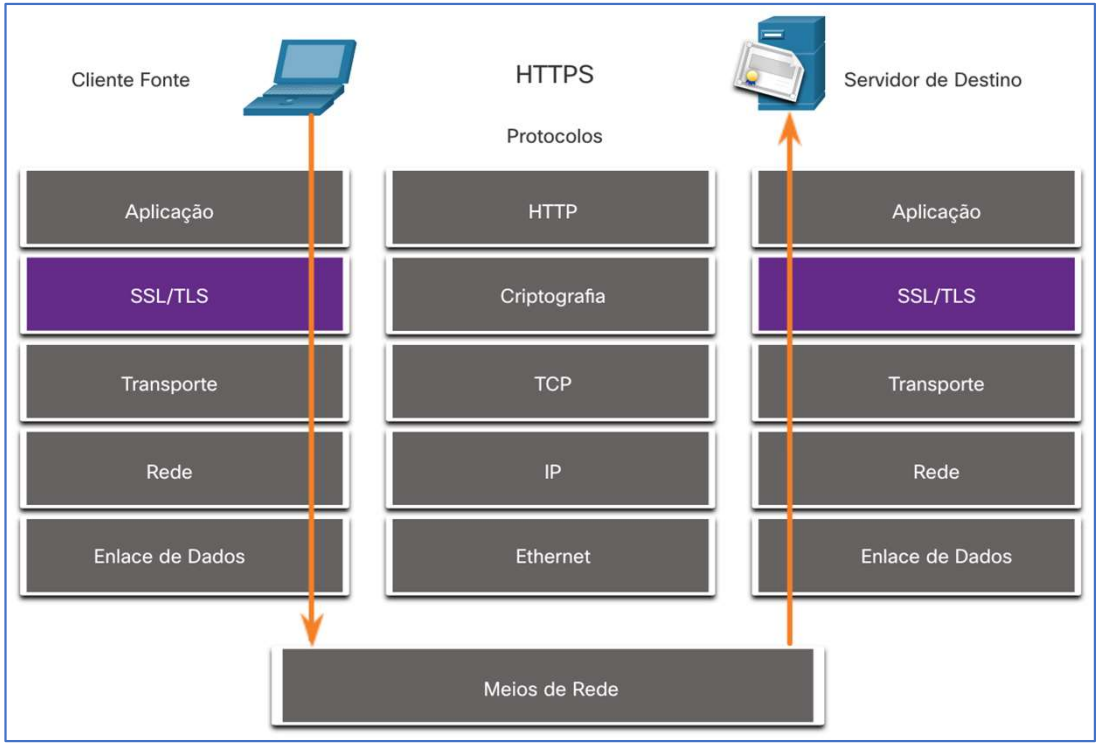


ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

HTTP e HTTPS (cont.)

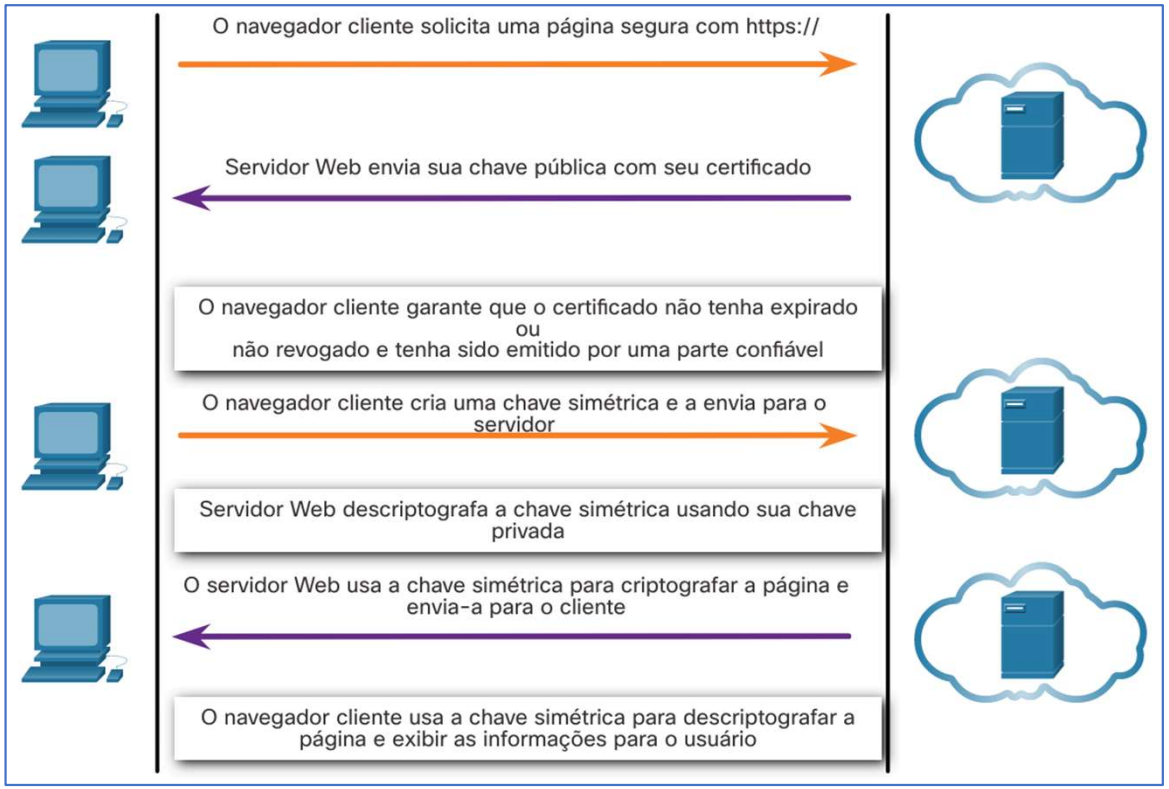
- Para lidar com a alteração ou interceptação de dados confidenciais, muitas organizações comerciais adotaram HTTPS ou implementaram políticas somente HTTPS para proteger os visitantes de seus sites e serviços.
- O HTTPS adiciona uma camada de criptografia ao protocolo HTTP usando Secure Socket Layer (SSL).
- Isso torna os dados HTTP ilegíveis, pois deixam o computador de origem até chegar ao servidor.
- Observe que HTTPS não é um mecanismo para a segurança do servidor Web. Ele só protege o tráfego de protocolo HTTP enquanto está em trânsito.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

HTTP e HTTPS (cont.)

- Infelizmente, o tráfego HTTPS criptografado complica o monitoramento de segurança de rede.
- Alguns dispositivos de segurança incluem descriptografia e inspeção SSL; no entanto, isso pode apresentar problemas de processamento e privacidade.
- Além disso, o HTTPS adiciona complexidade às capturas de pacotes devido às mensagens adicionais envolvidas no estabelecimento da conexão criptografada.
- Esse processo representa sobrecarga adicional sobre o HTTP.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Protocolos de e-mail

- Protocolos de e-mail como SMTP, POP3 e IMAP podem ser usados por atores de ameaças para espalhar malware, exfiltrar dados ou fornecer canais para servidores CNC de malware.
- SMTP envia dados de um host para um servidor de email e entre servidores de email. Como DNS e HTTP, é um protocolo comum para ver sair da rede.
- O SMTP foi usado no passado por malware para exfiltrar dados da rede.
- O monitoramento de segurança pode revelar esse tipo de tráfego de dados com base nos recursos da mensagem de e-mail.
- IMAP e POP3 são usados para baixar mensagens de email de um servidor de email para o computador host.
- Eles são os protocolos de aplicativos que são responsáveis por trazer malware para o host.
- O monitoramento de segurança pode identificar quando um anexo de malware entrou na rede e qual host ele infectou pela primeira vez.
- A análise retrospectiva pode então rastrear o comportamento do malware a partir desse ponto em diante.
- O comportamento do malware pode ser melhor compreendido e a ameaça identificada.
- As ferramentas de monitoramento de segurança também podem permitir a recuperação de anexos de arquivos infectados para envio a caixas de proteção de malware para análise.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Monitorando protocolos comuns

ICMP

- O ICMP tem muitos usos legítimos, no entanto, a funcionalidade do ICMP também foi usada para criar vários exploits.
- O ICMP pode ser usado para identificar hosts em uma rede, a estrutura de uma rede e para determinar os sistemas operacionais em uso na rede. Ele também pode ser usado como um veículo para vários tipos de ataques DoS.
- ICMP também pode ser usado para exfiltração de dados.
- Algumas variedades de malware usam pacotes ICMP criados para transferir arquivos de hosts infectados para agentes de ameaças usando o método de encapsulamento ICMP, como o exploit LOKI.
- Existem várias ferramentas para criar túneis. Procure na internet por Ping Tunnel para explorar uma dessas ferramentas.

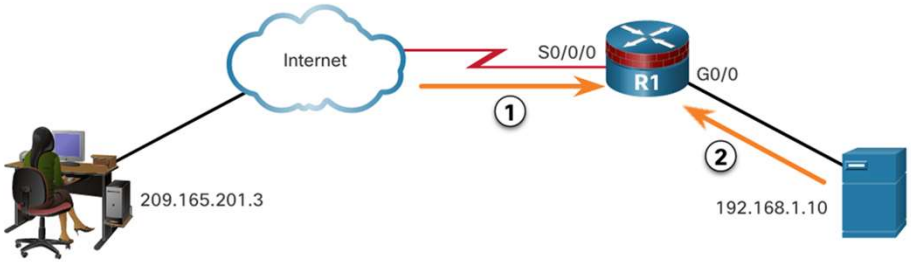
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.2 Tecnologias de Segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

ACLs

- Muitas tecnologias e protocolos podem ter impactos no monitoramento de segurança, como Access Control Lists (ACLs).
- ACLs são tecnologias que contribuem para um conjunto em evolução de proteções de segurança de rede, mas podem dar uma falsa sensação de segurança se forem excessivamente confiáveis.
- A figura ilustra o uso de ACLs para permitir apenas tipos específicos de tráfego de Internet Control (ICMP).
- O servidor em 192.168.1.10 faz parte da rede interna e tem permissão para enviar solicitações de ping para o host externo em 209.165.201.3.
- O tráfego ICMP de retorno do host externo é permitido se for uma resposta ICMP, extinção de origem (informa a origem para reduzir o ritmo do tráfego) ou qualquer mensagem ICMP inacessível.
- Todos os outros tipos de tráfego ICMP são negados.



1. Regras sobre R1 para tráfego ICMP da Internet

```
access-list 112 permit icmp any any echo-reply
access-list 112 permit icmp any any source-quench
access-list 112 permit icmp any any unreachable
access-list 112 deny icmp any any
access-list 112 permit ip any any
```

2. Regras sobre R1 para tráfego ICMP de dentro da rede

```
access-list 114 permit icmp 192.168.1.0 0.0.0.255 any echo
access-list 114 permit icmp 192.168.1.0 0.0.0.255 any parameter-problem
access-list 114 permit icmp 192.168.1.0 0.0.0.255 any packet-too-big
access-list 114 permit icmp 192.168.1.0 0.0.0.255 any source-quench
access-list 114 deny icmp any any
access-list 114 permit ip any any
```

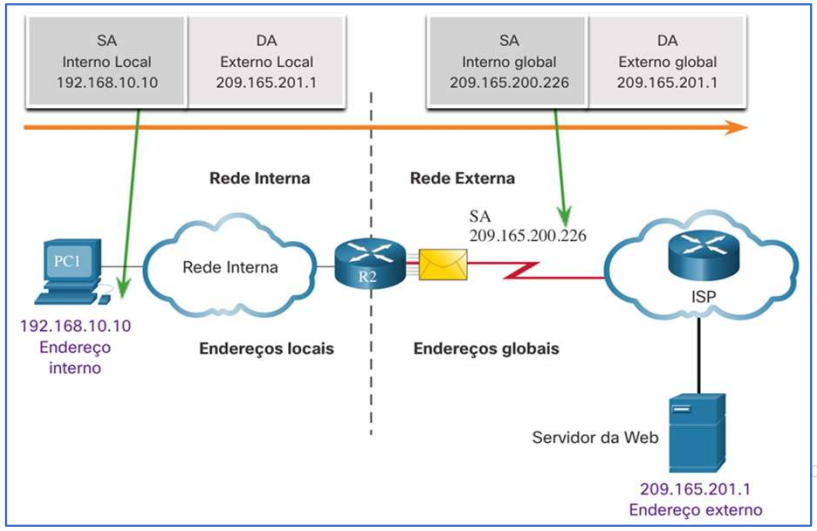
ACLs (cont.)

- Os invasores podem determinar quais endereços IP, protocolos e portas são permitidos pelas ACLs.
- Isso pode ser feito por varredura de portas, testes de penetração ou através de outras formas de reconhecimento.
- Os atacantes podem criar pacotes que usam endereços IP de origem falsificados.
- Os aplicativos podem estabelecer conexões em portas arbitrárias.
- Outros recursos do tráfego de protocolo também podem ser manipulados, como o sinalizador estabelecido em segmentos TCP.
- As regras não podem ser antecipadas e configuradas para todas as técnicas de manipulação de pacotes emergentes.
- Para detectar e reagir à manipulação de pacotes, um comportamento mais sofisticado e medidas baseadas em contexto precisam ser tomadas.
- Os firewalls Cisco Next Generation, Advanced Malware Protection (AMP), e-mail e dispositivos de conteúdo da Web podem solucionar as deficiências das medidas de segurança baseadas em regras.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

NAT e PAT

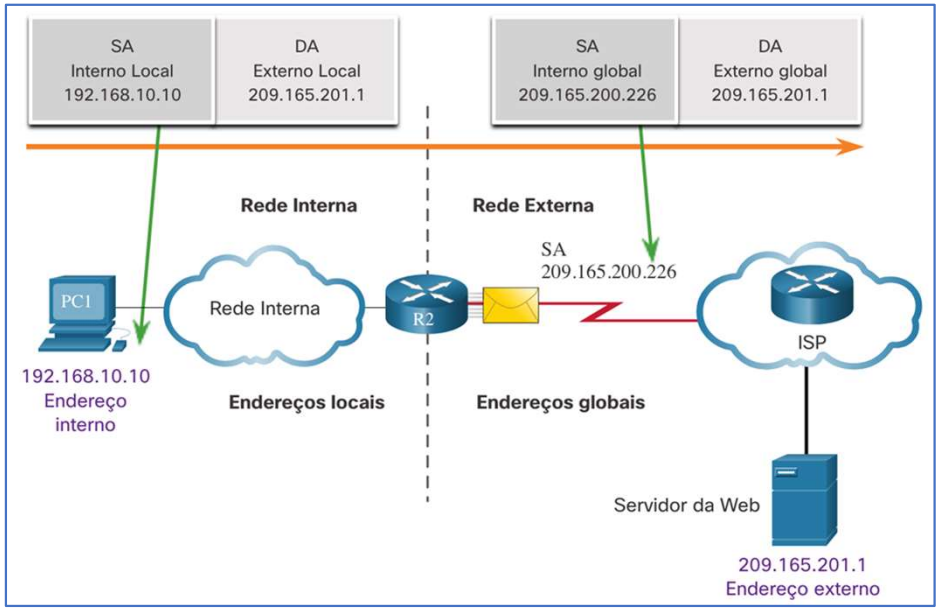
- Conversão de Endereços de Rede (NAT) e Tradução de Endereço de Porta (PAT) podem complicar o monitoramento de segurança.
- Vários endereços IP são mapeados para um ou mais endereços públicos visíveis na Internet, ocultando os endereços IP individuais que estão dentro da rede.
- Esse problema pode ser especialmente relevante com dados NetFlow.
- Os fluxos de NetFlow são unidirecionais e são definidos pelos endereços e portas que eles compartilham.
- O NAT basicamente quebrará um fluxo que passa por um gateway NAT, tornando as informações de fluxo além desse ponto indisponíveis.
- A Cisco oferece produtos de segurança que irão “costurar” fluir juntos mesmo que os endereços IP tenham sido substituídos pelo NAT.



© Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

NAT e PAT (cont.)

- A figura ilustra a relação entre endereços internos e externos que são usados como endereços de origem (SA) e endereços de destino (DA).
- Esses endereços internos e externos estão em uma rede que está usando NAT para se comunicar com um destino na Internet.
- Se o PAT estiver em vigor e todos os endereços IP que saem da rede usarem o endereço global 209.165.200.226 interno para tráfego na Internet, pode ser difícil registrar o dispositivo interno específico que está solicitando e recebendo o tráfego quando ele entra na rede.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Criptografia, encapsulamento e encapsulamento

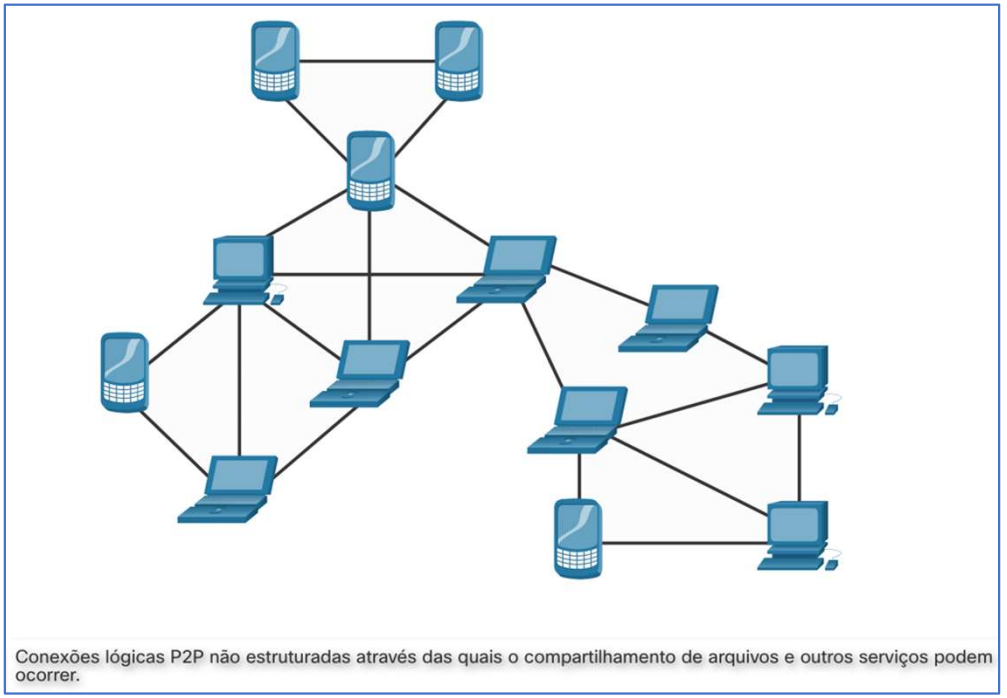
- Como mencionado com HTTPS, a criptografia pode apresentar desafios para o monitoramento de segurança tornando os detalhes do pacote ilegíveis.
- A criptografia faz parte das tecnologias VPN. O tráfego criptografado essencialmente estabelece uma conexão virtual ponto a ponto entre redes através de instalações públicas.
- A criptografia torna o tráfego ilegível para outros dispositivos, exceto os endpoints VPN.
- Uma tecnologia semelhante pode ser usada para criar uma conexão virtual ponto a ponto entre um host interno e dispositivos de atores de ameaças.
- O malware pode estabelecer um túnel criptografado que usa um protocolo comum e confiável e usá-lo para exfiltrar dados da rede.
- Um método semelhante de exfiltração de dados foi discutido para o DNS.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tecnologias de segurança

Rede ponto a ponto e Tor

- Na rede ponto a ponto (P2P), os hosts podem operar em funções de cliente e servidor.
- Existem três tipos de aplicativos P2P: compartilhamento de arquivos, compartilhamento de processadores e mensagens instantâneas.
- No compartilhamento de arquivos P2P, os arquivos em uma máquina participante são compartilhados com membros da rede P2P.
- Bitcoin é uma operação P2P que envolve o compartilhamento de um banco de dados distribuído, ou razão, que registra saldos e transações Bitcoin.
- BitTorrent é uma rede de compartilhamento de arquivos P2P.



Conexões lógicas P2P não estruturadas através das quais o compartilhamento de arquivos e outros serviços podem ocorrer.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Rede ponto a ponto e Tor (cont.)

- Sempre que usuários desconhecidos recebem acesso a recursos de rede, a segurança é uma preocupação.
- Aplicativos de compartilhamento de arquivos P2P não devem ser permitidos em redes corporativas.
- A atividade da rede P2P pode contornar as proteções de firewall e é um vetor comum para a propagação de malware.
- P2P é inerentemente dinâmico. Ele pode operar conectando-se a vários endereços IP de destino e também pode usar numeração dinâmica de portas.
- Arquivos compartilhados são frequentemente infectados com malware, e os atores de ameaças podem posicionar seu malware em clientes P2P para distribuição a outros usuários.
- Redes de compartilhamento de processador P2P doam ciclos de processador para tarefas computacionais distribuídas.
- Pesquisa de câncer, pesquisa de extraterrestres, e pesquisa científica usam ciclos de processador doados para distribuir tarefas computacionais.
- Mensagens instantâneas (IM) também é considerado um aplicativo P2P.
- IM tem valor legítimo dentro de organizações que têm equipes de projeto distribuídas geograficamente. Nesse caso, aplicativos de IM especializados estão disponíveis, como a plataforma Webex Teams, que são mais seguras do que as mensagens instantâneas que usam servidores públicos.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

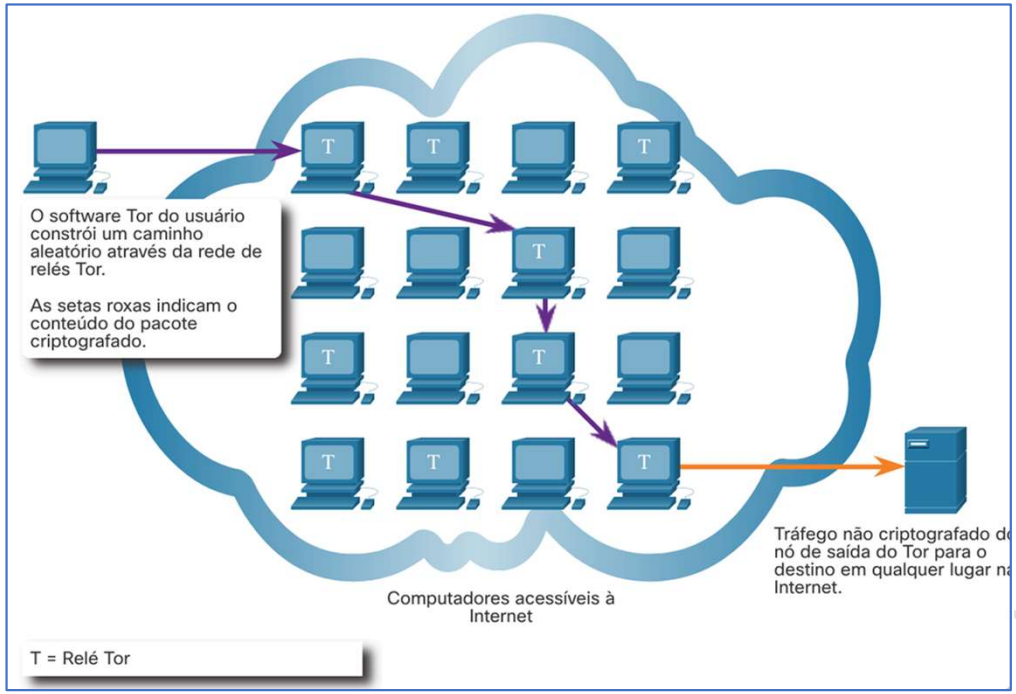
Rede ponto a ponto e Tor (cont.)

- Tor é uma plataforma de software e rede de hosts P2P que funcionam como roteadores de internet na rede Tor.
- A rede Tor permite que os usuários naveguem na Internet anonimamente usando um navegador especial.
- Quando uma sessão de navegação é iniciada, o navegador constrói um caminho em camadas de ponta a ponta na rede do servidor Tor que é criptografada.
- Cada camada criptografada é “removida” como as camadas de uma cebola (portanto, “onion routing”) à medida que o tráfego atravessa um retransmissor do Tor.
- As camadas contêm informações criptografadas do próximo salto que só podem ser lidas pelo roteador que precisa ler as informações.
- Dessa forma, nenhum dispositivo único conhece todo o caminho para o destino e as informações de roteamento só podem ser lidas pelo dispositivo que as requer.
- Finalmente, no final do caminho do Tor, o tráfego atinge seu destino na internet. Quando o tráfego é retornado à origem, um caminho criptografado em camadas é construído novamente.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Rede ponto a ponto e Tor (cont.)

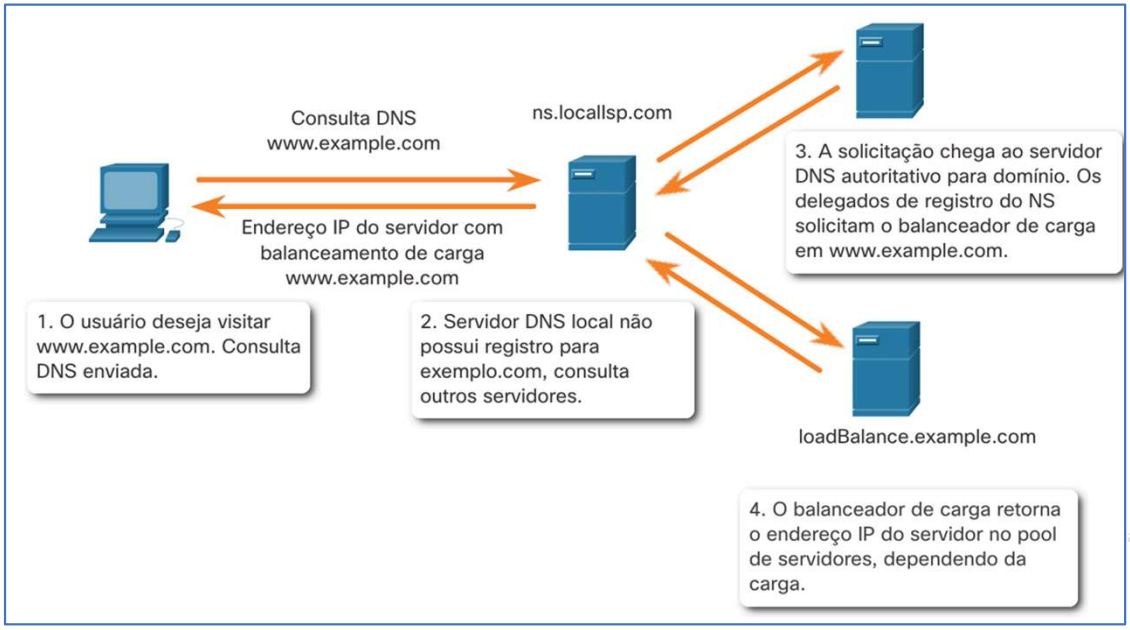
- O Tor apresenta vários desafios para os analistas de segurança cibernética.
- Primeiro, o Tor é amplamente utilizado por organizações criminosas na “Dark Net”.
- Além disso, Tor tem sido usado como um canal de comunicação para malware CNC.
- Como o endereço IP de destino do tráfego Tor é ofuscado pela criptografia, com apenas o nó Tor de próximo salto conhecido, o tráfego Tor evita listas negras configuradas em dispositivos de segurança.



u suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Balanceamento de carga

- O balanceamento de carga envolve a distribuição do tráfego entre dispositivos ou caminhos de rede para evitar recursos de rede sobrecarregados com muito tráfego.
- Se existirem recursos redundantes, um algoritmo ou dispositivo de balanceamento de carga funcionará para distribuir o tráfego entre esses recursos, conforme mostrado na figura.
- Uma maneira de fazer isso na internet é através de várias técnicas que usam DNS para enviar tráfego para recursos que têm o mesmo nome de domínio, mas vários endereços IP.



as afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Balanceamento de carga (cont.)

- Em alguns casos, a distribuição do serviço pode ser para servidores distribuídos geograficamente.
- Isso pode resultar em uma única transação de Internet sendo representada por vários endereços IP nos pacotes de entrada.
- Isso pode fazer com que recursos suspeitos apareçam em capturas de pacotes.
- Além disso, alguns dispositivos do gerenciador de balanceamento de carga (LBM) usam testes para testar o desempenho de diferentes caminhos e a integridade de diferentes dispositivos.
- Por exemplo, um LBM pode enviar sondagens para os diferentes servidores em que está balanceando a carga do tráfego para detectar se os servidores estão operando.
- Isso é feito para evitar o envio de tráfego para um recurso que não está disponível.
- No entanto, essas sondagens podem parecer tráfego suspeito se o analista de segurança cibernética não souber que esse tráfego faz parte da operação do LBM.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

9.3 Resumo de tecnologias e protocolos

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 10: Dados de Segurança de Rede

Defesa de rede

Objetivos do Módulo

Título do Módulo: Dados de segurança de Rede

Objetivo do Módulo: Usar diferentes tipos de logs e registros para armazenar informações sobre hosts e a rede.

Título do Tópico	Objetivo do Tópico
Tipos de Dados de Segurança	Descreva os tipos de dados usados no monitoramento de segurança.
Logs de Dispositivos Finais	Descrever os elementos de um arquivo de log de dispositivo final.
Logs de Rede	Usar diferentes tipos de serviços para coletar dados de rede.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.1 Tipos de Dados de Segurança

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados de Segurança

Dados de Alerta

- Dados de alerta consiste de mensagens geradas por IPS ou IDS em resposta ao tráfego que viola uma regra ou corresponde à assinatura de um exploit conhecido.

- Um IDS de rede (NIDS), como o Snort, vem configurado com regras para explorações conhecidas.

- Os alertas são gerados pelo Snort e são legíveis e pesquisáveis pelos aplicativos Sguil e Squert, que fazem parte do conjunto Security Onion de ferramentas NSM.

- Um site de teste usado para determinar se o Snort está funcionando é o site tesmyids.
  - Ele consiste em uma única página da Web que exibe apenas o seguinte texto **uid=0(root) gid=0(root) groups=0(root)**.
  - Se o Snort estiver funcionando corretamente e um host visitar este site, uma assinatura será correspondida e um alerta será acionado.
  - Esta é uma maneira fácil e inofensiva de verificar se o NIDS está em execução.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados de Segurança

Dados de Alerta (Cont.)

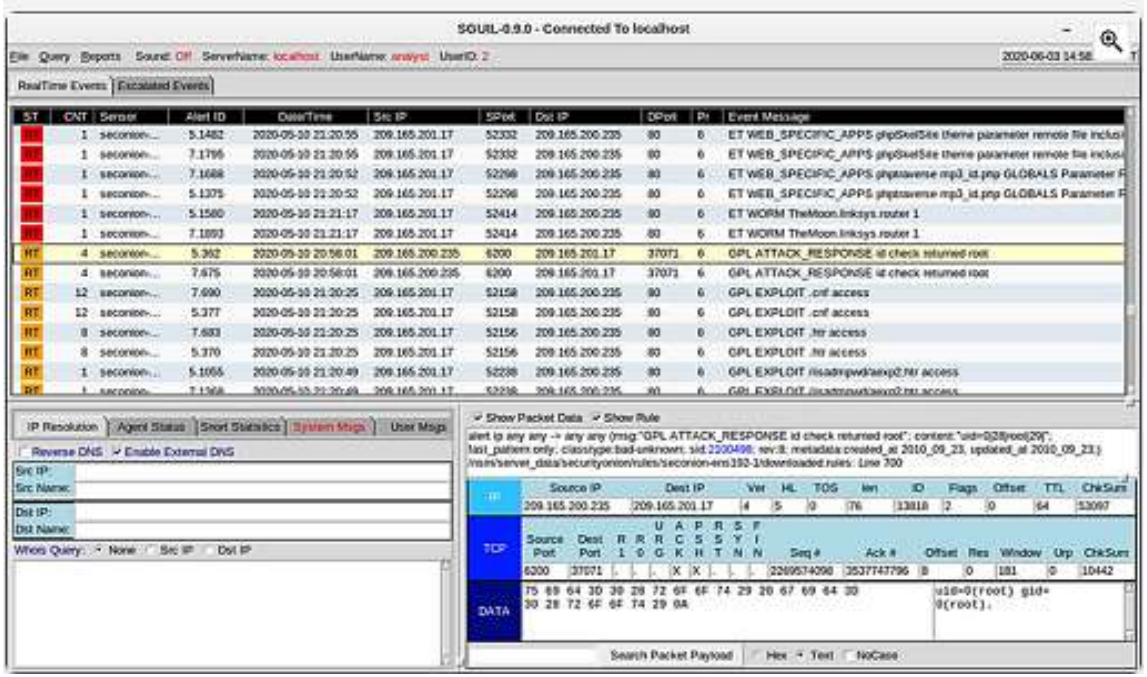
- A regra Snort acionada é:
  alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root"; content:"uid=0|28|root|29|"; fast_pattern:only; classtype:bad-unknown; sid:2100498; rev:8;)

- Esta regra gera um alerta se **qualquer endereço IP** na rede receber dados de uma fonte externa que contenha conteúdo com texto correspondente ao padrão de **uid=0(root)**.

- O alerta contém a mensagem **GPL ATTACK_RESPONSE id check returned root**.

- O ID da regra Snort que foi acionada é **2100498**.

- A linha destacada na figura exibe um alerta Sguil que foi gerado visitando o site testmyids.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados de Segurança

Dados de Sessão e Transação

- Dados de sessão é um registro de uma conversa entre dois pontos de extremidade de rede (geralmente, cliente e um servidor).
- O servidor pode estar dentro da rede corporativa ou em um local acessado pela Internet.
- Dados de sessão são dados sobre a sessão, não os dados recuperados e usados pelo cliente.
- Eles incluirão informações de identificação, como as **cinco tuplas** de endereços IP de origem e destino, números de porta de origem e destino, e o código IP do protocolo em uso.
- Os dados sobre a sessão geralmente incluem um ID de sessão, a quantidade de dados transferidos por origem e destino e informações relacionadas à duração da sessão.
- A figura no slide a seguir mostra uma saída parcial para três sessões HTTP de um log de conexão Zeek (uma ferramenta de monitoramento de segurança de rede).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados de Sessão e Transação (Cont.)



1	2	3	4	5	6	7	8	9	10	11	12	13
ts	uid	id.orig_h	id.orig_p	id.resp_h	id.resp_p	proto	service	duration	orig_bytes	resp_bytes	orig_pkts	resp_pkts
1320279567	CEvt2Z54N5gT3PwJLog	192.168.2.76	52034	174.129.249.33	80	tcp	http	0.082899	389	1495	5	4
1320279567	C6lUeb3SkSJHwASNN4	192.168.2.76	52035	184.72.234.3	80	tcp	http	2.56194	905	731	9	8
1320279567	CaTMSv1Sb8HtFunqj	192.168.2.76	52033	184.72.234.3	80	tcp	http	3.345539	1856	1445	15	13

1. **ts**: carimbo de data e hora
2. **uid**: ID de sessão única
3. **id.orig_h**: Endereço IP do host que originou a sessão (endereço de origem)
4. **id.orig_p**: porta de protocolo para o host de origem (porta de origem)
5. **id.resp_h**: Endereço IP do host que responde ao host de origem (endereço de destino)
6. **id.resp_p**: protocolo de host respondente (porta de destino)
7. **proto**: protocolo de camada de transporte para sessão
8. **service**: protocolo de camada de aplicativo
9. **duration**: duração da sessão
10. **orig_bytes**: bytes do host de origem
11. **resp_bytes**: bytes do host respondente
12. **orig_packets**: pacotes do host de origem
13. **resp_packets**: pacotes do host respondente

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Dados de Sessão e Transação (Cont.)

- Dados de Transação consistem de mensagens trocadas durante sessões de rede e podem ser visualizadas na transcrição de captura de pacotes

- Os logs de dispositivos mantidos por servidores também contêm informações sobre as transações que ocorrem entre clientes e servidores.

- Uma sessão pode incluir o download de conteúdo de um servidor web, como mostrado na figura.

- As transações que representam as solicitações e respostas seriam registradas em um log de acesso no servidor ou por um NIDS como Zeek.

- A sessão é todo o tráfego envolvido na elaboração da solicitação, a transação é a própria solicitação.

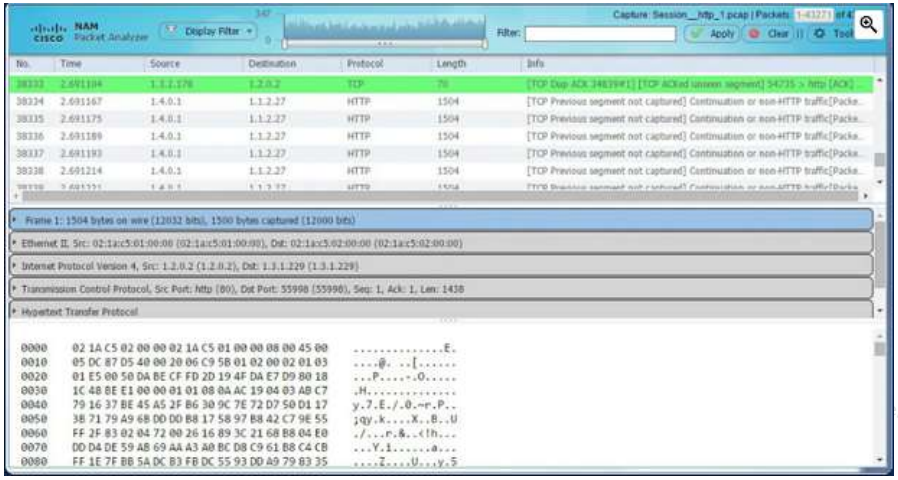


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados de Segurança

Capturas de Pacotes Completos

- As capturas completas de pacotes são os dados de rede mais detalhados que geralmente são coletados e os tipos de dados mais intensivos em armazenamento e recuperação usados no NSM.
- Eles contêm dados sobre conversas de rede (dados de sessão), o conteúdo real das conversas, o texto de mensagens de e-mail, o HTML em páginas da web e os arquivos que entram ou saem da rede.
- O conteúdo extraído pode ser recuperado de capturas completas de pacotes e analisado quanto a malware ou comportamento do usuário que viola as políticas de negócios e de segurança.
- A figura ilustra a interface do componente Monitor de Análise de Rede do sistema Cisco Prime Infrastructure, que, como o Wireshark, pode exibir capturas completas de pacotes.



/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados de Segurança

Dados Estatísticos

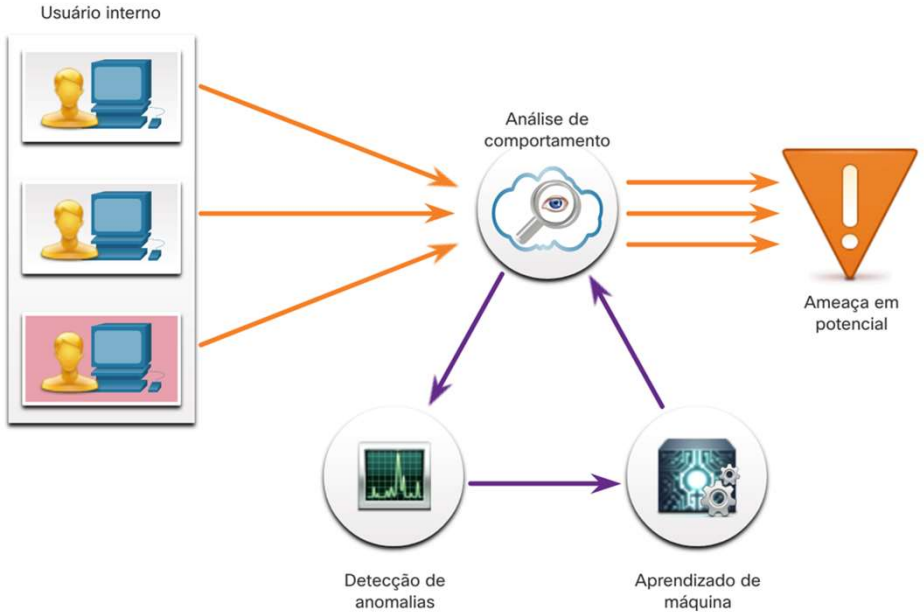
- Dados estatísticos são sobre o tráfego de rede que é criado através da análise de outras formas de dados de rede.
- As características estatísticas do comportamento normal da rede podem ser comparadas ao tráfego de rede atual para detectar anomalias.
- Estatísticas podem ser usadas para caracterizar quantidades normais de variação nos padrões de tráfego de rede , a fim de identificar condições de rede que estão significativamente fora desses intervalos.
- Diferenças estatisticamente significativas devem gerar alarmes e investigação imediata.
- A NBA (Network Behavior Analysis) e a Network Behavior Anomaly Detection (NBAD) são abordagens para monitoramento de segurança de rede que usam técnicas analíticas avançadas para analisar dados de telemetria de rede NetFlow ou IPFIX (Internet Protocol Flow Information Export).
- Técnicas como análise preditiva e inteligência artificial realizam análises avançadas de dados de sessão detalhados para detectar possíveis incidentes de segurança.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tipos de Dados de Segurança

Dados Estatísticos (Cont.)

- Cisco Cognitive Threat Analytics é um exemplo de uma ferramenta NSM que utiliza análise estatística, como mostrado na figura.
- Ele encontra atividades maliciosas que contornaram os controles de segurança ou entraram na rede por meio de canais não monitorados (incluindo mídia removível) e estão operando dentro do ambiente de uma organização.
- É um produto baseado em nuvem que usa aprendizado de máquina e modelagem estatística de redes, criando uma linha de base do tráfego em uma rede e identificando anomalias.
- Ele analisa o comportamento do usuário e do dispositivo e o tráfego da Web para descobrir comunicações de comando e controle, exfiltração de dados e aplicativos potencialmente indesejados que operam na infraestrutura.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.2 Logs de dispositivo final

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Dispositivos Finais

Logs do host

- Os sistemas de detecção de intrusão baseados em host (HIDS) podem detectar e prevenir invasões.
- Ele cria logs e os armazena no host e muitas proteções baseadas em host têm uma maneira de enviar logs para servidores de gerenciamento de log centralizado.
- Os sistemas HIDS podem usar agentes para enviar logs para servidores de gerenciamento e os logs podem ser pesquisados de um local central usando ferramentas NSM.
- Os logs de host do Microsoft Windows são visíveis localmente pelo Visualizador de Eventos, que mantém cinco tipos de logs:
  - **Logs de aplicativos** – Eles contêm eventos registrados por vários aplicativos.
  - **Logs do sistema** – Isso inclui eventos relacionados à operação de drivers, processos e hardware.
  - **Logs de instalação** – Estes registram informações sobre a instalação de software, incluindo atualizações do Windows.
  - **Logs de segurança** – Esses eventos registram relacionados à segurança, como tentativas de logon e operações relacionadas ao gerenciamento e acesso de arquivos ou objetos.
  - **Logs de linha de comando** – Os invasores que obtiveram acesso a um sistema e alguns tipos de malware executam comandos da interface de linha de comando (CLI) em vez de uma GUI.
- Vários logs podem ter diferentes tipos de eventos.
- Os logs de segurança consistem apenas em mensagens de falha ou êxito de auditoria.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Dispositivos Finais

Logs do host (Cont.)

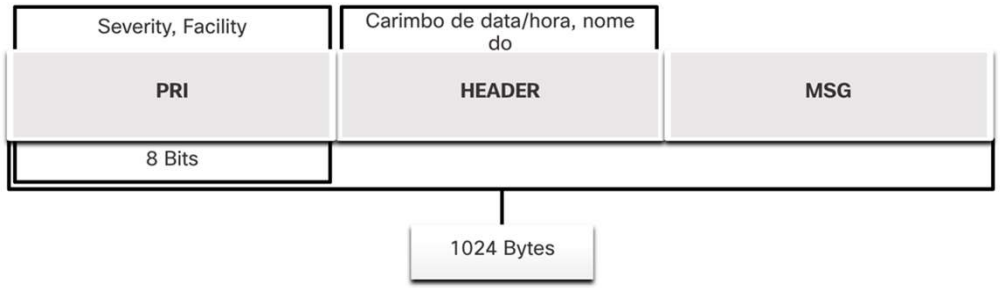
- Os Eventos do Windows são identificados por números de ID e descrições breves.
- Uma enciclopédia de IDs de eventos de segurança, algumas com detalhes adicionais, está disponível no Ultimate Windows Security na Web.
- A tabela explica o significado dos cinco tipos de eventos de log de host do Windows.

Tipo de evento	Descrição
Erro	É um evento que indica um problema significativo, como perda de dados ou perda de funcionalidade.
Aviso	Trata-se de um evento que não é necessariamente significativo, mas que pode indicar um possível problema futuro. Se um aplicativo pode se recuperar de um evento sem perda de funcionalidade ou dados, ele geralmente pode classificar o evento como um evento de aviso.
Informações	Ele descreve a operação bem-sucedida de um aplicativo, driver ou serviço. Observe que geralmente é inapropriado para um aplicativo de área de trabalho registrar um evento cada vez que ele é iniciado.
Auditoria de Sucesso	É um evento que registra uma tentativa de acesso de segurança auditada com êxito.
Auditoria de Falha	É um evento que registra uma tentativa de acesso de segurança auditada que falha.

Logs de Dispositivos Finais

Syslog

- O Syslog inclui especificações para formatos de mensagem, uma estrutura de aplicativos cliente-servidor e protocolo de rede.
- Muitos tipos diferentes de dispositivos de rede podem ser configurados para usar o padrão syslog para registrar eventos em servidores syslog centralizados.
- O remetente do Syslog envia uma pequena mensagem de texto (menos de 1 KB) para o receptor do Syslog ("syslogd", "Syslog daemon," ou "Syslog server").
- As mensagens Syslog podem ser enviadas via UDP (porta 514) e/ou TCP (normalmente, porta 5000), normalmente em texto simples pela rede.
- Uma mensagem Syslog vista na rede tem três partes distintas:.
  - **O PRI** (priority): dois elementos, a Facilidade e a Gravidade da mensagem (valores inteiros).
  - HEADER : o registro de data e hora no formato MMM DD HH:MM:SS e o nome do host ou endereço IP do dispositivo que é a origem da mensagem.
  - **MSG** (texto da mensagem): o significado da mensagem syslog.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Dispositivos Finais

Syslog (cont.)

- A Facilidade(Facility) consiste em amplas categorias de fontes que geraram a mensagem (sistema, processo ou aplicação).
- O valor PRI é calculado da seguinte forma **Prioridade = (Facility* 8) + Gravidade**
- A gravidade é um valor de 0 a 7 que define a gravidade da mensagem.

Valor	Severidade
0	**Emergência**: o sistema está inutilizável
1	**Alerta**: a ação deve ser tomada imediatamente
2	**Crítico**: condições críticas que devem ser corrigidas imediatamente e indica falha em um sistema
3	**Erro**: uma falha que não é urgente, deve ser resolvida dentro de um determinado tempo
4	**Aviso**: um erro não existe atualmente; no entanto, um erro ocorrerá no futuro se a condição não for resolvida
5	**Aviso**: Qual ferramenta está incluída no Security Onion que é usada pelo Snort para baixar automaticamente novas regras?
6	**Informativo**: mensagens emitidas relativas ao funcionamento normal
7	**Depuração**: mensagens de interesse para desenvolvedores

Logs do servidor

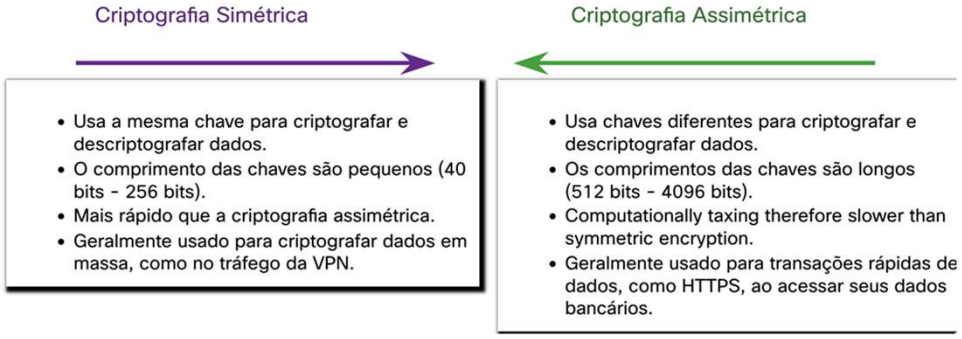
- Os logs do servidor são uma fonte essencial de dados para o monitoramento da segurança da rede.
- Os servidores de aplicativos de rede, como servidores de e-mail e Web, mantêm registros de acesso e erros.
- Os logs do servidor proxy DNS que documentam todas as consultas DNS e respostas que ocorrem na rede são especialmente importantes.
- Os logs de proxy DNS são úteis para identificar hosts que possam ter visitado sites perigosos e para identificar a exfiltração de dados DNS e conexões a servidores de comando e controle de malware.
- Muitos servidores UNIX e Linux usam syslog.
- Outros podem usar o registro proprietário. O conteúdo dos eventos do arquivo de log depende do tipo de servidor.
- Dois arquivos de log importantes para se familiarizar são os logs de acesso do servidor web Apache e os logs de acesso do Microsoft Internet Information Server (IIS).

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

SIEM e Coleta de Logs

- A tecnologia SIEM (Security Information and Event Management, gerenciamento de eventos e informações de segurança) é usada em muitas organizações para fornecer relatórios em tempo real e análise de longo prazo de eventos de segurança, conforme mostrado na figura.
- Ele combina as funções essenciais de gerenciamento de eventos de segurança (SEM) e ferramentas de gerenciamento de informações de segurança (SIM) para fornecer uma visão abrangente da rede empresarial usando as seguintes funções:
  - **Coleta de logs** – Coleta registros de eventos de origens em toda a organização.
  - **Normalização** – mapeia mensagens de log de diferentes sistemas em um modelo de dados comum
  - **Correlação** – Vincula logs e eventos de sistemas ou aplicativos diferentes.
  - **Agregação** – Reduz o volume de dados de eventos consolidando registros de eventos duplicados.
  - **Relatórios** – Apresenta os dados de eventos agregados e correlacionados em monitoramento em tempo real e resumos de longo prazo, incluindo painéis gráficos interativos.
  - **Conformidade** – são relatórios para atender aos requisitos de várias regulamentações de conformidade.

Entradas e Saídas SIEM



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

SIEM e Coleta de Logs (Cont.)

- Um SIEM popular é o Splunk, feito por um parceiro da Cisco, e é amplamente utilizado em SOCs.

- O SOAR pega o SIEM e vai além para automatizar fluxos de trabalho de resposta de segurança e facilitar a resposta a incidentes.

- Devido à importância da segurança de rede, inúmeras empresas trouxeram excelentes produtos para o mercado de ferramentas de segurança.

- No entanto, essas ferramentas não têm compatibilidade e exigem monitoramento de vários painéis de produtos independentes para processar os muitos alertas que eles geram.

- Devido à falta de profissionais de segurança cibernética para monitorar e analisar o grande volume de dados de segurança, é importante que as ferramentas de vários fornecedores possam ser integradas em uma única plataforma.

Painel de ameaças do Splunk



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.3 Logs de Rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Tcpdump

Um Domínio de Broadcast Grande



- A ferramenta de linha de comando tcpdump é um analisador de pacotes muito popular.
- Ele pode exibir capturas de pacotes em tempo real ou gravar capturas de pacotes em um arquivo.
- Ele captura dados detalhados de protocolo de pacotes e conteúdo.
- Wireshark é uma GUI construída sobre a funcionalidade tcpdump.
- A estrutura das capturas tcpdump varia dependendo do protocolo capturado e dos campos solicitados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Rede

NetFlow

- NetFlow é um protocolo desenvolvido pela Cisco como uma ferramenta para solução de problemas de rede e contabilidade baseada em sessão.
- Ele fornece eficientemente um importante conjunto de serviços para aplicações IP.
- Ele fornece informações valiosas sobre usuários e aplicativos de rede, tempos de uso de pico e roteamento de tráfego.
- Ele não faz uma captura completa do pacote ou captura o conteúdo real do pacote.
- Ele registra informações sobre o fluxo de pacotes, incluindo metadados.
- As informações do NetFlow podem ser visualizadas com ferramentas como o nfdump, que fornece um utilitário de linha de comando para visualizar os dados do NetFlow do daemon de captura nfcapd ou coletor.

Painel de dados da sessão do NetFlow Flow



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

NetFlow (cont.)

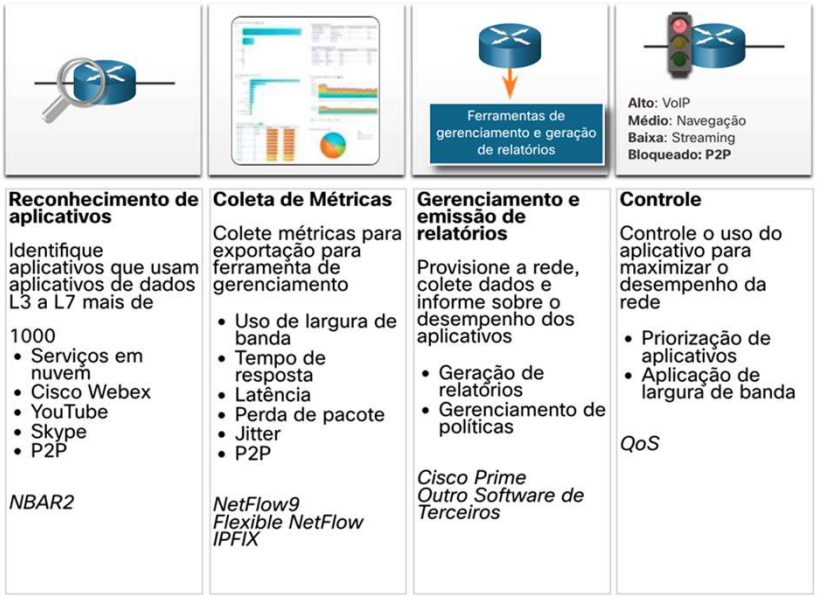
- Tradicionalmente, um Fluxo de IP é baseado em um conjunto de 5 a 7 atributos de pacotes IP que fluem em uma única direção.
- Um fluxo consiste em todos os pacotes transmitidos até que a conversa TCP termine.
- Os atributos de pacote IP usados pelo NetFlow são:
  - Endereço IP origem
  - Endereço IP de destino
  - Porta de origem
  - Porta de destino
  - Tipo de protocolo da camada 3
  - Classe de Serviço
  - Interface de roteador ou switch
- Todos os pacotes com o mesmo endereço IP de origem/destino, portas de origem/destino, interface de protocolo e classe de serviço são agrupados em um fluxo e, em seguida, pacotes e bytes são contabilizados.
- Essa metodologia de impressão digital ou determinação de um fluxo é escalável porque uma grande quantidade de informações de rede é condensada em um banco de dados de informações do NetFlow chamado cache do NetFlow.
- Todos os registros de fluxo NetFlow conterão os primeiros cinco itens na lista acima e carimbos de data/hora de início e fim do fluxo.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visibilidade e Controle de Aplicações

- O sistema AVC (Visibilidade e Controle de Aplicações) da Cisco combina várias tecnologias para reconhecer, analisar e controlar mais de 1000 aplicativos (voz e vídeo, e-mail, compartilhamento de arquivos, jogos, ponto a ponto (P2P) e aplicativos baseados em nuvem)
- A AVC usa o Cisco Next Generation Network-Based Application Recognition (NBAR2) para descobrir e classificar os aplicativos em uso na rede.
- A identificação de aplicativos de rede por porta fornece pouca granularidade e visibilidade do comportamento do usuário.

Cisco Application Visibility and Control (AVC)



o e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

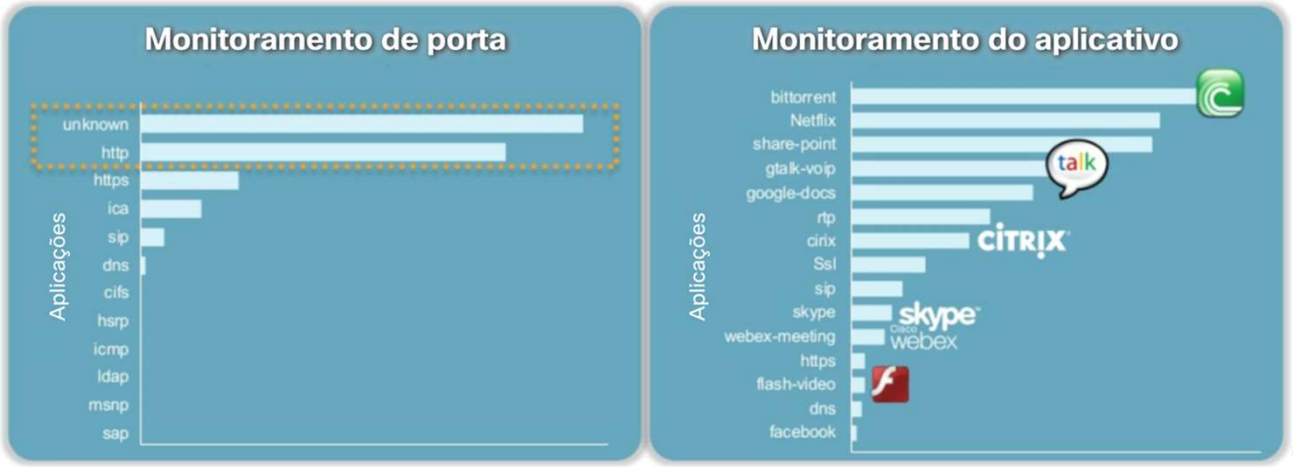
Logs de Rede

Visibilidade e Controle de Aplicações (Cont.)

- Um sistema de gerenciamento e geração de relatórios, como o Cisco Prime, analisa e apresenta os dados de análise de aplicativos em relatórios de painel para uso pelo pessoal de monitoramento de rede.

- O uso de aplicações também pode ser controlado por meio de políticas e classificação de qualidade de serviço com base nas informações do AVC.

Monitoramento de Portas versus



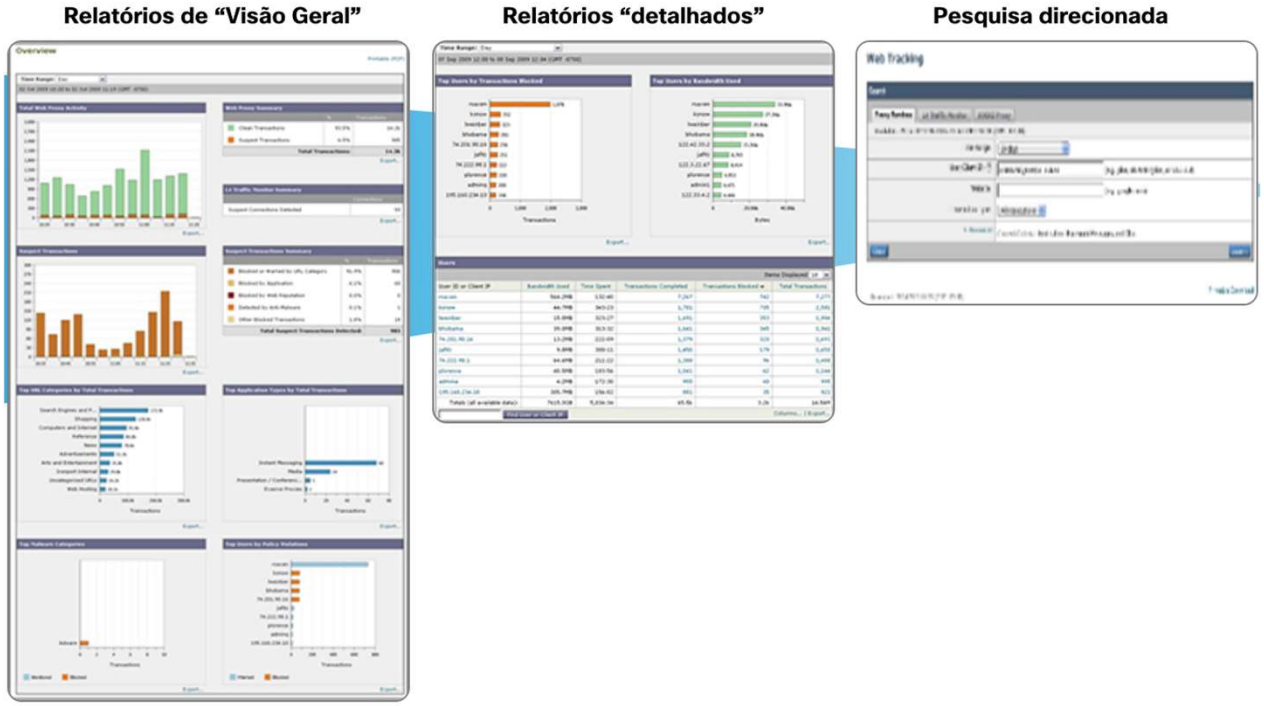
Logs de Filtro de Conteúdo

- Os dispositivos que fornecem filtragem de conteúdo, como o Cisco ESA e o Cisco WSA, fornecem uma ampla gama de funcionalidades para monitoramento de segurança.
- O log está disponível para muitas dessas funcionalidades.
- O ESA tem mais de 30 logs que podem ser usados para monitorar a maioria dos aspectos da entrega de e-mail, funcionamento do sistema, antivírus, operações antispam e decisões de lista negra e lista branca.
- A maioria dos logs são armazenados em arquivos de texto e podem ser coletados em servidores syslog, ou podem ser enviados para servidores FTP ou SCP.
- Umlerts sobre o funcionamento do próprio equipamento e seus subsistemas pode ser monitorado por e-mail para administradores responsáveis pelo monitoramento e operação do dispositivo.
- Os dispositivos WSA oferecem uma profundidade de funcionamento semelhante.
- O WSA atua efetivamente como um proxy da Web, o que significa que ele registra todas as informações de transação de entrada e saída para tráfego HTTP.
- O WSA pode ser configurado para enviar os logs para um servidor de várias maneiras, incluindo syslog, FTP e SCP.
- Outros logs disponíveis para o WSA: logs de decisão da ACL, logs de varredura de malware e logs de filtragem de reputação da Web.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Filtro de Conteúdo (Cont.)

- A figura ilustra os painéis de “detalhamento” disponíveis nos dispositivos de filtragem de conteúdo da Cisco.
- Ao clicar em componentes dos relatórios Visão geral, detalhes mais relevantes são exibidos.
- As buscas de destino fornecem as informações mais focadas.

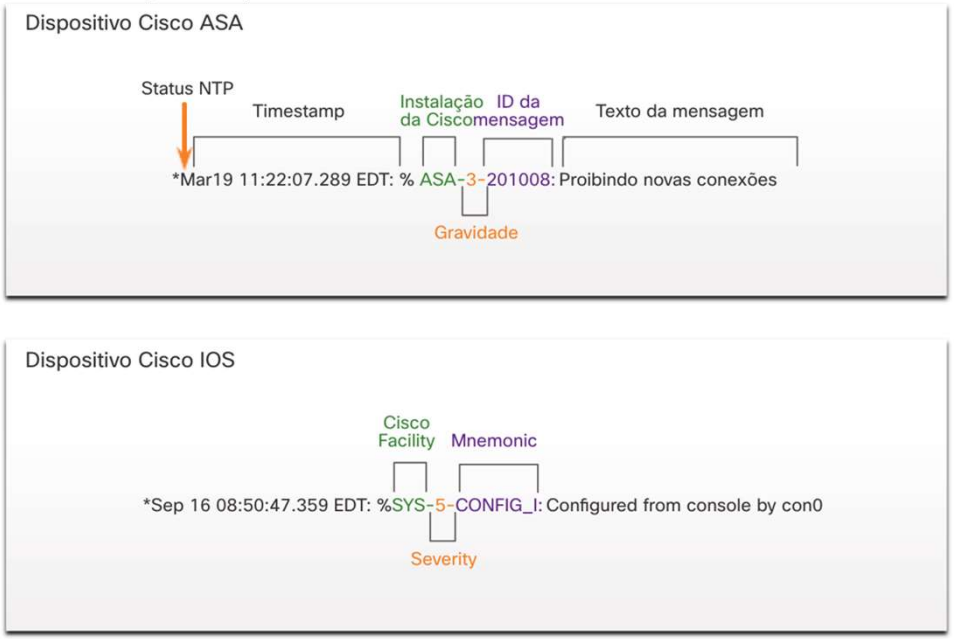


© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Dispositivos Cisco

- A figura ilustra uma mensagem syslog gerada por um dispositivo Cisco ASA e uma mensagem syslog gerada por um dispositivo Cisco IOS.
- Os dispositivos de segurança Cisco podem ser configurados para enviar eventos e alertas para plataformas de gerenciamento de segurança usando SNMP ou syslog.
- Há dois significados usados para o recurso termo em mensagens syslog da Cisco.
- O primeiro é o conjunto padrão de valores de Facilidade que foram estabelecidos pelos padrões syslog.
- Esses valores são usados na parte da mensagem PRI do pacote syslog para calcular a prioridade da mensagem.
- O outro valor Facility é atribuído pela Cisco e ocorre na parte MSG da mensagem syslog.
- Dispositivos Cisco podem usar formatos de mensagem syslog ligeiramente diferentes e podem usar mnemônicos em vez de IDs de mensagem.

Formatos de mensagens Cisco Syslog



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Redde

Logs de Proxy

- Servidores proxy são dispositivos que atuam como intermediários para clientes de rede que contêm logs valiosos que são uma fonte primária de dados para monitoramento de segurança de rede.
- Uma empresa pode configurar um proxy da web para lidar com solicitações da Web em nome de clientes.
- Em vez de solicitações de recursos da Web serem enviadas diretamente para o servidor do cliente, a solicitação é enviada primeiro para um servidor proxy.
- O servidor proxy solicita os recursos e os retorna ao cliente e gera logs de todas as solicitações e respostas.
- Os logs podem ser analisados para determinar quais hosts estão fazendo as solicitações, se os destinos são seguros ou potencialmente maliciosos, e também para obter insights sobre o tipo de recursos que foram baixados.
- Proxies da Web fornecem dados que ajudam a determinar se as respostas da Web foram geradas em resposta a solicitações legítimas ou foram manipuladas para parecer respostas, mas são, de fato, explorações.
- É possível usar proxies da web para inspecionar o tráfego de saída como meio de DLP, que envolve a verificação do tráfego de saída para detectar se os dados que estão saindo da web contêm informações sigilosas, confidenciais ou secretas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Rede

Logs de Proxy (Cont.)

Cisco Umbrella oferece um serviço DNS hospedado que estende a capacidade do DNS para incluir aprimoramentos de segurança.

"2015-01-16 17:48:41","ActiveDirectoryUserName",
"ActiveDirectoryUserName,ADSite,Network",
"10.10.1.100","24.123.132.133","Permitido","1 (A)",
"10.10.1.100","24.123.132.133","Permitido","1 (A)",
"Chat,Photo Sharing,Social Networking,Allow List"

A tabela explica o significado dos campos de uma entrada de log de proxy DNS (mostrado acima).

Campo	Exemplo	Explicação
Carimbo de hora	2015-01-16 17:48:41	uando esta solicitação foi feita em UTC.
Identidade da política	ActiveDirectoryUserName	A primeira identidade que correspondeu à solicitação.
Identidades	ActiveDirectoryUserName, AdSite, Rede	Todas as identidades associadas a esta solicitação.
IP Interno	10.10.1.100	O endereço IP interno que fez a solicitação.
IP Externo	24.123.132.133	O endereço IP externo que fez a solicitação.
Ação	Permitido	Se a solicitação foi permitida ou bloqueada.
QueryType	1 (A)	O tipo de solicitação DNS que foi feita.
ResponseCode	SEM ERRO	O código de retorno DNS para esta solicitação.
Domínio	domain-visited.com	Este é o domínio que foi solicitado.
Categorias	Chat,Photo Sharing,Social Networking	As categorias de segurança ou conteúdo correspondentes ao destino.

Firewalls de Última Geração

Dispositivos Firewall de Última Geração estendem a segurança da rede além dos endereços IP e números de porta da Camada 4 para a camada do aplicativo e além.

Uma dessas funcionalidades é relatar painéis com recursos interativos que permitem relatórios rápidos de apontar e clicar sobre informações muito específicas sem a necessidade de SIEM ou outros correladores de eventos.

A linha de dispositivos NGFW da Cisco usa Firepower Services para consolidar várias camadas de segurança em uma única plataforma, contendo custos e simplificando o gerenciamento.

Os serviços Firepower incluem visibilidade e controle de aplicativos, Firepower NGIPS, reputação e filtragem de URL baseada em categoria e AMP.

Dispositivos Firepower permitem monitorar a segurança da rede por meio de uma GUI habilitada para Web chamada Visualizador de Eventos.

Eventos comuns do NGFW incluem:

- **Evento de Conexão**.
- **Eventos de Invasão**
- **Host ou dispositivo final**
- **Evento de Descoberta de rede**
- **Evento Netflow**

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Rede

Firewalls de Última geração (Cont.)

Serviços prestados pela



direitos reservados. Documento confidencial da Cisco

Logs de Rede

Rastreador de pacotes - Explore uma implementação NetFlow

Nesta atividade do Packet Tracer, você explorará uma implementação do NetFlow.

Objetivos

- Parte 1: Observar registros de fluxo NetFlow - Uma direção
- Parte 2: Observe os registros NetFlow para uma sessão que entra e sai do coletor

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Logs de Rede

Log de Várias Origens

Nesta atividade, você usará o Rastreador de Pacotes para comparar dados de rede gerados por várias fontes, incluindo syslog, AAA e NetFlow.

Objetivos

- Parte 1: Usar syslog para capturar arquivos de log de vários dispositivos de rede
- Parte 2: Observe o registro de acesso do usuário AAA
- Parte 3: Observar as informações do NetFlow

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

10.4 Resumo de Dados de Segurança de Rede

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco



Módulo 11: Avaliação de Alertas

Defesa de rede

Objetivos do Módulo

Título do Módulo: Avaliação de Alertas

Objetivo do Módulo: Explicar o processo de avaliação de alertas

Título do Tópico	Objetivo do Tópico
Fonte de Alertas	Identificar a estrutura dos alertas.
Visão geral da Avaliação de Alertas	Explicar como os alertas são classificados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

11.1 Fonte de Alertas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Security Onion

- O Security Onion é um pacote de código aberto de ferramentas de Monitoramento de Segurança de Rede (NSM) que é executado em uma distribuição Ubuntu Linux.
- As ferramentas Security Onion fornecem três funções principais para o analista de segurança cibernética: captura completa de pacotes e tipos de dados, sistemas de detecção de intrusão baseados em rede e em host e ferramentas de analistas de alerta.
- Security Onion pode ser instalado como uma instalação autônoma ou como um sensor e plataforma de servidor.
- Alguns componentes do Security Onion são de propriedade e mantidos por corporações, como Cisco e Riverbend Technologies, mas são disponibilizados como código aberto.

Para obter mais informações e para obter o Security Onion, pesquise na internet o site Security Onion.

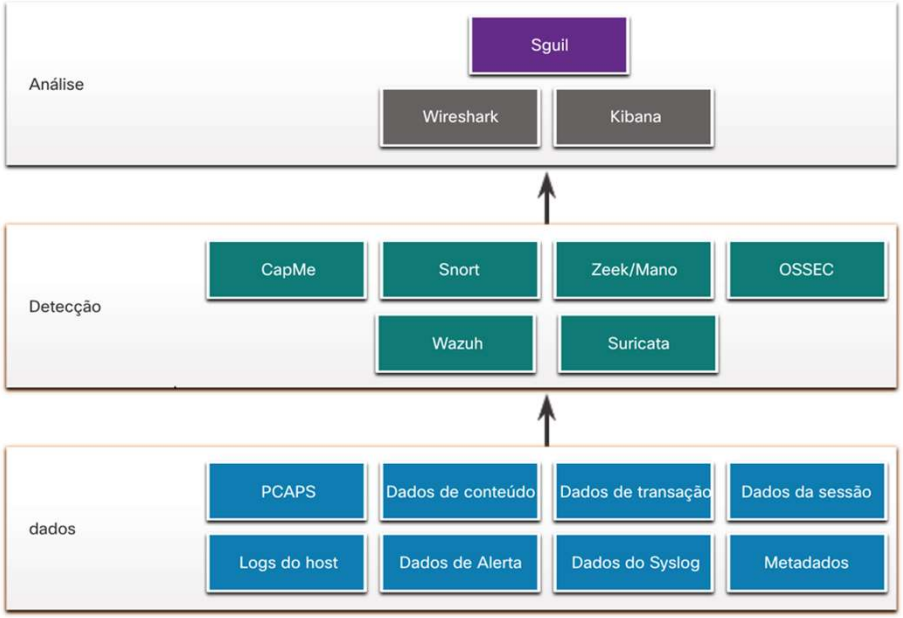
Observação: Em alguns recursos, você pode ver Security Onion abreviado como SO. Neste curso, usaremos Security Onion.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Ferramentas de detecção para coleta de dados de alerta

- Security Onion contém muitos componentes. É um ambiente integrado projetado para simplificar a implantação de uma solução NSM abrangente. A figura ilustra uma visão simplificada da maneira como alguns dos componentes do Security Onion trabalham juntos.



© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ferramentas de Detecção para Coleta de Dados de Alerta (Cont.)

CapME

- Esta é uma aplicação web que permite a visualização de transcrições pcap renderizadas com as ferramentas tcpflow ou Zeek.
- Ele pode ser acessado a partir da ferramenta ELSA (Enterprise Log Search and Archive).
- Ele fornece ao analista de cibersegurança um meio fácil de visualizar uma sessão inteira da Camada 4.
- Ele atua como um plugin para o ELSA e fornece acesso a arquivos pcap relevantes que podem ser abertos no Wireshark.

Snort

- Este é um Sistema de Detecção de Intrusão de Rede (NIDS).
- É uma importante fonte de dados de alerta indexados na ferramenta de análise Sguil.
- Ele usa regras e assinaturas para gerar alertas.
- Ele pode baixar automaticamente novas regras usando o componente PulledPork do Security Onion.
- Snort e PulledPork são ferramentas de código aberto que são patrocinadas pela Cisco.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Ferramentas de Detecção para Coleta de Dados de Alerta (Cont.)

Zeek

- Formalmente conhecido como Bro, este é um NIDS que usa mais uma abordagem baseada em comportamento para detecção de intrusões.
- Em vez de usar assinaturas ou regras, o Zeek usa políticas, na forma de scripts que determinam quais dados registrar e quando emitir notificações de alerta.
- O Zeek também pode enviar anexos de arquivos para análise de malware, bloquear o acesso a locais mal-intencionados e desligar um computador que parece estar violando políticas de segurança.

Observação: Algumas interfaces dentro do Security Onion ainda não foram atualizadas com a alteração de nome de Bro para Zeek.

OSSEC

- Este é um sistema de detecção de intrusão baseado em host (HIDS) integrado ao Security Onion.
- Ele monitora ativamente as operações do sistema host, incluindo a realização de monitoramento de integridade de arquivos, monitoramento de log local, monitoramento de processos do sistema e detecção de rootkit.
- Alertas e dados de log estão disponíveis para Sguil e Kibana.
- Ele requer que um agente seja executado nos computadores Windows da empresa.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Ferramentas de Detecção para Coleta de Dados de Alerta (Cont.)

Wazuh

- Este é um HIDS que substituirá OSSEC em Security Onion.
- É uma solução completa que fornece um amplo espectro de mecanismos de proteção de terminais, incluindo análise de arquivos de log do host, monitoramento de integridade de arquivos, detecção de vulnerabilidades, avaliação de configuração e resposta a incidentes.
- Assim como o OSSEC, ele exige que os agentes estejam sendo executados em hosts de rede.

Suricata

- Este é um NIDS que usa uma abordagem baseada em assinaturas.
- Ele também pode ser usado para prevenção de intrusões em linha.
- É semelhante ao Zeek mas o Suricata usa multithreading nativo, que permite a distribuição do processamento de fluxo de pacotes em vários núcleos de processadores.
- Ele também inclui alguns recursos adicionais, como bloqueio baseado em reputação e suporte para multithreading de unidade de processamento gráfico (GPU) para melhorar o desempenho.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Ferramentas de Análise

O Security Onion integra esses vários tipos de dados e logs do Sistema de Detecção de Intrusões (IDS) em uma única plataforma através das seguintes ferramentas:

- **Sguil** - Isso fornece um console de alto nível para investigar alertas de segurança de uma ampla variedade de fontes. Sguil serve como ponto de partida na investigação de alertas de segurança. Uma grande variedade de fontes de dados está disponível para o analista de segurança cibernética, girando diretamente do Sguil para outras ferramentas.
- **Kibana** - É uma interface de painel interativo para dados Elasticsearch. Ele permite a consulta de dados do NSM e fornece visualizações flexíveis desses dados. Ele fornece recursos de análise de dados de exploração de dados e aprendizado de máquina. É possível girar do Sguil diretamente para o Kibana para ver exibições contextualizadas com base nos endereços IP de origem e destino associados a um alerta.
- **Wireshark** - Este é um aplicativo de captura de pacotes integrado ao conjunto Security Onion. Ele pode ser aberto diretamente de outras ferramentas e exibirá capturas completas de pacotes relevantes para uma análise.
- **Zeek** - Este é um analisador de tráfego de rede que serve como um monitor de segurança. O Zeek inspeciona todo o tráfego em um segmento de rede e permite uma análise aprofundada desses dados. A rotação do Sguil para o Zeek fornece acesso a logs de transações muito precisos, conteúdo de arquivos e saída personalizada.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Geração de Alertas

- Alertas de segurança são mensagens de notificação geradas por ferramentas, sistemas e dispositivos de segurança do NSM.
- Os alertas podem vir em várias formas, dependendo da fonte.
- Por exemplo, o syslog fornece suporte para classificações de gravidade que podem ser usadas para alertar analistas de segurança cibernética sobre eventos que exigem atenção.
- No Security Onion, o Sguil fornece um console que integra alertas de várias fontes em uma fila com carimbo de data/hora.
- Um analista de segurança cibernética pode trabalhar na fila de segurança investigando, classificando, escalonando ou retirando alertas.
- Em vez de usar um sistema de gerenciamento de fluxo de trabalho dedicado, como o RTIR (Request Tracker for Incident Response), um analista de segurança cibernética usaria a saída de um aplicativo como o Sguil para orquestrar uma investigação do NSM.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Geração de alertas (Cont.)

- Os alertas geralmente incluem informações de cinco tuplas quando disponíveis, bem como carimbos de data/hora e informações que identificam qual dispositivo ou sistema gerou o alerta.

- As cinco tuplas incluem as seguintes informações para rastrear uma conversa entre um aplicativo de origem e destino:

  - **SrcIP** - o endereço IP de origem para o evento.
  - **SPort** - a porta de Camada 4 de origem (local) para o evento.
  - **DstIP** - o IP de destino para o evento.
  - **DPort** - a porta de Camada 4 de destino para o evento.
  - **Pr** - o número do protocolo IP para o evento.

- Informações adicionais podem ser uma decisão de permissão ou negação aplicada ao tráfego, alguns dados capturados da carga útil do pacote, um valor de hash para um arquivo baixado, ou qualquer um dos vários dados.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Geração de Alertas (Cont.)

Os campos disponíveis para os eventos em tempo real são os seguintes:

- **ST** - Este é o status do evento. RT significa tempo real. O evento é codificado por cor por prioridade. As prioridades são baseadas na categoria do alerta. Há quatro níveis de prioridade: muito baixo, baixo, médio e alto. As cores variam de amarelo claro a vermelho à medida que a prioridade aumenta.

- **CNT** - Esta é a contagem do número de vezes que este evento foi detectado para o mesmo endereço IP de origem e destino. O sistema determinou que este conjunto de eventos está correlacionado. Em vez de relatar cada um em uma série potencialmente longa de eventos correlacionados nesta janela, o evento é listado uma vez com o número de vezes que foi detectado nesta coluna. Números altos aqui podem representar um problema de segurança ou a necessidade de ajuste das assinaturas de eventos para limitar o número de eventos potencialmente falsos que estão sendo relatados.

- **Sensor** - Este é o agente que relata o evento. Os sensores disponíveis e seus números de identificação podem ser encontrados na guia Status do agente do painel, que aparece abaixo da janela de eventos à esquerda. Esses números também são usados na coluna ID de alerta. No painel Status do Agente, podemos ver que os sensores OSSEC, pcap e Snort estão reportando ao Sguil. Além disso, podemos ver os nomes de host padrão para esses sensores, que inclui a interface de monitoramento. Observe que cada interface de monitoramento tem dados pcap e Snort associados a ele.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Geração de Alertas (Cont.)

- **Alert ID** - Este número de duas partes representa o sensor que relatou o problema e o número de evento desse sensor. Podemos ver a partir da figura que o maior número de eventos que são exibidos são do sensor OSSEC (1). O sensor OSSEC relatou oito conjuntos de eventos correlacionados. Destes eventos, 232 foram relatados com ID de evento 1.24.

- **Date/Time** - Este é o carimbo de data/hora do evento. No caso de eventos correlacionados, é o carimbo de data/hora do primeiro evento.

- **Mensagem de Evento** - Este é o texto de identificação para o evento. Isso é configurado na regra que disparou o alerta. A regra associada pode ser visualizada no painel direito, logo acima dos dados do pacote. Para exibir a regra, a caixa de seleção Show Rule deve estar marcada.

Dependendo da tecnologia de segurança, os alertas podem ser gerados com base em regras, assinaturas, anomalias ou comportamentos. Não importa como eles são gerados, as condições que acionam um alerta devem ser predefinidas de alguma maneira.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Regras e Alertas

Alertas podem vir de várias fontes:

- **NIDS** - Snort, Zeek e Suricata
- **HIDS** - OSSEC, Wazuh
- **Gerenciamento e Monitoramento de Ativos** - Sistema de Detecção de Ativos Passivos (PADS)
- **Transações HTTP, DNS e TCP** - Registradas pelo Zeek e pcaps
- **Mensagens do Syslog** - Várias fontes

- As informações encontradas nos alertas que são exibidos no Sguil serão diferentes no formato de mensagem porque elas vêm de fontes diferentes.

- O alerta Sguil na figura foi acionado por uma regra que foi configurada no Snort. É importante que o analista de segurança cibernética seja capaz de interpretar o que acionou o alerta para que o alerta possa ser investigado. Por esse motivo, o analista de segurança cibernética deve entender os componentes das regras do Snort, que são uma das principais fontes de alertas em Security Onion.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Estrutura de Regra Snort

- As regras de Snort consistem em duas seções: o cabeçalho da regra e as opções da regra.
- O cabeçalho da regra contém a ação, o protocolo, os endereços IP de origem e destino e as máscaras de rede e as informações da porta de origem e destino.
- A seção Opções de regra contém mensagens de alerta e informações sobre quais partes do pacote devem ser inspecionadas para determinar se a ação da regra deve ser executada.
- A localização da regra às vezes é adicionada pelo Sguil.
- Local da Regra é o caminho para o arquivo que contém a regra e o número da linha em que a regra aparece para que ela possa ser encontrada e modificada, ou eliminada, se necessário.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Estrutura de Regra do Snort (Cont.)

Estrutura da regra Snort e informações fornecidas pelo Sguil

```
alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root";
content:"uid=0|28|root|29|"; fast_pattern:only; classtype:bad-unknown; sid:2100498;
rev:8;)
/nsm/server_data/securityonion/rules/seconion-eth1-1/downloaded.rules:Line 692
```

Componente	Exemplo (encurtado...)	Explicação
cabeçalho da regra	alert ip any any -> any any	Contém a ação a ser tomada, endereços e porta de origem e destino, e a direção do fluxo de tráfego
opções de regra	(msg:"GPL ATTACK_RESPONSE ID CHECK RETURNED ROOT";...)	Inclui a mensagem a ser exibida, detalhes do conteúdo do pacote, tipo de alerta, ID de origem e detalhes adicionais, como uma referência para a regra ou vulnerabilidade
local da regra	/nsm/server_data/securityonion/rules/...	Adicionado pelo Sguil para indicar a localização da regra na estrutura do arquivo Security Onion e no arquivo de regra especificado

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estrutura de Regra do Snort (Cont.)

O cabeçalho da regra

- O cabeçalho da regra contém a ação, o protocolo, o endereçamento e as informações da porta, conforme mostrado na figura.
- Além disso, a direção do fluxo que acionou o alerta é indicada.
- A estrutura da parte do cabeçalho é consistente entre as regras de alerta Snort.
- O Snort pode ser configurado para usar variáveis para representar endereços IP internos e externos.
- Essas variáveis, **$HOME_NET** e **$EXTERNAL_NET,** aparecem nas regras Snort.
- Eles simplificam a criação de regras, eliminando a necessidade de especificar endereços e máscaras específicos para cada regra.
- Os valores dessas variáveis são configurados no arquivo **snort.conf**.
- O Snort também permite que endereços IP individuais, blocos de endereços ou listas de ambos sejam especificados em regras.
- Os intervalos de portas podem ser especificados separando os valores superior e inferior do intervalo com dois pontos.
- Outros operadores também estão disponíveis.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Fontes de Alertas

Estrutura de Regra do Snort (Cont.)

Estrutura do Cabeçalho da Regra Snort

```
alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root";
content:"uid=0|28|root|29|"; fast_pattern:only; classtype:bad-unknown; sid:2100498;
rev:8;)
/nsm/server_data/securityonion/rules/seconion-eth1-1/downloaded.rules:Line 692
```

Componente	Explicação
alert	a ação a ser tomada é emitir um alerta, outras ações são registradas e passadas
ip	o protocolo
any any	a fonte especificada é qualquer endereço IP e qualquer porta da Camada 4
->	a direção do fluxo é da origem para o destino
any any	o destino especificado é qualquer endereço IP e qualquer porta da Camada 4

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estrutura de Regra do Snort (Cont.)

As Opções de Regra

- A estrutura da seção de opções da regra é variável. É a parte da regra que está entre parênteses.
- Ele contém a mensagem de texto que identifica o alerta. Ele também contém metadados sobre o alerta, como um URL que fornece informações de referência para o alerta.
- Outras informações podem ser incluídas, como o tipo de regra e um identificador numérico exclusivo para a regra e a revisão da regra.
- Além disso, os recursos da carga do pacote podem ser especificados nas opções.
- O manual de usuários do Snort, que pode ser encontrado na internet, fornece detalhes sobre regras e como criá-las.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estrutura de Regra do Snort (Cont.)

- Mensagens de regra do Snort podem incluir a origem da regra.
- Três fontes comuns para as regras do Snort são:
  - **GPL** - Regras mais antigas do Snort que foram criadas pelo Sourcefire e distribuídas sob uma GPLv2.O conjunto de regras da GPL não é certificado pela Cisco Talos. Inclui Snort SIDs 3464 e abaixo. O conjunto de regras GPL pode ser baixado do site do Snort e está incluído no Security Onion.
  - **ET** - Regras Snort de Emerging Threats (Ameaças Emergentes). Emerging Threats é um ponto de coleta para regras Snort de várias fontes. As regras ET são de código aberto sob uma licença BSD. O conjunto de regras ET contém regras de várias categorias. Um conjunto de regras ET está incluído com Security Onion.Emerging Threats é uma divisão da Proofpoint, Inc.
  - **VRT** - Essas regras estão imediatamente disponíveis para assinantes e são liberadas para usuários registrados 30 dias após sua criação, com algumas limitações. Eles agora são criados e mantidos pelo Cisco Talos.

- As regras podem ser baixadas automaticamente do Snort.org usando o utilitário de gerenciamento de regras PulledPork que está incluído com o Security Onion.
- Alertas que não são gerados pelas regras do Snort são identificados pelas tags OSSEC ou PADS, entre outras. Além disso, regras locais personalizadas podem ser criadas.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Estrutura de Regra do Snort (Cont.)

Estrutura de Opções de Regras Snort

```
alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root";
content:"uid=0|28|root|29|"; fast_pattern:only; classtype:bad-unknown; sid:2100498;
rev:8;)
/nsm/server_data/securityonion/rules/seconion-eth1-1/downloaded.rules:Line 692
```

Componente	Explicação
msg	Texto que descreve o alerta.
content	Refere-se ao conteúdo do pacote. Nesse caso, um alerta será enviado se o texto literal “uid=0 (root)” aparecer em qualquer lugar nos dados do pacote. Valores que especificam a localização do texto na carga de dados podem ser fornecidos.
reference	Não mostrado na figura, é um link para uma URL que fornece mais informações sobre a regra. Nesse caso, o sid é hipervinculado à origem da regra na Internet.
classtype	Uma categoria para o ataque. O Snort inclui um conjunto de categorias padrão que têm um dos quatro valores de prioridade.
sid	Um identificador numérico exclusivo para a regra.
rev	A revisão da regra que é representada pelo sid.

Fontes de Alertas

Laboratório - Regras de Snort e Firewall

Neste laboratório, para se familiarizar com as regras de firewall e as assinaturas IDS, você irá:

- Realizar monitoramento ao vivo de IDS e eventos.
- Configurar sua própria regra de firewall personalizada para impedir que hosts internos contatem um servidor de hospedagem de malware.
- Criar um pacote malicioso e inicie-o contra um alvo interno.
- Criar uma regra IDS personalizada para detectar o ataque personalizado e emitir um alerta com base nele.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

11.2 Resumo de Avaliação de Alertas

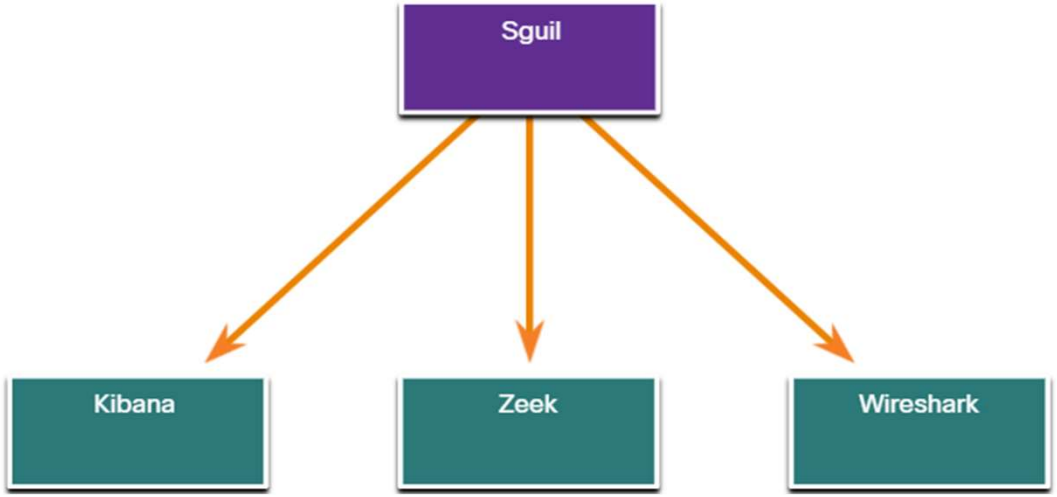
© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

A Necessidade de Avaliação de Alertas

- O cenário de ameaças está mudando constantemente à medida que novas vulnerabilidades são descobertas e novas ameaças evoluem. À medida que as necessidades do usuário e organizacional mudam, a superfície do ataque também.

- As explorações irão inevitavelmente fugir às medidas de protecção, por mais sofisticadas que sejam. Às vezes, o melhor que pode ser feito é detectar exploits durante ou depois de terem ocorrido. As regras de detecção devem ser excessivamente conservadoras.

- Os analistas de segurança cibernética de nível 1 costumam trabalhar em filas de alertas em uma ferramenta como Sguil, girando para ferramentas como Zeek, Wireshark e Kibana para verificar se um alerta representa uma exploracão real.



os direitos reservados. Documento confidencial da Cisco

Avaliação de Alertas

- Os incidentes de segurança são classificados usando um esquema emprestado de diagnósticos médicos.
- Este esquema de classificação é usado para orientar ações e avaliar procedimentos de diagnóstico.
- A preocupação é que o diagnóstico pode ser preciso, ou verdadeiro, ou impreciso, ou falso.
- Na análise de segurança de rede, o analista de segurança cibernética é apresentado com um alerta.
  - Isso é semelhante a um paciente indo ao médico e dizendo: “Estou doente”.
  - O analista de segurança cibernética, como o médico, precisa determinar se esse diagnóstico é verdadeiro.
  - O analista de segurança cibernética pergunta: “O sistema diz que ocorreu uma exploração. Isso é verdade?”

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Avaliação de Alertas (Cont.)

Os alertas podem ser classificados da seguinte forma:

- **Verdadeiro positivo:** O alerta foi verificado como um incidente de segurança real.
- **Falso Positivo:** O alerta não indica um incidente de segurança real. A atividade benigna que resulta em um falso positivo é às vezes referida como um gatilho benigno.

Uma situação alternativa é que um alerta não foi gerado. A ausência de um alerta pode ser classificada como:

- **Verdadeiro Negativo:** Nenhum incidente de segurança ocorreu. A atividade é benigna.
- **Falso Negativo:** Ocorreu um incidente não detectado.

Quando um alerta é emitido, ele receberá uma das quatro classificações possíveis:		
	Verdadeiro	Falso
Positivo (Alerta existe)	Ocorreu um incidente	Nenhum incidente ocorreu
Negativo (Nenhum alerta existe)	Nenhum incidente ocorreu	Ocorreu um incidente
Nota: Os eventos“Verdadeiros” são desejáveis. Os eventos “falsos” são indesejáveis e potencialmente perigosos.		

Avaliação de Alertas (Cont.)

- **Verdadeiros positivos** são o tipo de alerta desejado. Eles significam que as regras que geram alertas funcionaram corretamente.
- **Falsos positivos** não são desejáveis. Embora eles não indiquem que ocorreu uma exploração não detectada, eles são caros porque os analistas de segurança cibernética devem investigar alarmes falsos; portanto, o tempo é retirado da investigação de alertas que indicam verdadeiras explorações.
- **Verdadeiros negativos** são desejáveis. Eles indicam que o tráfego normal benigno é corretamente ignorado e alertas errôneos não estão sendo emitidos.
- **Falsos negativos** são perigosos. Eles indicam que as explorações não estão sendo detectadas pelos sistemas de segurança que estão em vigor. Esses incidentes podem passar despercebidos por um longo período de tempo, e a perda e danos contínuos de dados podem resultar.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Avaliação de Alertas (Cont.)

- Eventos benignos são aqueles que não devem acionar alertas.
- Os eventos benignos em excesso indicam que algumas regras ou outros detectores precisam ser melhorados ou eliminados.
- Quando os verdadeiros positivos são suspeitos, um analista de segurança cibernética às vezes é obrigado a escalar o alerta para um nível mais alto para investigação.
- O investigador avançará com a investigação, a fim de confirmar o incidente e identificar qualquer dano potencial que possa ter sido causado.
- Essas informações serão usadas por mais funcionários de segurança sênior que trabalharão para isolar os danos, solucionar vulnerabilidades, mitigar a ameaça e lidar com os requisitos de relatórios.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Avaliação de Alertas (Cont.)

- Um analista de cibersegurança também pode ser responsável por informar o pessoal de segurança de que falsos positivos estão ocorrendo na medida em que o tempo do analista de segurança cibernética é seriamente afetado.
  - Esta situação indica que os sistemas de monitoramento de segurança precisam ser ajustados para se tornarem mais eficientes.
  - Alterações legítimas na configuração da rede ou nas regras de detecção recém-baixadas podem resultar em um pico repentino de falsos positivos também.

- Falsos negativos podem ser descobertos bem depois de uma exploração ter ocorrido.
  - Isso pode acontecer por meio da análise de segurança retrospectiva (RSA).
  - A RSA pode ocorrer quando regras recém-obtidas ou outras informações sobre ameaças são aplicadas a dados de segurança de rede arquivados.
  - Por esse motivo, é importante monitorar as informações sobre ameaças para conhecer novas vulnerabilidades e explorações e avaliar a probabilidade de que a rede estava vulnerável a elas em algum momento no passado.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Análise Determinística e Análise Probabilística

- Técnicas estatísticas podem ser usadas para avaliar o risco de que as explorações serão bem-sucedidas em uma determinada rede.
- Esse tipo de análise pode ajudar os tomadores de decisão a avaliar melhor o custo de mitigar uma ameaça com os danos que uma exploração poderia causar.
- Duas abordagens gerais utilizadas para isso são a análise determinística e probabilística.
- A análise determinística avalia o risco com base no que é conhecido sobre uma vulnerabilidade.
- Ele pressupõe que, para que uma exploração seja bem-sucedida, todas as etapas anteriores do processo de exploração também devem ser bem-sucedidas.
- Este tipo de análise de risco só pode descrever o pior caso.
- No entanto, muitos atores ameaçadores, embora conscientes do processo para realizar uma exploração, podem não ter conhecimento ou experiência para concluir com sucesso cada passo no caminho para uma exploração bem-sucedida.
- Isso pode dar ao analista de segurança cibernética a oportunidade de detectar a exploração e impedi-la antes que ela prossiga.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Análise Determinística e Análise Probabilística (Cont.)

- A análise probabilística estima o sucesso potencial de uma exploração, estimando a probabilidade de que, se uma etapa de uma exploração tiver sido concluída com sucesso, a próxima etapa também será bem-sucedida.

- A análise probabilística é especialmente útil na análise de segurança de rede em tempo real em que inúmeras variáveis estão em jogo e um determinado ator de ameaça pode tomar decisões desconhecidas à medida que uma exploração é perseguida.

- A análise probabilística baseia-se em técnicas estatísticas que são projetadas para estimar a probabilidade de que um evento ocorrerá com base na probabilidade de ocorrerem eventos anteriores.

- Usando esse tipo de análise, os caminhos mais prováveis que uma exploração tomará podem ser estimados e a atenção do pessoal de segurança pode ser focada em prevenir ou detectar a exploração mais provável.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Análise Determinística e Análise Probabilística (Cont.)

- Em uma análise determinística, toda informação para realizar uma exploração é assumida como sendo conhecida.
- As características da exploração, como o uso de números de porta específicos, são conhecidas de outras instâncias da exploração ou porque portas padronizadas estão em uso.
- Na análise probabilística, presume-se que os números de porta que serão utilizados só podem ser previstos com algum grau de confiança.

As duas abordagens são resumidas a seguir.

- **Análise Determinística** - Para que uma exploração seja bem-sucedida, todas as etapas anteriores da exploração também devem ser bem-sucedidas. O analista de segurança cibernética conhece as etapas para uma exploração bem-sucedida.

- **Análise Probabilística** - Técnicas estatísticas são usadas para determinar a probabilidade de que uma exploração bem-sucedida ocorrerá com base na probabilidade de que cada etapa da exploração seja bem-sucedida.

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

Visão geral de Avaliação de Alertas

Laboratório - Classificar Alertas

Neste laboratório, você completará os seguintes objetivos:

- Parte 1: Pesquisar CVEs e IDs do Snort
- Parte 2: Classificar alertas em um ambiente Windows
- Parte 3: Classificar alertas em um ambiente Unix / Linux

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco

11.3 Resumo de Avaliação de Alertas

© 2020 Cisco e/ou suas afiliadas. Todos os direitos reservados. Documento confidencial da Cisco